

COMPTIA SECURITY+ SY0-701

700-QUESTION MASTER VISUAL STUDY GUIDE

350+ pages of scenario-based review, immediate answers, visual simulations, and exam-memory cues

700

ORIGINAL QUESTIONS

5

EXAM DOMAINS

40

PBQ-STYLE VISUALS

394

TARGET PAGES

EXAM COVERAGE

01

GENERAL CONCEPTS

02

THREATS & MITIGATIONS

03

ARCHITECTURE

04

SECURITY OPERATIONS

05

PROGRAM MANAGEMENT

BY MARC LAVOIE

MASTER STUDY EDITION

Independent practice resource - source-informed - visual memory anchors - simulated evidence only

Not an official CompTIA product, live exam dump, or representation of a private CompTIA question bank.

Source + Methodology

ORIGINAL PRACTICE BANK

This edition contains 700 independently created practice questions. It is not an official CompTIA exam, a live exam dump, or a claim about the size or contents of CompTIA's private item bank.

SOURCE-INFORMED COVERAGE

The supplied 11-hour Security+ course transcript was used as supporting study material to broaden coverage across all five domains. The 250-question visual edition was retained as a foundation and expanded with additional applied scenarios.

VISUAL CONVENTION

Dark console panels, logs, architecture maps, heatmaps, and dashboards are simulated study visuals. They are designed as memory anchors and are not presented as live production evidence.

LEARNER FEEDBACK CONTEXT

The supplied course page includes multiple self-reported comments from viewers who say they passed Security+ after using the course, sometimes alongside other practice resources. These comments are anecdotal and do not guarantee any individual exam result.

How to Use This Master Guide

1

IDENTIFY

What concept, attack, control, architecture, operational process, or governance decision is being tested?

2

DECIDE

Choose the BEST answer before reading the highlighted response. Security+ frequently asks for the best option, not merely a technically possible option.

3

EXPLAIN

State why the correct answer wins and why each alternative is weaker in this scenario.

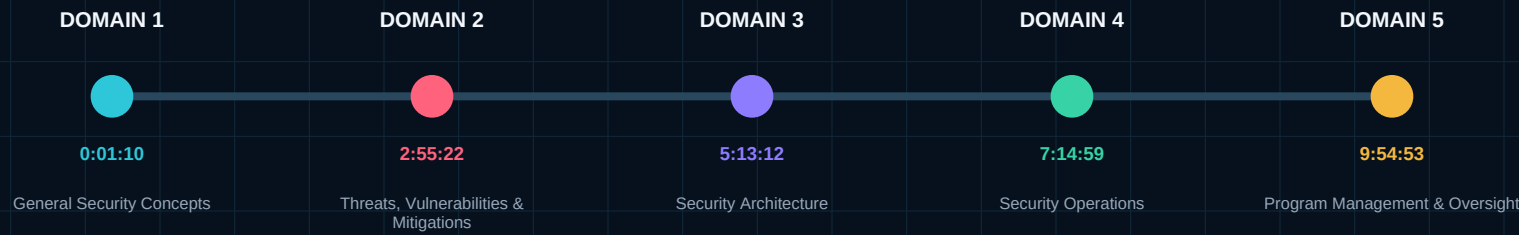
4

VISUALIZE

Use the simulated panel as a memory anchor: packet flow, control matrix, trust chain, timeline, dashboard, risk map, or evidence workflow.

11-Hour Course Cross-Reference

User-provided supporting course: CompTIA Security+ SY0-701 - Full Course 2026 (Computer Networks Decoded).



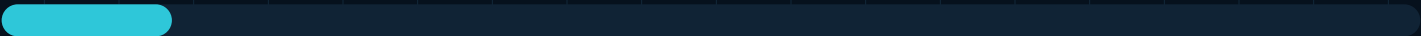
HOW THE SOURCE WAS USED

- Objective language and topic sequencing were used to broaden the question bank across all five domains.
- Concepts were converted into original scenarios rather than reproducing transcript wording or live exam content.
- The master bank emphasizes repeated exposure to the same concept in different contexts, mirroring how certification study requires transfer rather than memorizing one phrasing.
- The visual edition adds SOC, architecture, identity, forensics, risk, and gap-analysis memory anchors.

700-Question Domain Distribution

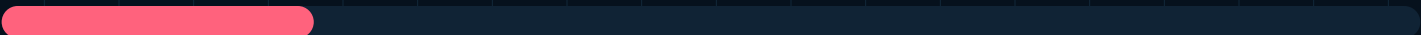
DOMAIN 1 | GENERAL SECURITY CONCEPTS

84 questions | 12% | Q1-84



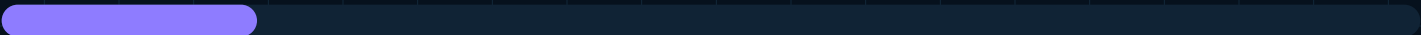
DOMAIN 2 | THREATS, VULNERABILITIES & MITIGATIONS

154 questions | 22% | Q85-238



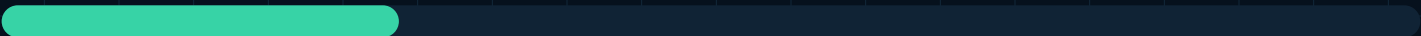
DOMAIN 3 | SECURITY ARCHITECTURE

126 questions | 18% | Q239-364



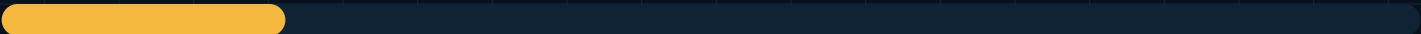
DOMAIN 4 | SECURITY OPERATIONS

196 questions | 28% | Q365-560



DOMAIN 5 | SECURITY PROGRAM MANAGEMENT & OVERSIGHT

140 questions | 20% | Q561-700



ANSWER-LETTER BALANCE

A = 175 B = 175 C = 175 D = 175

Correct-answer positions are deliberately balanced to reduce answer-pattern memorization.

Navigation 1 / 2

Domain 1 - General Security Concepts

Q1-84

CIA, crypto, controls, AAA, PKI, zero trust

Domain 2 - Threats, Vulnerabilities & Mitigations

Q85-238

Threat actors, social engineering, malware, web/network attacks

Domain 3 - Security Architecture

Q239-364

Cloud, segmentation, resilience, data protection, OT/IoT

Domain 4 - Security Operations

Q365-560

SIEM/EDR/XDR/SOAR, IR, forensics, IAM, vulnerabilities

Domain 5 - Program Management & Oversight

Q561-700

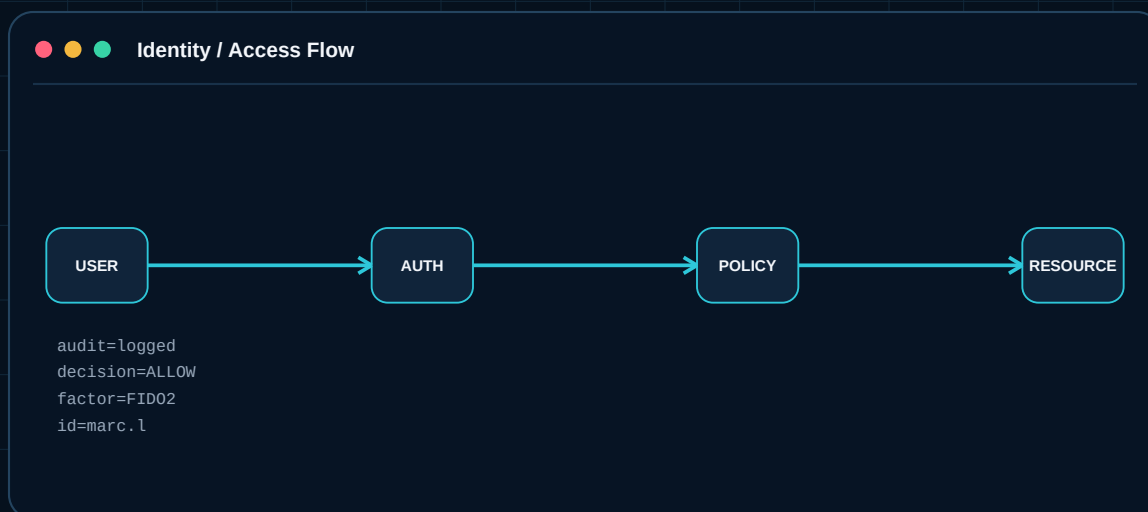
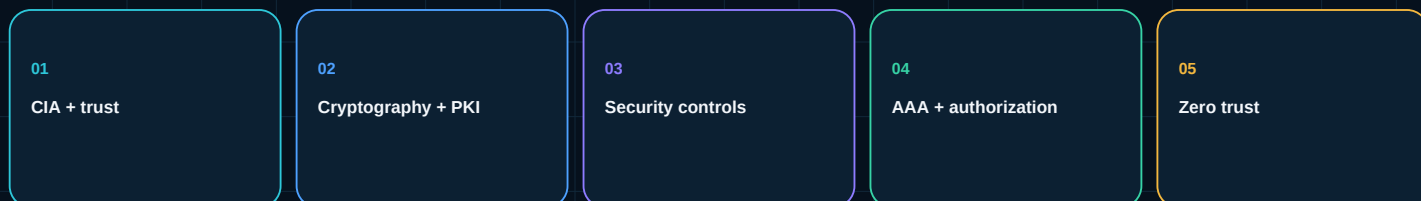
Policy, risk, vendors, audit, gap analysis, change, BCP/DR

Navigation 2 / 2

Visual Reference 01	CIA + Controls
Foundational objectives and control matrix	
Visual Reference 02	Cryptography + PKI
Hashing, signatures, certificates, HSM/TPM	
Visual Reference 03	AAA + IAM
Identity, authorization and accounting	
Visual Reference 04	Zero Trust
PEP/PDP, policy engine, planes and zones	
Visual Reference 05	Threat Map
Credential, social, web, network and malware	
Visual Reference 06	Cloud + Resilience
Service models, shared responsibility, backups	
Visual Reference 07	SOC Telemetry
SIEM/EDR/XDR/SOAR and evidence sources	
Visual Reference 08	IR + Forensics
Response lifecycle and evidence workflow	
Visual Reference 09	Identity + Email Trust
SAML/OAuth/OIDC and SPF/DKIM/DMARC	
Visual Reference 10	Risk + Recovery
SLE/ALE/ARO and RTO/RPO	

GENERAL SECURITY CONCEPTS

QUESTIONS 1-84 | 84 QUESTIONS



BY MARC LAVOIE

Security+ Master Visual Review | Questions 1-2

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 1 | MULTIFACTOR AUTHENTICATION

FOUNDATION

A company requires administrators to use a smart card and PIN before accessing production servers. Which security principle is being implemented?

A. Multifactor authentication

B. Non-repudiation

C. Accounting

D. Federation

CORRECT ANSWER: A - Multifactor authentication

WHY: The smart card is something you have, while the PIN is something you know. Two different authentication factor categories create MFA.

MEMORY CUE

The smart card is something you have, while the PIN is something you know. Two different authentication factor categories create MFA.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 2 | CONFIDENTIALITY

FOUNDATION

A payroll file must remain unreadable to unauthorized employees even if they can access the storage location. Which security objective is MOST directly required?

A. Integrity

B. Confidentiality

C. Non-repudiation

D. Availability

CORRECT ANSWER: B - Confidentiality

WHY: Confidentiality limits unauthorized disclosure of information.

MEMORY CUE

C = keep data secret from unauthorized viewers.

Security Objectives - CIA Triad

CONFIDENTIALITY



INTEGRITY

Disclosure | Modification | Access

AVAILABILITY

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 3-4

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 3 | CIA TRIAD

FOUNDATION

Which element of the CIA triad is **MOST** directly concerned with preventing unauthorized modification of information?

- A. Authentication
- B. Availability
- C. Integrity**
- D. Confidentiality

CORRECT ANSWER: C - Integrity

WHY: Integrity ensures information remains accurate and is not improperly modified.

MEMORY CUE

Confidentiality = prevent unauthorized disclosure Integrity = prevent unauthorized modification Availability = systems/data remain a...

Security Objectives - CIA Triad



QUESTION 4 | AVAILABILITY

FOUNDATION

A hospital requires its patient-record system to remain accessible during a server hardware failure. Which CIA objective is the **PRIMARY** concern?

- A. Authentication
- B. Confidentiality
- C. Integrity
- D. Availability**

CORRECT ANSWER: D - Availability

WHY: Availability ensures authorized users can access systems and data when needed.

MEMORY CUE

A = accessible when needed.

Security Objectives - CIA Triad



Security+ Master Visual Review | Questions 5-6

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 5 | SECURITY CONTROLS

FOUNDATION

A security team installs cameras throughout a data center primarily so investigators can review activity after an incident. What type of control are the cameras primarily providing?

- A. Detective
- B. Preventive
- C. Corrective
- D. Compensating

CORRECT ANSWER: A - Detective

WHY: Cameras help detect and investigate security events. They can also have a deterrent effect, but the question specifically emphasizes reviewing activity.

MEMORY CUE

Cameras help detect and investigate security events. They can also have a deterrent effect, but the question specifically emphasizes...

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 6 | SYMMETRIC ENCRYPTION

FOUNDATION

A backup system must encrypt terabytes of data quickly using the same secret for encryption and decryption. Which cryptographic approach BEST fits?

- A. Asymmetric encryption
- B. Symmetric encryption
- C. Hashing
- D. Tokenization

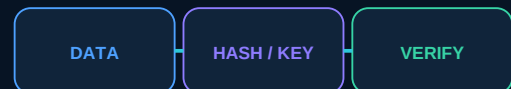
CORRECT ANSWER: B - Symmetric encryption

WHY: Symmetric algorithms use one shared secret key and are efficient for bulk data encryption.

MEMORY CUE

One shared key; fast for bulk data.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 7-8

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 7 | DIGITAL SIGNATURES

FOUNDATION

Which cryptographic mechanism provides the BEST evidence that a specific private-key holder approved a document?

- A. Symmetric encryption
- B. Hashing
- C. Digital signature**
- D. Tokenization

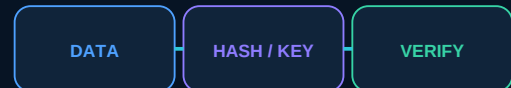
CORRECT ANSWER: C - Digital signature

WHY: A digital signature uses asymmetric cryptography to provide integrity, authentication, and support for non-repudiation.

MEMORY CUE

A digital signature uses asymmetric cryptography to provide integrity, authentication, and support for non-repudiation.

Cryptography / Trust



RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 8 | ASYMMETRIC ENCRYPTION

FOUNDATION

A secure messaging system needs a key pair in which one key can be shared publicly and the other remains secret. Which approach is being used?

- A. Symmetric encryption
- B. Salting
- C. Data masking
- D. Asymmetric encryption**

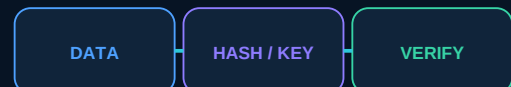
CORRECT ANSWER: D - Asymmetric encryption

WHY: Asymmetric cryptography uses mathematically related public and private keys.

MEMORY CUE

Public key + private key pair.

Cryptography / Trust



RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 9-10

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 9 | ZERO TRUST

FOUNDATION

An organization implementing zero trust wants to reduce reliance on the traditional concept of a trusted internal network. Which principle BEST supports this objective?

A. Verify explicitly and continuously

- B. Trust authenticated users indefinitely
- C. Permit internal traffic by default
- D. Authenticate only at the perimeter

CORRECT ANSWER: A - Verify explicitly and continuously

WHY: Zero trust does not automatically trust users or systems because they are inside the network.

MEMORY CUE

Never trust implicitly; continually verify.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 10 | PASSWORD SALTING

FOUNDATION

A password database stores a unique random value with each password hash to make precomputed attacks less effective. What is the random value called?

- A. Nonce reuse
- B. Salt**
- C. Token
- D. Initialization key

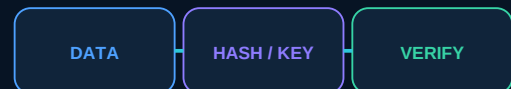
CORRECT ANSWER: B - Salt

WHY: A salt is unique random data added before hashing so identical passwords do not produce identical stored hashes.

MEMORY CUE

Salt defeats precomputed rainbow-table reuse.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 11-12

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 11 | FILE INTEGRITY

FOUNDATION

An administrator wants to verify that a downloaded software image has not changed since the vendor released it. What should the administrator compare?

- A. Initialization vector
- B. Encryption key
- C. Hash value**
- D. Digital certificate expiration date

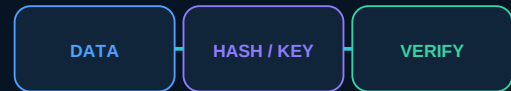
CORRECT ANSWER: C - Hash value

WHY: If the downloaded file produces the same trusted cryptographic hash as the vendor's original, its contents have not changed.

MEMORY CUE

If the downloaded file produces the same trusted cryptographic hash as the vendor's original, its contents have not changed.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 12 | PREVENTIVE CONTROL

FOUNDATION

A firewall rule blocks inbound TCP/445 from the internet before a connection can reach internal hosts. What control type is this?

- A. Detective
- B. Corrective
- C. Directive
- D. Preventive**

CORRECT ANSWER: D - Preventive

WHY: A preventive control is intended to stop an unwanted event before it occurs.

MEMORY CUE

Preventive = stop it first.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 13-14

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 13 | DECEPTION TECHNOLOGY

FOUNDATION

Which technology places decoy credentials in an environment so defenders can detect when an attacker attempts to use them?

- A. Honeytoken
- B. TPM
- C. HSM
- D. Load balancer

CORRECT ANSWER: A - Honeytoken

WHY: Honeytokens are fake credentials, API keys, records, files, or other digital resources intended to trigger alerts when attackers access them.

MEMORY CUE

Honeytokens are fake credentials, API keys, records, files, or other digital resources intended to trigger alerts when attackers acc...

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 14 | DETERRENT CONTROL

FOUNDATION

A warning banner states that unauthorized access is monitored and may result in disciplinary action. What control type is the banner?

- A. Detective
- B. Deterrent
- C. Compensating
- D. Corrective

CORRECT ANSWER: B - Deterrent

WHY: A deterrent control discourages unwanted behavior even if it does not physically prevent it.

MEMORY CUE

Deterrent = make the attacker/user think twice.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 15-16

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 15 | DUAL CONTROL

FOUNDATION

Two administrators must independently authorize a highly sensitive transaction. Which principle does this BEST demonstrate?

- A. Open permissions
- B. Federation
- C. Dual control**
- D. Least functionality

CORRECT ANSWER: C - Dual control

WHY: Dual control requires two people to authorize or complete a sensitive action.

MEMORY CUE

Dual control requires two people to authorize or complete a sensitive action.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 16 | CORRECTIVE CONTROL

FOUNDATION

After ransomware is removed, an administrator restores an affected server from a known-good backup. What control type is the restoration?

- A. Deterrent
- B. Preventive
- C. Directive
- D. Corrective**

CORRECT ANSWER: D - Corrective

WHY: Corrective controls reduce or reverse the impact after an event has occurred.

MEMORY CUE

Corrective = restore or repair after the event.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 17-18

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 17 | OPERATIONAL CONTROLS

FOUNDATION

Which security control category does an organization's mandatory annual security-awareness course represent?

- A. Operational
- B. Cryptographic
- C. Technical
- D. Physical

CORRECT ANSWER: A - Operational

WHY: Security awareness training is primarily a people- and process-based operational control.

MEMORY CUE

Security awareness training is primarily a people- and process-based operational control.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 18 | COMPENSATING CONTROL

FOUNDATION

A critical legacy application cannot be patched for two weeks, so the security team restricts access with a firewall rule until the vendor fix arrives. What control is the firewall rule serving as?

- A. Directive
- B. Compensating
- C. Detective
- D. Physical

CORRECT ANSWER: B - Compensating

WHY: A compensating control provides an alternate safeguard when the preferred control cannot yet be implemented.

MEMORY CUE

Compensating = alternate protection.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 19-20

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 19 | CHANGE MANAGEMENT

FOUNDATION

An organization is replacing a production firewall. Security personnel require documentation, testing, management approval, a maintenance window, and a rollback procedure. This is primarily an example of:

- A. Vulnerability disclosure
- B. Data classification
- C. Change management**
- D. Identity federation

CORRECT ANSWER: C - Change management

WHY: Controlled production changes should be documented, evaluated, approved, tested, scheduled, and capable of being rolled back.

MEMORY CUE

Controlled production changes should be documented, evaluated, approved, tested, scheduled, and capable of being rolled back.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 20 | DIRECTIVE CONTROL

FOUNDATION

A sign on a restricted laboratory door says "Authorized Personnel Only" but does not physically lock the door. What type of control is the sign?

- A. Detective
- B. Corrective
- C. Preventive
- D. Directive**

CORRECT ANSWER: D - Directive

WHY: Directive controls tell people what they are expected or required to do.

MEMORY CUE

Directive = instruct desired behavior.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 21-22

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 21 | NON-REPUDIATION

FOUNDATION

Which security property prevents a sender from credibly denying that they digitally signed a transaction?

A. Non-repudiation

- B. Obfuscation
- C. Availability
- D. Confidentiality

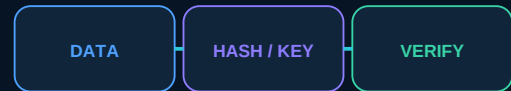
CORRECT ANSWER: A - Non-repudiation

WHY: Non-repudiation provides evidence tying an action or communication to its originator.

MEMORY CUE

Non-repudiation provides evidence tying an action or communication to its originator.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 22 | MANAGERIAL CONTROL

FOUNDATION

The CISO approves a written policy defining acceptable use of company systems. Which control category BEST describes the policy?

- A. Physical
- B. Managerial**
- C. Operational
- D. Technical

CORRECT ANSWER: B - Managerial

WHY: Managerial controls include governance, policies, risk decisions, and administrative direction.

MEMORY CUE

Managerial = governance and policy.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 23-24

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 23 | PHYSICAL CONTROL

FOUNDATION

A data center requires a badge to unlock the server-room door. Which control category BEST describes the badge-controlled lock?

- A. Technical
- B. Operational
- C. Physical**
- D. Managerial

CORRECT ANSWER: C - Physical

WHY: A physical control restricts physical access to facilities, rooms, equipment, or other tangible assets.

MEMORY CUE

Physical = tangible access barrier.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 24 | AAA - AUTHENTICATION

FOUNDATION

A VPN gateway checks a user password and hardware token to prove the user is who they claim to be. Which AAA function is occurring?

- A. Attestation
- B. Authorization
- C. Accounting
- D. Authentication**

CORRECT ANSWER: D - Authentication

WHY: Authentication verifies identity using credentials or authentication factors.

MEMORY CUE

Authentication = prove identity.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 25-26

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 25 | AAA - AUTHORIZATION

FOUNDATION

After a successful VPN login, the system determines that the user may access the SOC subnet but not the finance subnet. Which AAA function is this?

A. Authorization

B. Accounting

C. Identification

D. Authentication

CORRECT ANSWER: A - Authorization

WHY: Authorization determines what an authenticated identity is allowed to access or do.

MEMORY CUE

Authorization = what you may do.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 26 | AAA - ACCOUNTING

FOUNDATION

A RADIUS server records login time, session duration, and bytes transferred for each VPN connection. Which AAA function is being demonstrated?

A. Authorization

B. Accounting

C. Authentication

D. Federation

CORRECT ANSWER: B - Accounting

WHY: Accounting records activity associated with authenticated sessions for auditing and tracking.

MEMORY CUE

Accounting = log who did what and when.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 27-28

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 27 | CERTIFICATE AUTHORITY

FOUNDATION

An enterprise needs a trusted service to issue and digitally sign device certificates used for VPN authentication. What component is required?

- A. HSM only
- B. RADIUS client
- C. Certificate authority (CA)**
- D. SIEM

CORRECT ANSWER: C - Certificate authority (CA)

WHY: A certificate authority issues and signs certificates so relying systems can validate them against a trusted CA chain.

MEMORY CUE

CA = issue and sign certificates.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 28 | DATA PLANE

FOUNDATION

On a firewall, which functional plane handles real-time packet forwarding and network address translation?

- A. Governance plane
- B. Management policy
- C. Control plane
- D. Data plane**

CORRECT ANSWER: D - Data plane

WHY: The data plane performs the actual processing and forwarding of network traffic.

MEMORY CUE

Data plane = packets move here.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 29-30

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 29 | CONTROL PLANE

FOUNDATION

An engineer modifies routing entries and firewall policy logic on a network device. Which functional plane is being configured?

A. Control plane

- B. User plane
- C. Data plane
- D. Storage plane

CORRECT ANSWER: A - Control plane

WHY: The control plane contains the logic, policies, and state that govern data-plane behavior.

MEMORY CUE

Control plane = decisions and configuration.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 30 | POLICY ENFORCEMENT POINT

FOUNDATION

In a zero-trust design, which component acts as the gatekeeper that applies an allow, deny, or revoke decision to the connection?

- A. Certificate Authority
- B. Policy Enforcement Point (PEP)**
- C. Security Orchestrator
- D. Policy Engine only

CORRECT ANSWER: B - Policy Enforcement Point (PEP)

WHY: The PEP enforces access decisions for subjects attempting to reach resources.

MEMORY CUE

PEP = enforcement gate.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 31-32

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 31 | COMPENSATING CONTROL

APPLIED

During an enterprise security review, a critical legacy application cannot be patched for two weeks, so the security team restricts access with a firewall rule until the vendor fix arrives. What control is the firewall rule serving as?

A. Detective

B. Directive

C. Compensating

D. Physical

CORRECT ANSWER: C - Compensating

WHY: A compensating control provides an alternate safeguard when the preferred control cannot yet be implemented.

MEMORY CUE

Compensating = alternate protection.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 32 | AVAILABILITY

APPLIED

During an enterprise security review, a hospital requires its patient-record system to remain accessible during a server hardware failure. Which CIA objective is the PRIMARY concern?

A. Authentication

B. Confidentiality

C. Integrity

D. Availability

CORRECT ANSWER: D - Availability

WHY: Availability ensures authorized users can access systems and data when needed.

MEMORY CUE

A = accessible when needed.

Security Objectives - CIA Triad



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 33-34

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 33 | PHYSICAL CONTROL

APPLIED

A data center requires a badge to unlock the server-room door. What control category BEST describes the badge-controlled lock?

- A. Physical
- B. Operational
- C. Managerial
- D. Technical

CORRECT ANSWER: A - Physical

WHY: A physical control restricts physical access to facilities, rooms, equipment, or other tangible assets.

MEMORY CUE

Physical = tangible access barrier.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 34 | AAA - AUTHORIZATION

APPLIED

In a separate enterprise scenario, after a successful VPN login, the system determines that the user may access the SOC subnet but not the finance subnet. Which AAA function is this?

- A. Accounting
- B. Authorization
- C. Identification
- D. Authentication

CORRECT ANSWER: B - Authorization

WHY: Authorization determines what an authenticated identity is allowed to access or do.

MEMORY CUE

Authorization = what you may do.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 35-36

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 35 | ZERO TRUST

APPLIED

In a separate enterprise scenario, an organization implementing zero trust wants to reduce reliance on the traditional concept of a trusted internal network. Which principle BEST supports this objective?

- A. Authenticate only at the perimeter
- B. Trust authenticated users indefinitely
- C. Verify explicitly and continuously**
- D. Permit internal traffic by default

CORRECT ANSWER: C - Verify explicitly and continuously

WHY: Zero trust does not automatically trust users or systems because they are inside the network.

MEMORY CUE

Never trust implicitly; continually verify.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 36 | MANAGERIAL CONTROL

APPLIED

During an enterprise security review, the CISO approves a written policy defining acceptable use of company systems. Which control category BEST describes the policy?

- A. Operational
- B. Technical
- C. Physical
- D. Managerial**

CORRECT ANSWER: D - Managerial

WHY: Managerial controls include governance, policies, risk decisions, and administrative direction.

MEMORY CUE

Managerial = governance and policy.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 37

Immediate answers, concise rationales, and visual memory anchors.

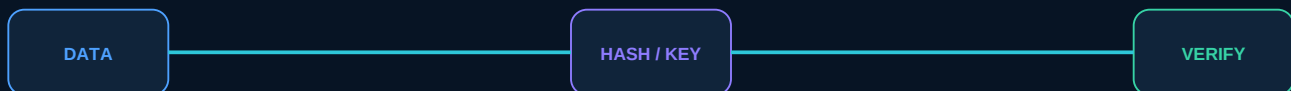
ANALYST TASK | DIGITAL SIGNATURES

In a separate enterprise scenario, which cryptographic mechanism provides the BEST evidence that a specific private-key holder approved a document?

- A. Digital signature
- B. Hashing
- C. Symmetric encryption
- D. Tokenization

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Cryptography / Trust



```
RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...
```

CORRECT ANSWER: A - Digital signature

RATIONALE

A digital signature uses asymmetric cryptography to provide integrity, authentication, and support for non-repudiation.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 38-39

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 38 | POLICY ENFORCEMENT POINT

APPLIED

During an enterprise security review, in a zero-trust design, which component acts as the gatekeeper that applies an allow, deny, or revoke decision to the connection?

- A. Policy Engine only
- B. Policy Enforcement Point (PEP)**
- C. Security Orchestrator
- D. Certificate Authority

CORRECT ANSWER: B - Policy Enforcement Point (PEP)

WHY: The PEP enforces access decisions for subjects attempting to reach resources.

MEMORY CUE

PEP = enforcement gate.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 39 | ASYMMETRIC ENCRYPTION

APPLIED

During an enterprise security review, a secure messaging system needs a key pair in which one key can be shared publicly and the other remains secret. What approach is being used?

- A. Symmetric encryption
- B. Salting
- C. Asymmetric encryption**
- D. Data masking

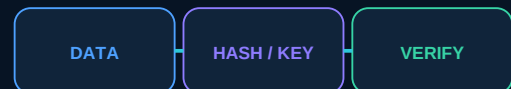
CORRECT ANSWER: C - Asymmetric encryption

WHY: Asymmetric cryptography uses mathematically related public and private keys.

MEMORY CUE

Public key + private key pair.

Cryptography / Trust



RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 40-41

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 40 | CONTROL PLANE

APPLIED

An engineer modifies routing entries and firewall policy logic on a network device. What functional plane is being configured?

- A. User plane
- B. Data plane
- C. Storage plane
- D. Control plane**

CORRECT ANSWER: D - Control plane

WHY: The control plane contains the logic, policies, and state that govern data-plane behavior.

MEMORY CUE

Control plane = decisions and configuration.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 41 | CIA TRIAD

APPLIED

In a separate enterprise scenario, which element of the CIA triad is MOST directly concerned with preventing unauthorized modification of information?

- A. Integrity**
- B. Confidentiality
- C. Authentication
- D. Availability

CORRECT ANSWER: A - Integrity

WHY: Integrity ensures information remains accurate and is not improperly modified.

MEMORY CUE

Confidentiality = prevent unauthorized disclosure Integrity = prevent unauthorized modification Availability = systems/data remain a...

Security Objectives - CIA Triad



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 42-43

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 42 | SECURITY CONTROLS

APPLIED

In a separate enterprise scenario, a security team installs cameras throughout a data center primarily so investigators can review activity after an incident. What type of control are the cameras primarily providing?

- A. Preventive
- B. Detective**
- C. Compensating
- D. Corrective

CORRECT ANSWER: B - Detective

WHY: Cameras help detect and investigate security events. They can also have a deterrent effect, but the question specifically emphasizes reviewing activity.

MEMORY CUE

Cameras help detect and investigate security events. They can also have a deterrent effect, but the question specifically emphasizes...

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 43 | AAA - AUTHENTICATION

APPLIED

During an enterprise security review, a VPN gateway checks a user password and hardware token to prove the user is who they claim to be. Which AAA function is occurring?

- A. Attestation
- B. Authorization
- C. Authentication**
- D. Accounting

CORRECT ANSWER: C - Authentication

WHY: Authentication verifies identity using credentials or authentication factors.

MEMORY CUE

Authentication = prove identity.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 44-45

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 44 | SYMMETRIC ENCRYPTION

APPLIED

During an enterprise security review, a backup system must encrypt terabytes of data quickly using the same secret for encryption and decryption. Which cryptographic approach BEST fits?

- A. Hashing
- B. Asymmetric encryption
- C. Tokenization

D. Symmetric encryption

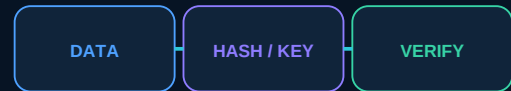
CORRECT ANSWER: D - Symmetric encryption

WHY: Symmetric algorithms use one shared secret key and are efficient for bulk data encryption.

MEMORY CUE

One shared key; fast for bulk data.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 45 | PREVENTIVE CONTROL

APPLIED

During an enterprise security review, a firewall rule blocks inbound TCP/445 from the internet before a connection can reach internal hosts. What control type is this?

- A. Preventive**
- B. Directive
- C. Corrective
- D. Detective

CORRECT ANSWER: A - Preventive

WHY: A preventive control is intended to stop an unwanted event before it occurs.

MEMORY CUE

Preventive = stop it first.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 46-47

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 46 | DUAL CONTROL

APPLIED

In a separate enterprise scenario, two administrators must independently authorize a highly sensitive transaction. Which principle does this BEST demonstrate?

- A. Federation
- B. Dual control**
- C. Least functionality
- D. Open permissions

CORRECT ANSWER: B - Dual control

WHY: Dual control requires two people to authorize or complete a sensitive action.

MEMORY CUE

Dual control requires two people to authorize or complete a sensitive action.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 47 | DETERRENT CONTROL

APPLIED

During an enterprise security review, a warning banner states that unauthorized access is monitored and may result in disciplinary action. What control type is the banner?

- A. Corrective
- B. Detective
- C. Deterrent**
- D. Compensating

CORRECT ANSWER: C - Deterrent

WHY: A deterrent control discourages unwanted behavior even if it does not physically prevent it.

MEMORY CUE

Deterrent = make the attacker/user think twice.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 48-49

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 48 | OPERATIONAL CONTROLS

APPLIED

What security control category does an organization's mandatory annual security-awareness course represent?

- A. Technical
- B. Cryptographic
- C. Physical
- D. Operational**

CORRECT ANSWER: D - Operational

WHY: Security awareness training is primarily a people- and process-based operational control.

MEMORY CUE

Security awareness training is primarily a people- and process-based operational control.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 49 | DECEPTION TECHNOLOGY

APPLIED

Which security technology places decoy credentials in an environment so defenders can detect when an attacker attempts to use them?

- A. Honeypot**
- B. HSM
- C. Load balancer
- D. TPM

CORRECT ANSWER: A - Honeypot

WHY: Honeypots are fake credentials, API keys, records, files, or other digital resources intended to trigger alerts when attackers access them.

MEMORY CUE

Honeypots are fake credentials, API keys, records, files, or other digital resources intended to trigger alerts when attackers acc...

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 50

Immediate answers, concise rationales, and visual memory anchors.

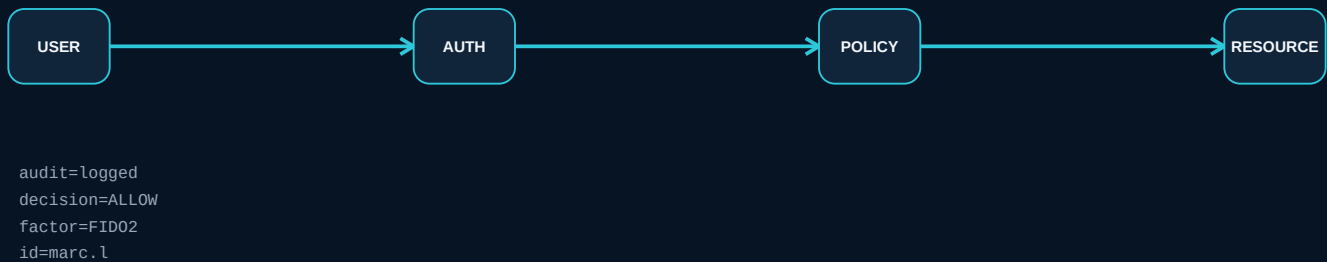
ANALYST TASK | AAA - ACCOUNTING

During an enterprise security review, a RADIUS server records login time, session duration, and bytes transferred for each VPN connection. What AAA function is being demonstrated?

- A. Federation
- B. Accounting
- C. Authentication
- D. Authorization

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Identity / Access Flow



CORRECT ANSWER: B - Accounting

RATIONALE Accounting records activity associated with authenticated sessions for auditing and tracking.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 51-52

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 51 | DIRECTIVE CONTROL

APPLIED

During an enterprise security review, a sign on a restricted laboratory door says "Authorized Personnel Only" but does not physically lock the door. What type of control is the sign?

- A. Corrective
- B. Preventive
- C. Directive**
- D. Detective

CORRECT ANSWER: C - Directive

WHY: Directive controls tell people what they are expected or required to do.

MEMORY CUE

Directive = instruct desired behavior.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 52 | CONFIDENTIALITY

APPLIED

During an enterprise security review, a payroll file must remain unreadable to unauthorized employees even if they can access the storage location. What security objective is MOST directly required?

- A. Availability
- B. Non-repudiation
- C. Integrity
- D. Confidentiality**

CORRECT ANSWER: D - Confidentiality

WHY: Confidentiality limits unauthorized disclosure of information.

MEMORY CUE

C = keep data secret from unauthorized viewers.

Security Objectives - CIA Triad



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 53-54

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 53 | DATA PLANE

APPLIED

During an enterprise security review, on a firewall, which functional plane handles real-time packet forwarding and network address translation?

A. Data plane

B. Control plane

C. Governance plane

D. Management policy

CORRECT ANSWER: A - Data plane

WHY: The data plane performs the actual processing and forwarding of network traffic.

MEMORY CUE

Data plane = packets move here.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 54 | FILE INTEGRITY

APPLIED

A security engineer wants to verify that a downloaded software image has not changed since the vendor released it. What should the administrator compare?

A. Digital certificate expiration date

B. Hash value

C. Initialization vector

D. Encryption key

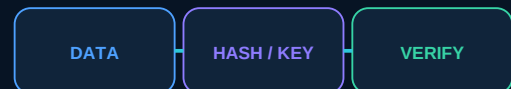
CORRECT ANSWER: B - Hash value

WHY: If the downloaded file produces the same trusted cryptographic hash as the vendor's original, its contents have not changed.

MEMORY CUE

If the downloaded file produces the same trusted cryptographic hash as the vendor's original, its contents have not changed.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 55-56

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 55 | NON-REPUDIATION

APPLIED

In a separate enterprise scenario, which security property prevents a sender from credibly denying that they digitally signed a transaction?

A. Confidentiality

B. Obfuscation

C. Non-repudiation

D. Availability

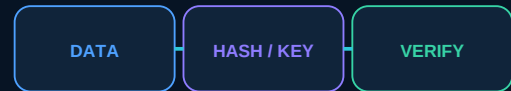
CORRECT ANSWER: C - Non-repudiation

WHY: Non-repudiation provides evidence tying an action or communication to its originator.

MEMORY CUE

Non-repudiation provides evidence tying an action or communication to its originator.

Cryptography / Trust



RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 56 | CORRECTIVE CONTROL

APPLIED

In a separate enterprise scenario, after ransomware is removed, an administrator restores an affected server from a known-good backup. What control type is the restoration?

A. Preventive

B. Directive

C. Deterrent

D. Corrective

CORRECT ANSWER: D - Corrective

WHY: Corrective controls reduce or reverse the impact after an event has occurred.

MEMORY CUE

Corrective = restore or repair after the event.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 57-58

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 57 | CERTIFICATE AUTHORITY

APPLIED

In a separate enterprise scenario, an enterprise needs a trusted service to issue and digitally sign device certificates used for VPN authentication. What component is required?

A. Certificate authority (CA)

B. HSM only

C. SIEM

D. RADIUS client

CORRECT ANSWER: A - Certificate authority (CA)

WHY: A certificate authority issues and signs certificates so relying systems can validate them against a trusted CA chain.

MEMORY CUE

CA = issue and sign certificates.

Identity / Access Flow



```
audit=logged  
decision=ALLOW  
factor=FIDO2  
id=marc.l
```

Illustrative study visual - not live production telemetry

QUESTION 58 | CHANGE MANAGEMENT

APPLIED

A multinational organization is replacing a production firewall. Security personnel require documentation, testing, management approval, a maintenance window, and a rollback procedure. This is primarily an example of:

A. Vulnerability disclosure

B. Change management

C. Data classification

D. Identity federation

CORRECT ANSWER: B - Change management

WHY: Controlled production changes should be documented, evaluated, approved, tested, scheduled, and capable of being rolled back.

MEMORY CUE

Controlled production changes should be documented, evaluated, approved, tested, scheduled, and capable of being rolled back.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 59-60

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 59 | MULTIFACTOR AUTHENTICATION

APPLIED

In a separate enterprise scenario, a company requires administrators to use a smart card and PIN before accessing production servers. Which security principle is being implemented?

- A. Accounting
- B. Non-repudiation
- C. Multifactor authentication**
- D. Federation

CORRECT ANSWER: C - Multifactor authentication

WHY: The smart card is something you have, while the PIN is something you know. Two different authentication factor categories create MFA.

MEMORY CUE

The smart card is something you have, while the PIN is something you know. Two different authentication factor categories create MFA.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 60 | PASSWORD SALTING

APPLIED

During an enterprise security review, a password database stores a unique random value with each password hash to make precomputed attacks less effective. What is the random value called?

- A. Initialization key
- B. Nonce reuse
- C. Token
- D. Salt**

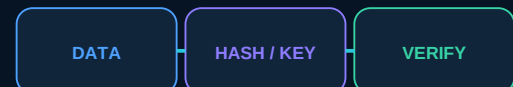
CORRECT ANSWER: D - Salt

WHY: A salt is unique random data added before hashing so identical passwords do not produce identical stored hashes.

MEMORY CUE

Salt defeats precomputed rainbow-table reuse.

Cryptography / Trust



```

RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 61-62

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 61 | FILE INTEGRITY

ADVANCED

A security architect is reviewing a control described as follows: if the downloaded file produces the same trusted cryptographic hash as the vendor's original, its contents have not changed. Which security principle, control, or technology BEST matches?

- A. Hash value
- B. Initialization vector
- C. Encryption key
- D. Digital certificate expiration date

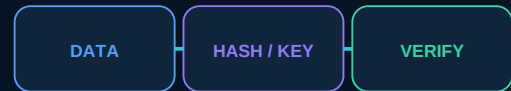
CORRECT ANSWER: A - Hash value

WHY: If the downloaded file produces the same trusted cryptographic hash as the vendor's original, its contents have not changed.

MEMORY CUE

If the downloaded file produces the same trusted cryptographic hash as the vendor's original, its contents have not changed.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 62 | PHYSICAL CONTROL

ADVANCED

A security architect is reviewing a control described as follows: a restricts access to facilities, rooms, equipment, or other tangible assets. Which security principle, control, or technology BEST matches?

- A. Managerial
- B. Physical
- C. Operational
- D. Technical

CORRECT ANSWER: B - Physical

WHY: A physical control restricts physical access to facilities, rooms, equipment, or other tangible assets.

MEMORY CUE

Physical = tangible access barrier.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 63

Immediate answers, concise rationales, and visual memory anchors.

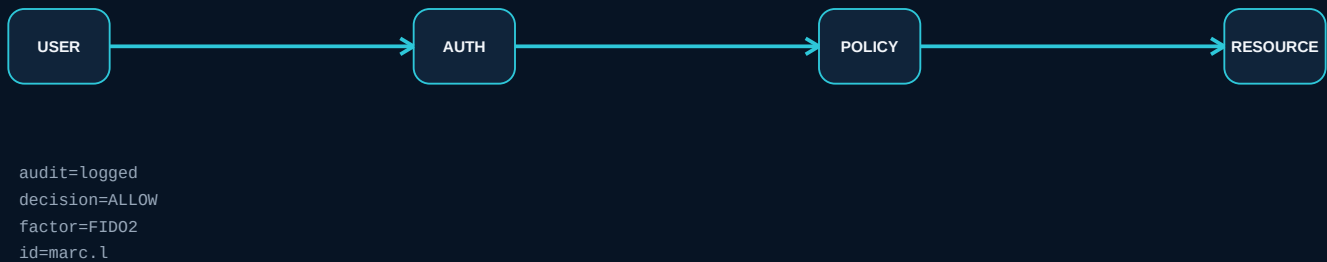
ANALYST TASK | AAA - AUTHENTICATION

A security architect is reviewing a control described as follows: verifies identity using credentials or factors. Which security principle, control, or technology BEST matches?

- A. Authorization
- B. Accounting
- C. Authentication
- D. Attestation

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Identity / Access Flow



CORRECT ANSWER: C - Authentication

RATIONALE Authentication verifies identity using credentials or authentication factors.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 64-65

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 64 | ASYMMETRIC ENCRYPTION

ADVANCED

A security architect is reviewing a control described as follows: asymmetric cryptography uses mathematically related public and private keys. Which security principle, control, or technology BEST matches?

- A. Symmetric encryption
- B. Salting
- C. Data masking
- D. Asymmetric encryption**

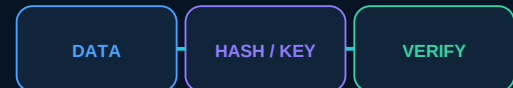
CORRECT ANSWER: D - Asymmetric encryption

WHY: Asymmetric cryptography uses mathematically related public and private keys.

MEMORY CUE

Public key + private key pair.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 65 | SYMMETRIC ENCRYPTION

ADVANCED

A security architect is reviewing a control described as follows: symmetric algorithms use one shared secret key and are efficient for bulk data encryption. Which security principle, control, or technology BEST matches?

- A. Symmetric encryption**
- B. Asymmetric encryption
- C. Tokenization
- D. Hashing

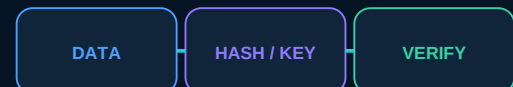
CORRECT ANSWER: A - Symmetric encryption

WHY: Symmetric algorithms use one shared secret key and are efficient for bulk data encryption.

MEMORY CUE

One shared key; fast for bulk data.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 66-67

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 66 | SECURITY CONTROLS

ADVANCED

A security architect is reviewing a control described as follows: cameras help detect and investigate security events. They can also have a deterrent effect, but the question specifically emphasizes reviewing activity. Which security principle, control, or technology BEST matches?

- A. Compensating
- B. Detective**
- C. Preventive
- D. Corrective

CORRECT ANSWER: B - Detective

WHY: Cameras help detect and investigate security events. They can also have a deterrent effect, but the question specifically emphasizes reviewing activity.

MEMORY CUE

Cameras help detect and investigate security events. They can also have a deterrent effect, but the question specifically emphasizes...

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 67 | PREVENTIVE CONTROL

ADVANCED

A security architect is reviewing a control described as follows: a intended to stop an unwanted event before it occurs. Which security principle, control, or technology BEST matches?

- A. Directive
- B. Detective
- C. Preventive**
- D. Corrective

CORRECT ANSWER: C - Preventive

WHY: A preventive control is intended to stop an unwanted event before it occurs.

MEMORY CUE

Preventive = stop it first.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 68-69

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 68 | CORRECTIVE CONTROL

ADVANCED

A security architect is reviewing a control described as follows: this controls reduce or reverse the impact after an event has occurred. Which security principle, control, or technology BEST matches?

- A. Deterrent
- B. Preventive
- C. Directive

D. Corrective

CORRECT ANSWER: D - Corrective

WHY: Corrective controls reduce or reverse the impact after an event has occurred.

MEMORY CUE

Corrective = restore or repair after the event.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 69 | OPERATIONAL CONTROLS

ADVANCED

A security architect is reviewing a control described as follows: security awareness training is primarily a people- and process-based control. Which security principle, control, or technology BEST matches?

- A. Operational**
- B. Technical
- C. Physical
- D. Cryptographic

CORRECT ANSWER: A - Operational

WHY: Security awareness training is primarily a people- and process-based operational control.

MEMORY CUE

Security awareness training is primarily a people- and process-based operational control.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 70-71

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 70 | CONFIDENTIALITY

ADVANCED

A security architect is reviewing a control described as follows: limits unauthorized disclosure of information. Which security principle, control, or technology BEST matches?

- A. Availability
- B. Confidentiality**
- C. Integrity
- D. Non-repudiation

CORRECT ANSWER: B - Confidentiality

WHY: Confidentiality limits unauthorized disclosure of information.

MEMORY CUE

C = keep data secret from unauthorized viewers.

Security Objectives - CIA Triad



QUESTION 71 | COMPENSATING CONTROL

ADVANCED

A security architect is reviewing a control described as follows: provides an alternate safeguard when the preferred control cannot yet be implemented. Which security principle, control, or technology BEST matches?

- A. Physical
- B. Directive
- C. Compensating**
- D. Detective

CORRECT ANSWER: C - Compensating

WHY: A compensating control provides an alternate safeguard when the preferred control cannot yet be implemented.

MEMORY CUE

Compensating = alternate protection.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 72-73

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 72 | MANAGERIAL CONTROL

ADVANCED

A security architect is reviewing a control described as follows: this controls include governance, policies, risk decisions, and administrative direction. Which security principle, control, or technology BEST matches?

- A. Technical
- B. Operational
- C. Physical
- D. Managerial**

CORRECT ANSWER: D - Managerial

WHY: Managerial controls include governance, policies, risk decisions, and administrative direction.

MEMORY CUE

Managerial = governance and policy.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 73 | DETERRENT CONTROL

ADVANCED

A security architect is reviewing a control described as follows: a discourages unwanted behavior even if it does not physically prevent it. Which security principle, control, or technology BEST matches?

- A. Deterrent**
- B. Corrective
- C. Detective
- D. Compensating

CORRECT ANSWER: A - Deterrent

WHY: A deterrent control discourages unwanted behavior even if it does not physically prevent it.

MEMORY CUE

Deterrent = make the attacker/user think twice.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 74-75

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 74 | AVAILABILITY

ADVANCED

A security architect is reviewing a control described as follows: ensures authorized users can access systems and data when needed. Which security principle, control, or technology BEST matches?

- A. Authentication
- B. Availability**
- C. Integrity
- D. Confidentiality

CORRECT ANSWER: B - Availability

WHY: Availability ensures authorized users can access systems and data when needed.

MEMORY CUE

A = accessible when needed.

Security Objectives - CIA Triad



QUESTION 75 | DECEPTION TECHNOLOGY

ADVANCED

A security architect is reviewing a control described as follows: this controls are fake credentials, API keys, records, files, or other digital resources intended to trigger alerts when attackers access them. Which security principle, control, or technology BEST matches?

- A. TPM
- B. Load balancer
- C. Honeytoken**
- D. HSM

CORRECT ANSWER: C - Honeytoken

WHY: Honeytokens are fake credentials, API keys, records, files, or other digital resources intended to trigger alerts when attackers acc...

MEMORY CUE

Honeytokens are fake credentials, API keys, records, files, or other digital resources intended to trigger alerts when attackers acc...

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 76

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | CIA TRIAD

A security architect is reviewing a control described as follows: ensures information remains accurate and is not improperly modified. Which security principle, control, or technology BEST matches?

- A. Authentication
- B. Confidentiality
- C. Availability
- D. Integrity

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Security Objectives - CIA Triad



CORRECT ANSWER: D - Integrity

RATIONALE Integrity ensures information remains accurate and is not improperly modified.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 77-78

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 77 | DIGITAL SIGNATURES

ADVANCED

A security architect is reviewing a control described as follows: uses asymmetric cryptography to provide integrity, authentication, and support for non-repudiation. Which security principle, control, or technology BEST matches?

A. Digital signature

B. Hashing

C. Symmetric encryption

D. Tokenization

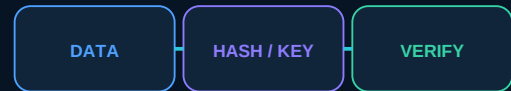
CORRECT ANSWER: A - Digital signature

WHY: A digital signature uses asymmetric cryptography to provide integrity, authentication, and support for non-repudiation.

MEMORY CUE

A digital signature uses asymmetric cryptography to provide integrity, authentication, and support for non-repudiation.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 78 | DIRECTIVE CONTROL

ADVANCED

A security architect is reviewing a control described as follows: this controls tell people what they are expected or required to do. Which security principle, control, or technology BEST matches?

A. Corrective

B. Directive

C. Preventive

D. Detective

CORRECT ANSWER: B - Directive

WHY: Directive controls tell people what they are expected or required to do.

MEMORY CUE

Directive = instruct desired behavior.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 79-80

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 79 | ZERO TRUST

ADVANCED

A security architect is reviewing a control described as follows: does not automatically trust users or systems because they are inside the network. Which security principle, control, or technology BEST matches?

- A. Authenticate only at the perimeter
- B. Trust authenticated users indefinitely
- C. Verify explicitly and continuously**
- D. Permit internal traffic by default

CORRECT ANSWER: C - Verify explicitly and continuously

WHY: Zero trust does not automatically trust users or systems because they are inside the network.

MEMORY CUE

Never trust implicitly; continually verify.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 80 | DUAL CONTROL

ADVANCED

A security architect is reviewing a control described as follows: requires two people to authorize or complete a sensitive action. Which security principle, control, or technology BEST matches?

- A. Least functionality
- B. Federation
- C. Open permissions
- D. Dual control**

CORRECT ANSWER: D - Dual control

WHY: Dual control requires two people to authorize or complete a sensitive action.

MEMORY CUE

Dual control requires two people to authorize or complete a sensitive action.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 81-82

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 81 | PASSWORD SALTING

ADVANCED

A security architect is reviewing a control described as follows: a unique random data added before hashing so identical passwords do not produce identical stored hashes. Which security principle, control, or technology BEST matches?

A. Salt

B. Initialization key

C. Nonce reuse

D. Token

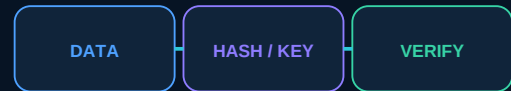
CORRECT ANSWER: A - Salt

WHY: A salt is unique random data added before hashing so identical passwords do not produce identical stored hashes.

MEMORY CUE

Salt defeats precomputed rainbow-table reuse.

Cryptography / Trust



RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 82 | CHANGE MANAGEMENT

ADVANCED

A security architect is reviewing a control described as follows: controlled production changes should be documented, evaluated, approved, tested, scheduled, and capable of being rolled back. Which security principle, control, or technology BEST matches?

A. Identity federation

B. Change management

C. Data classification

D. Vulnerability disclosure

CORRECT ANSWER: B - Change management

WHY: Controlled production changes should be documented, evaluated, approved, tested, scheduled, and capable of being rolled back.

MEMORY CUE

Controlled production changes should be documented, evaluated, approved, tested, scheduled, and capable of being rolled back.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 83-84

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 83 | MULTIFACTOR AUTHENTICATION

ADVANCED

A security architect is reviewing a control described as follows: the smart card is something you have, while the PIN is something you know. Two different authentication factor categories create MFA. Which security principle, control, or technology BEST matches?

- A. Federation
- B. Accounting
- C. Multifactor authentication**
- D. Non-repudiation

CORRECT ANSWER: C - Multifactor authentication

WHY: The smart card is something you have, while the PIN is something you know. Two different authentication factor categories create MFA.

MEMORY CUE

The smart card is something you have, while the PIN is something you know. Two different authentication factor categories create MFA.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 84 | NON-REPUDIATION

ADVANCED

A security architect is reviewing a control described as follows: provides evidence tying an action or communication to its originator. Which security principle, control, or technology BEST matches?

- A. Availability
- B. Confidentiality
- C. Obfuscation
- D. Non-repudiation**

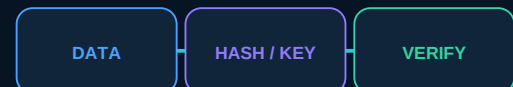
CORRECT ANSWER: D - Non-repudiation

WHY: Non-repudiation provides evidence tying an action or communication to its originator.

MEMORY CUE

Non-repudiation provides evidence tying an action or communication to its originator.

Cryptography / Trust



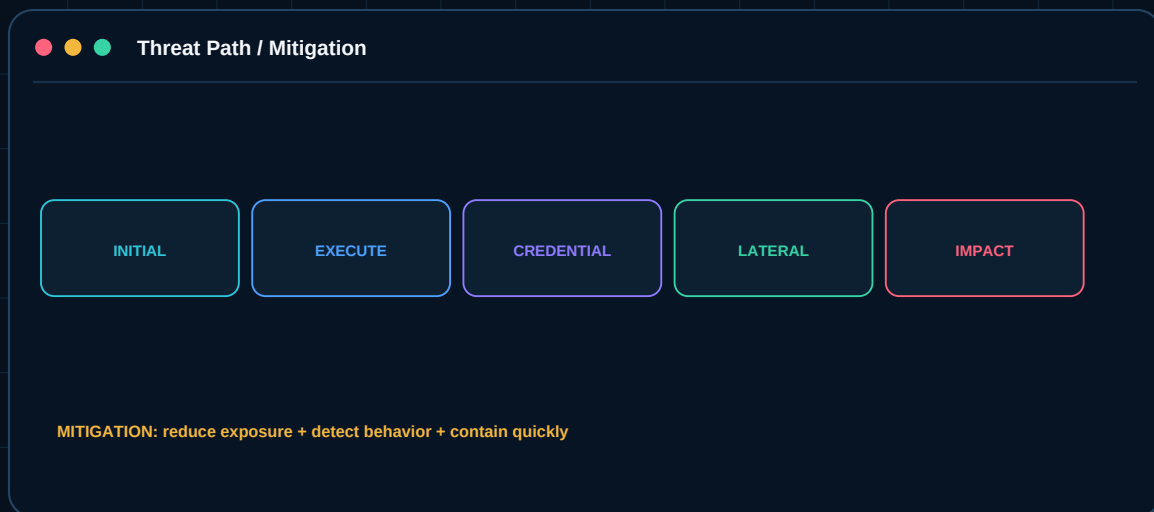
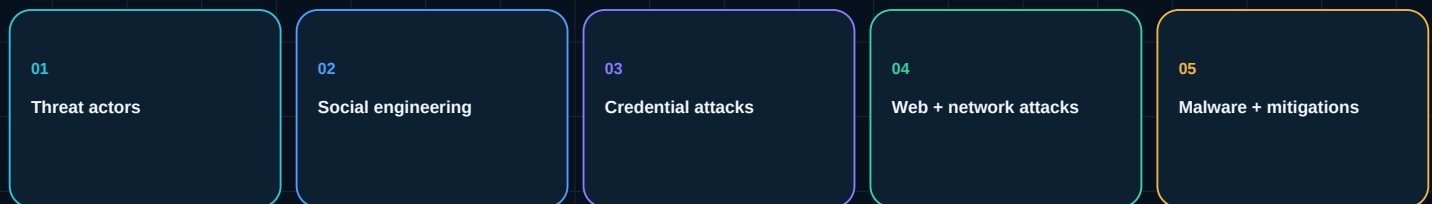
```

RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...
  
```

Illustrative study visual - not live production telemetry

THREATS, VULNERABILITIES & MITIGATIONS

QUESTIONS 85-238 | 154 QUESTIONS



BY MARC LAVOIE

Security+ Master Visual Review | Questions 85-86

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 85 | PASSWORD SPRAYING

FOUNDATION

An attacker attempts one commonly used password against hundreds of employee accounts. What attack is MOST likely occurring?

A. Password spraying

B. Credential stuffing

C. Pass-the-hash

D. Brute force

CORRECT ANSWER: A - Password spraying

WHY: Password spraying attempts the same password against many accounts to avoid account lockouts.

MEMORY CUE

Password spraying attempts the same password against many accounts to avoid account lockouts.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 86 | BRUTE-FORCE ATTACK

FOUNDATION

An attacker repeatedly tries thousands of different passwords against one administrator account. What attack is this?

A. Credential stuffing

B. Brute-force attack

C. Password spraying

D. Pass-the-hash

CORRECT ANSWER: B - Brute-force attack

WHY: Brute force systematically attempts many passwords against a target account.

MEMORY CUE

Many passwords -> one account.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 87-88

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 87 | CREDENTIAL STUFFING

FOUNDATION

Attackers use usernames and passwords stolen from another website to authenticate to a company's VPN. What attack is this?

- A. Password spraying
- B. Rainbow-table attack
- C. Credential stuffing**
- D. Kerberoasting

CORRECT ANSWER: C - Credential stuffing

WHY: Credential stuffing reuses stolen username/password combinations against other services.

MEMORY CUE

Credential stuffing reuses stolen username/password combinations against other services.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 88 | PASS-THE-HASH

FOUNDATION

An attacker steals an NTLM password hash and authenticates to another Windows system without recovering the plaintext password. What technique is this?

- A. Password spraying
- B. Rainbow-table attack
- C. Kerberoasting
- D. Pass-the-hash**

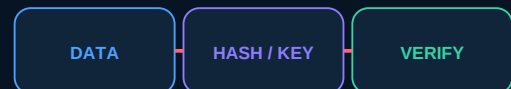
CORRECT ANSWER: D - Pass-the-hash

WHY: Pass-the-hash reuses a captured password hash directly for authentication in environments that accept it.

MEMORY CUE

Hash reused directly; plaintext not required.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 89-90

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 89 | SMISHING

FOUNDATION

An attacker sends a fraudulent text message containing a malicious link. This is:

A. Smishing

B. Tailgating

C. Pharming

D. Vishing

CORRECT ANSWER: A - Smishing

WHY: Smishing is phishing conducted through SMS/text messaging.

MEMORY CUE

Phishing = email/general Spear phishing = targeted Smishing = SMS Vishing = voice

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 90 | KERBEROASTING

FOUNDATION

An attacker requests service tickets for accounts with SPNs and cracks the ticket material offline to recover service-account passwords. What attack is this?

A. Credential stuffing

B. Kerberoasting

C. Pass-the-ticket

D. Password spraying

CORRECT ANSWER: B - Kerberoasting

WHY: Kerberoasting targets Kerberos service tickets associated with service accounts for offline password cracking.

MEMORY CUE

SPN + service ticket + offline cracking.

Threat Path / Mitigation

INITIAL

EXECUTE

CREDENTIAL

LATERAL

IMPACT

MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 91-92

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 91 | SPEAR PHISHING

FOUNDATION

A company's CEO receives a highly customized phishing email referencing a confidential acquisition. Which term BEST describes the attack?

A. Shoulder surfing

B. Smishing

C. Spear phishing

D. Dumpster diving

CORRECT ANSWER: C - Spear phishing

WHY: Spear phishing targets a specific person with customized information. A CEO-focused spear-phishing attack may also be called whaling.

MEMORY CUE

Spear phishing targets a specific person with customized information. A CEO-focused spear-phishing attack may also be called whaling.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 92 | MFA FATIGUE

FOUNDATION

A user receives dozens of unexpected push notifications until they finally approve one to make them stop. What attack is being attempted?

A. Tokenization

B. Credential stuffing

C. SIM swapping

D. MFA fatigue

CORRECT ANSWER: D - MFA fatigue

WHY: MFA fatigue bombards a user with authentication prompts in hopes they approve a malicious request.

MEMORY CUE

Repeated prompts pressure the user to approve.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 93-94

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 93 | SQL INJECTION

FOUNDATION

A web application builds the following database statement using unvalidated user input: `SELECT * FROM users WHERE username='INPUT'`; Which vulnerability should be the PRIMARY concern?

- A. SQL injection
- B. XSS
- C. CSRF
- D. Directory traversal

CORRECT ANSWER: A - SQL injection

WHY: User-controlled input is being directly incorporated into a SQL query, potentially allowing the attacker to alter database commands.

MEMORY CUE

User-controlled input is being directly incorporated into a SQL query, potentially allowing the attacker to alter database commands.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 94 | WHALING

FOUNDATION

An attacker sends a highly tailored fraudulent wire-transfer request specifically to the CFO. Which social-engineering attack BEST describes this?

- A. Smishing
- B. Whaling
- C. Tailgating
- D. Pharming

CORRECT ANSWER: B - Whaling

WHY: Whaling is targeted phishing aimed at executives or other high-value individuals.

MEMORY CUE

Whaling = executive-targeted phishing.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 95-96

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 95 | CROSS-SITE SCRIPTING

FOUNDATION

An application displays user-supplied comments without properly encoding them. An attacker inserts JavaScript that executes inside other users' browsers. What vulnerability exists?

- A. Race condition
- B. SQL injection
- C. Cross-site scripting**
- D. Integer overflow

CORRECT ANSWER: C - Cross-site scripting

WHY: XSS allows attacker-controlled script to execute in another user's browser.

MEMORY CUE

XSS allows attacker-controlled script to execute in another user's browser.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 96 | VISHING

FOUNDATION

An attacker calls the help desk, pretends to be an executive, and asks for a password reset. What attack is this?

- A. Pharming
- B. Smishing
- C. Shoulder surfing
- D. Vishing**

CORRECT ANSWER: D - Vishing

WHY: Vishing is voice-based phishing or social engineering conducted by telephone or voice communication.

MEMORY CUE

Vishing = voice phishing.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 97-98

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 97 | DIRECTORY TRAVERSAL

FOUNDATION

An attacker accesses:
`https://example.com/download?file=../../../../etc/passwd` Which technique is being attempted?

A. Directory traversal

- B. Buffer overflow
- C. SQL injection
- D. Credential stuffing

CORRECT ANSWER: A - Directory traversal

WHY: `../` attempts to move upward through the filesystem to access files outside the application's intended directory.

MEMORY CUE

`../` attempts to move upward through the filesystem to access files outside the application's intended directory.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 98 | PHARMING

FOUNDATION

Users who type the correct banking URL are silently redirected to a fraudulent site because local name resolution was altered. What attack is this?

- A. Whaling
- B. Pharming**
- C. Smishing
- D. Tailgating

CORRECT ANSWER: B - Pharming

WHY: Pharming redirects victims to malicious sites despite entering the expected address, often through DNS or hosts-file manipulation.

MEMORY CUE

Correct URL, wrong destination.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 99-100

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 99 | ZERO-DAY VULNERABILITY

FOUNDATION

A system is compromised through a vulnerability for which the vendor has not yet released a patch. What is this commonly called?

- A. Race condition
- B. Misconfiguration
- C. Zero-day vulnerability**
- D. Legacy vulnerability

CORRECT ANSWER: C - Zero-day vulnerability

WHY: A zero-day vulnerability lacks an available vendor fix when exploitation occurs.

MEMORY CUE

A zero-day vulnerability lacks an available vendor fix when exploitation occurs.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 100 | BUSINESS EMAIL COMPROMISE

FOUNDATION

A finance employee receives an apparently legitimate message from the CEO requesting an urgent change to a vendor bank account. What attack is MOST likely?

- A. Smishing
- B. Shoulder surfing
- C. Watering-hole attack
- D. Business email compromise (BEC)**

CORRECT ANSWER: D - Business email compromise (BEC)

WHY: BEC abuses trusted business identity or email context to induce fraudulent payments or sensitive actions.

MEMORY CUE

BEC = business trust + fraudulent transaction.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 101-102

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 101 | NETWORK SEGMENTATION

FOUNDATION

A ransomware infection encrypts a company's shared file servers. Which control would MOST directly help limit the ransomware from spreading between network segments?

A. Network segmentation

B. Certificate pinning

C. Tokenization

D. RAID 10

CORRECT ANSWER: A - Network segmentation

WHY: Segmentation limits lateral movement by restricting communication between systems and network zones.

MEMORY CUE

Segmentation limits lateral movement by restricting communication between systems and network zones.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 102 | PRETEXTING

FOUNDATION

An attacker claims to be an external auditor and invents a believable story to convince an employee to disclose internal procedures. What technique is this?

A. Credential stuffing

B. Pretexting

C. Typosquatting

D. ARP poisoning

CORRECT ANSWER: B - Pretexting

WHY: Pretexting uses a fabricated scenario or identity to manipulate a target into revealing information or taking action.

MEMORY CUE

Pretext = believable false story.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 103-104

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 103 | ON-PATH ATTACK

FOUNDATION

An attacker secretly intercepts and modifies communications between two systems. What type of attack is this?

- A. Password spraying
- B. DDoS
- C. On-path attack**
- D. Directory traversal

CORRECT ANSWER: C - On-path attack

WHY: The attacker places themselves between two communicating parties and can observe or modify communications.

MEMORY CUE

The attacker places themselves between two communicating parties and can observe or modify communications.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 104 | TAILGATING

FOUNDATION

An unauthorized person follows an employee through a badge-controlled door before it closes. What physical social-engineering technique is this?

- A. Shoulder surfing
- B. Vishing
- C. Dumpster diving
- D. Tailgating**

CORRECT ANSWER: D - Tailgating

WHY: Tailgating occurs when an unauthorized person gains physical access by following an authorized person.

MEMORY CUE

Follow an authorized person through the door.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 105-106

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 105 | DNS TUNNELING

FOUNDATION

A workstation continuously sends DNS queries containing unusually long encoded subdomains: aGVsbG8uZmlsZTE.attacker.example What should an analyst MOST suspect?

A. DNS tunneling

B. ARP spoofing

C. DHCP starvation

D. SYN flooding

CORRECT ANSWER: A - DNS tunneling

WHY: Attackers can encode commands or stolen data inside DNS queries and responses for C2 or exfiltration.

MEMORY CUE

Attackers can encode commands or stolen data inside DNS queries and responses for C2 or exfiltration.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
09:14:02	WS-17	resolver	aGVsbG8u...
09:14:03	WS-17	resolver	bG9uZy5x...
09:14:04	WS-17	resolver	NXDOMAIN

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 106 | SHOULDER SURFING

FOUNDATION

A person watches an employee enter a PIN at a workstation from a nearby desk. What technique is being used?

A. Smishing

B. Shoulder surfing

C. Pretexting

D. Pharming

CORRECT ANSWER: B - Shoulder surfing

WHY: Shoulder surfing obtains sensitive information by directly observing a user entering or viewing it.

MEMORY CUE

Observation of secrets on screen or keyboard.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 107-108

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 107 | SYN FLOOD

FOUNDATION

A server receives millions of TCP SYN packets but very few completed three-way handshakes. Which attack is MOST likely occurring?

- A. SQL injection
- B. DNS poisoning
- C. SYN flood**
- D. ARP spoofing

CORRECT ANSWER: C - SYN flood

WHY: SYN flooding creates large numbers of incomplete TCP connections to consume server resources.

MEMORY CUE

SYN flooding creates large numbers of incomplete TCP connections to consume server resources.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 108 | DUMPSTER DIVING

FOUNDATION

An attacker searches discarded paperwork for printed passwords and network diagrams. What technique is this?

- A. Evil twin
- B. Tailgating
- C. Whaling
- D. Dumpster diving**

CORRECT ANSWER: D - Dumpster diving

WHY: Dumpster diving searches discarded materials for sensitive information that was not properly destroyed.

MEMORY CUE

Trash can contain intelligence.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 109-110

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 109 | ARP POISONING

FOUNDATION

An attacker sends forged ARP responses to hosts on the same LAN to intercept their traffic. What attack is this?

A. ARP poisoning

B. VLAN hopping

C. MAC flooding

D. DNSSEC attack

CORRECT ANSWER: A - ARP poisoning

WHY: Forged ARP messages can associate an attacker's MAC address with another system's IP address, enabling interception.

MEMORY CUE

Forged ARP messages can associate an attacker's MAC address with another system's IP address, enabling interception.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 110 | RANSOMWARE

FOUNDATION

Malware encrypts shared files and displays a demand for cryptocurrency in exchange for a decryption key. What malware type is this?

A. Worm

B. Ransomware

C. Spyware

D. Rootkit

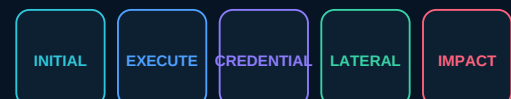
CORRECT ANSWER: B - Ransomware

WHY: Ransomware denies access to data or systems, commonly through encryption, and demands payment.

MEMORY CUE

Encryption + ransom demand.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 111-112

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 111 | HARDWARE KEYLOGGER

FOUNDATION

An employee finds several unauthorized USB devices attached between keyboards and company computers. What should investigators consider?

- A. NFC attacks
- B. Rogue access points
- C. Hardware keyloggers**
- D. Evil twins

CORRECT ANSWER: C - Hardware keyloggers

WHY: Physical keyloggers can be inserted between keyboards and computers to capture keystrokes.

MEMORY CUE

Physical keyloggers can be inserted between keyboards and computers to capture keystrokes.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 112 | WORM

FOUNDATION

Malware exploits a network service and automatically copies itself to other vulnerable hosts without user interaction. What type of malware is this?

- A. Logic bomb
- B. Spyware
- C. Trojan
- D. Worm**

CORRECT ANSWER: D - Worm

WHY: A worm self-propagates across systems or networks without requiring a user to execute each copy.

MEMORY CUE

Self-propagating malware.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 113-114

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 113 | SUPPLY-CHAIN ATTACK

FOUNDATION

An attacker compromises a software vendor and inserts malware into a legitimate software update delivered to thousands of customers. What type of attack is this?

A. Supply-chain attack

B. Replay attack

C. Watering-hole attack

D. Password attack

CORRECT ANSWER: A - Supply-chain attack

WHY: The attacker compromises a trusted supplier to gain access to downstream victims.

MEMORY CUE

The attacker compromises a trusted supplier to gain access to downstream victims.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 114 | TROJAN

FOUNDATION

A user installs a program advertised as a free PDF converter, but the program also installs a backdoor. What malware type BEST describes the program?

A. Logic bomb

B. Trojan

C. Worm

D. Rootkit

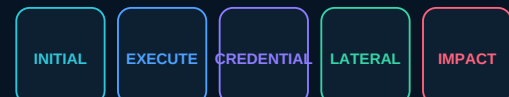
CORRECT ANSWER: B - Trojan

WHY: A Trojan disguises malicious functionality as legitimate or desirable software.

MEMORY CUE

Looks legitimate; carries malicious payload.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 115-116

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 115 | DATA LOSS PREVENTION

FOUNDATION

A malicious insider copies proprietary documents to personal cloud storage before leaving the company. Which technology is BEST suited to detect or prevent this behavior?

- A. NTP
- B. DHCP
- C. DLP**
- D. RAID

CORRECT ANSWER: C - DLP

WHY: Data Loss Prevention technology detects and restricts unauthorized movement of sensitive information.

MEMORY CUE

Data Loss Prevention technology detects and restricts unauthorized movement of sensitive information.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 116 | ROOTKIT

FOUNDATION

Malware modifies low-level system components to hide processes, files, and persistence from normal administration tools. What is this?

- A. Botnet
- B. Adware
- C. Ransomware
- D. Rootkit**

CORRECT ANSWER: D - Rootkit

WHY: Rootkits conceal malicious activity by manipulating or replacing low-level operating-system functionality.

MEMORY CUE

Rootkit = stealth at low system layers.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 117-118

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 117 | HACKTIVIST

FOUNDATION

A threat actor is primarily motivated by promoting a political or ideological cause. Which threat-actor category BEST applies?

- A. Hacktivist
- B. Shadow IT
- C. Organized crime
- D. Competitor

CORRECT ANSWER: A - Hacktivist

WHY: Hacktivists conduct cyber operations primarily to support political, social, or ideological objectives.

MEMORY CUE

Hacktivists conduct cyber operations primarily to support political, social, or ideological objectives.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 118 | SPYWARE

FOUNDATION

Software silently records browsing activity and sends the collected information to a third party. What malware category is this?

- A. Logic bomb
- B. Spyware
- C. Ransomware
- D. Worm

CORRECT ANSWER: B - Spyware

WHY: Spyware covertly monitors user or system activity and transmits collected data.

MEMORY CUE

Spyware = covert monitoring and collection.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 119-120

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 119 | NATION-STATE

FOUNDATION

A highly capable attacker conducts a multi-year espionage campaign against a defense contractor and appears to have extensive resources. Which threat actor is MOST likely?

- A. Untrained insider
- B. Script kiddie
- C. Nation-state actor**
- D. Casual attacker

CORRECT ANSWER: C - Nation-state actor

WHY: Long-term espionage, sophisticated capabilities, strategic objectives, and extensive resources commonly indicate state-sponsored operations.

MEMORY CUE

Long-term espionage, sophisticated capabilities, strategic objectives, and extensive resources commonly indicate state-sponsored operations.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 120 | LOGIC BOMB

FOUNDATION

Malicious code remains dormant until a specific date, then deletes application data. What type of malicious mechanism is this?

- A. Rootkit
- B. Trojan only
- C. Worm
- D. Logic bomb**

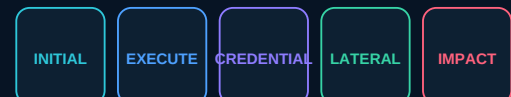
CORRECT ANSWER: D - Logic bomb

WHY: A logic bomb activates when a predefined condition or trigger is met.

MEMORY CUE

Dormant until a trigger condition.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 121-122

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 121 | MISCONFIGURATION

FOUNDATION

An attacker gains administrative access because a publicly accessible cloud service was mistakenly configured to allow anonymous administrative actions. What is the PRIMARY vulnerability?

A. Misconfiguration

B. Integer overflow

C. Zero-day

D. Buffer overflow

CORRECT ANSWER: A - Misconfiguration

WHY: The underlying technology was not necessarily vulnerable; insecure configuration created the exposure.

MEMORY CUE

The underlying technology was not necessarily vulnerable; insecure configuration created the exposure.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 122 | FILELESS MALWARE

FOUNDATION

An attacker executes malicious PowerShell directly in memory and leaves no traditional executable on disk. What technique does this BEST represent?

A. Boot-sector virus

B. Fileless malware

C. Worm

D. Firmware attack

CORRECT ANSWER: B - Fileless malware

WHY: Fileless malware relies heavily on memory and legitimate system tools instead of conventional malicious files on disk.

MEMORY CUE

Memory + built-in tools; little disk footprint.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 123-124

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 123 | ATTACK SURFACE REDUCTION

FOUNDATION

Which technique would BEST reduce an operating system's attack surface?

- A. Increase password expiration frequency
- B. Disable logging
- C. Remove unnecessary software and disable unused services**
- D. Enable every available service

CORRECT ANSWER: C - Remove unnecessary software and disable unused services

WHY: unused services Every unnecessary application, service, port, and feature can create additional attack opportunities.

MEMORY CUE

unused services Every unnecessary application, service, port, and feature can create additional attack opportunities.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 124 | BOTNET

FOUNDATION

Thousands of compromised home routers are remotely controlled to generate attack traffic against one target. What does the collection of compromised devices form?

- A. PKI
- B. VLAN
- C. Sandbox
- D. Botnet**

CORRECT ANSWER: D - Botnet

WHY: A botnet is a group of compromised devices controlled together by an attacker.

MEMORY CUE

Many compromised devices under common control.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 125-126

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 125 | CROSS-SITE REQUEST FORGERY

FOUNDATION

A victim is already authenticated to a banking site. A malicious page causes the browser to submit an unwanted transfer using the victim's existing session. What vulnerability is being exploited?

A. Cross-site request forgery (CSRF)

B. SQL injection

C. Cross-site scripting (XSS)

D. Directory traversal

CORRECT ANSWER: A - Cross-site request forgery (CSRF)

WHY: CSRF abuses a trusted authenticated browser session to submit an unintended request to another site.

MEMORY CUE

CSRF = victim browser sends unwanted authenticated action.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 126 | BUFFER OVERFLOW

FOUNDATION

An application writes more data into a fixed-size memory buffer than the buffer can hold, corrupting adjacent memory. What vulnerability is this?

A. Directory traversal

B. Buffer overflow

C. Race condition

D. SQL injection

CORRECT ANSWER: B - Buffer overflow

WHY: A buffer overflow occurs when a program writes beyond allocated memory boundaries.

MEMORY CUE

Too much data for allocated buffer.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 127-128

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 127 | RACE CONDITION

FOUNDATION

Two processes access and modify the same resource in an unexpected order, creating a security weakness that depends on timing. What vulnerability is this?

- A. Integer overflow
- B. Buffer overflow
- C. Race condition**
- D. Cross-site scripting

CORRECT ANSWER: C - Race condition

WHY: A race condition occurs when security-relevant behavior depends on the timing or sequence of concurrent operations.

MEMORY CUE

Race = timing/order of concurrent actions.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 128 | INTEGER OVERFLOW

FOUNDATION

A calculation exceeds the maximum value that can be represented by an integer type and wraps to an unexpected value. What weakness is this?

- A. Buffer overflow
- B. SQL injection
- C. Race condition
- D. Integer overflow**

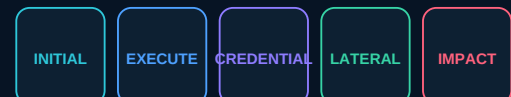
CORRECT ANSWER: D - Integer overflow

WHY: Integer overflow occurs when arithmetic exceeds the representable range and produces an unexpected result.

MEMORY CUE

Numeric value exceeds data type range.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 129-130

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 129 | DNS POISONING

FOUNDATION

A resolver cache is manipulated so that a legitimate hostname resolves to an attacker-controlled IP address. What attack is this?

A. DNS poisoning

B. DHCP starvation

C. DNS tunneling

D. ARP poisoning

CORRECT ANSWER: A - DNS poisoning

WHY: DNS poisoning corrupts name-resolution data to redirect users to an unintended destination.

MEMORY CUE

Poisoned DNS = wrong IP for correct name.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
09:14:02	WS-17	resolver	aGVsbG8u...
09:14:03	WS-17	resolver	bG9uZy5x...
09:14:04	WS-17	resolver	NXDOMAIN

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 130 | EVIL TWIN

FOUNDATION

A wireless access point is configured with the same SSID as the company guest network to trick users into connecting through the attacker. What attack is this?

A. DNS tunneling

B. Evil twin

C. ARP poisoning

D. VLAN hopping

CORRECT ANSWER: B - Evil twin

WHY: An evil twin impersonates a legitimate wireless network to intercept or manipulate user traffic.

MEMORY CUE

Fake AP mimics a trusted SSID.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 131-132

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 131 | ROGUE ACCESS POINT

FOUNDATION

An employee connects an unauthorized consumer Wi-Fi router to the corporate LAN. What has been introduced?

- A. NAC appliance
- B. Evil twin only
- C. Rogue access point**
- D. Wireless controller

CORRECT ANSWER: C - Rogue access point

WHY: A rogue access point is an unauthorized wireless device connected to an organization's network.

MEMORY CUE

Rogue AP = unauthorized AP on the network.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 132 | VLAN HOPPING

FOUNDATION

An attacker crafts traffic to gain access to a VLAN that should not be reachable from the attacker's assigned access port. What attack is being attempted?

- A. DNS poisoning
- B. Smishing
- C. ARP poisoning
- D. VLAN hopping**

CORRECT ANSWER: D - VLAN hopping

WHY: VLAN hopping attempts to bypass logical Layer 2 segmentation and reach traffic on another VLAN.

MEMORY CUE

VLAN hopping = escape assigned Layer 2 segment.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,200
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 133-134

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 133 | DHCP STARVATION

FOUNDATION

An attacker floods a DHCP server with requests using many spoofed MAC addresses until the address pool is exhausted. What attack is this?

A. DHCP starvation

B. DNS tunneling

C. ARP poisoning

D. SYN flood

CORRECT ANSWER: A - DHCP starvation

WHY: DHCP starvation consumes available leases so legitimate clients cannot obtain addresses.

MEMORY CUE

Exhaust DHCP lease pool.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 134 | AMPLIFICATION DDOS

FOUNDATION

An attacker sends small spoofed requests to public UDP services that return much larger responses to the victim. What attack technique is this?

A. Password spraying

B. Amplification DDoS

C. CSRF

D. VLAN hopping

CORRECT ANSWER: B - Amplification DDoS

WHY: Amplification attacks abuse services with a high response-to-request ratio and spoof the victim's source address.

MEMORY CUE

Small spoofed request -> large victim-bound response.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 135-136

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 135 | WATERING-HOLE ATTACK

FOUNDATION

Attackers compromise a website frequently visited by employees of a target organization and use it to deliver malicious code. What attack is this?

- A. Credential stuffing
- B. Whaling
- C. Watering-hole attack**
- D. Smishing

CORRECT ANSWER: C - Watering-hole attack

WHY: A watering-hole attack compromises a site that the intended victims are likely to visit.

MEMORY CUE

Compromise a site the target community already trusts.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 136 | MALICIOUS INSIDER

FOUNDATION

A database administrator intentionally exports customer records to sell them to a competitor. Which threat-actor category BEST applies?

- A. Unskilled attacker
- B. Hacktivist
- C. Nation-state actor
- D. Malicious insider**

CORRECT ANSWER: D - Malicious insider

WHY: A malicious insider abuses legitimate organizational access for unauthorized or harmful purposes.

MEMORY CUE

Insider = legitimate access abused intentionally.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 137-138

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 137 | ORGANIZED CRIME

FOUNDATION

A financially motivated group deploys ransomware across multiple companies and operates an affiliate payment system. Which threat actor is MOST likely?

A. Organized crime

B. Shadow IT

C. Hacktivist

D. Unskilled attacker

CORRECT ANSWER: A - Organized crime

WHY: Organized cybercrime groups typically pursue financial gain and can operate sophisticated criminal ecosystems.

MEMORY CUE

Primary motive: money.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 138 | UNSKILLED ATTACKER

FOUNDATION

A novice downloads a public exploit script and runs it without understanding the vulnerability or code. Which threat actor BEST fits?

A. Nation-state actor

B. Unskilled attacker

C. Insider threat

D. Organized crime

CORRECT ANSWER: B - Unskilled attacker

WHY: An unskilled attacker relies heavily on existing tools and instructions rather than advanced original capability.

MEMORY CUE

Low skill; uses ready-made tools.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 139-140

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 139 | TYPOSQUATTING

FOUNDATION

An attacker registers paypa1-support.example hoping users will mistake it for a trusted brand domain. What technique is this?

- A. DNS tunneling
- B. Credential stuffing
- C. Typosquatting**
- D. Tailgating

CORRECT ANSWER: C - Typosquatting

WHY: Typosquatting registers look-alike or misspelled domains to deceive users.

MEMORY CUE

Look-alike domain names exploit typing/visual mistakes.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 140 | BUSINESS EMAIL COMPROMISE

APPLIED

In a separate enterprise scenario, a finance employee receives an apparently legitimate message from the CEO requesting an urgent change to a vendor bank account. What attack is MOST likely?

- A. Shoulder surfing
- B. Watering-hole attack
- C. Smishing
- D. Business email compromise (BEC)**

CORRECT ANSWER: D - Business email compromise (BEC)

WHY: BEC abuses trusted business identity or email context to induce fraudulent payments or sensitive actions.

MEMORY CUE

BEC = business trust + fraudulent transaction.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 141-142

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 141 | SUPPLY-CHAIN ATTACK

APPLIED

During an incident investigation, an attacker compromises a software vendor and inserts malware into a legitimate software update delivered to thousands of customers. Which attack category BEST matches the scenario?

A. Supply-chain attack

B. Replay attack

C. Watering-hole attack

D. Password attack

CORRECT ANSWER: A - Supply-chain attack

WHY: The attacker compromises a trusted supplier to gain access to downstream victims.

MEMORY CUE

The attacker compromises a trusted supplier to gain access to downstream victims.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 142 | SPEAR PHISHING

APPLIED

During an incident investigation, a company's CEO receives a highly customized phishing email referencing a confidential acquisition. Which term BEST describes the attack?

A. Shoulder surfing

B. Spear phishing

C. Smishing

D. Dumpster diving

CORRECT ANSWER: B - Spear phishing

WHY: Spear phishing targets a specific person with customized information. A CEO-focused spear-phishing attack may also be called whaling.

MEMORY CUE

Spear phishing targets a specific person with customized information. A CEO-focused spear-phishing attack may also be called whaling.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 143-144

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 143 | FILELESS MALWARE

APPLIED

In a separate enterprise scenario, an attacker executes malicious PowerShell directly in memory and leaves no traditional executable on disk. What technique does this BEST represent?

A. Boot-sector virus

B. Worm

C. Fileless malware

D. Firmware attack

CORRECT ANSWER: C - Fileless malware

WHY: Fileless malware relies heavily on memory and legitimate system tools instead of conventional malicious files on disk.

MEMORY CUE

Memory + built-in tools; little disk footprint.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 144 | CREDENTIAL STUFFING

APPLIED

During an incident investigation, threat actors use usernames and passwords stolen from another website to authenticate to a company's VPN. Which attack technique BEST explains this behavior?

A. Password spraying

B. Rainbow-table attack

C. Kerberoasting

D. Credential stuffing

CORRECT ANSWER: D - Credential stuffing

WHY: Credential stuffing reuses stolen username/password combinations against other services.

MEMORY CUE

Credential stuffing reuses stolen username/password combinations against other services.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 145-147

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 145 | SPYWARE

APPLIED

In a separate enterprise scenario, software silently records browsing activity and sends the collected information to a third party. What malware category is this?

- A. Spyware
- B. Logic bomb
- C. Ransomware
- D. Worm

CORRECT ANSWER: A - Spyware

WHY: Spyware covertly monitors user or system activity and transmits collected data.

MEMORY CUE

Spyware = covert monitoring and collection.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 147 | ROGUE ACCESS POINT

APPLIED

During an incident investigation, an employee connects an unauthorized consumer Wi-Fi router to the corporate LAN. What has been introduced?

- A. NAC appliance
- B. Wireless controller
- C. Rogue access point
- D. Evil twin only

CORRECT ANSWER: C - Rogue access point

WHY: A rogue access point is an unauthorized wireless device connected to an organization's network.

MEMORY CUE

Rogue AP = unauthorized AP on the network.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 146

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | TROJAN

In a separate enterprise scenario, a user installs a program advertised as a free PDF converter, but the program also installs a backdoor. What malware type BEST describes the program?

- A. Logic bomb
- B. Trojan
- C. Worm
- D. Rootkit

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Threat Path / Mitigation

INITIAL

EXECUTE

CREDENTIAL

LATERAL

IMPACT

MITIGATION: reduce exposure + detect behavior + contain quickly

CORRECT ANSWER: B - Trojan

RATIONALE A Trojan disguises malicious functionality as legitimate or desirable software.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 148-149

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 148 | WORM

APPLIED

In a separate enterprise scenario, malware exploits a network service and automatically copies itself to other vulnerable hosts without user interaction. What type of malware is this?

- A. Spyware
- B. Trojan
- C. Logic bomb

D. Worm

CORRECT ANSWER: D - Worm

WHY: A worm self-propagates across systems or networks without requiring a user to execute each copy.

MEMORY CUE

Self-propagating malware.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 149 | VLAN HOPPING

APPLIED

In a separate enterprise scenario, an attacker crafts traffic to gain access to a VLAN that should not be reachable from the attacker's assigned access port. What attack is being attempted?

- A. VLAN hopping**
- B. DNS poisoning
- C. Smishing
- D. ARP poisoning

CORRECT ANSWER: A - VLAN hopping

WHY: VLAN hopping attempts to bypass logical Layer 2 segmentation and reach traffic on another VLAN.

MEMORY CUE

VLAN hopping = escape assigned Layer 2 segment.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 150-151

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 150 | KERBEROASTING

APPLIED

An attacker requests service tickets for accounts with SPNs and cracks the ticket material offline to recover service-account passwords. Which attack technique BEST explains this behavior?

- A. Password spraying
- B. Kerberoasting**
- C. Credential stuffing
- D. Pass-the-ticket

CORRECT ANSWER: B - Kerberoasting

WHY: Kerberoasting targets Kerberos service tickets associated with service accounts for offline password cracking.

MEMORY CUE

SPN + service ticket + offline cracking.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 151 | TYPOSQUATTING

APPLIED

During an incident investigation, a threat actor registers paypa1-support.example hoping users will mistake it for a trusted brand domain. What technique is this?

- A. Credential stuffing
- B. Tailgating
- C. Typosquatting**
- D. DNS tunneling

CORRECT ANSWER: C - Typosquatting

WHY: Typosquatting registers look-alike or misspelled domains to deceive users.

MEMORY CUE

Look-alike domain names exploit typing/visual mistakes.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 152-153

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 152 | BRUTE-FORCE ATTACK

APPLIED

An attacker repeatedly tries thousands of different passwords against one administrator account. Which attack technique BEST explains this behavior?

- A. Password spraying
- B. Credential stuffing
- C. Pass-the-hash

D. Brute-force attack

CORRECT ANSWER: D - Brute-force attack

WHY: Brute force systematically attempts many passwords against a target account.

MEMORY CUE

Many passwords -> one account.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 153 | VISHING

APPLIED

An attacker calls the help desk, pretends to be an executive, and asks for a password reset. Which attack technique BEST explains this behavior?

- A. Vishing**
- B. Shoulder surfing
- C. Pharming
- D. Smishing

CORRECT ANSWER: A - Vishing

WHY: Vishing is voice-based phishing or social engineering conducted by telephone or voice communication.

MEMORY CUE

Vishing = voice phishing.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 154-155

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 154 | BUFFER OVERFLOW

APPLIED

In a separate enterprise scenario, an application writes more data into a fixed-size memory buffer than the buffer can hold, corrupting adjacent memory. What vulnerability is this?

- A. Directory traversal
- B. Buffer overflow
- C. SQL injection
- D. Race condition

CORRECT ANSWER: B - Buffer overflow

WHY: A buffer overflow occurs when a program writes beyond allocated memory boundaries.

MEMORY CUE
Too much data for allocated buffer.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 155 | DNS POISONING

APPLIED

During an incident investigation, a resolver cache is manipulated so that a legitimate hostname resolves to an attacker-controlled IP address. Which attack technique BEST explains this behavior?

- A. DHCP starvation
- B. ARP poisoning
- C. DNS poisoning
- D. DNS tunneling

CORRECT ANSWER: C - DNS poisoning

WHY: DNS poisoning corrupts name-resolution data to redirect users to an unintended destination.

MEMORY CUE
Poisoned DNS = wrong IP for correct name.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
09:14:02	WS-17	resolver	aGvSbG8u...
09:14:03	WS-17	resolver	bG9uZy5x...
09:14:04	WS-17	resolver	NXDOMAIN

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 156-157

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 156 | AMPLIFICATION DDOS

APPLIED

In a separate enterprise scenario, an attacker sends small spoofed requests to public UDP services that return much larger responses to the victim. What attack technique is this?

- A. CSRF
- B. VLAN hopping
- C. Password spraying

D. Amplification DDoS

CORRECT ANSWER: D - Amplification DDoS

WHY: Amplification attacks abuse services with a high response-to-request ratio and spoof the victim's source address.

MEMORY CUE

Small spoofed request -> large victim-bound response.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 157 | WATERING-HOLE ATTACK

APPLIED

During an incident investigation, threat actors compromise a website frequently visited by employees of a target organization and use it to deliver malicious code. Which attack technique BEST explains this behavior?

- A. Watering-hole attack**
- B. Credential stuffing
- C. Smishing
- D. Whaling

CORRECT ANSWER: A - Watering-hole attack

WHY: A watering-hole attack compromises a site that the intended victims are likely to visit.

MEMORY CUE

Compromise a site the target community already trusts.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 158

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | SYN FLOOD

During an incident investigation, a server receives millions of TCP SYN packets but very few completed three-way handshakes. Which attack is MOST likely occurring?

- A. ARP spoofing
- B. SYN flood
- C. DNS poisoning
- D. SQL injection

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

CORRECT ANSWER: B - SYN flood

RATIONALE SYN flooding creates large numbers of incomplete TCP connections to consume server resources.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 159-160

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 159 | NATION-STATE

APPLIED

During an incident investigation, a highly capable attacker conducts a multi-year espionage campaign against a defense contractor and appears to have extensive resources. Which threat actor is MOST likely?

- A. Script kiddie
- B. Casual attacker
- C. Nation-state actor**
- D. Untrained insider

CORRECT ANSWER: C - Nation-state actor

WHY: Long-term espionage, sophisticated capabilities, strategic objectives, and extensive resources commonly indicate state-sponsored operations.

MEMORY CUE

Long-term espionage, sophisticated capabilities, strategic objectives, and extensive resources commonly indicate state-sponsored operations.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 160 | NETWORK SEGMENTATION

APPLIED

During an incident investigation, a ransomware infection encrypts a company's shared file servers. Which control would most directly help limit the ransomware from spreading between network segments?

- A. Certificate pinning
- B. RAID 10
- C. Tokenization
- D. Network segmentation**

CORRECT ANSWER: D - Network segmentation

WHY: Segmentation limits lateral movement by restricting communication between systems and network zones.

MEMORY CUE

Segmentation limits lateral movement by restricting communication between systems and network zones.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 161-162

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 161 | LOGIC BOMB

APPLIED

In a separate enterprise scenario, malicious code remains dormant until a specific date, then deletes application data. What type of malicious mechanism is this?

A. Logic bomb

B. Trojan only

C. Rootkit

D. Worm

CORRECT ANSWER: A - Logic bomb

WHY: A logic bomb activates when a predefined condition or trigger is met.

MEMORY CUE

Dormant until a trigger condition.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 162 | MALICIOUS INSIDER

APPLIED

In a separate enterprise scenario, a database administrator intentionally exports customer records to sell them to a competitor. Which threat-actor category BEST applies?

A. Hacktivist

B. Malicious insider

C. Unskilled attacker

D. Nation-State actor

CORRECT ANSWER: B - Malicious insider

WHY: A malicious insider abuses legitimate organizational access for unauthorized or harmful purposes.

MEMORY CUE

Insider = legitimate access abused intentionally.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 163-164

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 163 | HARDWARE KEYLOGGER

APPLIED

During an incident investigation, an employee finds several unauthorized USB devices attached between keyboards and company computers. What should investigators consider?

- A. Rogue access points
- B. NFC attacks
- C. Hardware keyloggers**
- D. Evil twins

CORRECT ANSWER: C - Hardware keyloggers

WHY: Physical keyloggers can be inserted between keyboards and computers to capture keystrokes.

MEMORY CUE

Physical keyloggers can be inserted between keyboards and computers to capture keystrokes.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 164 | RANSOMWARE

APPLIED

In a separate enterprise scenario, malware encrypts shared files and displays a demand for cryptocurrency in exchange for a decryption key. What malware type is this?

- A. Spyware
- B. Worm
- C. Rootkit
- D. Ransomware**

CORRECT ANSWER: D - Ransomware

WHY: Ransomware denies access to data or systems, commonly through encryption, and demands payment.

MEMORY CUE

Encryption + ransom demand.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 165-166

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 165 | HACKTIVIST

APPLIED

During an incident investigation, a threat actor is primarily motivated by promoting a political or ideological cause. What threat-actor category BEST applies?

- A. **Hacktivist**
- B. Competitor
- C. Shadow IT
- D. Organized crime

CORRECT ANSWER: A - Hacktivist

WHY: Hacktivists conduct cyber operations primarily to support political, social, or ideological objectives.

MEMORY CUE

Hacktivists conduct cyber operations primarily to support political, social, or ideological objectives.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 166 | INTEGER OVERFLOW

APPLIED

In a separate enterprise scenario, a calculation exceeds the maximum value that can be represented by an integer type and wraps to an unexpected value. What weakness is this?

- A. SQL injection
- B. **Integer overflow**
- C. Race condition
- D. Buffer overflow

CORRECT ANSWER: B - Integer overflow

WHY: Integer overflow occurs when arithmetic exceeds the representable range and produces an unexpected result.

MEMORY CUE

Numeric value exceeds data type range.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 167-168

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 167 | SHOULDER SURFING

APPLIED

In a separate enterprise scenario, a person watches an employee enter a PIN at a workstation from a nearby desk. What technique is being used?

A. Pretexting

B. Smishing

C. Shoulder surfing

D. Pharming

CORRECT ANSWER: C - Shoulder surfing

WHY: Shoulder surfing obtains sensitive information by directly observing a user entering or viewing it.

MEMORY CUE

Observation of secrets on screen or keyboard.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 168 | PRETEXTING

APPLIED

In a separate enterprise scenario, an attacker claims to be an external auditor and invents a believable story to convince an employee to disclose internal procedures. What technique is this?

A. Typosquatting

B. ARP poisoning

C. Credential stuffing

D. Pretexting

CORRECT ANSWER: D - Pretexting

WHY: Pretexting uses a fabricated scenario or identity to manipulate a target into revealing information or taking action.

MEMORY CUE

Pretext = believable false story.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 169-171

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 169 | ARP POISONING

APPLIED

During an incident investigation, a threat actor sends forged ARP responses to hosts on the same LAN to intercept their traffic. Which attack technique BEST explains this behavior?

A. ARP poisoning

B. VLAN hopping

C. MAC flooding

D. DNSSEC attack

CORRECT ANSWER: A - ARP poisoning

WHY: Forged ARP messages can associate an attacker's MAC address with another system's IP address, enabling interception.

MEMORY CUE

Forged ARP messages can associate an attacker's MAC address with another system's IP address, enabling interception.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 171 | UNSKILLED ATTACKER

APPLIED

A novice downloads a public exploit script and runs it without understanding the vulnerability or code. What threat actor BEST fits?

A. Organized crime

B. Insider threat

C. Unskilled attacker

D. Nation-state actor

CORRECT ANSWER: C - Unskilled attacker

WHY: An unskilled attacker relies heavily on existing tools and instructions rather than advanced original capability.

MEMORY CUE

Low skill; uses ready-made tools.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 170

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | BOTNET

In a separate enterprise scenario, thousands of compromised home routers are remotely controlled to generate attack traffic against one target. What does the collection of compromised devices form?

- A. VLAN
- B. Botnet
- C. PKI
- D. Sandbox

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Threat Path / Mitigation

INITIAL

EXECUTE

CREDENTIAL

LATERAL

IMPACT

MITIGATION: reduce exposure + detect behavior + contain quickly

CORRECT ANSWER: B - Botnet

RATIONALE

A botnet is a group of compromised devices controlled together by an attacker.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 172-173

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 172 | SMISHING

APPLIED

During an incident investigation, an attacker sends a fraudulent text message containing a malicious link. This is:

- A. Pharming
- B. Tailgating
- C. Vishing

D. Smishing

CORRECT ANSWER: D - Smishing

WHY: Smishing is phishing conducted through SMS/text messaging.

MEMORY CUE

Phishing = email/general Spear phishing = targeted Smishing = SMS Vishing = voice

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 173 | ROOTKIT

APPLIED

In a separate enterprise scenario, malware modifies low-level system components to hide processes, files, and persistence from normal administration tools. What is this?

A. Rootkit

- B. Botnet
- C. Ransomware
- D. Adware

CORRECT ANSWER: A - Rootkit

WHY: Rootkits conceal malicious activity by manipulating or replacing low-level operating-system functionality.

MEMORY CUE

Rootkit = stealth at low system layers.

Threat Path / Mitigation

INITIAL

EXECUTE

CREDENTIAL

LATERAL

IMPACT

MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 174-175

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 174 | MFA FATIGUE

APPLIED

An employee receives dozens of unexpected push notifications until they finally approve one to make them stop. What attack is being attempted?

- A. Tokenization
- B. MFA fatigue**
- C. Credential stuffing
- D. SIM swapping

CORRECT ANSWER: B - MFA fatigue

WHY: MFA fatigue bombards a user with authentication prompts in hopes they approve a malicious request.

MEMORY CUE

Repeated prompts pressure the user to approve.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 175 | PASS-THE-HASH

APPLIED

A threat actor steals an NTLM password hash and authenticates to another Windows system without recovering the plaintext password. What technique is this?

- A. Kerberoasting
- B. Rainbow-table attack
- C. Pass-the-hash**
- D. Password spraying

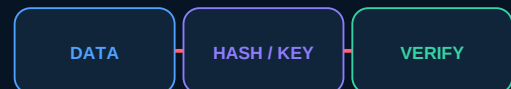
CORRECT ANSWER: C - Pass-the-hash

WHY: Pass-the-hash reuses a captured password hash directly for authentication in environments that accept it.

MEMORY CUE

Hash reused directly; plaintext not required.

Cryptography / Trust



```

RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 176-177

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 176 | ON-PATH ATTACK

APPLIED

During an incident investigation, a threat actor secretly intercepts and modifies communications between two systems. Which attack category BEST matches the scenario?

- A. Password spraying
- B. Directory traversal
- C. DDoS

D. On-path attack

CORRECT ANSWER: D - On-path attack

WHY: The attacker places themselves between two communicating parties and can observe or modify communications.

MEMORY CUE

The attacker places themselves between two communicating parties and can observe or modify communications.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 177 | DHCP STARVATION

APPLIED

During an incident investigation, a threat actor floods a DHCP server with requests using many spoofed MAC addresses until the address pool is exhausted. Which attack technique BEST explains this behavior?

A. DHCP starvation

- B. ARP poisoning
- C. DNS tunneling
- D. SYN flood

CORRECT ANSWER: A - DHCP starvation

WHY: DHCP starvation consumes available leases so legitimate clients cannot obtain addresses.

MEMORY CUE

Exhaust DHCP lease pool.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 178-179

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 178 | MISCONFIGURATION

APPLIED

During an incident investigation, a threat actor gains administrative access because a publicly accessible cloud service was mistakenly configured to allow anonymous administrative actions. What is the PRIMARY vulnerability?

- A. Buffer overflow
- B. Misconfiguration**
- C. Zero-day
- D. Integer overflow

CORRECT ANSWER: B - Misconfiguration

WHY: The underlying technology was not necessarily vulnerable; insecure configuration created the exposure.

MEMORY CUE

The underlying technology was not necessarily vulnerable; insecure configuration created the exposure.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 179 | ORGANIZED CRIME

APPLIED

During an incident investigation, a financially motivated group deploys ransomware across multiple companies and operates an affiliate payment system. Which threat actor is MOST likely?

- A. Unskilled attacker
- B. Shadow IT
- C. Organized crime**
- D. Hacktivist

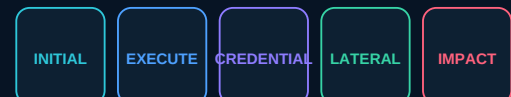
CORRECT ANSWER: C - Organized crime

WHY: Organized cybercrime groups typically pursue financial gain and can operate sophisticated criminal ecosystems.

MEMORY CUE

Primary motive: money.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 180-181

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 180 | RACE CONDITION

APPLIED

During an incident investigation, two processes access and modify the same resource in an unexpected order, creating a security weakness that depends on timing. What vulnerability is this?

- A. Buffer overflow
- B. Cross-site scripting
- C. Integer overflow

D. Race condition

CORRECT ANSWER: D - Race condition

WHY: A race condition occurs when security-relevant behavior depends on the timing or sequence of concurrent operations.

MEMORY CUE

Race = timing/order of concurrent actions.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 181 | EVIL TWIN

APPLIED

A wireless access point is configured with the same SSID as the company guest network to trick users into connecting through the attacker. Which attack technique BEST explains this behavior?

- A. Evil twin**
- B. DNS tunneling
- C. ARP poisoning
- D. VLAN hopping

CORRECT ANSWER: A - Evil twin

WHY: An evil twin impersonates a legitimate wireless network to intercept or manipulate user traffic.

MEMORY CUE

Fake AP mimics a trusted SSID.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 182

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | CROSS-SITE REQUEST FORGERY

During an incident investigation, a victim is already authenticated to a banking site. A malicious page causes the browser to submit an unwanted transfer using the victim's existing session. What vulnerability is being exploited?

- A. SQL injection
- B. Cross-site request forgery (CSRF)
- C. Cross-site scripting (XSS)
- D. Directory traversal

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Threat Path / Mitigation

INITIAL

EXECUTE

CREDENTIAL

LATERAL

IMPACT

MITIGATION: reduce exposure + detect behavior + contain quickly

CORRECT ANSWER: B - Cross-site request forgery (CSRF)

RATIONALE

CSRF abuses a trusted authenticated browser session to submit an unintended request to another site.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 183-184

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 183 | WHALING

APPLIED

A threat actor sends a highly tailored fraudulent wire-transfer request specifically to the CFO. Which social-engineering attack BEST describes this?

- A. Smishing
- B. Pharming
- C. Whaling**
- D. Tailgating

CORRECT ANSWER: C - Whaling

WHY: Whaling is targeted phishing aimed at executives or other high-value individuals.

MEMORY CUE

Whaling = executive-targeted phishing.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 184 | CROSS-SITE SCRIPTING

APPLIED

During an incident investigation, an application displays user-supplied comments without properly encoding them. An attacker inserts JavaScript that executes inside other users' browsers. What vulnerability exists?

- A. Integer overflow
- B. Race condition
- C. SQL injection
- D. Cross-site scripting**

CORRECT ANSWER: D - Cross-site scripting

WHY: XSS allows attacker-controlled script to execute in another user's browser.

MEMORY CUE

XSS allows attacker-controlled script to execute in another user's browser.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 185-186

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 185 | PASSWORD SPRAYING

APPLIED

During an incident investigation, a threat actor attempts one commonly used password against hundreds of employee accounts. What attack is MOST likely occurring?

A. Password spraying

- B. Pass-the-hash
- C. Credential stuffing
- D. Brute force

CORRECT ANSWER: A - Password spraying

WHY: Password spraying attempts the same password against many accounts to avoid account lockouts.

MEMORY CUE

Password spraying attempts the same password against many accounts to avoid account lockouts.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 186 | TAILGATING

APPLIED

In a separate enterprise scenario, an unauthorized person follows an employee through a badge-controlled door before it closes. What physical social-engineering technique is this?

- A. Shoulder surfing
- B. Tailgating**
- C. Dumpster diving
- D. Vishing

CORRECT ANSWER: B - Tailgating

WHY: Tailgating occurs when an unauthorized person gains physical access by following an authorized person.

MEMORY CUE

Follow an authorized person through the door.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 187-188

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 187 | ATTACK SURFACE REDUCTION

APPLIED

During an incident investigation, what technique would BEST reduce an operating system's attack surface?

- A. Enable every available service
- B. Disable logging
- C. Remove unnecessary software and disable unused services**
- D. Increase password expiration frequency

CORRECT ANSWER: C - Remove unnecessary software and disable unused services

WHY: unused services Every unnecessary application, service, port, and feature can create additional attack opportunities.

MEMORY CUE

unused services Every unnecessary application, service, port, and feature can create additional attack opportunities.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 188 | ZERO-DAY VULNERABILITY

APPLIED

During an incident investigation, a system is compromised through a vulnerability for which the vendor has not yet released a patch. What is this commonly called?

- A. Misconfiguration
- B. Race condition
- C. Legacy vulnerability
- D. Zero-day vulnerability**

CORRECT ANSWER: D - Zero-day vulnerability

WHY: A zero-day vulnerability lacks an available vendor fix when exploitation occurs.

MEMORY CUE

A zero-day vulnerability lacks an available vendor fix when exploitation occurs.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 189-190

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 189 | DIRECTORY TRAVERSAL

APPLIED

During an incident investigation, a threat actor accesses: `https://example.com/download?file=../../../../etc/passwd` Which technique is being attempted?

A. Directory traversal

- B. Credential stuffing
- C. SQL injection
- D. Buffer overflow

CORRECT ANSWER: A - Directory traversal

WHY: `../` attempts to move upward through the filesystem to access files outside the application's intended directory.

MEMORY CUE

`../` attempts to move upward through the filesystem to access files outside the application's intended directory.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 190 | DUMPSTER DIVING

APPLIED

In a separate enterprise scenario, an attacker searches discarded paperwork for printed passwords and network diagrams. What technique is this?

- A. Tailgating
- B. Dumpster diving**
- C. Whaling
- D. Evil twin

CORRECT ANSWER: B - Dumpster diving

WHY: Dumpster diving searches discarded materials for sensitive information that was not properly destroyed.

MEMORY CUE

Trash can contain intelligence.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 191-192

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 191 | SQL INJECTION

APPLIED

During an incident investigation, a web application builds the following database statement using unvalidated user input: **SELECT * FROM users WHERE username='INPUT'**; What vulnerability should be the **PRIMARY** concern?

- A. XSS
- B. Directory traversal

C. SQL injection

D. CSRF

CORRECT ANSWER: C - SQL injection

WHY: User-controlled input is being directly incorporated into a SQL query, potentially allowing the attacker to alter database commands.

MEMORY CUE

User-controlled input is being directly incorporated into a SQL query, potentially allowing the attacker to alter database commands.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 192 | DNS TUNNELING

APPLIED

During an incident investigation, a workstation continuously sends DNS queries containing unusually long encoded subdomains: **aGVsbG8uZmlsZTE.attacker.example** What should an analyst **MOST** suspect?

- A. DHCP starvation
- B. SYN flooding
- C. ARP spoofing

D. DNS tunneling

CORRECT ANSWER: D - DNS tunneling

WHY: Attackers can encode commands or stolen data inside DNS queries and responses for C2 or exfiltration.

MEMORY CUE

Attackers can encode commands or stolen data inside DNS queries and responses for C2 or exfiltration.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
09:14:02	WS-17	resolver	aGVsbG8u...
09:14:03	WS-17	resolver	bG9uZy5x...
09:14:04	WS-17	resolver	NXDOMAIN

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 193-195

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 193 | DATA LOSS PREVENTION

APPLIED

During an incident investigation, a malicious insider copies proprietary documents to personal cloud storage before leaving the company. Which security technology is BEST suited to detect or prevent this behavior?

- A. DLP
- B. DHCP
- C. RAID
- D. NTP

CORRECT ANSWER: A - DLP

WHY: Data Loss Prevention technology detects and restricts unauthorized movement of sensitive information.

MEMORY CUE

Data Loss Prevention technology detects and restricts unauthorized movement of sensitive information.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 195 | BRUTE-FORCE ATTACK

ADVANCED

A SOC analyst is classifying behavior described as follows: brute force systematically attempts many passwords against a target account. Which threat, vulnerability, or mitigation BEST matches?

- A. Pass-the-hash
- B. Password spraying
- C. Brute-force attack
- D. Credential stuffing

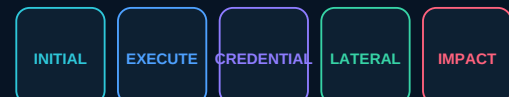
CORRECT ANSWER: C - Brute-force attack

WHY: Brute force systematically attempts many passwords against a target account.

MEMORY CUE

Many passwords -> one account.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 194

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | PHARMING

Users who type the correct banking URL are silently redirected to a fraudulent site because local name resolution was altered. Which attack technique BEST explains this behavior?

- A. Smishing
- B. Pharming
- C. Whaling
- D. Tailgating

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Threat Path / Mitigation

INITIAL

EXECUTE

CREDENTIAL

LATERAL

IMPACT

MITIGATION: reduce exposure + detect behavior + contain quickly

CORRECT ANSWER: B - Pharming

RATIONALE

Pharming redirects victims to malicious sites despite entering the expected address, often through DNS or hosts-file manipulation.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 196-197

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 196 | HACKTIVIST

ADVANCED

A SOC analyst is classifying behavior described as follows: this controls conduct cyber operations primarily to support political, social, or ideological objectives. Which threat, vulnerability, or mitigation BEST matches?

- A. Competitor
- B. Organized crime
- C. Shadow IT

D. Hacktivist

CORRECT ANSWER: D - Hacktivist

WHY: Hacktivists conduct cyber operations primarily to support political, social, or ideological objectives.

MEMORY CUE

Hacktivists conduct cyber operations primarily to support political, social, or ideological objectives.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 197 | DATA LOSS PREVENTION

ADVANCED

A SOC analyst is classifying behavior described as follows: technology detects and restricts unauthorized movement of sensitive information. Which threat, vulnerability, or mitigation BEST matches?

- A. DLP**
- B. DHCP
- C. RAID
- D. NTP

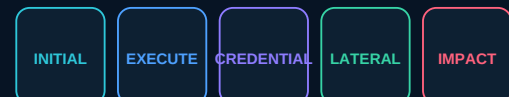
CORRECT ANSWER: A - DLP

WHY: Data Loss Prevention technology detects and restricts unauthorized movement of sensitive information.

MEMORY CUE

Data Loss Prevention technology detects and restricts unauthorized movement of sensitive information.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 198-199

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 198 | MFA FATIGUE

ADVANCED

A SOC analyst is classifying behavior described as follows: bombards a user with authentication prompts in hopes they approve a malicious request. Which threat, vulnerability, or mitigation BEST matches?

- A. Credential stuffing
- B. MFA fatigue**
- C. SIM swapping
- D. Tokenization

CORRECT ANSWER: B - MFA fatigue

WHY: MFA fatigue bombards a user with authentication prompts in hopes they approve a malicious request.

MEMORY CUE

Repeated prompts pressure the user to approve.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 199 | FILELESS MALWARE

ADVANCED

A SOC analyst is classifying behavior described as follows: relies heavily on memory and legitimate system tools instead of conventional malicious files on disk. Which threat, vulnerability, or mitigation BEST matches?

- A. Firmware attack
- B. Boot-sector virus
- C. Fileless malware**
- D. Worm

CORRECT ANSWER: C - Fileless malware

WHY: Fileless malware relies heavily on memory and legitimate system tools instead of conventional malicious files on disk.

MEMORY CUE

Memory + built-in tools; little disk footprint.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 200-201

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 200 | LOGIC BOMB

ADVANCED

A SOC analyst is classifying behavior described as follows: a activates when a predefined condition or trigger is met. Which threat, vulnerability, or mitigation BEST matches?

- A. Worm
- B. Rootkit
- C. Trojan only
- D. Logic bomb

D. Logic bomb

CORRECT ANSWER: D - Logic bomb

WHY: A logic bomb activates when a predefined condition or trigger is met.

MEMORY CUE

Dormant until a trigger condition.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 201 | NETWORK SEGMENTATION

ADVANCED

A SOC analyst is classifying behavior described as follows: segmentation limits lateral movement by restricting communication between systems and network zones. Which threat, vulnerability, or mitigation BEST matches?

- A. Network segmentation
- B. Tokenization
- C. RAID 10
- D. Certificate pinning

CORRECT ANSWER: A - Network segmentation

WHY: Segmentation limits lateral movement by restricting communication between systems and network zones.

MEMORY CUE

Segmentation limits lateral movement by restricting communication between systems and network zones.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 202-203

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 202 | SQL INJECTION

ADVANCED

A SOC analyst is classifying behavior described as follows: user-controlled input is being directly incorporated into a SQL query, potentially allowing the attacker to alter database commands. Which threat, vulnerability, or mitigation BEST matches?

- A. CSRF
- B. SQL injection**
- C. XSS
- D. Directory traversal

CORRECT ANSWER: B - SQL injection

WHY: User-controlled input is being directly incorporated into a SQL query, potentially allowing the attacker to alter database commands.

MEMORY CUE

User-controlled input is being directly incorporated into a SQL query, potentially allowing the attacker to alter database commands.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 203 | WHALING

ADVANCED

A SOC analyst is classifying behavior described as follows: targeted phishing aimed at executives or other high-value individuals. Which threat, vulnerability, or mitigation BEST matches?

- A. Smishing
- B. Pharming
- C. Whaling**
- D. Tailgating

CORRECT ANSWER: C - Whaling

WHY: Whaling is targeted phishing aimed at executives or other high-value individuals.

MEMORY CUE

Whaling = executive-targeted phishing.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 204-205

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 204 | ZERO-DAY VULNERABILITY

ADVANCED

A SOC analyst is classifying behavior described as follows: a lacks an available vendor fix when exploitation occurs. Which threat, vulnerability, or mitigation BEST matches?

- A. Misconfiguration
- B. Legacy vulnerability
- C. Race condition

D. Zero-day vulnerability

CORRECT ANSWER: D - Zero-day vulnerability

WHY: A zero-day vulnerability lacks an available vendor fix when exploitation occurs.

MEMORY CUE

A zero-day vulnerability lacks an available vendor fix when exploitation occurs.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 205 | PHARMING

ADVANCED

A SOC analyst is classifying behavior described as follows: redirects victims to malicious sites despite entering the expected address, often through DNS or hosts-file manipulation. Which threat, vulnerability, or mitigation BEST matches?

- A. Pharming**
- B. Whaling
- C. Smishing
- D. Tailgating

CORRECT ANSWER: A - Pharming

WHY: Pharming redirects victims to malicious sites despite entering the expected address, often through DNS or hosts-file manipulation.

MEMORY CUE

Correct URL, wrong destination.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 206

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | RACE CONDITION

A SOC analyst is classifying behavior described as follows: a occurs when security-relevant behavior depends on the timing or sequence of concurrent operations. Which threat, vulnerability, or mitigation BEST matches?

- A. Buffer overflow
- B. Race condition
- C. Cross-site scripting
- D. Integer overflow

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Threat Path / Mitigation

INITIAL

EXECUTE

CREDENTIAL

LATERAL

IMPACT

MITIGATION: reduce exposure + detect behavior + contain quickly

CORRECT ANSWER: B - Race condition

RATIONALE

A race condition occurs when security-relevant behavior depends on the timing or sequence of concurrent operations.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 207-208

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 207 | ARP POISONING

ADVANCED

A SOC analyst is classifying behavior described as follows: forged ARP messages can associate an attacker's MAC address with another system's IP address, enabling interception. Which threat, vulnerability, or mitigation BEST matches?

A. DNSSEC attack

B. VLAN hopping

C. ARP poisoning

D. MAC flooding

CORRECT ANSWER: C - ARP poisoning

WHY: Forged ARP messages can associate an attacker's MAC address with another system's IP address, enabling interception.

MEMORY CUE

Forged ARP messages can associate an attacker's MAC address with another system's IP address, enabling interception.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 208 | WORM

ADVANCED

A SOC analyst is classifying behavior described as follows: a self-propagates across systems or networks without requiring a user to execute each copy. Which threat, vulnerability, or mitigation BEST matches?

A. Logic bomb

B. Trojan

C. Spyware

D. Worm

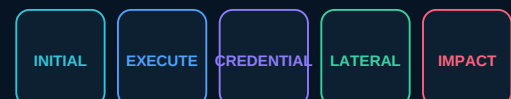
CORRECT ANSWER: D - Worm

WHY: A worm self-propagates across systems or networks without requiring a user to execute each copy.

MEMORY CUE

Self-propagating malware.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 209-210

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 209 | SPYWARE

ADVANCED

A SOC analyst is classifying behavior described as follows: covertly monitors user or system activity and transmits collected data. Which threat, vulnerability, or mitigation BEST matches?

- A. Spyware
- B. Worm
- C. Logic bomb
- D. Ransomware

CORRECT ANSWER: A - Spyware

WHY: Spyware covertly monitors user or system activity and transmits collected data.

MEMORY CUE

Spyware = covert monitoring and collection.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 210 | PASSWORD SPRAYING

ADVANCED

A SOC analyst is classifying behavior described as follows: attempts the same password against many accounts to avoid account lockouts. Which threat, vulnerability, or mitigation BEST matches?

- A. Brute force
- B. Password spraying
- C. Credential stuffing
- D. Pass-the-hash

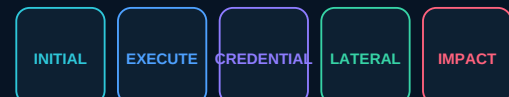
CORRECT ANSWER: B - Password spraying

WHY: Password spraying attempts the same password against many accounts to avoid account lockouts.

MEMORY CUE

Password spraying attempts the same password against many accounts to avoid account lockouts.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 211-212

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 211 | SUPPLY-CHAIN ATTACK

ADVANCED

A SOC analyst is classifying behavior described as follows: the attacker compromises a trusted supplier to gain access to downstream victims. Which threat, vulnerability, or mitigation BEST matches?

- A. Password attack
- B. Replay attack
- C. Supply-chain attack**
- D. Watering-hole attack

CORRECT ANSWER: C - Supply-chain attack

WHY: The attacker compromises a trusted supplier to gain access to downstream victims.

MEMORY CUE

The attacker compromises a trusted supplier to gain access to downstream victims.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 212 | ATTACK SURFACE REDUCTION

ADVANCED

A SOC analyst is classifying behavior described as follows: unused services Every unnecessary application, service, port, and feature can create additional attack opportunities. Which threat, vulnerability, or mitigation BEST matches?

- A. Enable every available service
- B. Increase password expiration frequency
- C. Disable logging
- D. Remove unnecessary software and disable unused services**

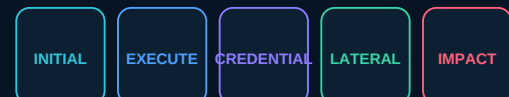
CORRECT ANSWER: D - Remove unnecessary software and disable unused services

WHY: unused services Every unnecessary application, service, port, and feature can create additional attack opportunities.

MEMORY CUE

unused services Every unnecessary application, service, port, and feature can create additional attack opportunities.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 213-214

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 213 | TROJAN

ADVANCED

A SOC analyst is classifying behavior described as follows: a disguises malicious functionality as legitimate or desirable software. Which threat, vulnerability, or mitigation BEST matches?

A. Trojan

B. Logic bomb

C. Rootkit

D. Worm

CORRECT ANSWER: A - Trojan

WHY: A Trojan disguises malicious functionality as legitimate or desirable software.

MEMORY CUE

Looks legitimate; carries malicious payload.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 214 | DNS TUNNELING

ADVANCED

A SOC analyst is classifying behavior described as follows: attackers can encode commands or stolen data inside DNS queries and responses for C2 or exfiltration. Which threat, vulnerability, or mitigation BEST matches?

A. ARP spoofing

B. DNS tunneling

C. SYN flooding

D. DHCP starvation

CORRECT ANSWER: B - DNS tunneling

WHY: Attackers can encode commands or stolen data inside DNS queries and responses for C2 or exfiltration.

MEMORY CUE

Attackers can encode commands or stolen data inside DNS queries and responses for C2 or exfiltration.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
09:14:02	WS-17	resolver	aGVsbG8u...
09:14:03	WS-17	resolver	bG9uZy5x...
09:14:04	WS-17	resolver	NXDOMAIN

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 215-216

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 215 | SPEAR PHISHING

ADVANCED

A SOC analyst is classifying behavior described as follows: targets a specific person with customized information. A CEO-focused spear-phishing attack may also be called whaling. Which threat, vulnerability, or mitigation BEST matches?

- A. Smishing
- B. Dumpster diving
- C. Spear phishing**
- D. Shoulder surfing

CORRECT ANSWER: C - Spear phishing

WHY: Spear phishing targets a specific person with customized information. A CEO-focused spear-phishing attack may also be called whaling.

MEMORY CUE

Spear phishing targets a specific person with customized information. A CEO-focused spear-phishing attack may also be called whaling.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 216 | BOTNET

ADVANCED

A SOC analyst is classifying behavior described as follows: a group of compromised devices controlled together by an attacker. Which threat, vulnerability, or mitigation BEST matches?

- A. Sandbox
- B. VLAN
- C. PKI
- D. Botnet**

CORRECT ANSWER: D - Botnet

WHY: A botnet is a group of compromised devices controlled together by an attacker.

MEMORY CUE

Many compromised devices under common control.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 217-219

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 217 | BUSINESS EMAIL COMPROMISE

ADVANCED

A SOC analyst is classifying behavior described as follows: bEC abuses trusted business identity or email context to induce fraudulent payments or sensitive actions. Which threat, vulnerability, or mitigation BEST matches?

A. Business email compromise (BEC)

- B. Shoulder surfing
- C. Watering-hole attack
- D. Smishing

CORRECT ANSWER: A - Business email compromise (BEC)

WHY: BEC abuses trusted business identity or email context to induce fraudulent payments or sensitive actions.

MEMORY CUE

BEC = business trust + fraudulent transaction.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 219 | INTEGER OVERFLOW

ADVANCED

A SOC analyst is classifying behavior described as follows: occurs when arithmetic exceeds the representable range and produces an unexpected result. Which threat, vulnerability, or mitigation BEST matches?

- A. SQL injection
- B. Race condition
- C. Integer overflow**
- D. Buffer overflow

CORRECT ANSWER: C - Integer overflow

WHY: Integer overflow occurs when arithmetic exceeds the representable range and produces an unexpected result.

MEMORY CUE

Numeric value exceeds data type range.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 218

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | KERBEROASTING

A SOC analyst is classifying behavior described as follows: targets Kerberos service tickets associated with service accounts for offline password cracking. Which threat, vulnerability, or mitigation BEST matches?

- A. Pass-the-ticket
- B. Kerberoasting
- C. Password spraying
- D. Credential stuffing

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Threat Path / Mitigation

INITIAL

EXECUTE

CREDENTIAL

LATERAL

IMPACT

MITIGATION: reduce exposure + detect behavior + contain quickly

CORRECT ANSWER: B - Kerberoasting

RATIONALE

Kerberoasting targets Kerberos service tickets associated with service accounts for offline password cracking.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 220-221

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 220 | VISHING

ADVANCED

A SOC analyst is classifying behavior described as follows: voice-based phishing or social engineering conducted by telephone or voice communication. Which threat, vulnerability, or mitigation BEST matches?

- A. Smishing
- B. Pharming
- C. Shoulder surfing

D. Vishing

CORRECT ANSWER: D - Vishing

WHY: Vishing is voice-based phishing or social engineering conducted by telephone or voice communication.

MEMORY CUE

Vishing = voice phishing.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 221 | RANSOMWARE

ADVANCED

A SOC analyst is classifying behavior described as follows: denies access to data or systems, commonly through encryption, and demands payment. Which threat, vulnerability, or mitigation BEST matches?

A. Ransomware

- B. Worm
- C. Spyware
- D. Rootkit

CORRECT ANSWER: A - Ransomware

WHY: Ransomware denies access to data or systems, commonly through encryption, and demands payment.

MEMORY CUE

Encryption + ransom demand.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 222-223

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 222 | TAILGATING

ADVANCED

A SOC analyst is classifying behavior described as follows: occurs when an unauthorized person gains physical access by following an authorized person. Which threat, vulnerability, or mitigation BEST matches?

A. Shoulder surfing

B. Tailgating

C. Dumpster diving

D. Vishing

CORRECT ANSWER: B - Tailgating

WHY: Tailgating occurs when an unauthorized person gains physical access by following an authorized person.

MEMORY CUE

Follow an authorized person through the door.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 223 | ROOTKIT

ADVANCED

A SOC analyst is classifying behavior described as follows: this controls conceal malicious activity by manipulating or replacing low-level operating-system functionality. Which threat, vulnerability, or mitigation BEST matches?

A. Adware

B. Ransomware

C. Rootkit

D. Botnet

CORRECT ANSWER: C - Rootkit

WHY: Rootkits conceal malicious activity by manipulating or replacing low-level operating-system functionality.

MEMORY CUE

Rootkit = stealth at low system layers.

Threat Path / Mitigation

INITIAL

EXECUTE

CREDENTIAL

LATERAL

IMPACT

MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 224-225

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 224 | CROSS-SITE REQUEST FORGERY

ADVANCED

A SOC analyst is classifying behavior described as follows: cSRF abuses a trusted authenticated browser session to submit an unintended request to another site. Which threat, vulnerability, or mitigation BEST matches?

- A. SQL injection
- B. Directory traversal
- C. Cross-site scripting (XSS)

D. Cross-site request forgery (CSRF)

CORRECT ANSWER: D - Cross-site request forgery (CSRF)

WHY: CSRF abuses a trusted authenticated browser session to submit an unintended request to another site.

MEMORY CUE

CSRF = victim browser sends unwanted authenticated action.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 225 | NATION-STATE

ADVANCED

A SOC analyst is classifying behavior described as follows: long-term espionage, sophisticated capabilities, strategic objectives, and extensive resources commonly indicate state-sponsored operations. Which threat, vulnerability, or mitigation BEST matches?

A. Nation-state actor

- B. Casual attacker
- C. Script kiddie
- D. Untrained insider

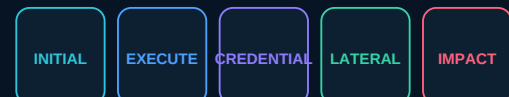
CORRECT ANSWER: A - Nation-state actor

WHY: Long-term espionage, sophisticated capabilities, strategic objectives, and extensive resources commonly indicate state-sponsored operations.

MEMORY CUE

Long-term espionage, sophisticated capabilities, strategic objectives, and extensive resources commonly indicate state-sponsored operations.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 226-227

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 226 | BUFFER OVERFLOW

ADVANCED

A SOC analyst is classifying behavior described as follows: a occurs when a program writes beyond allocated memory boundaries. Which threat, vulnerability, or mitigation BEST matches?

- A. SQL injection
- B. Buffer overflow**
- C. Race condition
- D. Directory traversal

CORRECT ANSWER: B - Buffer overflow

WHY: A buffer overflow occurs when a program writes beyond allocated memory boundaries.

MEMORY CUE

Too much data for allocated buffer.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 227 | SMISHING

ADVANCED

A SOC analyst is classifying behavior described as follows: phishing conducted through SMS/text messaging. Which threat, vulnerability, or mitigation BEST matches?

- A. Vishing
- B. Pharming
- C. Smishing**
- D. Tailgating

CORRECT ANSWER: C - Smishing

WHY: Smishing is phishing conducted through SMS/text messaging.

MEMORY CUE

Phishing = email/general Spear phishing = targeted Smishing = SMS Vishing = voice

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 228-229

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 228 | SYN FLOOD

ADVANCED

A SOC analyst is classifying behavior described as follows: this controlling creates large numbers of incomplete TCP connections to consume server resources. Which threat, vulnerability, or mitigation BEST matches?

- A. SQL injection
- B. DNS poisoning
- C. ARP spoofing

D. SYN flood

CORRECT ANSWER: D - SYN flood

WHY: SYN flooding creates large numbers of incomplete TCP connections to consume server resources.

MEMORY CUE

SYN flooding creates large numbers of incomplete TCP connections to consume server resources.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 229 | SHOULDER SURFING

ADVANCED

A SOC analyst is classifying behavior described as follows: obtains sensitive information by directly observing a user entering or viewing it. Which threat, vulnerability, or mitigation BEST matches?

A. Shoulder surfing

- B. Smishing
- C. Pretexting
- D. Pharming

CORRECT ANSWER: A - Shoulder surfing

WHY: Shoulder surfing obtains sensitive information by directly observing a user entering or viewing it.

MEMORY CUE

Observation of secrets on screen or keyboard.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 230

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | CREDENTIAL STUFFING

A SOC analyst is classifying behavior described as follows: reuses stolen username/password combinations against other services. Which threat, vulnerability, or mitigation BEST matches?

- A. Password spraying
- B. Credential stuffing
- C. Rainbow-table attack
- D. Kerberoasting

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Threat Path / Mitigation

INITIAL

EXECUTE

CREDENTIAL

LATERAL

IMPACT

MITIGATION: reduce exposure + detect behavior + contain quickly

CORRECT ANSWER: B - Credential stuffing

RATIONALE

Credential stuffing reuses stolen username/password combinations against other services.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 231-232

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 231 | MISCONFIGURATION

ADVANCED

A SOC analyst is classifying behavior described as follows: the underlying technology was not necessarily vulnerable; insecure configuration created the exposure. Which threat, vulnerability, or mitigation BEST matches?

A. Integer overflow

B. Buffer overflow

C. Misconfiguration

D. Zero-day

CORRECT ANSWER: C - Misconfiguration

WHY: The underlying technology was not necessarily vulnerable; insecure configuration created the exposure.

MEMORY CUE

The underlying technology was not necessarily vulnerable; insecure configuration created the exposure.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 232 | ON-PATH ATTACK

ADVANCED

A SOC analyst is classifying behavior described as follows: the attacker places themselves between two communicating parties and can observe or modify communications. Which threat, vulnerability, or mitigation BEST matches?

A. Password spraying

B. Directory traversal

C. DDoS

D. On-path attack

CORRECT ANSWER: D - On-path attack

WHY: The attacker places themselves between two communicating parties and can observe or modify communications.

MEMORY CUE

The attacker places themselves between two communicating parties and can observe or modify communications.

Simulated Security Telemetry

TIME	SOURCE	DEST	EVENT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 233-234

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 233 | PRETEXTING

ADVANCED

A SOC analyst is classifying behavior described as follows: uses a fabricated scenario or identity to manipulate a target into revealing information or taking action. Which threat, vulnerability, or mitigation BEST matches?

A. Pretexting

- B. Typosquatting
- C. Credential stuffing
- D. ARP poisoning

CORRECT ANSWER: A - Pretexting

WHY: Pretexting uses a fabricated scenario or identity to manipulate a target into revealing information or taking action.

MEMORY CUE

Pretext = believable false story.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 234 | DUMPSTER DIVING

ADVANCED

A SOC analyst is classifying behavior described as follows: searches discarded materials for sensitive information that was not properly destroyed. Which threat, vulnerability, or mitigation BEST matches?

- A. Tailgating
- B. Dumpster diving**
- C. Whaling
- D. Evil twin

CORRECT ANSWER: B - Dumpster diving

WHY: Dumpster diving searches discarded materials for sensitive information that was not properly destroyed.

MEMORY CUE

Trash can contain intelligence.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

[OPEN LINK](#)

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 235-236

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 235 | HARDWARE KEYLOGGER

ADVANCED

A SOC analyst is classifying behavior described as follows: physical keyloggers can be inserted between keyboards and computers to capture keystrokes. Which threat, vulnerability, or mitigation BEST matches?

- A. Rogue access points
- B. Evil twins
- C. Hardware keyloggers**
- D. NFC attacks

CORRECT ANSWER: C - Hardware keyloggers

WHY: Physical keyloggers can be inserted between keyboards and computers to capture keystrokes.

MEMORY CUE

Physical keyloggers can be inserted between keyboards and computers to capture keystrokes.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

QUESTION 236 | CROSS-SITE SCRIPTING

ADVANCED

A SOC analyst is classifying behavior described as follows: xSS allows attacker-controlled script to execute in another user's browser. Which threat, vulnerability, or mitigation BEST matches?

- A. Integer overflow
- B. SQL injection
- C. Race condition
- D. Cross-site scripting**

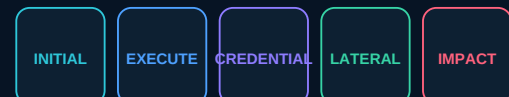
CORRECT ANSWER: D - Cross-site scripting

WHY: XSS allows attacker-controlled script to execute in another user's browser.

MEMORY CUE

XSS allows attacker-controlled script to execute in another user's browser.

Threat Path / Mitigation



MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 237-238

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 237 | PASS-THE-HASH

ADVANCED

A SOC analyst is classifying behavior described as follows: reuses a captured password hash directly for authentication in environments that accept it. Which threat, vulnerability, or mitigation BEST matches?

- A. Pass-the-hash
- B. Kerberoasting
- C. Rainbow-table attack
- D. Password spraying

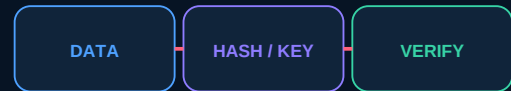
CORRECT ANSWER: A - Pass-the-hash

WHY: Pass-the-hash reuses a captured password hash directly for authentication in environments that accept it.

MEMORY CUE

Hash reused directly; plaintext not required.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 238 | DIRECTORY TRAVERSAL

ADVANCED

A SOC analyst is classifying behavior described as follows: / attempts to move upward through the filesystem to access files outside the application's intended directory. Which threat, vulnerability, or mitigation BEST matches?

- A. Buffer overflow
- B. Directory traversal
- C. Credential stuffing
- D. SQL injection

CORRECT ANSWER: B - Directory traversal

WHY: ../ attempts to move upward through the filesystem to access files outside the application's intended directory.

MEMORY CUE

../ attempts to move upward through the filesystem to access files outside the application's intended directory.

Threat Path / Mitigation

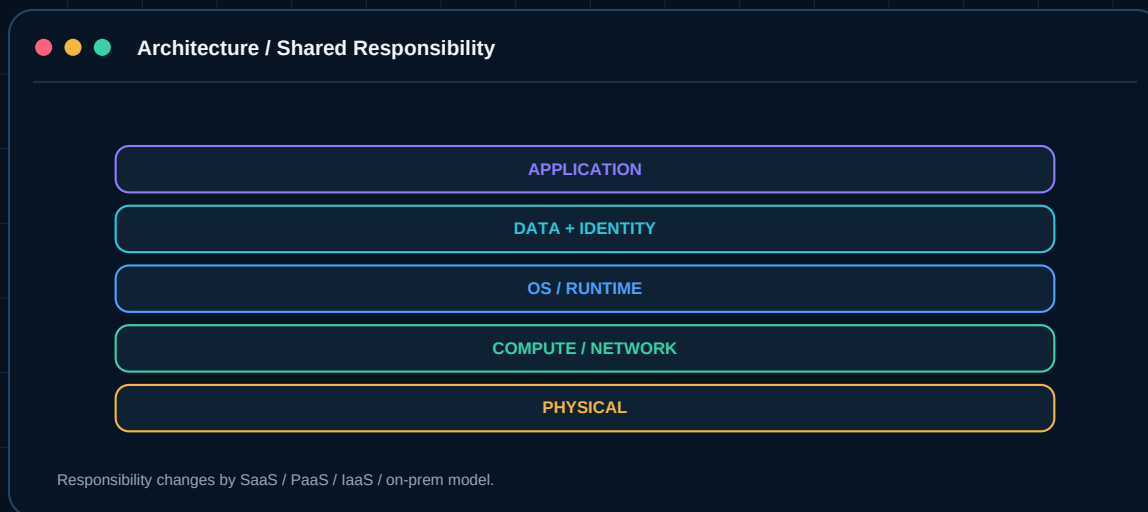
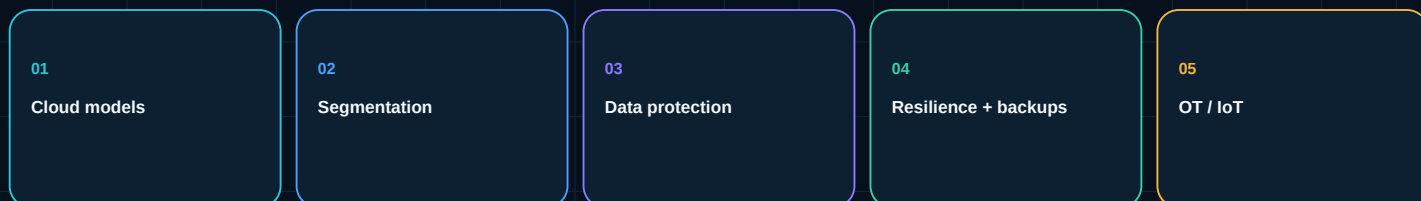


MITIGATION: reduce exposure + detect behavior + contain quickly

Illustrative study visual - not live production telemetry

SECURITY ARCHITECTURE

QUESTIONS 239-364 | 126 QUESTIONS



BY MARC LAVOIE

Security+ Master Visual Review | Questions 239-240

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 239 | DMZ

FOUNDATION

A company wants an application server to be accessible from the internet but does not want it placed directly on the internal network. Where should the server be located?

- A. SAN
- B. Loopback network
- C. DMZ**
- D. Management VLAN

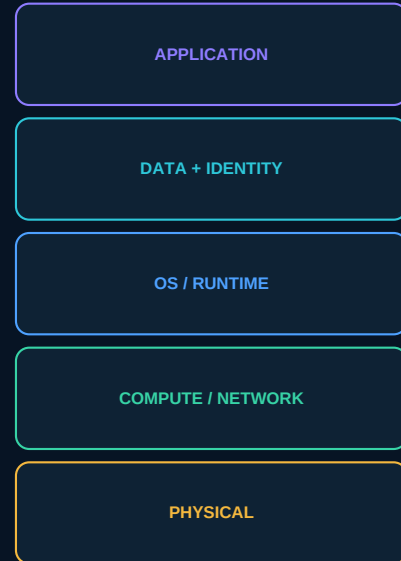
CORRECT ANSWER: C - DMZ

WHY: A DMZ provides a controlled network segment for internet-facing systems separated from trusted internal resources.

MEMORY CUE

A DMZ provides a controlled network segment for internet-facing systems separated from trusted internal resources.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 240 | PLATFORM AS A SERVICE

FOUNDATION

Developers deploy application code to a provider-managed runtime without managing the underlying operating system. Which cloud service model is this?

- A. Colocation
- B. IaaS
- C. SaaS
- D. PaaS**

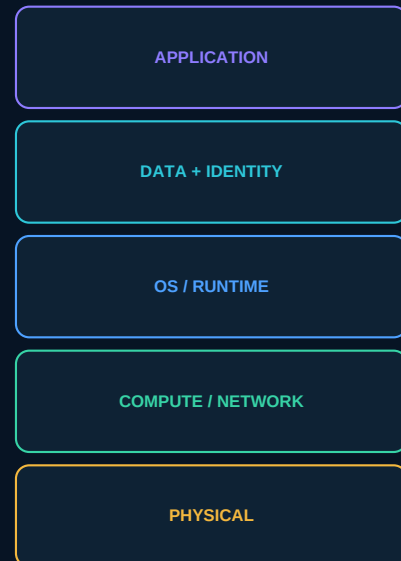
CORRECT ANSWER: D - PaaS

WHY: PaaS provides a managed application platform and runtime while the provider manages more of the underlying stack.

MEMORY CUE

PaaS = deploy code, provider manages platform.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 241-242

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 241 | INFRASTRUCTURE AS A SERVICE

FOUNDATION

Which cloud model provides customers with virtual machines, networking, and storage while the customer manages the operating systems?

- A. IaaS
- B. SaaS
- C. FaaS only
- D. PaaS

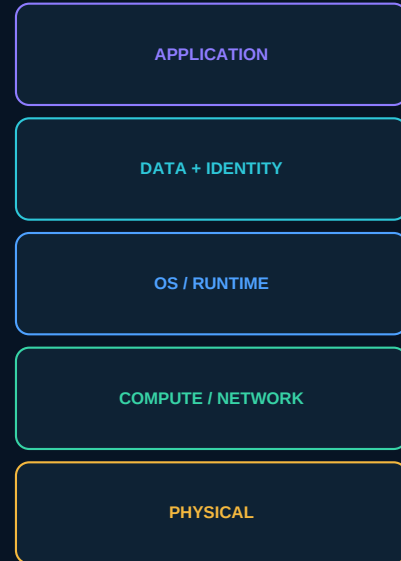
CORRECT ANSWER: A - IaaS

WHY: With Infrastructure as a Service, the provider operates the physical infrastructure while the customer manages virtual operating systems and workloads.

MEMORY CUE

With Infrastructure as a Service, the provider operates the physical infrastructure while the customer manages virtual operating systems...

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 242 | HYBRID CLOUD

FOUNDATION

An organization keeps regulated databases in its private environment but bursts web workloads into a public cloud. Which deployment model is this?

- A. Public cloud
- B. Hybrid cloud
- C. Community cloud
- D. Private cloud

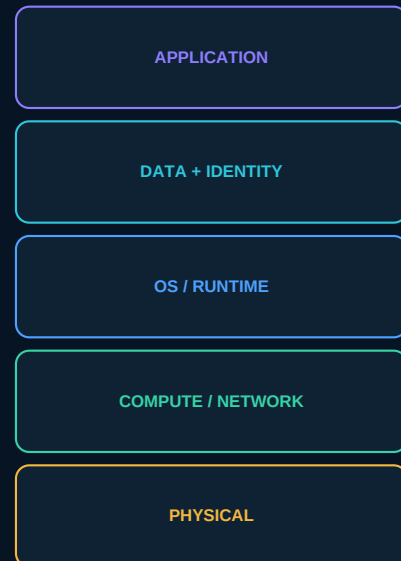
CORRECT ANSWER: B - Hybrid cloud

WHY: Hybrid cloud combines private and public cloud resources in an integrated architecture.

MEMORY CUE

Hybrid = private + public.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 243-244

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 243 | SOFTWARE AS A SERVICE

FOUNDATION

A company uses Microsoft 365 for email. The provider operates the application and underlying infrastructure. What service model is this?

- A. IaaS
- B. Bare metal
- C. SaaS**
- D. Colocation

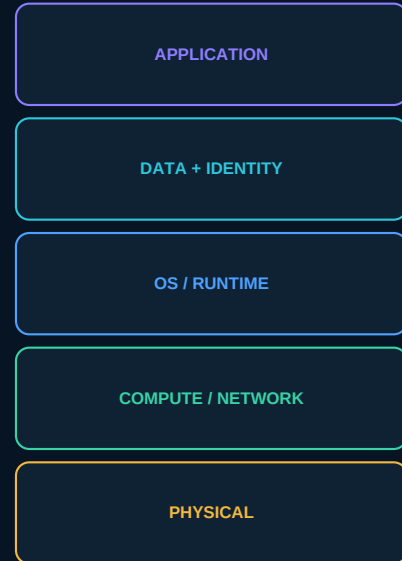
CORRECT ANSWER: C - SaaS

WHY: Software as a Service provides a complete application managed by the cloud provider.

MEMORY CUE

Software as a Service provides a complete application managed by the cloud provider.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 244 | PRIVATE CLOUD

FOUNDATION

A company operates cloud-like virtualization and self-service infrastructure dedicated exclusively to its own organization. Which deployment model is this?

- A. Public cloud
- B. Hybrid cloud
- C. Community cloud
- D. Private cloud**

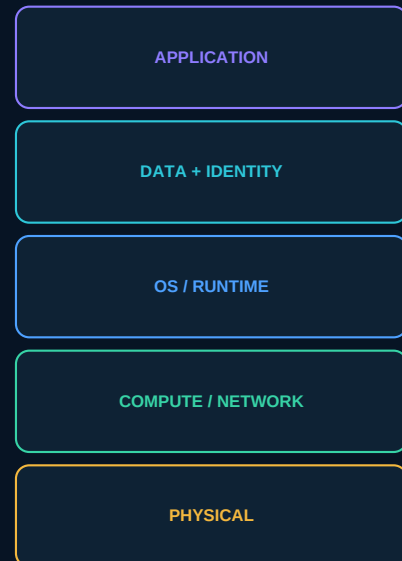
CORRECT ANSWER: D - Private cloud

WHY: A private cloud is dedicated to a single organization, whether on-premises or hosted.

MEMORY CUE

Private cloud = dedicated to one organization.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 245-246

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 245 | NETWORK SEGMENTATION

FOUNDATION

Which technology allows an organization to create logically separated network segments across shared switching infrastructure?

- A. VLANs
- B. Hashing
- C. Data masking
- D. Digital signing

CORRECT ANSWER: A - VLANs

WHY: VLANs logically divide a physical switching environment into separate Layer 2 broadcast domains.

MEMORY CUE

VLANs logically divide a physical switching environment into separate Layer 2 broadcast domains.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 246 | PUBLIC CLOUD

FOUNDATION

A startup runs workloads on infrastructure shared among many customers and owned by a commercial cloud provider. Which deployment model is this?

- A. Community-only cloud
- B. Public cloud
- C. Air-gapped cloud
- D. Private cloud

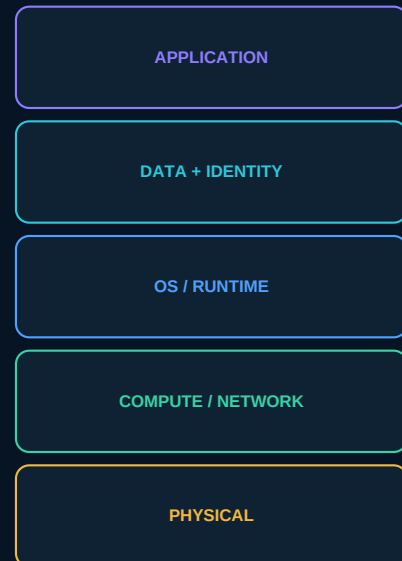
CORRECT ANSWER: B - Public cloud

WHY: Public cloud services are provider-owned and delivered over shared infrastructure to many customers.

MEMORY CUE

Public cloud = provider-owned shared service.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 247-248

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 247 | HARDWARE SECURITY MODULE

FOUNDATION

A company stores encryption keys in a tamper-resistant dedicated cryptographic appliance. Which technology is MOST likely being used?

- A. NAC
- B. WAF
- C. HSM**
- D. IDS

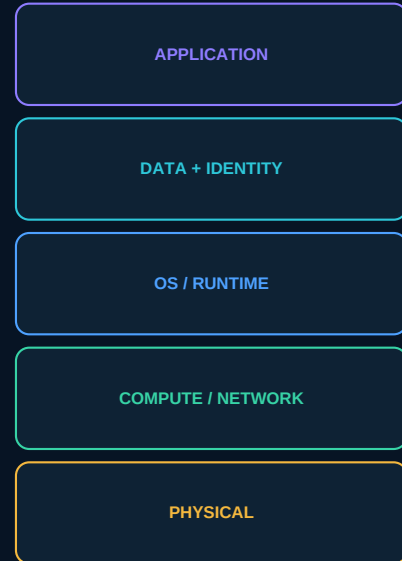
CORRECT ANSWER: C - HSM

WHY: A Hardware Security Module is designed specifically to securely generate, store, and use cryptographic keys.

MEMORY CUE

A Hardware Security Module is designed specifically to securely generate, store, and use cryptographic keys.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 248 | SHARED RESPONSIBILITY

FOUNDATION

In an IaaS deployment, who is typically responsible for patching the guest operating system?

- A. The certificate authority
- B. The ISP
- C. The cloud provider only
- D. The customer**

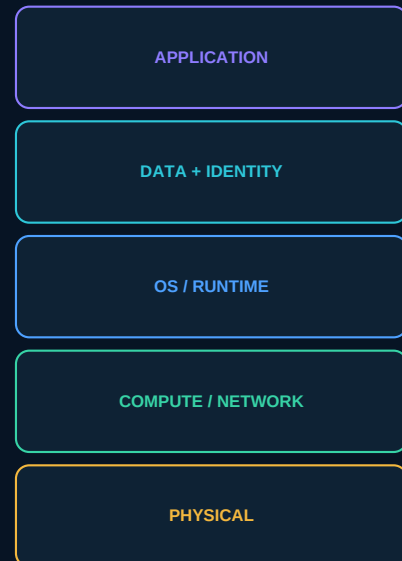
CORRECT ANSWER: D - The customer

WHY: In IaaS, the provider secures underlying infrastructure while the customer generally manages and patches guest operating systems and workloads.

MEMORY CUE

IaaS: customer owns more of the software stack.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 249-250

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 249 | TRUSTED PLATFORM MODULE

FOUNDATION

Which component commonly protects cryptographic secrets on an individual endpoint and can support measured boot?

- A. TPM
- B. Load balancer
- C. SIEM
- D. IPS

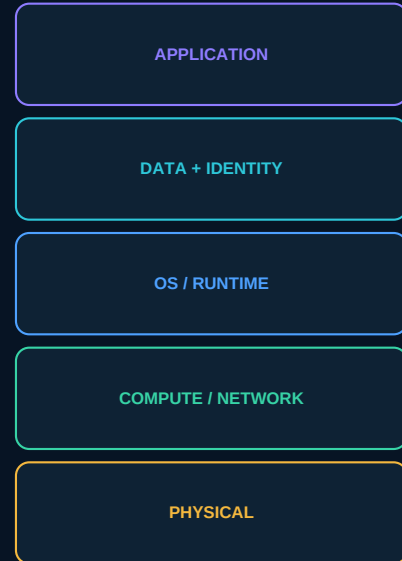
CORRECT ANSWER: A - TPM

WHY: A Trusted Platform Module provides hardware-backed cryptographic storage and platform-integrity functionality.

MEMORY CUE

A Trusted Platform Module provides hardware-backed cryptographic storage and platform-integrity functionality.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 250 | HYPERVISOR

FOUNDATION

Which component allows multiple virtual machines to share the compute resources of one physical host?

- A. WAF
- B. Hypervisor
- C. RADIUS server
- D. HSM

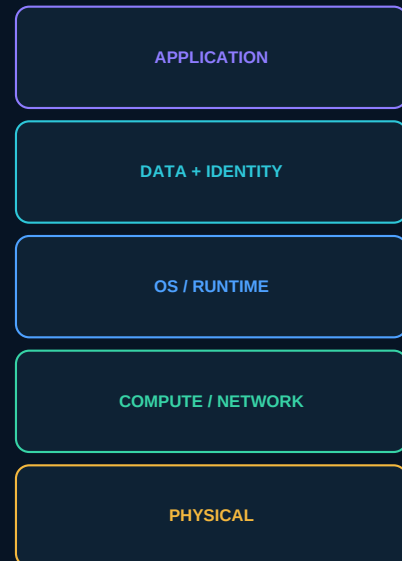
CORRECT ANSWER: B - Hypervisor

WHY: A hypervisor abstracts physical compute resources and presents virtual hardware to multiple VMs.

MEMORY CUE

Hypervisor = virtualization layer.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 251-252

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 251 | ICS/OT

FOUNDATION

An organization must retain critical systems locally because the systems control industrial machinery and cannot tolerate internet latency. Which environment BEST fits?

- A. Public social network
- B. CDN
- C. ICS/OT environment**
- D. SaaS CRM

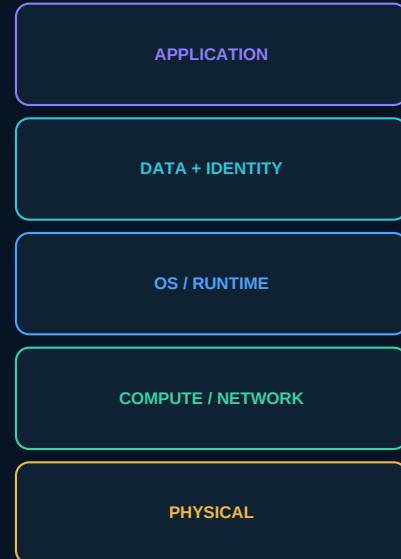
CORRECT ANSWER: C - ICS/OT environment

WHY: Industrial Control Systems and Operational Technology directly interact with physical equipment and processes.

MEMORY CUE

Industrial Control Systems and Operational Technology directly interact with physical equipment and processes.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 252 | CONTAINERS

FOUNDATION

An application team wants isolated application environments that share the host operating-system kernel rather than running a full guest OS for each workload. What technology BEST fits?

- A. Bare-metal clustering
- B. Traditional virtual machines only
- C. Tape virtualization
- D. Containers**

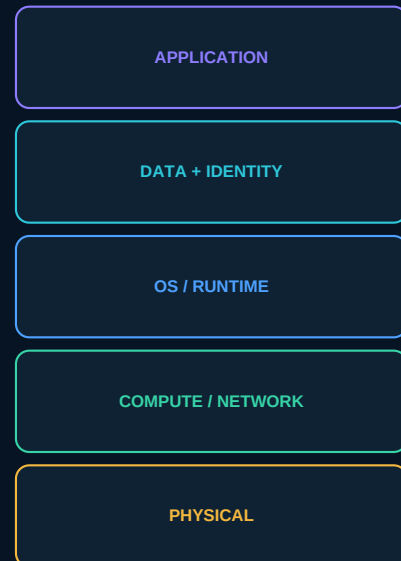
CORRECT ANSWER: D - Containers

WHY: Containers package applications and dependencies while sharing the host kernel, making them lighter than full VMs.

MEMORY CUE

Containers share the host kernel.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 253-254

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 253 | ZERO-TRUST ARCHITECTURE

FOUNDATION

Which architectural approach assumes systems may already be compromised and minimizes implicit trust between workloads?

A. Zero-trust architecture

B. Flat network

C. Open federation

D. Hub-and-spoke trust

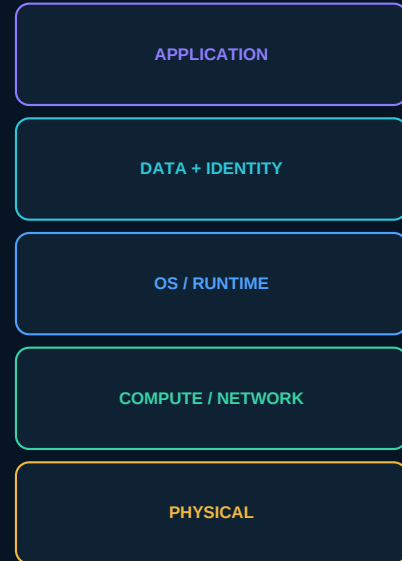
CORRECT ANSWER: A - Zero-trust architecture

WHY: Zero trust assumes breach and continuously evaluates access based on identity, device, context, and policy.

MEMORY CUE

Zero trust assumes breach and continuously evaluates access based on identity, device, context, and policy.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 254 | SERVERLESS

FOUNDATION

Developers deploy event-driven functions while the cloud provider handles server provisioning and scaling. Which architecture is being used?

A. Private WAN

B. Serverless / FaaS

C. Colocation

D. Bare metal

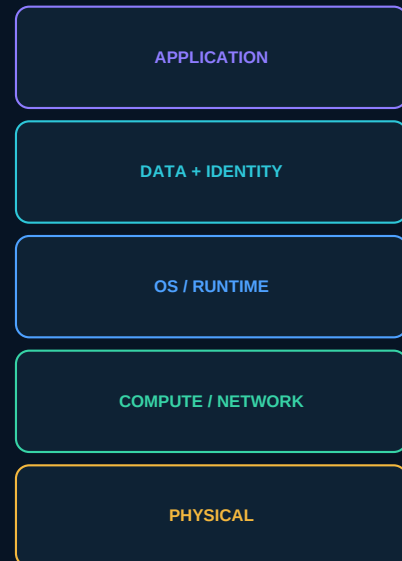
CORRECT ANSWER: B - Serverless / FaaS

WHY: Serverless computing lets developers run functions without managing servers directly.

MEMORY CUE

Serverless = provider manages execution infrastructure.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 255-256

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 255 | ENCRYPTION AT REST

FOUNDATION

An organization wants highly sensitive employee data to remain unreadable even if a storage device is stolen. Which protection is **MOST** appropriate?

- A. DNSSEC
- B. NAT
- C. Encryption at rest**
- D. Load balancing

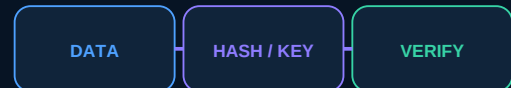
CORRECT ANSWER: C - Encryption at rest

WHY: Encryption at rest protects stored files, disks, databases, and other persistent information.

MEMORY CUE

Encryption at rest protects stored files, disks, databases, and other persistent information.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 256 | INFRASTRUCTURE AS CODE

FOUNDATION

A security team stores cloud network and firewall definitions in version-controlled templates that can be repeatedly deployed. What practice is this?

- A. Warm-site recovery
- B. Tokenization
- C. Data masking
- D. Infrastructure as code (IaC)**

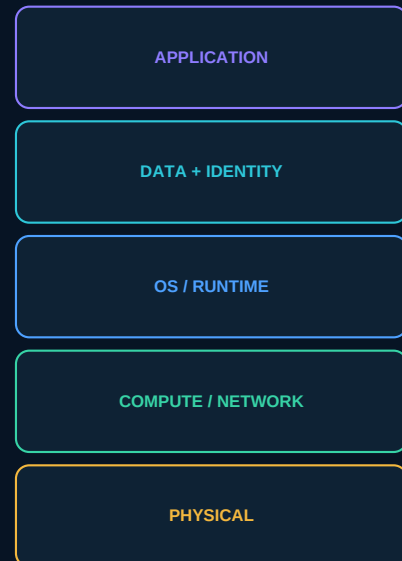
CORRECT ANSWER: D - Infrastructure as code (IaC)

WHY: IaC defines infrastructure through machine-readable configuration so environments can be versioned, reviewed, and reproduced.

MEMORY CUE

IaC = infrastructure defined in code/config.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 257-258

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 257 | DATA IN TRANSIT

FOUNDATION

An application encrypts communications between a browser and web server using TLS. Which state of data is being protected?

- A. Data in transit
- B. Data destruction
- C. Data remanence
- D. Data at rest

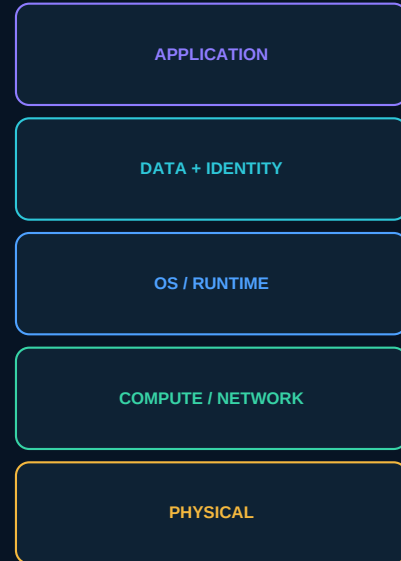
CORRECT ANSWER: A - Data in transit

WHY: TLS protects information while it travels across a network.

MEMORY CUE

TLS protects information while it travels across a network.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 258 | MICROSERVICES

FOUNDATION

A large application is divided into small independently deployable services communicating through APIs. Which architecture is this?

- A. Cold-site architecture
- B. Microservices
- C. Air-gapped architecture
- D. Monolithic architecture

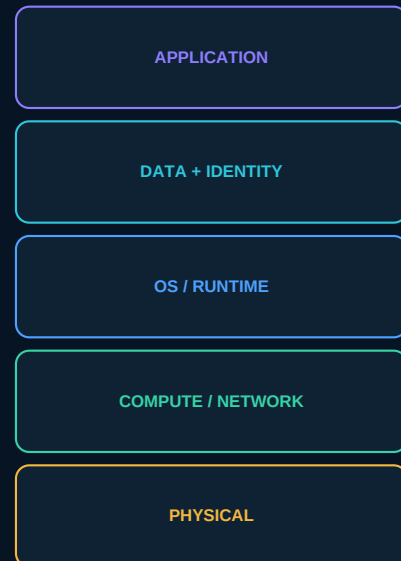
CORRECT ANSWER: B - Microservices

WHY: Microservices decompose an application into independently deployable services with defined interfaces.

MEMORY CUE

Small independent services instead of one monolith.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 259-260

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 259 | TOKENIZATION

FOUNDATION

Which technique substitutes sensitive information with a nonsensitive value while the original value is maintained in a secured system?

- A. Hashing
- B. Steganography
- C. Tokenization**
- D. Compression

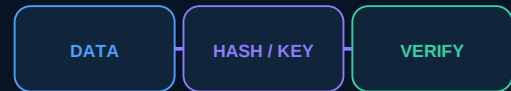
CORRECT ANSWER: C - Tokenization

WHY: Tokenization replaces sensitive information with a substitute token that has no meaningful value by itself.

MEMORY CUE

Tokenization replaces sensitive information with a substitute token that has no meaningful value by itself.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 260 | MICROSEGMENTATION

FOUNDATION

A data center applies workload-level policies so two servers in the same VLAN cannot communicate unless explicitly allowed. What design is this?

- A. RAID
- B. Tokenization
- C. Load balancing
- D. Microsegmentation**

CORRECT ANSWER: D - Microsegmentation

WHY: Microsegmentation enforces fine-grained east-west controls between workloads, often beyond traditional VLAN boundaries.

MEMORY CUE

Microsegmentation = fine-grained east-west control.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 261-262

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 261 | WARM SITE

FOUNDATION

A business requires a recovery site containing hardware and connectivity but must restore systems and data after a disaster before becoming operational. Which site is this?

- A. Warm site
- B. Active-active site
- C. Cold site
- D. Hot site

CORRECT ANSWER: A - Warm site

WHY: A warm site contains infrastructure but normally requires additional restoration or configuration before full operations can resume.

MEMORY CUE

A warm site contains infrastructure but normally requires additional restoration or configuration before full operations can resume.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 262 | AIR GAP

FOUNDATION

A classified system has no direct network connection to the corporate network or internet. What architectural control is being used?

- A. Federation
- B. Air gap
- C. Load balancing
- D. Content delivery network

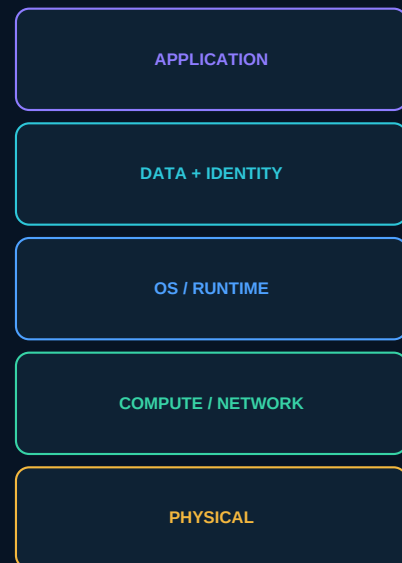
CORRECT ANSWER: B - Air gap

WHY: An air gap physically or logically isolates a system from other networks to reduce connectivity-based risk.

MEMORY CUE

Air gap = no direct network path.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 263-264

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 263 | HOT SITE

FOUNDATION

Which disaster recovery configuration generally provides the **FASTEST** recovery?

- A. Offline warehouse
- B. Tape archive only
- C. Hot site**
- D. Cold site

CORRECT ANSWER: C - Hot site

WHY: Hot sites maintain ready-to-use systems, communications, and frequently replicated data.

MEMORY CUE

Hot sites maintain ready-to-use systems, communications, and frequently replicated data.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 264 | VPN

FOUNDATION

A remote employee needs an encrypted tunnel across the public internet to reach internal corporate resources. What technology **BEST** fits?

- A. NAT only
- B. Load balancer
- C. VLAN
- D. VPN**

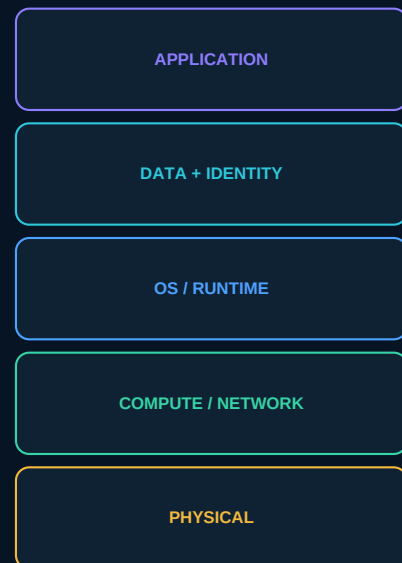
CORRECT ANSWER: D - VPN

WHY: A VPN creates a protected tunnel across an untrusted network for remote or site-to-site connectivity.

MEMORY CUE

VPN = encrypted tunnel over untrusted network.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 265-266

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 265 | HIGH AVAILABILITY

FOUNDATION

A company has two web servers simultaneously serving customer requests. If one fails, the second continues processing traffic. Which concept is demonstrated?

A. High availability

B. Data masking

C. Obfuscation

D. Air gapping

CORRECT ANSWER: A - High availability

WHY: Redundant systems reduce downtime and maintain service when individual components fail.

MEMORY CUE

Redundant systems reduce downtime and maintain service when individual components fail.

Security Objectives - CIA Triad



QUESTION 266 | LOAD BALANCER

FOUNDATION

Incoming HTTPS requests are distributed across four healthy web servers, and failed servers are removed from rotation. Which component is responsible?

A. NAC

B. Load balancer

C. Certificate authority

D. HSM

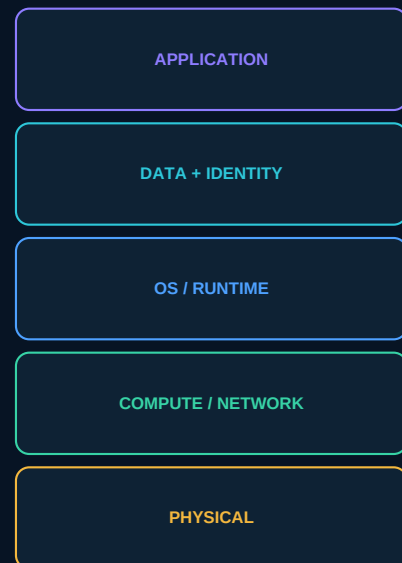
CORRECT ANSWER: B - Load balancer

WHY: A load balancer distributes client traffic across multiple backend systems and can support health-aware failover.

MEMORY CUE

Load balancer spreads requests across healthy backends.

Architecture / Shared Responsibility



Security+ Master Visual Review | Questions 267-268

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 267 | DIFFERENTIAL BACKUP

FOUNDATION

Which backup type copies all files changed since the LAST FULL backup?

- A. Incremental
- B. Full
- C. Differential**
- D. Snapshot only

CORRECT ANSWER: C - Differential

WHY: Differential backups always reference the most recent full backup.

MEMORY CUE

Incremental = changes since the previous backup Differential = changes since the previ full backup

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 268 | CLUSTERING

FOUNDATION

Two database nodes operate as a coordinated group and automatically move service ownership if one node fails. What design is this?

- A. DNS tunneling
- B. Data masking
- C. Tokenization
- D. Clustering**

CORRECT ANSWER: D - Clustering

WHY: Clustering groups systems to provide coordinated service, redundancy, and failover.

MEMORY CUE

Cluster = coordinated nodes providing one service.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 269-270

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 269 | MALWARE SANDBOX

FOUNDATION

Which system is **MOST** appropriate for keeping a highly sensitive malware-analysis environment separated from production?

- A. Isolated sandbox
- B. Shared administrative workstation
- C. Public Wi-Fi network
- D. Flat production network

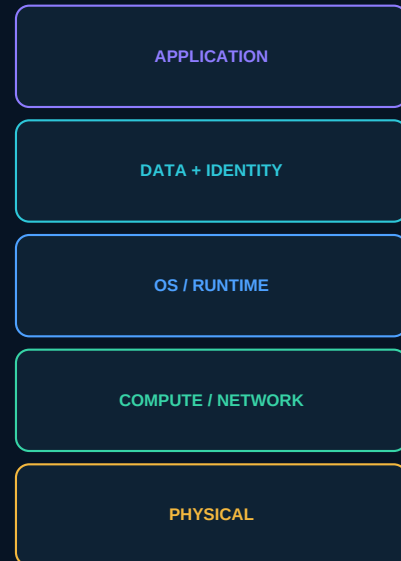
CORRECT ANSWER: A - Isolated sandbox

WHY: Malware analysis should occur within an isolated and controlled environment to prevent accidental propagation.

MEMORY CUE

Malware analysis should occur within an isolated and controlled environment to prevent accidental propagation.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 270 | REDUNDANCY

FOUNDATION

A server contains two independent power supplies connected to separate electrical circuits. Which resilience principle is demonstrated?

- A. Non-repudiation
- B. Redundancy
- C. Federation
- D. Obfuscation

CORRECT ANSWER: B - Redundancy

WHY: Redundancy duplicates critical components so a single failure does not necessarily interrupt service.

MEMORY CUE

Redundancy removes single points of failure.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 271-272

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 271 | GEOGRAPHIC DISPERSION

FOUNDATION

A company operates production services in data centers hundreds of miles apart to reduce the impact of a regional disaster. What resilience strategy is this?

- A. Password rotation
- B. Data masking
- C. Geographic dispersion**
- D. Single-site clustering

CORRECT ANSWER: C - Geographic dispersion

WHY: Geographic dispersion places resources in separate regions to reduce correlated physical or regional failures.

MEMORY CUE

Separate regions reduce shared disaster risk.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 272 | INCREMENTAL BACKUP

FOUNDATION

Which backup type copies only data changed since the most recent backup of any type?

- A. Cold site
- B. Full backup
- C. Differential backup
- D. Incremental backup**

CORRECT ANSWER: D - Incremental backup

WHY: Incremental backups capture changes since the last backup, whether that last backup was full or incremental.

MEMORY CUE

Incremental = since previous backup.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 273-274

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 273 | FULL BACKUP

FOUNDATION

Which backup type creates a complete copy of all selected data each time it runs?

- A. Full backup
- B. Incremental backup
- C. Differential backup
- D. Snapshot delta only

CORRECT ANSWER: A - Full backup

WHY: A full backup copies all selected data and serves as a baseline for other backup strategies.

MEMORY CUE

Full = everything selected.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 274 | SNAPSHOT

FOUNDATION

An administrator captures the point-in-time state of a virtual machine before a risky software upgrade. What mechanism is being used?

- A. Air gap
- B. Snapshot
- C. Tokenization
- D. Warm site

CORRECT ANSWER: B - Snapshot

WHY: A snapshot records a point-in-time state that can often be used for rapid rollback, though it is not always a complete independent backup.

MEMORY CUE

Snapshot = point-in-time state/rollback aid.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 275-276

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 275 | REPLICATION

FOUNDATION

A primary storage system continuously copies changed blocks to a secondary site. Which resilience mechanism is this?

- A. Key escrow
- B. Tokenization
- C. Replication**
- D. Obfuscation

CORRECT ANSWER: C - Replication

WHY: Replication maintains another copy of data or service state, often at a separate system or location.

MEMORY CUE

Replication = maintain a second synchronized copy.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 276 | DATA IN USE

FOUNDATION

Sensitive information is decrypted in application memory while calculations are performed. Which data state is being described?

- A. Data remanence
- B. Data in transit
- C. Data at rest
- D. Data in use**

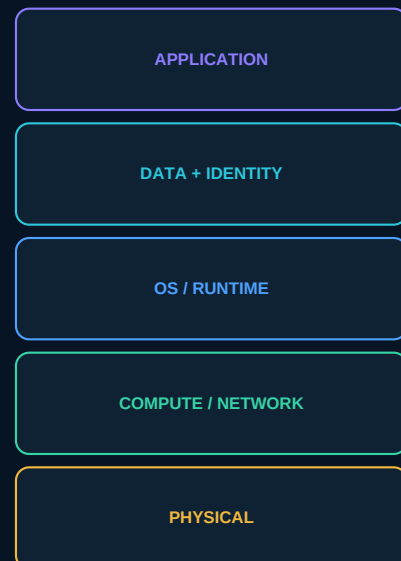
CORRECT ANSWER: D - Data in use

WHY: Data in use is actively processed in memory or by a computing workload.

MEMORY CUE

In use = actively being processed.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 277-278

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 277 | DATA MASKING

FOUNDATION

A support portal displays a credit-card number as **** * 4821 while the real value remains stored securely. What technique is this?

A. Data masking

B. Digital signing

C. Hashing

D. Compression

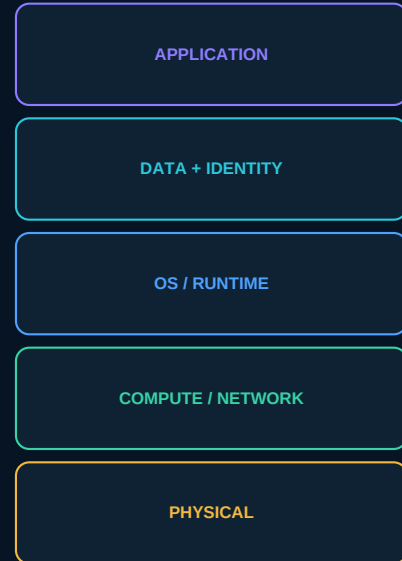
CORRECT ANSWER: A - Data masking

WHY: Data masking obscures sensitive values when full data is not needed for the user or process.

MEMORY CUE

Masking hides portions of sensitive data.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 278 | SECURE ENCLAVE

FOUNDATION

A mobile device stores highly sensitive cryptographic keys in a hardware-isolated execution environment separate from the main operating system. What concept BEST fits?

A. SIEM

B. Secure enclave

C. Load balancer

D. DNSSEC

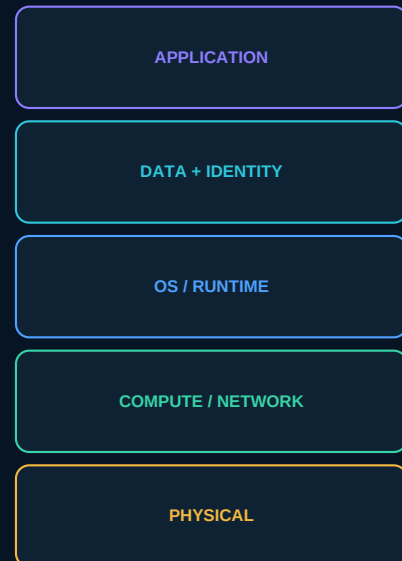
CORRECT ANSWER: B - Secure enclave

WHY: A secure enclave or trusted execution environment isolates sensitive computation and secrets from the general OS.

MEMORY CUE

Hardware-isolated protected execution area.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 279-280

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 279 | UPS

FOUNDATION

A server room needs immediate short-term electrical power when utility power fails so systems can remain online until a generator starts. What should be used?

- A. NAC
- B. WAF
- C. UPS**
- D. HSM

CORRECT ANSWER: C - UPS

WHY: An uninterruptible power supply provides near-immediate temporary power during an outage or power disturbance.

MEMORY CUE

UPS bridges short outages and generator startup.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 280 | GENERATOR

FOUNDATION

A facility must continue operating through a multi-hour utility outage after battery backup is depleted. Which control BEST supports this requirement?

- A. Load balancer
- B. Tokenization
- C. Honeypot
- D. Generator**

CORRECT ANSWER: D - Generator

WHY: A generator supplies longer-duration backup power after primary utility loss.

MEMORY CUE

Generator = extended alternate power.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 281-282

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 281 | ICS SAFETY

FOUNDATION

A security change to an industrial control network could interrupt a process that controls physical machinery. What architectural priority requires special consideration?

- A. Safety and operational availability
- B. Maximum password complexity only
- C. Social-media continuity
- D. Marketing availability

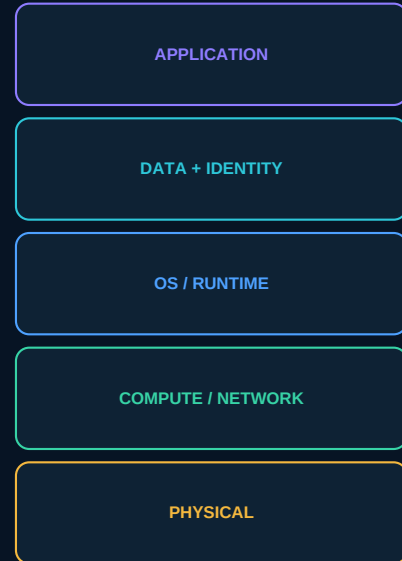
CORRECT ANSWER: A - Safety and operational availability

WHY: ICS/OT security must consider physical safety and operational continuity because cyber changes can affect real-world processes.

MEMORY CUE

OT security decisions can affect physical safety.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 282 | IOT SEGMENTATION

FOUNDATION

A company deploys smart cameras that cannot support enterprise EDR. Which architecture BEST reduces their ability to reach sensitive servers if compromised?

- A. Share administrator credentials
- B. Place the IoT devices on a restricted segmented network
- C. Disable all firewall logging
- D. Put them on the domain-controller VLAN

CORRECT ANSWER: B - Place the IoT devices on a restricted segmented network

WHY: segmented network Segmentation limits the communication paths available to less-trusted IoT devices and reduces lateral movement.

MEMORY CUE

Untrusted/limited devices belong in constrained segments.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 283-284

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 283 | BASTION HOST

FOUNDATION

Administrators must connect through one hardened, monitored system before accessing isolated production servers. What is the hardened intermediary commonly called?

- A. Honeypot only
- B. DNS resolver
- C. Bastion / jump host**
- D. Load balancer

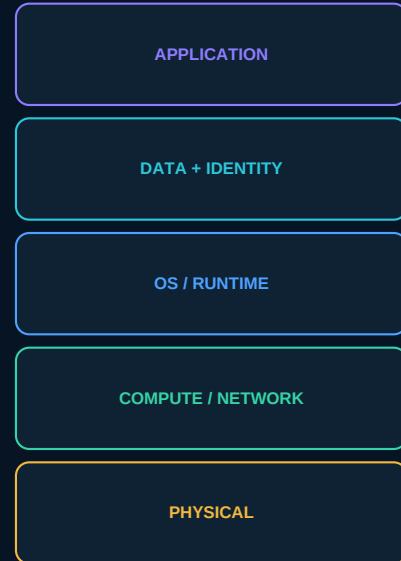
CORRECT ANSWER: C - Bastion / jump host

WHY: A bastion or jump host is a hardened controlled entry point used for administrative access to protected environments.

MEMORY CUE

Jump host = controlled admin entry point.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 284 | IOT SEGMENTATION

APPLIED

While redesigning an enterprise environment, a company deploys smart cameras that cannot support enterprise EDR. Which architecture BEST reduces their ability to reach sensitive servers if compromised?

- A. Disable all firewall logging
- B. Put them on the domain-controller VLAN
- C. Share administrator credentials
- D. Place the IoT devices on a restricted segmented network**

CORRECT ANSWER: D - Place the IoT devices on a restricted segmented network

WHY: segmented network Segmentation limits the communication paths available to less-trusted IoT devices and reduces lateral movement.

MEMORY CUE

Untrusted/limited devices belong in constrained segments.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 285-286

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 285 | DMZ

APPLIED

A regional enterprise wants an application server to be accessible from the internet but does not want it placed directly on the internal network. Where should the server be located?

A. DMZ

B. Management VLAN

C. Loopback network

D. SAN

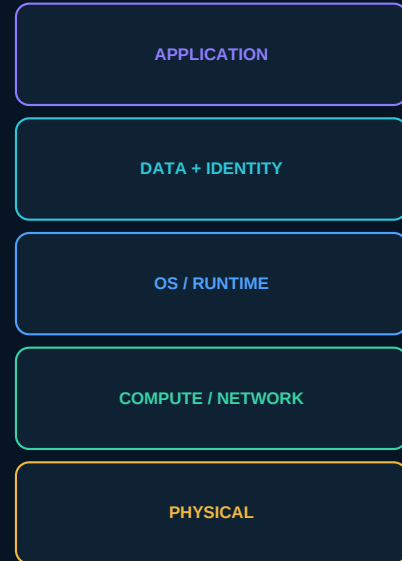
CORRECT ANSWER: A - DMZ

WHY: A DMZ provides a controlled network segment for internet-facing systems separated from trusted internal resources.

MEMORY CUE

A DMZ provides a controlled network segment for internet-facing systems separated from trusted internal resources.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 286 | SHARED RESPONSIBILITY

APPLIED

While redesigning an enterprise environment, in an IaaS deployment, who is typically responsible for patching the guest operating system?

A. The certificate authority

B. The customer

C. The cloud provider only

D. The ISP

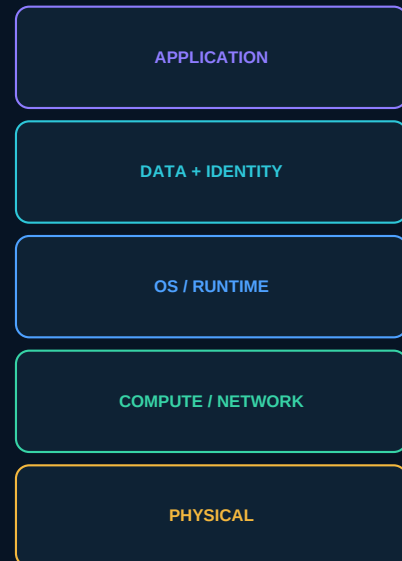
CORRECT ANSWER: B - The customer

WHY: In IaaS, the provider secures underlying infrastructure while the customer generally manages and patches guest operating systems and workloads.

MEMORY CUE

IaaS: customer owns more of the software stack.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 287-289

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 287 | PRIVATE CLOUD

APPLIED

While redesigning an enterprise environment, a company operates cloud-like virtualization and self-service infrastructure dedicated exclusively to its own organization. Which deployment model is this?

- A. Public cloud
- B. Hybrid cloud
- C. Private cloud**
- D. Community cloud

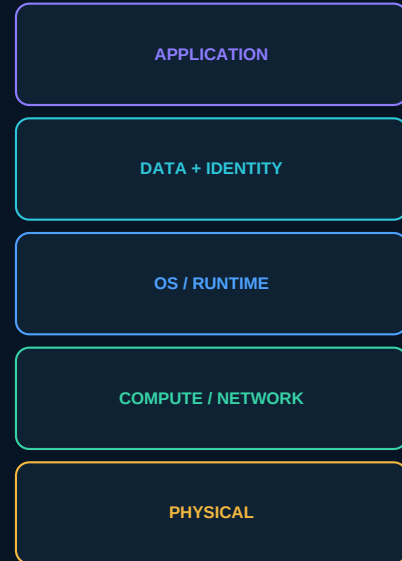
CORRECT ANSWER: C - Private cloud

WHY: A private cloud is dedicated to a single organization, whether on-premises or hosted.

MEMORY CUE

Private cloud = dedicated to one organization.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 289 | REDUNDANCY

APPLIED

While redesigning an enterprise environment, a server contains two independent power supplies connected to separate electrical circuits. Which resilience principle is demonstrated?

- A. Redundancy**
- B. Non-repudiation
- C. Obfuscation
- D. Federation

CORRECT ANSWER: A - Redundancy

WHY: Redundancy duplicates critical components so a single failure does not necessarily interrupt service.

MEMORY CUE

Redundancy removes single points of failure.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 288

Immediate answers, concise rationales, and visual memory anchors.

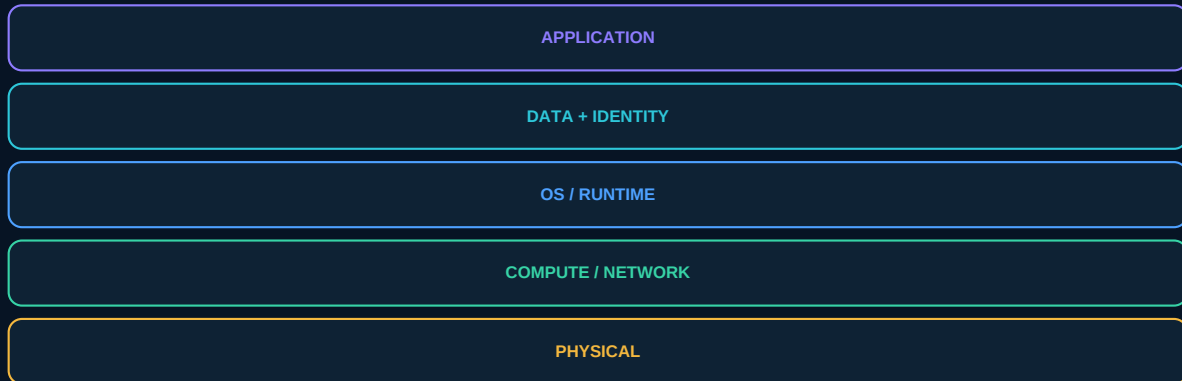
ANALYST TASK | HARDWARE SECURITY MODULE

A company stores encryption keys in a tamper-resistant dedicated cryptographic appliance. Which security technology is MOST likely being used?

- A. WAF
- B. IDS
- C. NAC
- D. HSM

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

CORRECT ANSWER: D - HSM

RATIONALE

A Hardware Security Module is designed specifically to securely generate, store, and use cryptographic keys.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 290-291

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 290 | GEOGRAPHIC DISPERSION

APPLIED

In a separate enterprise scenario, a company operates production services in data centers hundreds of miles apart to reduce the impact of a regional disaster. What resilience strategy is this?

- A. Password rotation
- B. Geographic dispersion**
- C. Single-site clustering
- D. Data masking

CORRECT ANSWER: B - Geographic dispersion

WHY: Geographic dispersion places resources in separate regions to reduce correlated physical or regional failures.

MEMORY CUE

Separate regions reduce shared disaster risk.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 291 | VPN

APPLIED

While redesigning an enterprise environment, a remote employee needs an encrypted tunnel across the public internet to reach internal corporate resources. What technology BEST fits?

- A. NAT only
- B. VLAN
- C. VPN**
- D. Load balancer

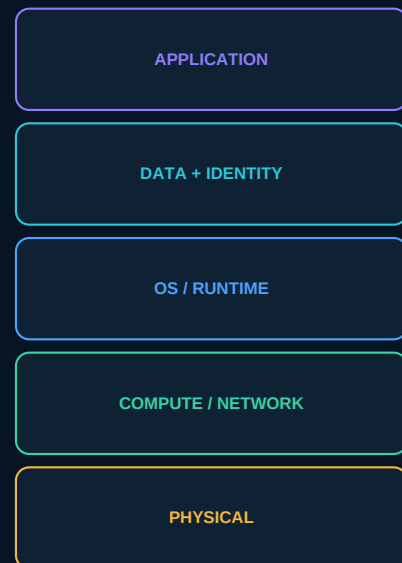
CORRECT ANSWER: C - VPN

WHY: A VPN creates a protected tunnel across an untrusted network for remote or site-to-site connectivity.

MEMORY CUE

VPN = encrypted tunnel over untrusted network.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 292-293

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 292 | GENERATOR

APPLIED

While redesigning an enterprise environment, a facility must continue operating through a multi-hour utility outage after battery backup is depleted. Which control BEST supports this requirement?

- A. Tokenization
- B. Honeypot
- C. Load balancer

D. Generator

CORRECT ANSWER: D - Generator

WHY: A generator supplies longer-duration backup power after primary utility loss.

MEMORY CUE

Generator = extended alternate power.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 293 | CONTAINERS

APPLIED

While redesigning an enterprise environment, an application team wants isolated application environments that share the host operating-system kernel rather than running a full guest OS for each workload. What technology BEST fits?

- A. Containers**
- B. Bare-metal clustering
- C. Traditional virtual machines only
- D. Tape virtualization

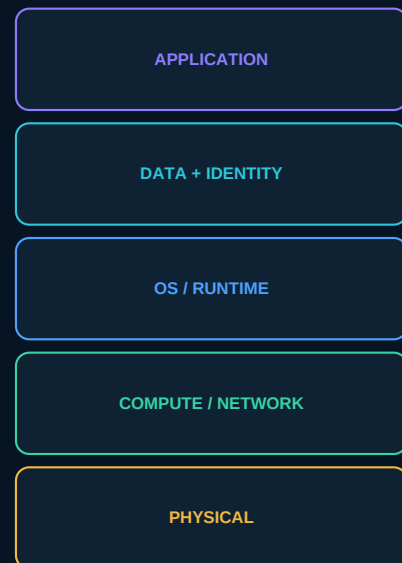
CORRECT ANSWER: A - Containers

WHY: Containers package applications and dependencies while sharing the host kernel, making them lighter than full VMs.

MEMORY CUE

Containers share the host kernel.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 294-295

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 294 | HYBRID CLOUD

APPLIED

While redesigning an enterprise environment, an organization keeps regulated databases in its private environment but bursts web workloads into a public cloud. What deployment model is this?

- A. Private cloud
- B. Hybrid cloud**
- C. Community cloud
- D. Public cloud

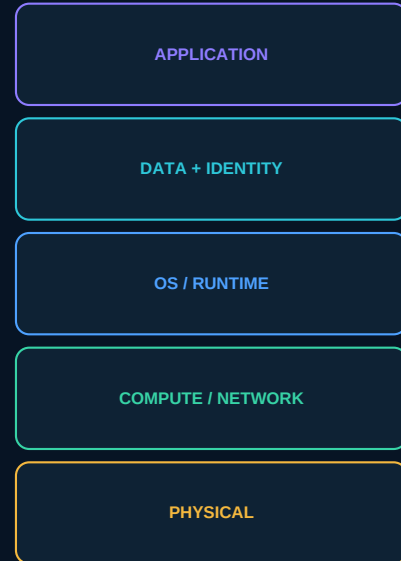
CORRECT ANSWER: B - Hybrid cloud

WHY: Hybrid cloud combines private and public cloud resources in an integrated architecture.

MEMORY CUE

Hybrid = private + public.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 295 | UPS

APPLIED

In a separate enterprise scenario, a server room needs immediate short-term electrical power when utility power fails so systems can remain online until a generator starts. What should be used?

- A. NAC
- B. WAF
- C. UPS**
- D. HSM

CORRECT ANSWER: C - UPS

WHY: An uninterruptible power supply provides near-immediate temporary power during an outage or power disturbance.

MEMORY CUE

UPS bridges short outages and generator startup.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 296

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | MICROSEGMENTATION

While redesigning an enterprise environment, a data center applies workload-level policies so two servers in the same VLAN cannot communicate unless explicitly allowed. What design is this?

- A. RAID
- B. Load balancing
- C. Tokenization
- D. Microsegmentation

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

CORRECT ANSWER: D - Microsegmentation

RATIONALE Microsegmentation enforces fine-grained east-west controls between workloads, often beyond traditional VLAN boundaries.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 297-298

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 297 | PUBLIC CLOUD

APPLIED

While redesigning an enterprise environment, a startup runs workloads on infrastructure shared among many customers and owned by a commercial cloud provider. Which deployment model is this?

- A. Public cloud
- B. Community-only cloud
- C. Private cloud
- D. Air-gapped cloud

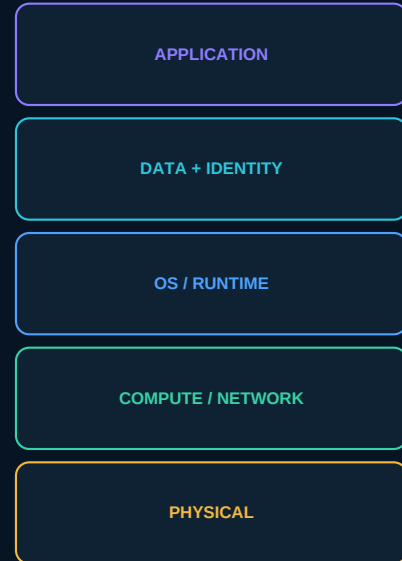
CORRECT ANSWER: A - Public cloud

WHY: Public cloud services are provider-owned and delivered over shared infrastructure to many customers.

MEMORY CUE

Public cloud = provider-owned shared service.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 298 | NETWORK SEGMENTATION

APPLIED

What technology allows an organization to create logically separated network segments across shared switching infrastructure?

- A. Digital signing
- B. VLANs
- C. Data masking
- D. Hashing

CORRECT ANSWER: B - VLANs

WHY: VLANs logically divide a physical switching environment into separate Layer 2 broadcast domains.

MEMORY CUE

VLANs logically divide a physical switching environment into separate Layer 2 broadcast domains.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 299-300

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 299 | ICS/OT

APPLIED

An organization must retain critical systems locally because the systems control industrial machinery and cannot tolerate internet latency. What environment BEST fits?

- A. CDN
- B. SaaS CRM
- C. ICS/OT environment**
- D. Public social network

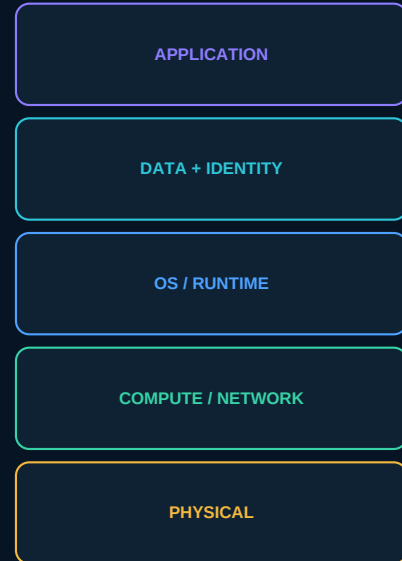
CORRECT ANSWER: C - ICS/OT environment

WHY: Industrial Control Systems and Operational Technology directly interact with physical equipment and processes.

MEMORY CUE

Industrial Control Systems and Operational Technology directly interact with physical equipment and processes.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 300 | SERVERLESS

APPLIED

While redesigning an enterprise environment, developers deploy event-driven functions while the cloud provider handles server provisioning and scaling. What architecture is being used?

- A. Private WAN
- B. Colocation
- C. Bare metal
- D. Serverless / FaaS**

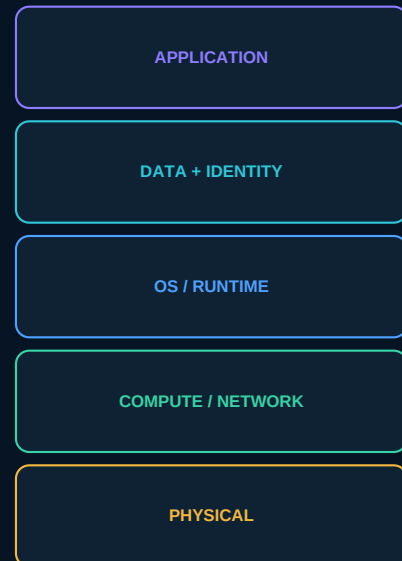
CORRECT ANSWER: D - Serverless / FaaS

WHY: Serverless computing lets developers run functions without managing servers directly.

MEMORY CUE

Serverless = provider manages execution infrastructure.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 301-302

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 301 | MICROSERVICES

APPLIED

While redesigning an enterprise environment, a large application is divided into small independently deployable services communicating through APIs. Which architecture is this?

A. Microservices

B. Air-gapped architecture

C. Cold-site architecture

D. Monolithic architecture

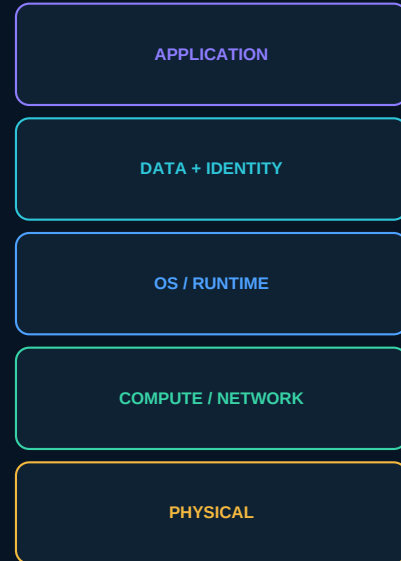
CORRECT ANSWER: A - Microservices

WHY: Microservices decompose an application into independently deployable services with defined interfaces.

MEMORY CUE

Small independent services instead of one monolith.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 302 | INFRASTRUCTURE AS A SERVICE

APPLIED

In a separate enterprise scenario, which cloud model provides customers with virtual machines, networking, and storage while the customer manages the operating systems?

A. PaaS

B. IaaS

C. SaaS

D. FaaS only

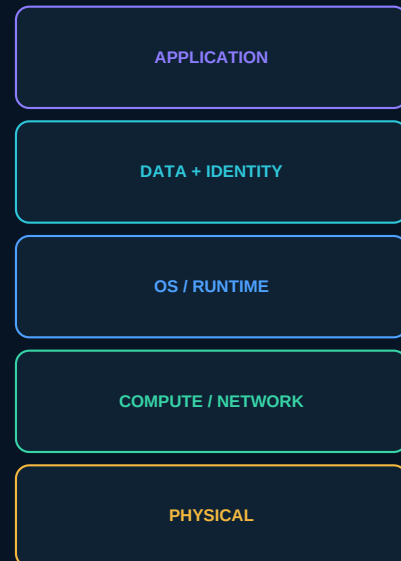
CORRECT ANSWER: B - IaaS

WHY: With Infrastructure as a Service, the provider operates the physical infrastructure while the customer manages virtual operating systems and workloads.

MEMORY CUE

With Infrastructure as a Service, the provider operates the physical infrastructure while the customer manages virtual operating sys...

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 303-305

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 303 | PLATFORM AS A SERVICE

APPLIED

While redesigning an enterprise environment, developers deploy application code to a provider-managed runtime without managing the underlying operating system. Which cloud service model is this?

- A. SaaS
- B. IaaS
- C. PaaS**
- D. Colocation

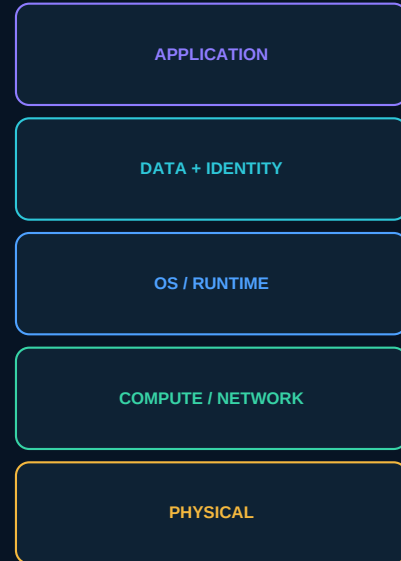
CORRECT ANSWER: C - PaaS

WHY: PaaS provides a managed application platform and runtime while the provider manages more of the underlying stack.

MEMORY CUE

PaaS = deploy code, provider manages platform.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 305 | LOAD BALANCER

APPLIED

While redesigning an enterprise environment, incoming HTTPS requests are distributed across four healthy web servers, and failed servers are removed from rotation. What component is responsible?

- A. Load balancer**
- B. NAC
- C. HSM
- D. Certificate authority

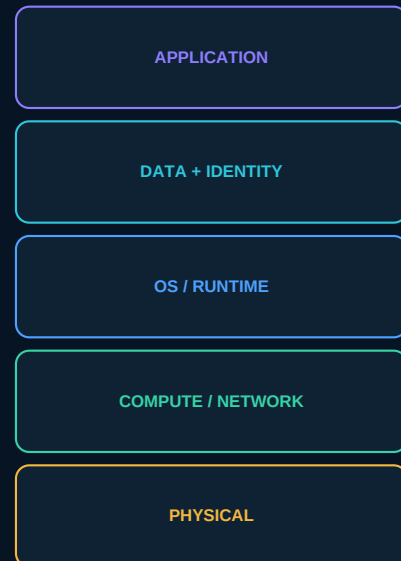
CORRECT ANSWER: A - Load balancer

WHY: A load balancer distributes client traffic across multiple backend systems and can support health-aware failover.

MEMORY CUE

Load balancer spreads requests across healthy backends.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 304

Immediate answers, concise rationales, and visual memory anchors.

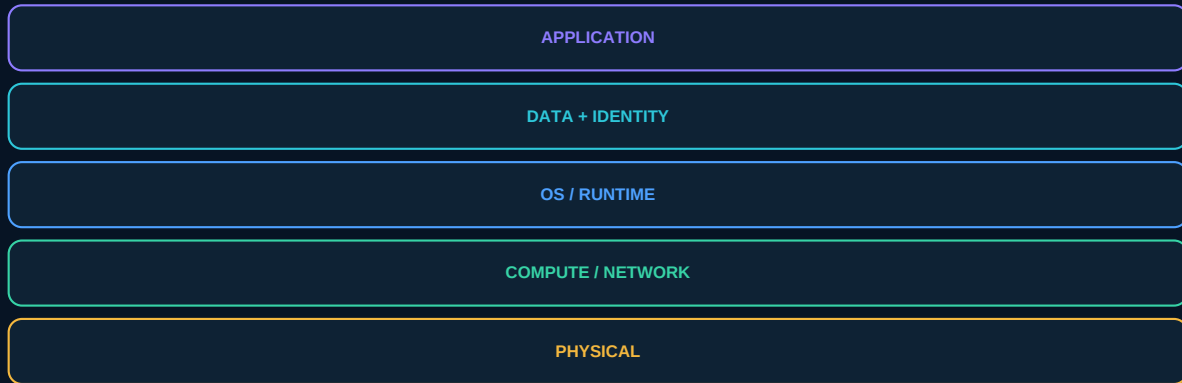
ANALYST TASK | TRUSTED PLATFORM MODULE

In a separate enterprise scenario, which component commonly protects cryptographic secrets on an individual endpoint and can support measured boot?

- A. IPS
- B. Load balancer
- C. SIEM
- D. TPM

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

CORRECT ANSWER: D - TPM

RATIONALE

A Trusted Platform Module provides hardware-backed cryptographic storage and platform-integrity functionality.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 306-307

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 306 | FULL BACKUP

APPLIED

In a separate enterprise scenario, which backup type creates a complete copy of all selected data each time it runs?

- A. Differential backup
- B. Full backup**
- C. Snapshot delta only
- D. Incremental backup

CORRECT ANSWER: B - Full backup

WHY: A full backup copies all selected data and serves as a baseline for other backup strategies.

MEMORY CUE

Full = everything selected.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 307 | ICS SAFETY

APPLIED

In a separate enterprise scenario, a security change to an industrial control network could interrupt a process that controls physical machinery. What architectural priority requires special consideration?

- A. Maximum password complexity only
- B. Social-media continuity
- C. Safety and operational availability**
- D. Marketing availability

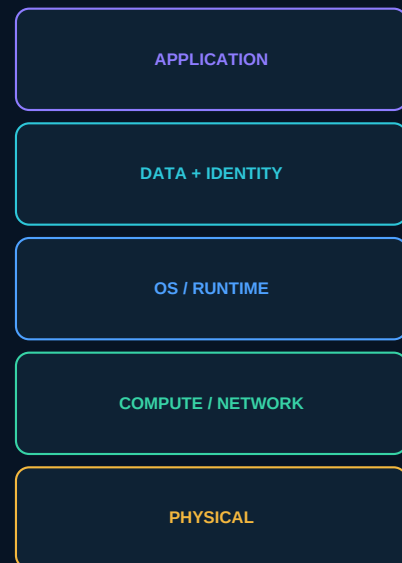
CORRECT ANSWER: C - Safety and operational availability

WHY: ICS/OT security must consider physical safety and operational continuity because cyber changes can affect real-world processes.

MEMORY CUE

OT security decisions can affect physical safety.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 308-309

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 308 | MALWARE SANDBOX

APPLIED

What system is **MOST** appropriate for keeping a highly sensitive malware-analysis environment separated from production?

- A. Shared administrative workstation
- B. Flat production network
- C. Public Wi-Fi network

D. Isolated sandbox

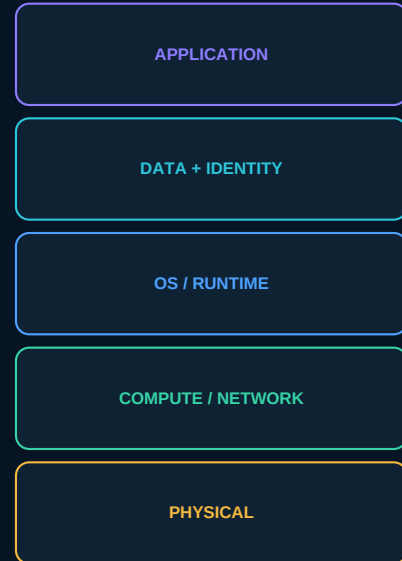
CORRECT ANSWER: D - Isolated sandbox

WHY: Malware analysis should occur within an isolated and controlled environment to prevent accidental propagation.

MEMORY CUE

Malware analysis should occur within an isolated and controlled environment to prevent accidental propagation.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 309 | ZERO-TRUST ARCHITECTURE

APPLIED

In a separate enterprise scenario, which architectural approach assumes systems may already be compromised and minimizes implicit trust between workloads?

- A. Zero-trust architecture**
- B. Flat network
- C. Open federation
- D. Hub-and-spoke trust

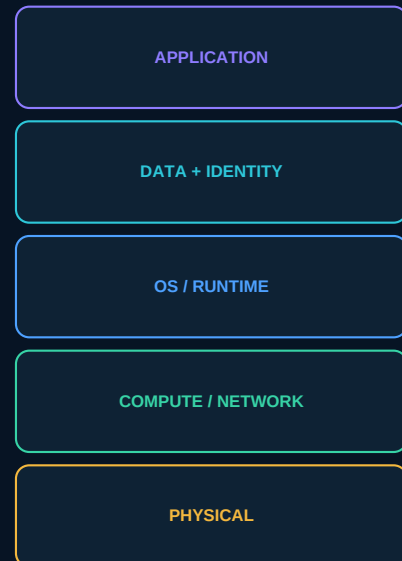
CORRECT ANSWER: A - Zero-trust architecture

WHY: Zero trust assumes breach and continuously evaluates access based on identity, device, context, and policy.

MEMORY CUE

Zero trust assumes breach and continuously evaluates access based on identity, device, context, and policy.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 310-311

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 310 | TOKENIZATION

APPLIED

In a separate enterprise scenario, which technique substitutes sensitive information with a nonsensitive value while the original value is maintained in a secured system?

- A. Steganography
- B. Tokenization**
- C. Hashing
- D. Compression

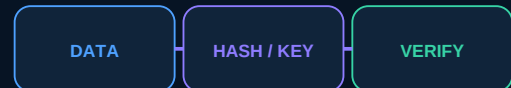
CORRECT ANSWER: B - Tokenization

WHY: Tokenization replaces sensitive information with a substitute token that has no meaningful value by itself.

MEMORY CUE

Tokenization replaces sensitive information with a substitute token that has no meaningful value by itself.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 311 | SOFTWARE AS A SERVICE

APPLIED

In a separate enterprise scenario, a company uses Microsoft 365 for email. The provider operates the application and underlying infrastructure. What service model is this?

- A. IaaS
- B. Bare metal
- C. SaaS**
- D. Colocation

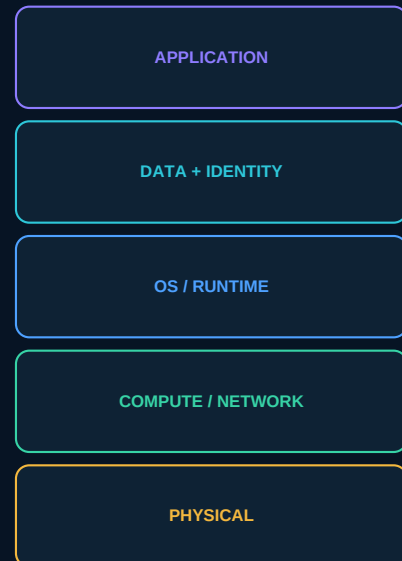
CORRECT ANSWER: C - SaaS

WHY: Software as a Service provides a complete application managed by the cloud provider.

MEMORY CUE

Software as a Service provides a complete application managed by the cloud provider.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 312

Immediate answers, concise rationales, and visual memory anchors.

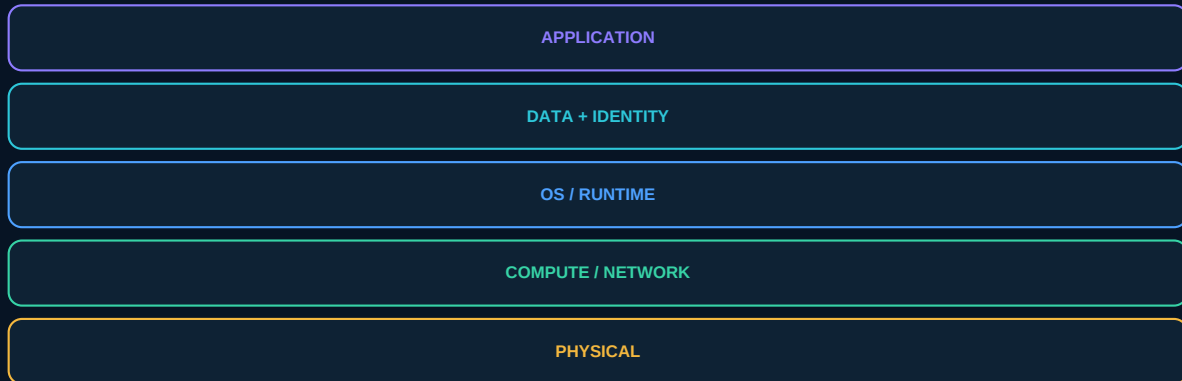
ANALYST TASK | DATA MASKING

In a separate enterprise scenario, a support portal displays a credit-card number as **** * 4821 while the real value remains stored securely. What technique is this?

- A. Compression
- B. Hashing
- C. Digital signing
- D. Data masking

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

CORRECT ANSWER: D - Data masking

RATIONALE

Data masking obscures sensitive values when full data is not needed for the user or process.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 313-314

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 313 | REPLICATION

APPLIED

A primary storage system continuously copies changed blocks to a secondary site. What resilience mechanism is this?

- A. Replication
- B. Obfuscation
- C. Key escrow
- D. Tokenization

CORRECT ANSWER: A - Replication

WHY: Replication maintains another copy of data or service state, often at a separate system or location.

MEMORY CUE

Replication = maintain a second synchronized copy.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 314 | SECURE ENCLAVE

APPLIED

While redesigning an enterprise environment, a mobile device stores highly sensitive cryptographic keys in a hardware-isolated execution environment separate from the main operating system. What concept BEST fits?

- A. SIEM
- B. Secure enclave
- C. Load balancer
- D. DNSSEC

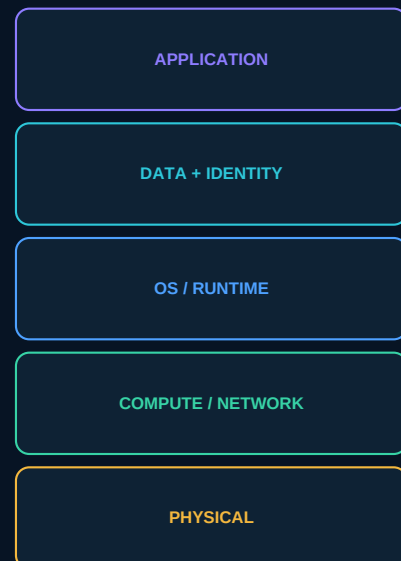
CORRECT ANSWER: B - Secure enclave

WHY: A secure enclave or trusted execution environment isolates sensitive computation and secrets from the general OS.

MEMORY CUE

Hardware-isolated protected execution area.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 315-316

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 315 | INCREMENTAL BACKUP

APPLIED

While redesigning an enterprise environment, what backup type copies only data changed since the most recent backup of any type?

- A. Cold site
- B. Full backup
- C. Incremental backup**
- D. Differential backup

CORRECT ANSWER: C - Incremental backup

WHY: Incremental backups capture changes since the last backup, whether that last backup was full or incremental.

MEMORY CUE

Incremental = since previous backup.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 316 | HYPERVISOR

APPLIED

While redesigning an enterprise environment, which component allows multiple virtual machines to share the compute resources of one physical host?

- A. RADIUS server
- B. HSM
- C. WAF
- D. Hypervisor**

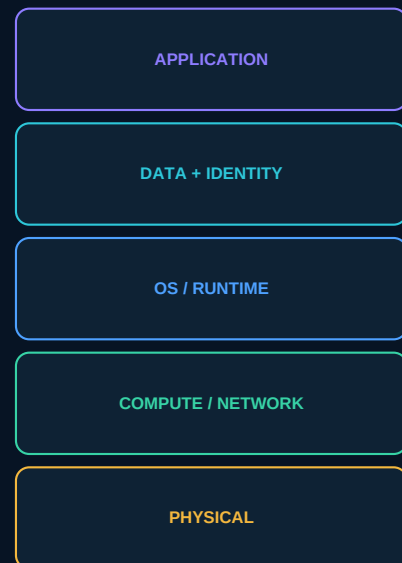
CORRECT ANSWER: D - Hypervisor

WHY: A hypervisor abstracts physical compute resources and presents virtual hardware to multiple VMs.

MEMORY CUE

Hypervisor = virtualization layer.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 317-318

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 317 | SNAPSHOT

APPLIED

While redesigning an enterprise environment, an administrator captures the point-in-time state of a virtual machine before a risky software upgrade. What mechanism is being used?

- A. Snapshot
- B. Warm site
- C. Air gap
- D. Tokenization

CORRECT ANSWER: A - Snapshot

WHY: A snapshot records a point-in-time state that can often be used for rapid rollback, though it is not always a complete independent backup.

MEMORY CUE

Snapshot = point-in-time state/rollback aid.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 318 | BASTION HOST

APPLIED

In a separate enterprise scenario, administrators must connect through one hardened, monitored system before accessing isolated production servers. What is the hardened intermediary commonly called?

- A. Honeypot only
- B. Bastion / jump host
- C. Load balancer
- D. DNS resolver

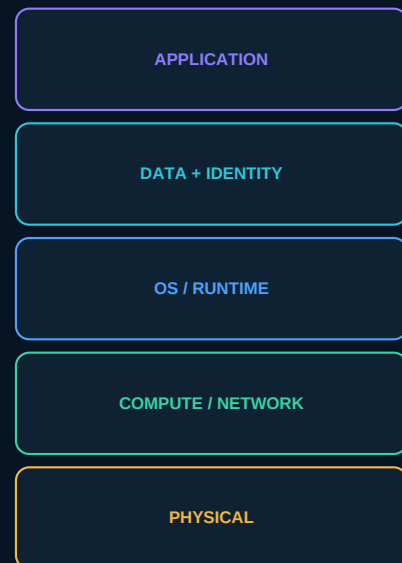
CORRECT ANSWER: B - Bastion / jump host

WHY: A bastion or jump host is a hardened controlled entry point used for administrative access to protected environments.

MEMORY CUE

Jump host = controlled admin entry point.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 319-321

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 319 | DIFFERENTIAL BACKUP

APPLIED

In a separate enterprise scenario, which backup type copies all files changed since the LAST FULL backup?

- A. Full
- B. Incremental
- C. Differential**
- D. Snapshot only

CORRECT ANSWER: C - Differential

WHY: Differential backups always reference the most recent full backup.

MEMORY CUE

Incremental = changes since the previous backup Differential = changes since the previ full backup

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 321 | HOT SITE

APPLIED

What disaster recovery configuration generally provides the FASTEST recovery?

- A. Hot site**
- B. Tape archive only
- C. Cold site
- D. Offline warehouse

CORRECT ANSWER: A - Hot site

WHY: Hot Sites maintain ready-to-use systems, communications, and frequently replicated data.

MEMORY CUE

Hot sites maintain ready-to-use systems, communications, and frequently replicated data.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 320

Immediate answers, concise rationales, and visual memory anchors.

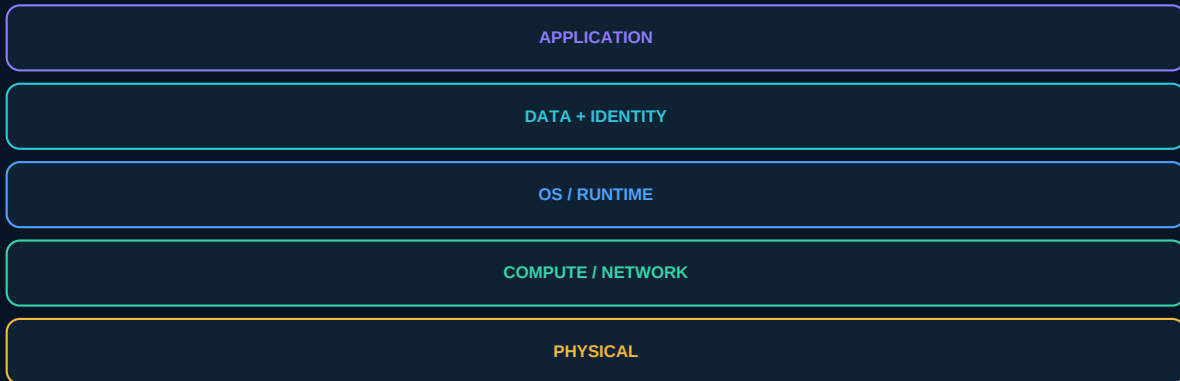
ANALYST TASK | INFRASTRUCTURE AS CODE

While redesigning an enterprise environment, an information-security team stores cloud network and firewall definitions in version-controlled templates that can be repeatedly deployed. What practice is this?

- A. Warm-site recovery
- B. Tokenization
- C. Data masking
- D. Infrastructure as code (IaC)

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

CORRECT ANSWER: D - Infrastructure as code (IaC)

RATIONALE

IaC defines infrastructure through machine-readable configuration so environments can be versioned, reviewed, and reproduced.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 322-323

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 322 | ENCRYPTION AT REST

APPLIED

In a separate enterprise scenario, an organization wants highly sensitive employee data to remain unreadable even if a storage device is stolen. Which protection is **MOST** appropriate?

- A. DNSSEC
- B. Encryption at rest**
- C. Load balancing
- D. NAT

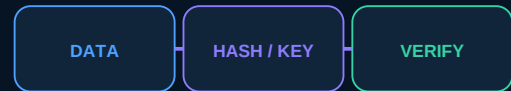
CORRECT ANSWER: B - Encryption at rest

WHY: Encryption at rest protects stored files, disks, databases, and other persistent information.

MEMORY CUE

Encryption at rest protects stored files, disks, databases, and other persistent information.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 323 | WARM SITE

APPLIED

A midsize business requires a recovery site containing hardware and connectivity but must restore systems and data after a disaster before becoming operational. Which site is **this**?

- A. Active-active site
- B. Cold site
- C. Warm site**
- D. Hot site

CORRECT ANSWER: C - Warm site

WHY: A warm site contains infrastructure but normally requires additional restoration or configuration before full operations can resume.

MEMORY CUE

A warm site contains infrastructure but normally requires additional restoration or configuration before full operations can resume.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 324-325

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 324 | HIGH AVAILABILITY

APPLIED

A company has two web servers simultaneously serving customer requests. If one fails, the second continues processing traffic. Which security concept is demonstrated?

- A. Obfuscation
- B. Air gapping
- C. Data masking
- D. High availability**

CORRECT ANSWER: D - High availability

WHY: Redundant systems reduce downtime and maintain service when individual components fail.

MEMORY CUE

Redundant systems reduce downtime and maintain service when individual components fail.

Security Objectives - CIA Triad



QUESTION 325 | CLUSTERING

APPLIED

While redesigning an enterprise environment, two database nodes operate as a coordinated group and automatically move service ownership if one node fails. What design is this?

- A. Clustering**
- B. Data masking
- C. Tokenization
- D. DNS tunneling

CORRECT ANSWER: A - Clustering

WHY: Clustering groups systems to provide coordinated service, redundancy, and failover.

MEMORY CUE

Cluster = coordinated nodes providing one service.

Resilience / Recovery Timeline



Security+ Master Visual Review | Questions 326-327

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 326 | AIR GAP

APPLIED

While redesigning an enterprise environment, a classified system has no direct network connection to the corporate network or internet. What architectural control is being used?

- A. Load balancing
- B. Air gap**
- C. Federation
- D. Content delivery network

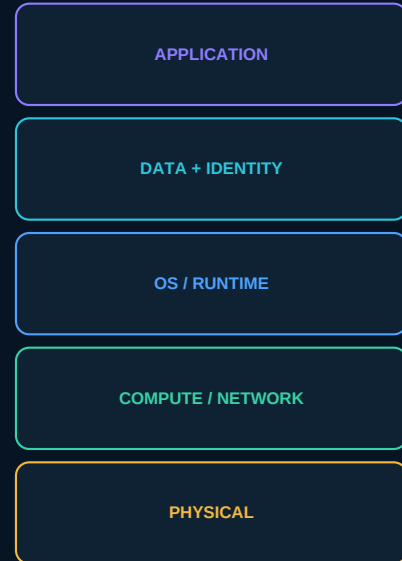
CORRECT ANSWER: B - Air gap

WHY: An air gap physically or logically isolates a system from other networks to reduce connectivity-based risk.

MEMORY CUE

Air gap = no direct network path.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 327 | DATA IN USE

APPLIED

While redesigning an enterprise environment, sensitive information is decrypted in application memory while calculations are performed. Which data state is being described?

- A. Data in transit
- B. Data at rest
- C. Data in use**
- D. Data remanence

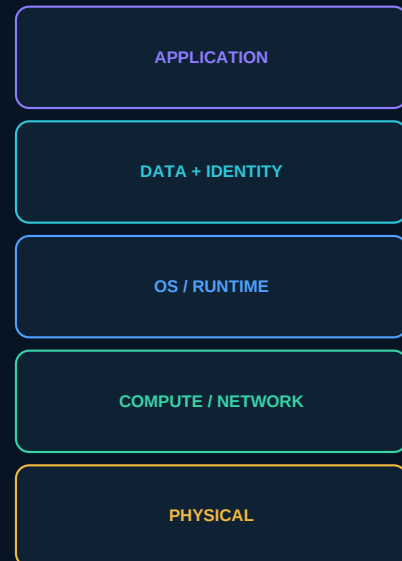
CORRECT ANSWER: C - Data in use

WHY: Data in use is actively processed in memory or by a computing workload.

MEMORY CUE

In use = actively being processed.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 328

Immediate answers, concise rationales, and visual memory anchors.

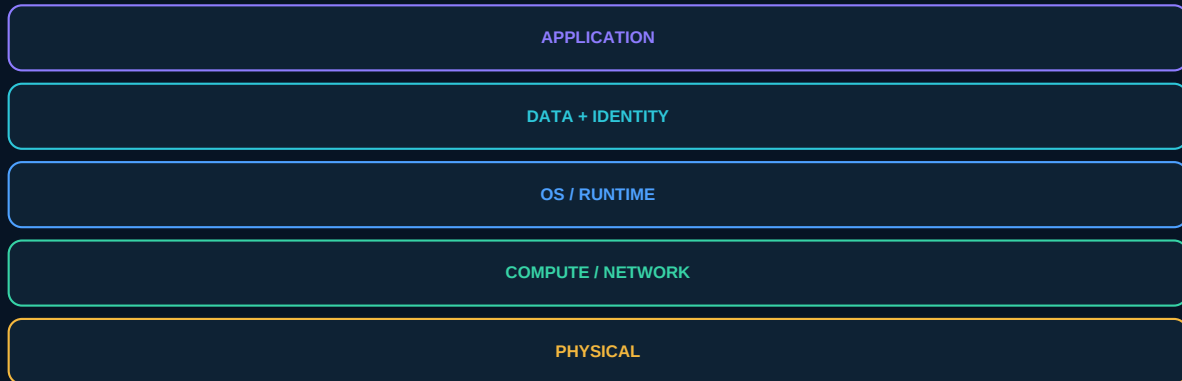
ANALYST TASK | DATA IN TRANSIT

An application encrypts communications between a browser and web server using TLS. What state of data is being protected?

- A. Data remanence
- B. Data destruction
- C. Data at rest
- D. Data in transit

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

CORRECT ANSWER: D - Data in transit

RATIONALE TLS protects information while it travels across a network.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 329-330

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 329 | DMZ

ADVANCED

An infrastructure architect is evaluating a design described as follows: provides a controlled network segment for internet-facing systems separated from trusted internal resources. Which architecture, resilience, or data-protection concept BEST fits?

A. DMZ

B. Management VLAN

C. Loopback network

D. SAN

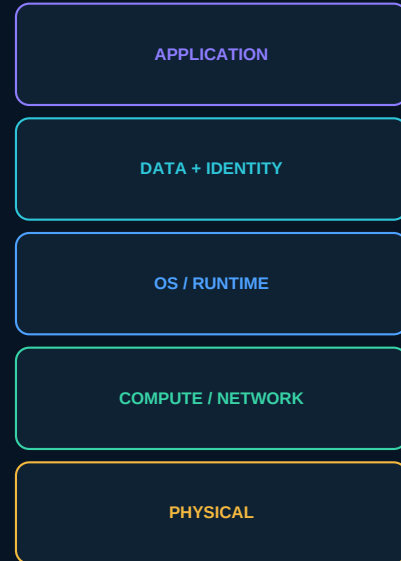
CORRECT ANSWER: A - DMZ

WHY: A DMZ provides a controlled network segment for internet-facing systems separated from trusted internal resources.

MEMORY CUE

A DMZ provides a controlled network segment for internet-facing systems separated from trusted internal resources.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 330 | TRUSTED PLATFORM MODULE

ADVANCED

An infrastructure architect is evaluating a design described as follows: provides hardware-backed cryptographic storage and platform-integrity functionality. Which architecture, resilience, or data-protection concept BEST fits?

A. SIEM

B. TPM

C. Load balancer

D. IPS

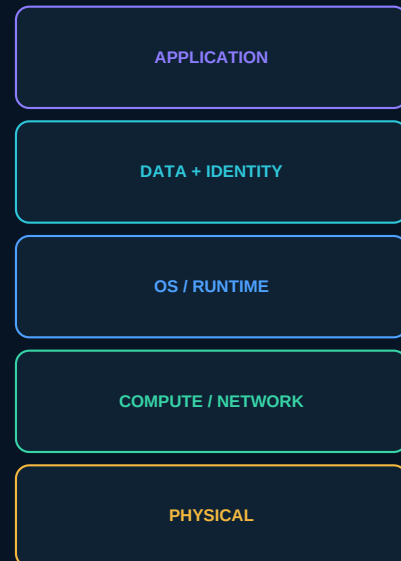
CORRECT ANSWER: B - TPM

WHY: A Trusted Platform Module provides hardware-backed cryptographic storage and platform-integrity functionality.

MEMORY CUE

A Trusted Platform Module provides hardware-backed cryptographic storage and platform-integrity functionality.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 331-332

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 331 | CLUSTERING

ADVANCED

An infrastructure architect is evaluating a design described as follows: groups systems to provide coordinated service, redundancy, and failover. Which architecture, resilience, or data-protection concept BEST fits?

- A. Tokenization
- B. Data masking
- C. Clustering**
- D. DNS tunneling

CORRECT ANSWER: C - Clustering

WHY: Clustering groups systems to provide coordinated service, redundancy, and failover.

MEMORY CUE

Cluster = coordinated nodes providing one service.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 332 | ZERO-TRUST ARCHITECTURE

ADVANCED

An infrastructure architect is evaluating a design described as follows: zero trust assumes breach and continuously evaluates access based on identity, device, context, and policy. Which architecture, resilience, or data-protection concept BEST fits?

- A. Open federation
- B. Hub-and-spoke trust
- C. Flat network
- D. Zero-trust architecture**

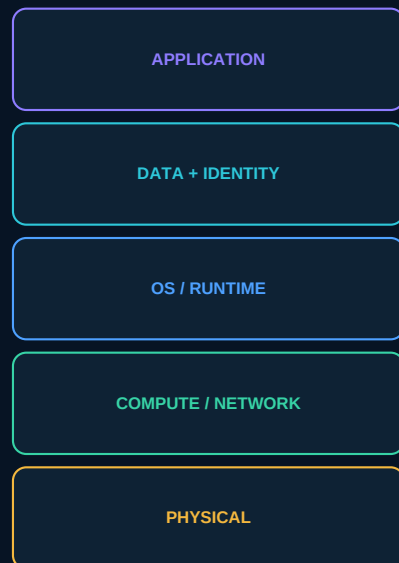
CORRECT ANSWER: D - Zero-trust architecture

WHY: Zero trust assumes breach and continuously evaluates access based on identity, device, context, and policy.

MEMORY CUE

Zero trust assumes breach and continuously evaluates access based on identity, device, context, and policy.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 333-334

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 333 | REDUNDANCY

ADVANCED

An infrastructure architect is evaluating a design described as follows: duplicates critical components so a single failure does not necessarily interrupt service. Which architecture, resilience, or data-protection concept BEST fits?

- A. Redundancy
- B. Non-repudiation
- C. Federation
- D. Obfuscation

CORRECT ANSWER: A - Redundancy

WHY: Redundancy duplicates critical components so a single failure does not necessarily interrupt service.

MEMORY CUE

Redundancy removes single points of failure.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 334 | INFRASTRUCTURE AS CODE

ADVANCED

An infrastructure architect is evaluating a design described as follows: IaC defines infrastructure through machine-readable configuration so environments can be versioned, reviewed, and reproduced. Which architecture, resilience, or data-protection concept BEST fits?

- A. Tokenization
- B. Infrastructure as code (IaC)
- C. Data masking
- D. Warm-site recovery

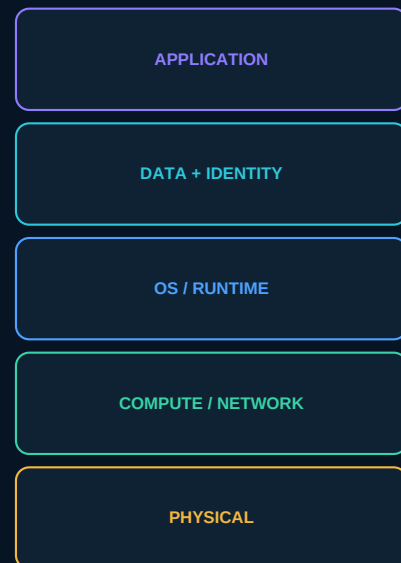
CORRECT ANSWER: B - Infrastructure as code (IaC)

WHY: IaC defines infrastructure through machine-readable configuration so environments can be versioned, reviewed, and reproduced.

MEMORY CUE

IaC = infrastructure defined in code/config.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 335-337

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 335 | AIR GAP

ADVANCED

An infrastructure architect is evaluating a design described as follows: an physically or logically isolates a system from other networks to reduce connectivity-based risk. Which architecture, resilience, or data-protection concept BEST fits?

- A. Content delivery network
- B. Federation
- C. Air gap**
- D. Load balancing

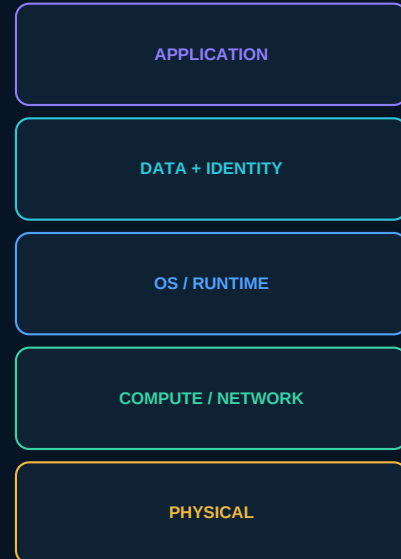
CORRECT ANSWER: C - Air gap

WHY: An air gap physically or logically isolates a system from other networks to reduce connectivity-based risk.

MEMORY CUE

Air gap = no direct network path.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 337 | MICROSERVICES

ADVANCED

An infrastructure architect is evaluating a design described as follows: decompose an application into independently deployable services with defined interfaces. Which architecture, resilience, or data-protection concept BEST fits?

- A. Microservices**
- B. Air-gapped architecture
- C. Cold-site architecture
- D. Monolithic architecture

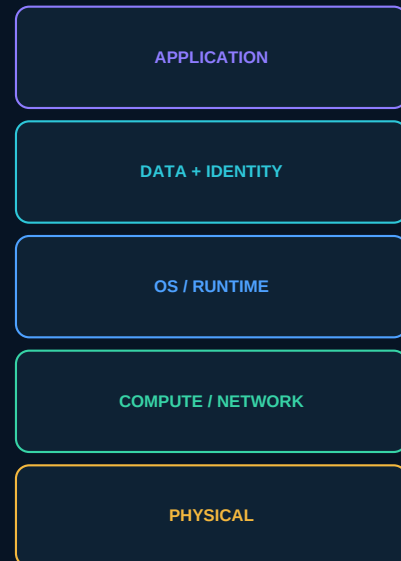
CORRECT ANSWER: A - Microservices

WHY: Microservices decompose an application into independently deployable services with defined interfaces.

MEMORY CUE

Small independent services instead of one monolith.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 336

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | HOT SITE

An infrastructure architect is evaluating a design described as follows: this controls maintain ready-to-use systems, communications, and frequently replicated data. Which architecture, resilience, or data-protection concept BEST fits?

- A. Tape archive only
- B. Offline warehouse
- C. Cold site
- D. Hot site

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

CORRECT ANSWER: D - Hot site

RATIONALE

Hot sites maintain ready-to-use systems, communications, and frequently replicated data.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 338-339

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 338 | ENCRYPTION AT REST

ADVANCED

An infrastructure architect is evaluating a design described as follows: protects stored files, disks, databases, and other persistent information. Which architecture, resilience, or data-protection concept BEST fits?

- A. DNSSEC
- B. Encryption at rest**
- C. Load balancing
- D. NAT

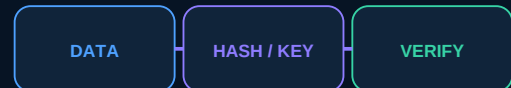
CORRECT ANSWER: B - Encryption at rest

WHY: Encryption at rest protects stored files, disks, databases, and other persistent information.

MEMORY CUE

Encryption at rest protects stored files, disks, databases, and other persistent information.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 339 | WARM SITE

ADVANCED

An infrastructure architect is evaluating a design described as follows: contains infrastructure but normally requires additional restoration or configuration before full operations can resume. Which architecture, resilience, or data-protection concept BEST fits?

- A. Active-active site
- B. Hot site
- C. Warm site**
- D. Cold site

CORRECT ANSWER: C - Warm site

WHY: A warm site contains infrastructure but normally requires additional restoration or configuration before full operations can resume.

MEMORY CUE

A warm site contains infrastructure but normally requires additional restoration or configuration before full operations can resume.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 340-341

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 340 | GEOGRAPHIC DISPERSION

ADVANCED

An infrastructure architect is evaluating a design described as follows: places resources in separate regions to reduce correlated physical or regional failures. Which architecture, resilience, or data-protection concept BEST fits?

- A. Data masking
- B. Single-site clustering
- C. Password rotation
- D. Geographic dispersion

CORRECT ANSWER: D - Geographic dispersion

WHY: Geographic dispersion places resources in separate regions to reduce correlated physical or regional failures.

MEMORY CUE

Separate regions reduce shared disaster risk.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 341 | INCREMENTAL BACKUP

ADVANCED

An infrastructure architect is evaluating a design described as follows: this controls capture changes since the last backup, whether that last backup was full or incremental. Which architecture, resilience, or data-protection concept BEST fits?

- A. Incremental backup
- B. Full backup
- C. Differential backup
- D. Cold site

CORRECT ANSWER: A - Incremental backup

WHY: Incremental backups capture changes since the last backup, whether that last backup was full or incremental.

MEMORY CUE

Incremental = since previous backup.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 342-343

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 342 | LOAD BALANCER

ADVANCED

An infrastructure architect is evaluating a design described as follows: a distributes client traffic across multiple backend systems and can support health-aware failover. Which architecture, resilience, or data-protection concept BEST fits?

- A. NAC
- B. Load balancer**
- C. Certificate authority
- D. HSM

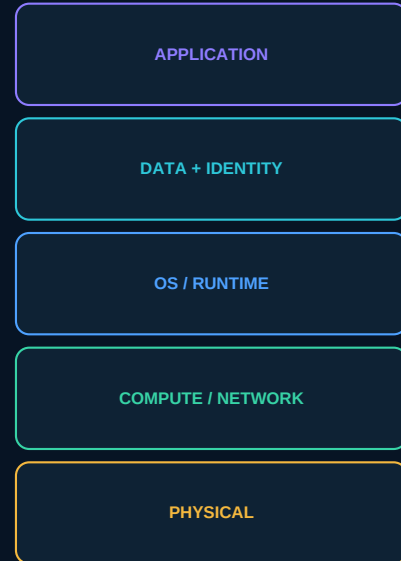
CORRECT ANSWER: B - Load balancer

WHY: A load balancer distributes client traffic across multiple backend systems and can support health-aware failover.

MEMORY CUE

Load balancer spreads requests across healthy backends.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 343 | HARDWARE SECURITY MODULE

ADVANCED

An infrastructure architect is evaluating a design described as follows: a designed specifically to securely generate, store, and use cryptographic keys. Which architecture, resilience, or data-protection concept BEST fits?

- A. IDS
- B. NAC
- C. HSM**
- D. WAF

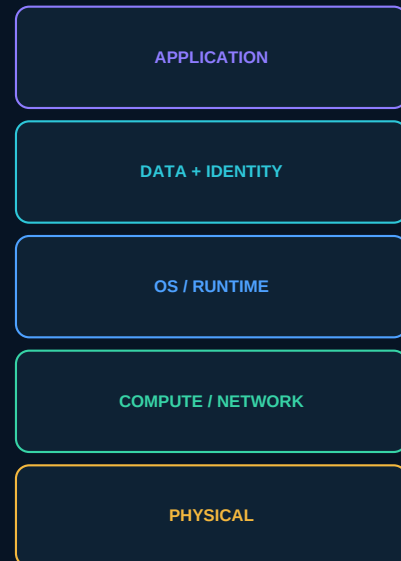
CORRECT ANSWER: C - HSM

WHY: A Hardware Security Module is designed specifically to securely generate, store, and use cryptographic keys.

MEMORY CUE

A Hardware Security Module is designed specifically to securely generate, store, and use cryptographic keys.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 344

Immediate answers, concise rationales, and visual memory anchors.

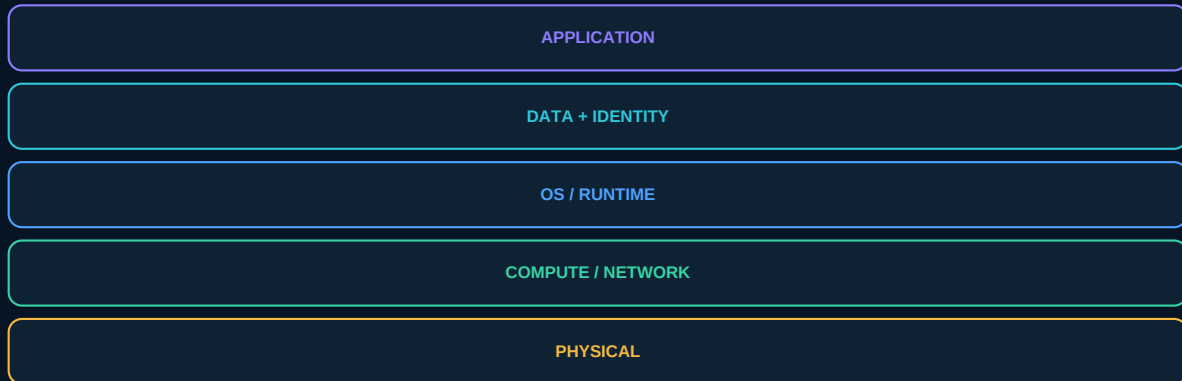
ANALYST TASK | INFRASTRUCTURE AS A SERVICE

An infrastructure architect is evaluating a design described as follows: with this control, the provider operates the physical infrastructure while the customer manages virtual operating systems and workloads. Which architecture, resilience, or data-protection concept BEST fits?

- A. PaaS
- B. SaaS
- C. FaaS only
- D. IaaS

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

CORRECT ANSWER: D - IaaS

RATIONALE

With Infrastructure as a Service, the provider operates the physical infrastructure while the customer manages virtual operating systems and workloads.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 345-346

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 345 | SHARED RESPONSIBILITY

ADVANCED

An infrastructure architect is evaluating a design described as follows: in IaaS, the provider secures underlying infrastructure while generally manages and patches guest operating systems and workloads. Which architecture, resilience, or data-protection concept BEST fits?

- A. The customer
- B. The cloud provider only
- C. The ISP
- D. The certificate authority

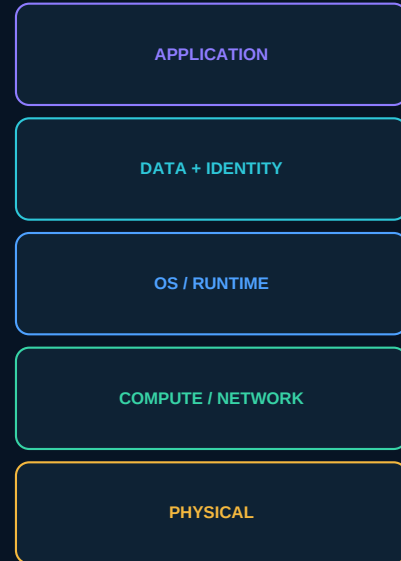
CORRECT ANSWER: A - The customer

WHY: In IaaS, the provider secures underlying infrastructure while the customer generally manages and patches guest operating systems and workloads.

MEMORY CUE

IaaS: customer owns more of the software stack.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 346 | HYPERVISOR

ADVANCED

An infrastructure architect is evaluating a design described as follows: a abstracts physical compute resources and presents virtual hardware to multiple VMs. Which architecture, resilience, or data-protection concept BEST fits?

- A. RADIUS server
- B. Hypervisor
- C. WAF
- D. HSM

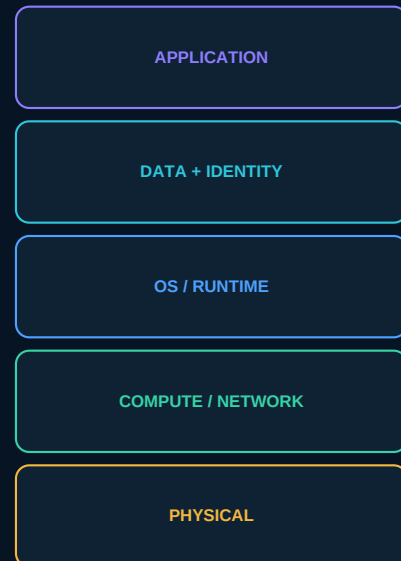
CORRECT ANSWER: B - Hypervisor

WHY: A hypervisor abstracts physical compute resources and presents virtual hardware to multiple VMs.

MEMORY CUE

Hypervisor = virtualization layer.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 347-348

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 347 | MICROSEGMENTATION

ADVANCED

An infrastructure architect is evaluating a design described as follows: enforces fine-grained east-west controls between workloads, often beyond traditional VLAN boundaries. Which architecture, resilience, or data-protection concept BEST fits?

- A. RAID
- B. Load balancing
- C. Microsegmentation**
- D. Tokenization

CORRECT ANSWER: C - Microsegmentation

WHY: Microsegmentation enforces fine-grained east-west controls between workloads, often beyond traditional VLAN boundaries.

MEMORY CUE

Microsegmentation = fine-grained east-west control.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 348 | PUBLIC CLOUD

ADVANCED

An infrastructure architect is evaluating a design described as follows: services are provider-owned and delivered over shared infrastructure to many customers. Which architecture, resilience, or data-protection concept BEST fits?

- A. Community-only cloud
- B. Air-gapped cloud
- C. Private cloud
- D. Public cloud**

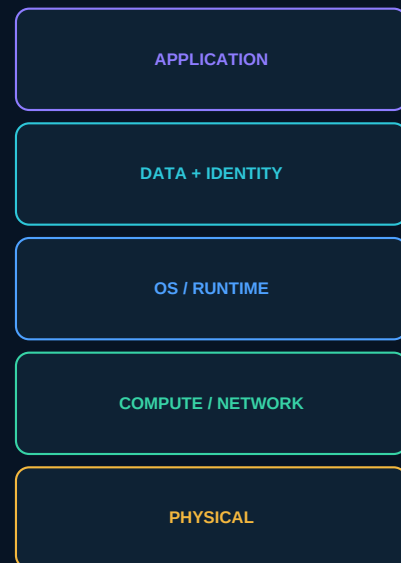
CORRECT ANSWER: D - Public cloud

WHY: Public cloud services are provider-owned and delivered over shared infrastructure to many customers.

MEMORY CUE

Public cloud = provider-owned shared service.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 349-350

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 349 | FULL BACKUP

ADVANCED

An infrastructure architect is evaluating a design described as follows: a copies all selected data and serves as a baseline for other backup strategies. Which architecture, resilience, or data-protection concept BEST fits?

- A. Full backup
- B. Snapshot delta only
- C. Differential backup
- D. Incremental backup

CORRECT ANSWER: A - Full backup

WHY: A full backup copies all selected data and serves as a baseline for other backup strategies.

MEMORY CUE

Full = everything selected.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 350 | SNAPSHOT

ADVANCED

An infrastructure architect is evaluating a design described as follows: records a point-in-time state that can often be used for rapid rollback, though it is not always a complete independent backup. Which architecture, resilience, or data-protection concept BEST fits?

- A. Tokenization
- B. Snapshot
- C. Air gap
- D. Warm site

CORRECT ANSWER: B - Snapshot

WHY: A snapshot records a point-in-time state that can often be used for rapid rollback, though it is not always a complete independent backup.

MEMORY CUE

Snapshot = point-in-time state/rollback aid.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 351-353

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 351 | DATA IN TRANSIT

ADVANCED

An infrastructure architect is evaluating a design described as follows: tLS protects information while it travels across a network. Which architecture, resilience, or data-protection concept BEST fits?

- A. Data remanence
- B. Data at rest
- C. Data in transit**
- D. Data destruction

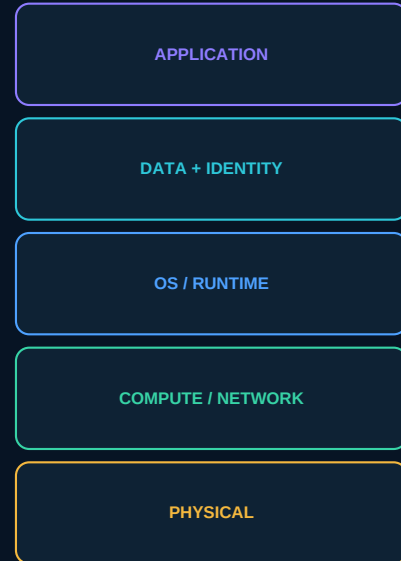
CORRECT ANSWER: C - Data in transit

WHY: TLS protects information while it travels across a network.

MEMORY CUE

TLS protects information while it travels across a network.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 353 | SERVERLESS

ADVANCED

An infrastructure architect is evaluating a design described as follows: computing lets developers run functions without managing servers directly. Which architecture, resilience, or data-protection concept BEST fits?

- A. Serverless / FaaS**
- B. Private WAN
- C. Colocation
- D. Bare metal

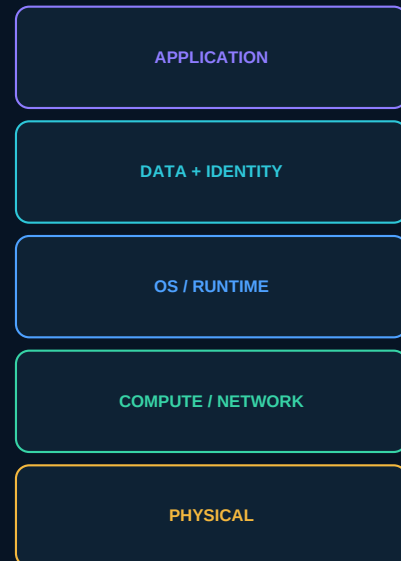
CORRECT ANSWER: A - Serverless / FaaS

WHY: Serverless computing lets developers run functions without managing servers directly.

MEMORY CUE

Serverless = provider manages execution infrastructure.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 352

Immediate answers, concise rationales, and visual memory anchors.

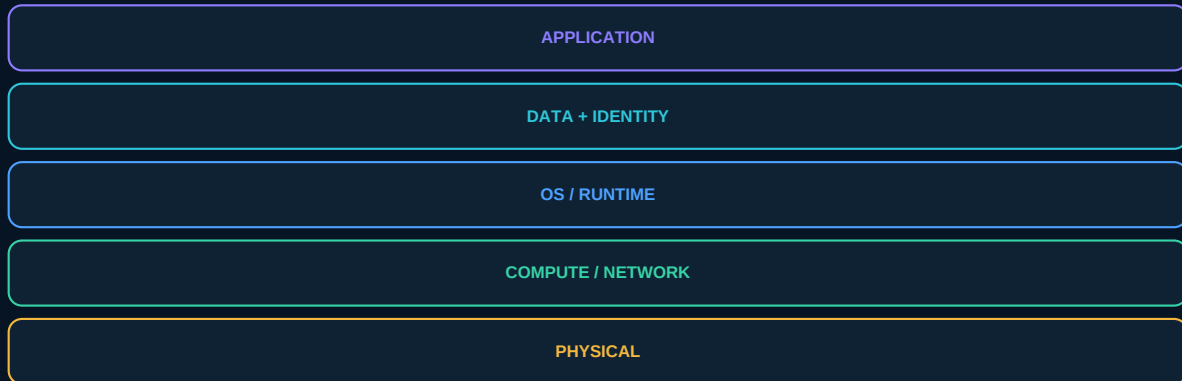
ANALYST TASK | ICS/OT

An infrastructure architect is evaluating a design described as follows: industrial Control Systems and Operational Technology directly interact with physical equipment and processes. Which architecture, resilience, or data-protection concept BEST fits?

- A. CDN
- B. SaaS CRM
- C. Public social network
- D. ICS/OT environment

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

CORRECT ANSWER: D - ICS/OT environment

RATIONALE

Industrial Control Systems and Operational Technology directly interact with physical equipment and processes.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 354-355

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 354 | DIFFERENTIAL BACKUP

ADVANCED

An infrastructure architect is evaluating a design described as follows: this controls always reference the most recent full backup. Which architecture, resilience, or data-protection concept BEST fits?

- A. Snapshot only
- B. Differential**
- C. Full
- D. Incremental

CORRECT ANSWER: B - Differential

WHY: Differential backups always reference the most recent full backup.

MEMORY CUE

Incremental = changes since the previous backup Differential = changes since the previ full backup

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

Illustrative study visual - not live production telemetry

QUESTION 355 | HYBRID CLOUD

ADVANCED

An infrastructure architect is evaluating a design described as follows: combines private and public cloud resources in an integrated architecture. Which architecture, resilience, or data-protection concept BEST fits?

- A. Community cloud
- B. Private cloud
- C. Hybrid cloud**
- D. Public cloud

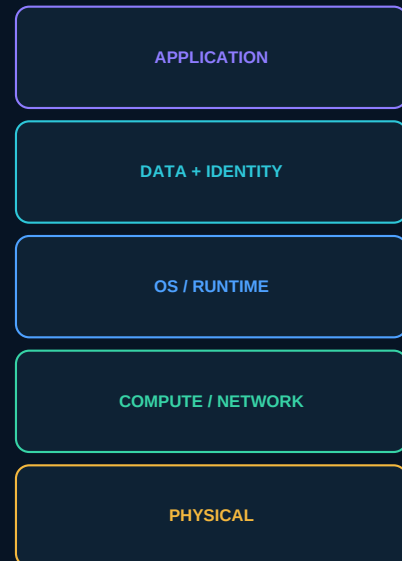
CORRECT ANSWER: C - Hybrid cloud

WHY: Hybrid cloud combines private and public cloud resources in an integrated architecture.

MEMORY CUE

Hybrid = private + public.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 356-357

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 356 | NETWORK SEGMENTATION

ADVANCED

An infrastructure architect is evaluating a design described as follows: logically divide a physical switching environment into separate Layer 2 broadcast domains. Which architecture, resilience, or data-protection concept BEST fits?

- A. Digital signing
- B. Hashing
- C. Data masking

D. VLANs

CORRECT ANSWER: D - VLANs

WHY: VLANs logically divide a physical switching environment into separate Layer 2 broadcast domains.

MEMORY CUE

VLANs logically divide a physical switching environment into separate Layer 2 broadcast domains.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 357 | VPN

ADVANCED

An infrastructure architect is evaluating a design described as follows: creates a protected tunnel across an untrusted network for remote or site-to-site connectivity. Which architecture, resilience, or data-protection concept BEST fits?

- A. VPN
- B. VLAN
- C. Load balancer
- D. NAT only

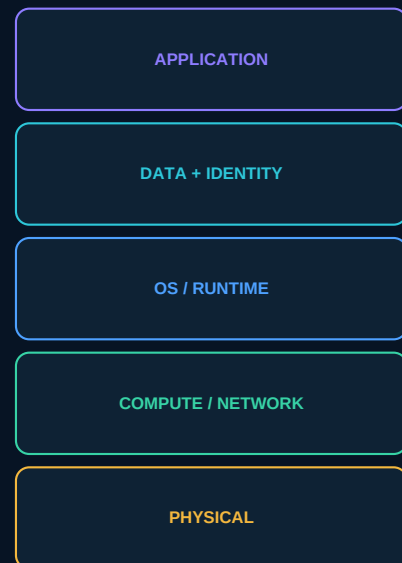
CORRECT ANSWER: A - VPN

WHY: A VPN creates a protected tunnel across an untrusted network for remote or site-to-site connectivity.

MEMORY CUE

VPN = encrypted tunnel over untrusted network.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 358-359

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 358 | PRIVATE CLOUD

ADVANCED

An infrastructure architect is evaluating a design described as follows: a dedicated to a single organization, whether on-premises or hosted. Which architecture, resilience, or data-protection concept BEST fits?

- A. Public cloud
- B. Private cloud**
- C. Community cloud
- D. Hybrid cloud

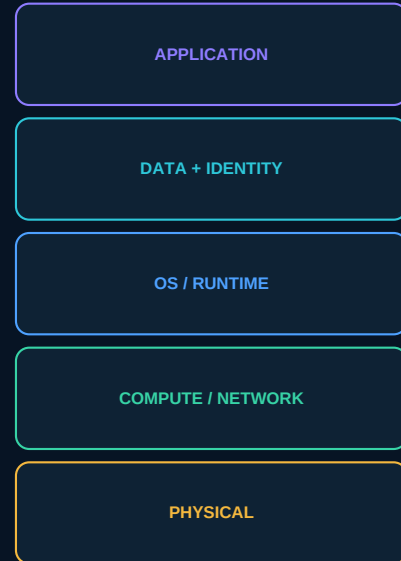
CORRECT ANSWER: B - Private cloud

WHY: A private cloud is dedicated to a single organization, whether on-premises or hosted.

MEMORY CUE

Private cloud = dedicated to one organization.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 359 | CONTAINERS

ADVANCED

An infrastructure architect is evaluating a design described as follows: package applications and dependencies while sharing the host kernel, making them lighter than full VMs. Which architecture, resilience, or data-protection concept BEST fits?

- A. Tape virtualization
- B. Bare-metal clustering
- C. Containers**
- D. Traditional virtual machines only

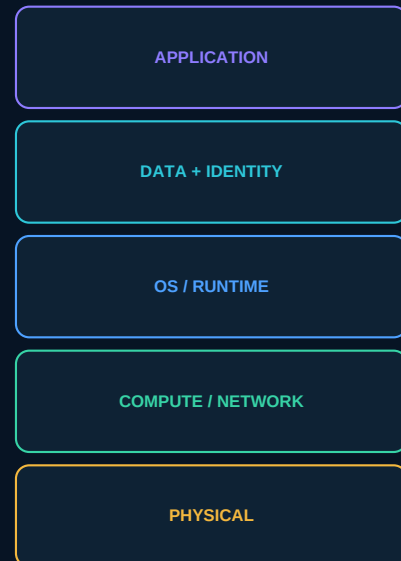
CORRECT ANSWER: C - Containers

WHY: Containers package applications and dependencies while sharing the host kernel, making them lighter than full VMs.

MEMORY CUE

Containers share the host kernel.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 360

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | MALWARE SANDBOX

An infrastructure architect is evaluating a design described as follows: malware analysis should occur within an isolated and controlled environment to prevent accidental propagation. Which architecture, resilience, or data-protection concept BEST fits?

- A. Public Wi-Fi network
- B. Shared administrative workstation
- C. Flat production network
- D. Isolated sandbox

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Architecture / Shared Responsibility

APPLICATION

DATA + IDENTITY

OS / RUNTIME

COMPUTE / NETWORK

PHYSICAL

Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

CORRECT ANSWER: D - Isolated sandbox

RATIONALE

Malware analysis should occur within an isolated and controlled environment to prevent accidental propagation.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 361-362

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 361 | TOKENIZATION

ADVANCED

An infrastructure architect is evaluating a design described as follows: replaces sensitive information with a substitute token that has no meaningful value by itself. Which architecture, resilience, or data-protection concept BEST fits?

- A. Tokenization
- B. Compression
- C. Steganography
- D. Hashing

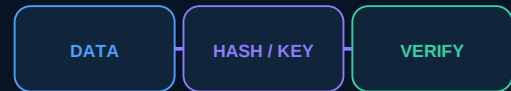
CORRECT ANSWER: A - Tokenization

WHY: Tokenization replaces sensitive information with a substitute token that has no meaningful value by itself.

MEMORY CUE

Tokenization replaces sensitive information with a substitute token that has no meaningful value by itself.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 362 | HIGH AVAILABILITY

ADVANCED

An infrastructure architect is evaluating a design described as follows: redundant systems reduce downtime and maintain service when individual components fail. Which architecture, resilience, or data-protection concept BEST fits?

- A. Obfuscation
- B. High availability
- C. Air gapping
- D. Data masking

CORRECT ANSWER: B - High availability

WHY: Redundant systems reduce downtime and maintain service when individual components fail.

MEMORY CUE

Redundant systems reduce downtime and maintain service when individual components fail.

Security Objectives - CIA Triad



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 363-364

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 363 | PLATFORM AS A SERVICE

ADVANCED

An infrastructure architect is evaluating a design described as follows: provides a managed application platform and runtime while the provider manages more of the underlying stack. Which architecture, resilience, or data-protection concept **BEST** fits?

- A. Colocation
- B. SaaS
- C. PaaS**
- D. IaaS

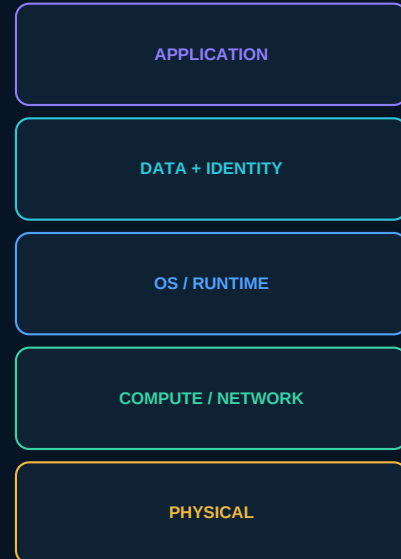
CORRECT ANSWER: C - PaaS

WHY: PaaS provides a managed application platform and runtime while the provider manages more of the underlying stack.

MEMORY CUE

PaaS = deploy code, provider manages platform.

Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

QUESTION 364 | SOFTWARE AS A SERVICE

ADVANCED

An infrastructure architect is evaluating a design described as follows: provides a complete application managed by the cloud provider. Which architecture, resilience, or data-protection concept **BEST** fits?

- A. Colocation
- B. Bare metal
- C. IaaS
- D. SaaS**

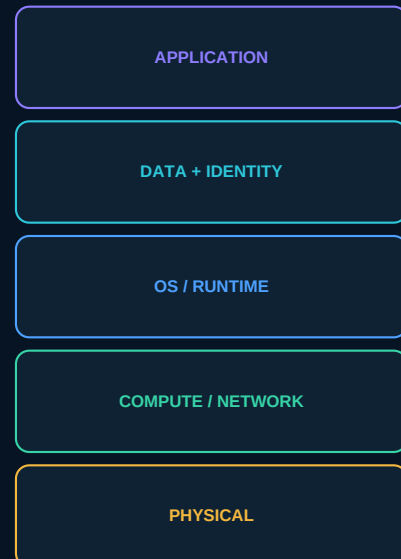
CORRECT ANSWER: D - SaaS

WHY: Software as a Service provides a complete application managed by the cloud provider.

MEMORY CUE

Software as a Service provides a complete application managed by the cloud provider.

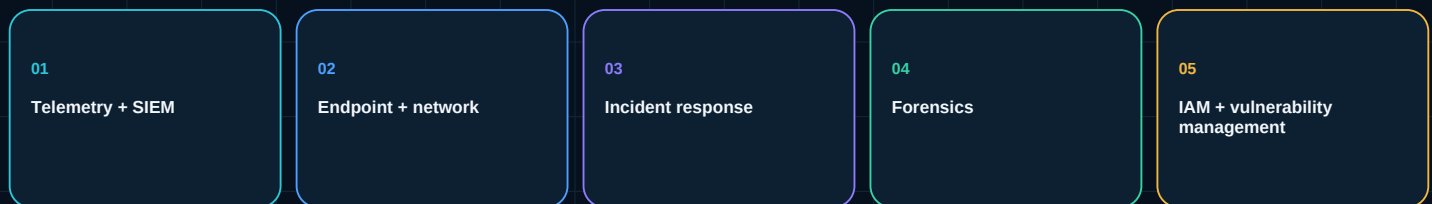
Architecture / Shared Responsibility



Responsibility changes by SaaS / PaaS / IaaS / on-prem model.
Illustrative study visual - not live production telemetry

SECURITY OPERATIONS

QUESTIONS 365-560 | 196 QUESTIONS



BY MARC LAVOIE

Security+ Master Visual Review | Questions 365-366

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 365 | SUSPICIOUS POWERSHELL

FOUNDATION

A SOC receives an alert that powershell.exe launched with an encoded command and then connected to an unfamiliar IP. What should the analyst do FIRST?

A. Investigate the process and related telemetry

B. Reimage the entire enterprise

C. Disable the SIEM

D. Delete PowerShell

CORRECT ANSWER: A - Investigate the process and related telemetry

WHY: telemetry The analyst first needs to establish context and determine whether the behavior is malicious before taking disproportionate action. Useful evidence could include: - Parent process - Command line - User account - Destination IP - DNS activity -

MEMORY CUE

telemetry The analyst first needs to establish context and determine whether the behavior is malicious before taking disproportionat...

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 366 | PROXY LOGS

FOUNDATION

An analyst needs to determine which URLs an internal workstation requested through the organization's web gateway. Which log source is MOST useful?

A. Printer logs

B. Proxy logs

C. BIOS logs

D. UPS logs

CORRECT ANSWER: B - Proxy logs

WHY: Proxy logs record web requests such as destination domains, URLs, users, methods, and actions.

MEMORY CUE

Proxy logs = web browsing/request telemetry.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 367-368

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 367 | FIREWALL LOGS

FOUNDATION

Which log source would BEST identify outbound connections permitted or denied at the network perimeter?

- A. BIOS logs
- B. Printer logs
- C. Firewall logs**
- D. Badge-reader logs

CORRECT ANSWER: C - Firewall logs

WHY: Firewall logs commonly contain source/destination IPs, ports, protocols, actions, policies, and connection information.

MEMORY CUE

Firewall logs commonly contain source/destination IPs, ports, protocols, actions, policies, and connection information.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 368 | DNS LOGS

FOUNDATION

An analyst wants to identify which internal hosts resolved a newly registered malicious domain. Which telemetry should be queried first?

- A. Badge-reader logs
- B. BIOS logs
- C. RAID logs
- D. DNS logs**

CORRECT ANSWER: D - DNS logs

WHY: DNS logs map clients to queried domain names and resolution results, making them valuable for domain-based hunting.

MEMORY CUE

DNS logs connect hosts to domain lookups.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 369-370

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 369 | SYSMON

FOUNDATION

Which Windows log source is particularly useful for recording detailed process creation when properly configured?

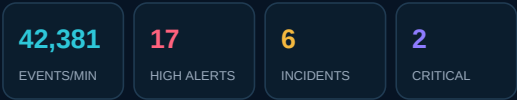
- A. Sysmon
- B. DNS root hints
- C. DHCP only
- D. SNMP traps

CORRECT ANSWER: A - Sysmon

WHY: Sysmon provides detailed endpoint telemetry such as process creation, network connections, registry activity, image loading, and file events.

MEMORY CUE
Sysmon provides detailed endpoint telemetry such as process creation, network connections, registry activity, image loading, and file events.

SOC Correlation Dashboard



```
EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 370 | DHCP LOGS

FOUNDATION

Investigators have an IP address from an alert and need to determine which endpoint had that address at 10:15 AM. Which log source is MOST useful?

- A. Email gateway logs
- B. DHCP logs
- C. WAF logs
- D. Certificate transparency logs

CORRECT ANSWER: B - DHCP logs

WHY: DHCP logs map leased IP addresses to client identifiers over time.

MEMORY CUE
DHCP answers: who had this IP at that time?

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 371-372

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 371 | WIRESHARK

FOUNDATION

An analyst needs to examine the exact packets exchanged between a compromised host and a suspected command-and-control server. Which tool is MOST appropriate?

- A. BitLocker
- B. Active Directory Users and Computers

C. Wireshark

- D. Group Policy Management

CORRECT ANSWER: C - Wireshark

WHY: Wireshark performs packet-level network protocol analysis.

MEMORY CUE

Wireshark performs packet-level network protocol analysis.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...
DNS  long encoded subdomain
FW   outbound 443 -> 203.0.113.50
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 372 | AUTHENTICATION LOGS

FOUNDATION

A SOC analyst needs to review failed and successful sign-in events for a privileged account. Which telemetry is MOST relevant?

- A. File compression logs
- B. Printer logs
- C. UPS logs

D. Authentication logs

CORRECT ANSWER: D - Authentication logs

WHY: Authentication logs record sign-in attempts, results, identity details, and often source systems or IP addresses.

MEMORY CUE

Auth logs = sign-in evidence.

Identity / Access Flow



```
audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 373-374

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 373 | SIEM

FOUNDATION

Which technology aggregates security logs from multiple systems and performs correlation and alerting?

A. SIEM

B. UPS

C. HSM

D. RAID

CORRECT ANSWER: A - SIEM

WHY: A Security Information and Event Management platform centralizes security telemetry for search, correlation, detection, investigation, and alerting.

MEMORY CUE

A Security Information and Event Management platform centralizes security telemetry for search, correlation, detection, investigatio...

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 374 | WAF LOGS

FOUNDATION

An analyst is investigating repeated SQL injection attempts against an internet-facing application. Which log source is MOST directly relevant?

A. Badge logs

B. WAF logs

C. DHCP logs

D. UPS logs

CORRECT ANSWER: B - WAF logs

WHY: A web application firewall records and can block HTTP-layer attacks such as SQL injection and XSS.

MEMORY CUE

WAF logs = application-layer web attack telemetry.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 375-376

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 375 | EDR

FOUNDATION

Which technology focuses on endpoint telemetry, behavioral detection, investigation, and response?

- A. DNSSEC
- B. RAID
- C. EDR**
- D. VLAN

CORRECT ANSWER: C - EDR

WHY: Endpoint Detection and Response provides visibility and response capabilities directly on endpoints. Examples include: - CrowdStrike Falcon - Microsoft Defender for Endpoint - SentinelOne

MEMORY CUE

Endpoint Detection and Response provides visibility and response capabilities directly on endpoints. Examples include: - CrowdStrike...

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...  
DNS  long encoded subdomain  
FW   outbound 443 -> 203.0.113.50  
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 376 | NETFLOW

FOUNDATION

A network team wants a compact record of who communicated with whom, over which ports, and how many bytes were transferred without storing full packet payloads. What data source BEST fits?

- A. Sysmon registry events
- B. Full PCAP only
- C. BIOS audit logs
- D. NetFlow / flow records**

CORRECT ANSWER: D - NetFlow / flow records

WHY: Flow records summarize network conversations using metadata such as source, destination, ports, duration, and byte counts.

MEMORY CUE

Flow = conversation metadata, not full payload.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...  
DNS  long encoded subdomain  
FW   outbound 443 -> 203.0.113.50  
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 377-378

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 377 | XDR

FOUNDATION

An organization wants to combine telemetry and response capabilities across endpoints, identities, cloud workloads, and network security products. Which technology BEST fits?

A. XDR

B. FTP

C. SAN

D. NAT

CORRECT ANSWER: A - XDR

WHY: Extended Detection and Response correlates information across multiple security domains.

MEMORY CUE

Extended Detection and Response correlates information across multiple security domains.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...  
DNS  long encoded subdomain  
FW   outbound 443 -> 203.0.113.50  
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 378 | PACKET CAPTURE

FOUNDATION

An analyst must inspect TCP flags and application payload bytes for a suspicious connection. Which evidence source is required?

A. Asset inventory

B. Packet capture (PCAP)

C. DHCP lease table

D. NetFlow only

CORRECT ANSWER: B - Packet capture (PCAP)

WHY: PCAP preserves packet-level headers and payload data needed for detailed protocol analysis.

MEMORY CUE

PCAP = exact packets.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...  
DNS  long encoded subdomain  
FW   outbound 443 -> 203.0.113.50  
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 379-380

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 379 | SOAR

FOUNDATION

A SOC wants to automatically disable a malicious account, isolate its endpoint, and open a ticket after a confirmed alert. Which platform is MOST applicable?

- A. HSM
- B. UPS
- C. SOAR**
- D. RAID controller

CORRECT ANSWER: C - SOAR

WHY: Security Orchestration, Automation, and Response platforms automate repeatable incident-response workflows.

MEMORY CUE

Security Orchestration, Automation, and Response platforms automate repeatable incident-response workflows.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 380 | CLOUD AUDIT LOGS

FOUNDATION

A cloud administrator suspects that an access policy was changed through the provider control plane. Which log source should be reviewed?

- A. Switch CAM table only
- B. Printer logs
- C. Endpoint temperature logs
- D. Cloud audit / activity logs**

CORRECT ANSWER: D - Cloud audit / activity logs

WHY: Cloud audit logs record administrative and API actions performed against cloud resources and control-plane services.

MEMORY CUE

Cloud audit logs = who changed cloud configuration.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 381-382

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 381 | VULNERABILITY PRIORITIZATION

FOUNDATION

A vulnerability scanner reports a critical vulnerability on an internet-facing server. What should security personnel consider when prioritizing remediation? intelligence

A. Severity, exposure, exploitability, asset importance, and threat

B. User preference only

C. Server color and physical appearance

D. CVSS alone and nothing else

CORRECT ANSWER: A - Severity, exposure, exploitability, asset importance, and threat

WHY: importance, and threat intelligence Real risk depends on both vulnerability severity and organizational context.

MEMORY CUE

importance, and threat intelligence Real risk depends on both vulnerability severity and organizational context.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 382 | EMAIL GATEWAY LOGS

FOUNDATION

An analyst needs to determine whether a phishing message was delivered, quarantined, or blocked and which recipients were targeted. Which telemetry is BEST?

A. UPS logs

B. Email gateway logs

C. BIOS logs

D. DHCP logs

CORRECT ANSWER: B - Email gateway logs

WHY: Email gateway logs record message routing, sender/recipient, reputation, authentication results, and disposition.

MEMORY CUE

Email gateway = mail delivery and filtering evidence.

SOC Correlation Dashboard

42,381	17	6	2
EVENTS/MIN	HIGH ALERTS	INCIDENTS	CRITICAL

EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 383-384

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 383 | FALSE POSITIVE

FOUNDATION

A vulnerability scanner identifies a vulnerability, but manual investigation confirms the affected component is not actually installed. This is a:

- A. True negative
- B. Zero-day exploit
- C. False positive
- D. True positive

CORRECT ANSWER: C - False positive

WHY: The security tool reported a vulnerability that does not actually exist on the system.

MEMORY CUE

The security tool reported a vulnerability that does not actually exist on the system.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 384 | IDS

FOUNDATION

Which technology primarily detects suspicious network activity and generates alerts without necessarily blocking the traffic?

- A. IPS
- B. NAC
- C. HSM
- D. IDS

CORRECT ANSWER: D - IDS

WHY: An intrusion detection system monitors traffic and alerts on suspicious or known-bad behavior.

MEMORY CUE

IDS = detect and alert.

SOC Correlation Dashboard

42,381	17	6	2
EVENTS/MIN	HIGH ALERTS	INCIDENTS	CRITICAL

EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 385-386

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 385 | REMEDIATION VALIDATION

FOUNDATION

After applying a security patch, what should the organization do to verify remediation?

- A. Rescan or validate the affected system
- B. Delete previous scan results
- C. Disable monitoring
- D. Assume the vulnerability is fixed

CORRECT ANSWER: A - Rescan or validate the affected system
WHY: Security teams should verify that remediation actually eliminated the vulnerability.

MEMORY CUE
Security teams should verify that remediation actually eliminated the vulnerability.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 386 | IPS

FOUNDATION

Which technology is positioned to detect malicious network traffic and actively block it inline?

- A. SIEM only
- B. IPS
- C. IDS only
- D. HSM

CORRECT ANSWER: B - IPS
WHY: An intrusion prevention system can take inline action to block detected malicious traffic.

MEMORY CUE
IPS = detect + prevent inline.

SOC Correlation Dashboard

42,381	17	6	2
EVENTS/MIN	HIGH ALERTS	INCIDENTS	CRITICAL

EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 387-388

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 387 | RBAC

FOUNDATION

Which access-control model grants permissions based on a person's job function?

- A. MAC exclusively
- B. DAC exclusively
- C. RBAC
- D. Hash-based access

CORRECT ANSWER: C - RBAC

WHY: Role-Based Access Control assigns permissions according to organizational roles. Example: SOC Analyst → SIEM read/search + EDR investigation

MEMORY CUE
Role-Based Access Control assigns permissions according to organizational roles. Example: SOC Analyst → SIEM read/search + EDR inves...

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 388 | NETWORK ACCESS CONTROL

FOUNDATION

A laptop fails posture checks because its endpoint protection is disabled. Which technology can quarantine the device before full network access is granted?

- A. HSM
- B. RAID
- C. SIEM
- D. NAC

CORRECT ANSWER: D - NAC

WHY: Network Access Control evaluates devices or identities and can restrict noncompliant systems to a remediation network.

MEMORY CUE
NAC = admission control and posture enforcement.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 389-390

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 389 | LEAST PRIVILEGE

FOUNDATION

Which access-control concept gives a SOC analyst only the permissions required for SOC duties?

- A. Least privilege
- B. Open access
- C. Transitive trust
- D. Shared accounts

CORRECT ANSWER: A - Least privilege

WHY: Users should receive only the minimum permissions required to perform authorized responsibilities.

MEMORY CUE
Users should receive only the minimum permissions required to perform authorized responsibilities.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 390 | WEB APPLICATION FIREWALL

FOUNDATION

Which control is specifically designed to inspect HTTP/S requests and protect web applications from attacks such as SQL injection and XSS?

- A. UPS
- B. WAF
- C. HSM
- D. RADIUS

CORRECT ANSWER: B - WAF

WHY: A web application firewall filters application-layer web traffic and applies rules for common web attacks.

MEMORY CUE
WAF protects HTTP/S application traffic.

SOC Correlation Dashboard

42,381	17	6	2
EVENTS/MIN	HIGH ALERTS	INCIDENTS	CRITICAL

EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 391-392

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 391 | PRIVILEGED ACCOUNT SEPARATION

FOUNDATION

An administrator uses a normal account for email and a separate privileged account for server administration. What security practice is demonstrated?

- A. Password spraying
- B. Data masking
- C. Privileged account separation
- D. Federation

CORRECT ANSWER: C - Privileged account separation

WHY: Administrative credentials should not be exposed during everyday activities such as browsing or email.

MEMORY CUE
Administrative credentials should not be exposed during everyday activities such as browsing or email.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

QUESTION 392 | THREAT INTELLIGENCE

FOUNDATION

A SOC enriches an alert with reputation, malware-family, and observed-in-campaign information about an external IP. What capability is being used?

- A. RAID parity
- B. Load balancing
- C. Data masking
- D. Threat intelligence

CORRECT ANSWER: D - Threat intelligence

WHY: Threat intelligence supplies contextual information about adversaries, indicators, campaigns, and malicious infrastructure.

MEMORY CUE
Threat intel adds adversary context to telemetry.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 393-394

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 393 | TRUE MFA

FOUNDATION

Which authentication combination represents true multifactor authentication?

- A. Password + hardware security key
- B. Password + PIN
- C. Fingerprint + face scan
- D. Security question + password

CORRECT ANSWER: A - Password + hardware security key

WHY: Password = something you know Hardware key = something you have Two credentials from the same category do not constitute true multifactor authentication.

MEMORY CUE

Password = something you know Hardware key = something you have Two credentials from the same category do not constitute true multifactor authentication.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

QUESTION 394 | MALWARE SANDBOX

FOUNDATION

An analyst wants to execute a suspicious attachment in a controlled environment and observe child processes, registry changes, and network behavior. What should be used?

- A. Public file share
- B. Malware sandbox
- C. Unfiltered user workstation
- D. Production domain controller

CORRECT ANSWER: B - Malware sandbox

WHY: A sandbox safely executes suspicious code in an isolated environment for behavioral analysis.

MEMORY CUE

Sandbox = controlled detonation and observation.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 395-396

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 395 | SAML

FOUNDATION

Which protocol is commonly used to provide web-based identity federation and enterprise SSO?

- A. TFTP
- B. ARP
- C. SAML
- D. Telnet

CORRECT ANSWER: C - SAML

WHY: Security Assertion Markup Language exchanges authentication and authorization assertions between identity and service providers.

MEMORY CUE

Security Assertion Markup Language exchanges authentication and authorization assertions between identity and service providers.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

QUESTION 396 | DNS SINKHOLE

FOUNDATION

A security team wants known malicious domains to resolve to a controlled internal address instead of their real C2 servers. Which control is this?

- A. Load balancing
- B. ARP poisoning
- C. DHCP relay
- D. DNS sinkhole

CORRECT ANSWER: D - DNS sinkhole

WHY: A DNS sinkhole redirects known-malicious domain resolution to a controlled destination to block or observe connections.

MEMORY CUE

Sinkhole malicious DNS to a safe controlled host.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
09:14:02	WS-17	resolver	aGVsbG8u...
09:14:03	WS-17	resolver	bG9uZy5x...
09:14:04	WS-17	resolver	NXDOMAIN

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 397-398

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 397 | OAUTH

FOUNDATION

OAuth is primarily associated with:

- A. Delegated authorization
- B. Password hashing
- C. Disk encryption
- D. Packet routing

CORRECT ANSWER: A - Delegated authorization

WHY: OAuth lets applications obtain limited access to resources without requiring users to hand over their passwords.

MEMORY CUE

OAuth lets applications obtain limited access to resources without requiring users to hand over their passwords.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

QUESTION 398 | INCIDENT PREPARATION

FOUNDATION

Which incident-response phase includes establishing playbooks, contacts, tools, logging, and communication procedures before an incident occurs?

- A. Lessons learned only
- B. Preparation
- C. Eradication
- D. Recovery

CORRECT ANSWER: B - Preparation

WHY: Preparation builds the capabilities and procedures needed to respond effectively before incidents happen.

MEMORY CUE

Prepare before the incident.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 399-400

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 399 | SSH

FOUNDATION

Which protocol should administrators use instead of Telnet when remotely managing a Linux server?

- A. SNMPv1
- B. HTTP
- C. SSH**
- D. FTP

CORRECT ANSWER: C - SSH

WHY: SSH encrypts administrative sessions, while Telnet sends information without comparable transport protection.

MEMORY CUE

SSH encrypts administrative sessions, while Telnet sends information without comparable transport protection.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 400 | INCIDENT IDENTIFICATION

FOUNDATION

A SOC correlates alerts, confirms malicious activity, and determines that an incident is actually occurring. Which response activity is being performed?

- A. Eradication
- B. Recovery
- C. Business continuity

D. Detection and analysis / identification

CORRECT ANSWER: D - Detection and analysis / identification

WHY: Identification and analysis determine whether an event is a security incident and establish scope and severity.

MEMORY CUE

Confirm and understand the incident.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 401-402

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 401 | NAC

FOUNDATION

A NAC solution discovers that a connecting laptop has an outdated antivirus product. What action can NAC take?

A. Place the system in a remediation network

B. Remove encryption from the network

C. Automatically destroy the laptop

D. Change the system's motherboard

CORRECT ANSWER: A - Place the system in a remediation network

WHY: Network Access Control can quarantine noncompliant systems until security requirements are satisfied.

MEMORY CUE

Network Access Control can quarantine noncompliant systems until security requirements are satisfied.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 402 | INCIDENT CONTAINMENT

FOUNDATION

A compromised endpoint is isolated from the network to stop lateral movement while preserving evidence. Which response phase is this?

A. Preparation

B. Containment

C. Lessons learned

D. Recovery

CORRECT ANSWER: B - Containment

WHY: Containment limits spread and damage after an incident has been identified.

MEMORY CUE

Containment = stop the bleeding.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 403-404

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 403 | SPF

FOUNDATION

Which email security mechanism allows a domain owner to specify which systems are authorized to send mail for the domain?

- A. NTP
- B. DHCP
- C. SPF
- D. SSH

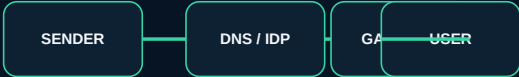
CORRECT ANSWER: C - SPF

WHY: Sender Policy Framework publishes authorized mail-sending infrastructure through DNS.

MEMORY CUE

Sender Policy Framework publishes authorized mail-sending infrastructure through DNS.

Email / Federation Trust



SPF=PASS DKIM=PASS DMARC=PASS ALIGN=TRUE

Illustrative study visual - not live production telemetry

QUESTION 404 | INCIDENT ERADICATION

FOUNDATION

Responders remove persistence mechanisms, delete malicious scheduled tasks, and patch the exploited vulnerability. Which phase is this?

- A. Recovery only
- B. Detection
- C. Preparation
- D. Eradication

CORRECT ANSWER: D - Eradication

WHY: Eradication removes the attacker, malware, persistence, and root cause from the environment.

MEMORY CUE

Eradication = remove threat and persistence.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 405-406

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 405 | DKIM

FOUNDATION

Which email-security technology provides cryptographic authentication of selected message headers and message content?

A. DKIM

B. ARP

C. VLAN

D. NAT

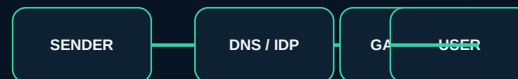
CORRECT ANSWER: A - DKIM

WHY: DomainKeys Identified Mail attaches a cryptographic signature that receiving mail systems can verify.

MEMORY CUE

DomainKeys Identified Mail attaches a cryptographic signature that receiving mail systems can verify.

Email / Federation Trust



SPF=PASS DKIM=PASS DMARC=PASS ALIGN=TRUE

Illustrative study visual - not live production telemetry

QUESTION 406 | LESSONS LEARNED

FOUNDATION

After service is restored, the response team documents root cause, timeline, control failures, and improvements. Which activity is this?

A. Authentication

B. Lessons learned / post-incident review

C. Initial access

D. Containment

CORRECT ANSWER: B - Lessons learned / post-incident review

WHY: Post-incident review captures lessons, identifies improvements, and updates controls and procedures.

MEMORY CUE

Afterward: learn, document, improve.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 407-408

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 407 | DMARC

FOUNDATION

DMARC primarily builds on which two email-authentication technologies?

- A. SFTP and SNMP
- B. DNSSEC and DHCP

C. SPF and DKIM

- D. SSH and TLS

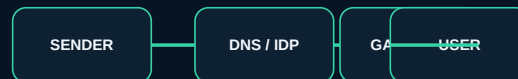
CORRECT ANSWER: C - SPF and DKIM

WHY: DMARC uses SPF/DKIM authentication and domain alignment to establish email policy. Memorize together: SPF + DKIM + DMARC

MEMORY CUE

DMARC uses SPF/DKIM authentication and domain alignment to establish email policy. Memorize together: SPF + DKIM + DMARC

Email / Federation Trust



SPF=PASS DKIM=PASS DMARC=PASS ALIGN=TRUE

Illustrative study visual - not live production telemetry

QUESTION 408 | ORDER OF VOLATILITY

FOUNDATION

During live forensics, which evidence should generally be captured before powering off a compromised workstation?

- A. Cold-site inventory
- B. Archived tape backups
- C. Printed policies

D. Volatile memory (RAM)

CORRECT ANSWER: D - Volatile memory (RAM)

WHY: Volatile data such as RAM can be lost when power is removed and should be captured early when appropriate.

MEMORY CUE

Most volatile evidence first.

Forensic Evidence Workflow



SHA256=9f2a... custodian=ML time=10:42:19Z
write_blocker=ON evidence_id=E-2026-014

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 409-410

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 409 | RANSOMWARE CONTAINMENT

FOUNDATION

An incident-response team confirms that a workstation is communicating with a ransomware C2 server. What is the MOST appropriate immediate containment action?

A. Isolate the endpoint from the network

- B. Inform the attacker
- C. Delete every corporate backup
- D. Disable logging

CORRECT ANSWER: A - Isolate the endpoint from the network

WHY: Isolation limits C2 traffic, propagation, lateral movement, and additional attacker activity.

MEMORY CUE

Isolation limits C2 traffic, propagation, lateral movement, and additional attacker activity.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 410 | FORENSIC IMAGING

FOUNDATION

An investigator needs a bit-for-bit copy of a suspect drive for examination while preserving the original. What should be created?

- A. Token
- B. Forensic image
- C. Data mask
- D. Incremental backup only

CORRECT ANSWER: B - Forensic image

WHY: A forensic image is a sector-level duplicate used for analysis while the original evidence is preserved.

MEMORY CUE

Analyze the forensic copy, preserve original evidence.

Forensic Evidence Workflow



SHA256=9f2a... custodian=ML time=10:42:19Z
write_blocker=ON evidence_id=E-2026-014

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 411-412

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 411 | RECOVERY

FOUNDATION

After containment and eradication, which incident-response activity restores affected systems to normal business operation?

- A. Reconnaissance
- B. Preparation
- C. Recovery
- D. Detection

CORRECT ANSWER: C - Recovery

WHY: Recovery returns systems and services to normal operation and verifies that they remain secure.

MEMORY CUE

Recovery returns systems and services to normal operation and verifies that they remain secure.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 412 | WRITE BLOCKER

FOUNDATION

Which device or capability is used to prevent accidental modification of a storage device while forensic data is being acquired?

- A. Load balancer
- B. NAC
- C. HSM
- D. Write blocker

CORRECT ANSWER: D - Write blocker

WHY: A write blocker permits read access while preventing writes that could alter evidence.

MEMORY CUE

Write blocker protects source evidence from modification.

Forensic Evidence Workflow



SHA256=9f2a... custodian=ML time=10:42:19Z
write_blocker=0N evidence_id=E-2026-014

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 413-414

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 413 | CHAIN OF CUSTODY

FOUNDATION

Why is maintaining chain of custody important when collecting forensic evidence?

A. It proves who handled evidence and helps demonstrate evidence integrity

B. It encrypts the entire network

C. It automatically proves the suspect is guilty

D. It eliminates the need for documentation

CORRECT ANSWER: A - It proves who handled evidence and helps demonstrate evidence integrity

WHY: demonstrate evidence integrity Chain-of-custody documentation records evidence collection, transfer, storage, examination, and handling.

MEMORY CUE

demonstrate evidence integrity Chain-of-custody documentation records evidence collection, transfer, storage, examination, and handling.

Forensic Evidence Workflow

COLLECT

HASH

PRESERVE

ANALYZE

REPORT

```
SHA256=9f2a...  custodian=ML  time=10:42:19Z
write_blocker=ON  evidence_id=E-2026-014
```

Illustrative study visual - not live production telemetry

QUESTION 414 | EVIDENCE HASH

FOUNDATION

Investigators calculate SHA-256 values before and after copying evidence. What are the hashes primarily used to demonstrate?

A. Data confidentiality

B. Evidence integrity

C. User authorization

D. Network availability

CORRECT ANSWER: B - Evidence integrity

WHY: Matching cryptographic hashes help show that evidence has not changed during handling or acquisition.

MEMORY CUE

Hash before/after to verify unchanged evidence.

Cryptography / Trust

DATA

HASH / KEY

VERIFY

```
RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 415-416

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 415 | LEGAL HOLD

FOUNDATION

Legal counsel instructs IT not to delete email or files related to pending litigation even if normal retention periods expire. What process is this?

- A. Key rotation
- B. Network segmentation
- C. Legal hold
- D. Data masking

CORRECT ANSWER: C - Legal hold

WHY: A legal hold suspends normal deletion or destruction for information relevant to litigation or investigation.

MEMORY CUE
Legal hold overrides normal deletion schedules.

Forensic Evidence Workflow



SHA256=9f2a... custodian=ML time=10:42:19Z
write_blocker=ON evidence_id=E-2026-014

Illustrative study visual - not live production telemetry

QUESTION 416 | INDICATOR OF COMPROMISE

FOUNDATION

A known malicious file hash and C2 domain are distributed to analysts for hunting. What are these artifacts?

- A. Service-level objectives
- B. Data owners
- C. Authentication factors
- D. Indicators of compromise (IOCs)

CORRECT ANSWER: D - Indicators of compromise (IOCs)

WHY: IOCs are observable artifacts associated with malicious activity, such as hashes, domains, IPs, or filenames.

MEMORY CUE
IOC = observable artifact linked to compromise.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 417-418

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 417 | INDICATOR OF ATTACK

FOUNDATION

A detection focuses on behavior such as credential dumping followed by remote service creation rather than a fixed file hash. What is this behavioral evidence called?

A. Indicator of attack (IOA)

B. RPO

C. Cold-site metric

D. Data classification

CORRECT ANSWER: A - Indicator of attack (IOA)

WHY: IOAs focus on adversary behavior or intent rather than only static artifacts.

MEMORY CUE

IOA = malicious behavior pattern.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 418 | HUNT HYPOTHESIS

FOUNDATION

A threat hunter starts with the statement, "If an attacker is using DNS for C2, affected hosts will show long high-entropy subdomains and unusual query volume." What is this statement?

A. SLA

B. Hunt hypothesis

C. Access-control list

D. Certificate chain

CORRECT ANSWER: B - Hunt hypothesis

WHY: A hunt hypothesis is a testable idea that guides proactive analysis of telemetry.

MEMORY CUE

Hypothesis = testable threat-hunting proposition.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 419-420

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 419 | BEHAVIORAL BASELINE

FOUNDATION

An analyst compares today's outbound traffic to a 30-day profile to identify systems with unusually high transfer volume. What technique is being used?

A. Cold-site recovery

B. Tokenization

C. Behavioral baselining / anomaly detection

D. Digital signing

CORRECT ANSWER: C - Behavioral baselining / anomaly detection

WHY: Baselining establishes normal behavior so meaningful deviations can be identified.

MEMORY CUE

Know normal to find abnormal.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 420 | CVSS

FOUNDATION

Which scoring system is commonly used to express the technical severity characteristics of a vulnerability?

A. SLA

B. RPO

C. SPF

D. CVSS

CORRECT ANSWER: D - CVSS

WHY: The Common Vulnerability Scoring System provides standardized severity metrics for vulnerabilities.

MEMORY CUE

CVSS = vulnerability severity score.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 421-422

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 421 | RISK-BASED EXCEPTION

FOUNDATION

A critical server cannot be patched before quarter-end because the vendor application would fail. Management formally approves temporary network restrictions and a future patch date. What should this be documented as?

- A. Risk exception
- B. Data classification
- C. Password spray
- D. DNS sinkhole

CORRECT ANSWER: A - Risk exception

WHY: A risk exception documents temporary acceptance or alternate treatment when a required control cannot be implemented as scheduled.

MEMORY CUE

Exception = documented temporary deviation with risk treatment.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 422 | PATCH WINDOW

FOUNDATION

A security team schedules operating-system updates for Sunday at 02:00 when business impact is lowest. What operational concept is this?

- A. Federation
- B. Maintenance / patch window
- C. Key escrow
- D. RPO

CORRECT ANSWER: B - Maintenance / patch window

WHY: A maintenance window is an approved period for changes such as patching with controlled operational impact.

MEMORY CUE

Patch windows manage change timing and impact.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 423-424

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 423 | APPLICATION ALLOWLISTING

FOUNDATION

An endpoint is configured so only software approved by the organization may execute. What control is being used?

- A. Network address translation
- B. Password spraying
- C. Application allowlisting
- D. Data masking

CORRECT ANSWER: C - Application allowlisting

WHY: Application allowlisting blocks unapproved executables by permitting only known authorized software.

MEMORY CUE
Allowlisting = only approved code runs.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 424 | PRIVILEGED ACCESS MANAGEMENT

FOUNDATION

An organization stores administrator credentials in a vault, rotates them, records privileged sessions, and requires approval for checkout. What solution category BEST fits?

- A. DLP
- B. NAC
- C. WAF
- D. PAM

CORRECT ANSWER: D - PAM

WHY: Privileged Access Management secures, governs, and monitors high-privilege accounts and credentials.

MEMORY CUE
PAM = vault + control + monitor privileged access.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FID02
id=marc.l

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 425-426

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 425 | JUST-IN-TIME ACCESS

FOUNDATION

An administrator receives elevated privileges for 30 minutes to perform a specific task, after which the privilege is automatically removed. What model is this?

- A. Just-in-time (JIT) access
- B. Shared administrator account
- C. Open access
- D. Permanent standing privilege

CORRECT ANSWER: A - Just-in-time (JIT) access

WHY: JIT access grants privileged rights only when needed and for a limited duration.

MEMORY CUE
JIT reduces standing privilege.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 426 | SINGLE SIGN-ON

FOUNDATION

A user authenticates once to an enterprise identity provider and then accesses several approved applications without entering credentials again. What capability is this?

- A. NAT
- B. Single sign-on (SSO)
- C. Password spraying
- D. Key escrow

CORRECT ANSWER: B - Single sign-on (SSO)

WHY: SSO allows one authentication event to establish access to multiple integrated applications.

MEMORY CUE
SSO = authenticate once, access multiple apps.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 427-428

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 427 | OPENID CONNECT

FOUNDATION

A web application needs an identity layer that provides user authentication information on top of OAuth 2.0. Which protocol BEST fits?

- A. SNMPv1
- B. TFTP
- C. OpenID Connect (OIDC)
- D. ARP

CORRECT ANSWER: C - OpenID Connect (OIDC)

WHY: OIDC adds an authentication and identity layer to OAuth 2.0 using ID tokens and standardized claims.

MEMORY CUE

OIDC = authentication/identity on OAuth 2.0.

Identity / Access Flow



```
audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
```

Illustrative study visual - not live production telemetry

QUESTION 428 | LDAP

FOUNDATION

Which protocol is commonly used to query and manage directory information such as users, groups, and organizational objects?

- A. TFTP
- B. NTP
- C. IPsec
- D. LDAP

CORRECT ANSWER: D - LDAP

WHY: LDAP is a directory-access protocol used to query and manage directory services.

MEMORY CUE

LDAP = directory lookup/management.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 429-430

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 429 | RADIUS

FOUNDATION

A network device sends centralized authentication requests for VPN users to an AAA service commonly using UDP. Which protocol is MOST likely?

A. RADIUS

B. NFS

C. SMTP

D. TACACS+

CORRECT ANSWER: A - RADIUS

WHY: RADIUS is widely used for centralized network access AAA, including VPN and wireless authentication.

MEMORY CUE

RADIUS = common network-access AAA.

Identity / Access Flow



```
audit=logged  
decision=ALLOW  
factor=FIDO2  
id=marc.l
```

Illustrative study visual - not live production telemetry

QUESTION 430 | TACACS+

FOUNDATION

A company wants centralized AAA for network-device administrators with separation of authentication, authorization, and accounting and TCP transport. Which protocol BEST fits?

A. DNSSEC

B. TACACS+

C. RADIUS

D. SFTP

CORRECT ANSWER: B - TACACS+

WHY: TACACS+ is commonly used for administrative AAA on network devices and uses TCP.

MEMORY CUE

TACACS+ = network-device admin AAA.

Identity / Access Flow



```
audit=logged  
decision=ALLOW  
factor=FIDO2  
id=marc.l
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 431-432

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 431 | PASSWORDLESS AUTHENTICATION

FOUNDATION

A user signs in with a FIDO2 security key using public-key cryptography and no reusable password. What authentication approach is this?

- A. Basic HTTP authentication
- B. Password spraying
- C. Passwordless authentication**
- D. Shared-secret-only authentication

CORRECT ANSWER: C - Passwordless authentication

WHY: FIDO2/WebAuthn can provide phishing-resistant passwordless authentication using public-key credentials.

MEMORY CUE

Passwordless = no reusable shared password.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 432 | OFFBOARDING

FOUNDATION

An employee leaves the organization at 5:00 PM. Which identity-management action should occur promptly as part of offboarding?

- A. Delete all security logs
- B. Share the account with the replacement
- C. Increase the user's privileges
- D. Disable or revoke the user's access**

CORRECT ANSWER: D - Disable or revoke the user's access

WHY: Offboarding should promptly remove or disable access to prevent former personnel from using organizational resources.

MEMORY CUE

Offboarding = revoke access quickly.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 433-434

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 433 | CERTIFICATE-BASED AUTHENTICATION

FOUNDATION

A managed laptop proves its device identity to a VPN gateway using a certificate signed by the enterprise CA. What authentication method is being used?

- A. Certificate-based authentication
- B. SYN cookies
- C. Password spraying
- D. Data masking

CORRECT ANSWER: A - Certificate-based authentication

WHY: Certificates can serve as authentication factors when the relying system trusts the issuing CA and validates the certificate.

MEMORY CUE
Trusted device certificate can authenticate the endpoint.

 Identity / Access Flow

```
audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
```

Illustrative study visual - not live production telemetry

QUESTION 434 | SECURE BASELINE

FOUNDATION

An enterprise applies a standardized hardened Windows configuration to every new workstation before deployment. What operational practice is this?

- A. DNS poisoning
- B. Secure configuration baseline
- C. Credential stuffing
- D. Tokenization

CORRECT ANSWER: B - Secure configuration baseline

WHY: A secure baseline defines approved hardened settings that are consistently applied and maintained across systems.

MEMORY CUE
Baseline = standardized secure configuration.

 Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 435-436

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 435 | AUTHENTICATION LOGS

APPLIED

A SOC analyst needs to review failed and successful sign-in events for a privileged account. What telemetry is MOST relevant?

- A. UPS logs
- B. File compression logs
- C. Authentication logs**
- D. Printer logs

CORRECT ANSWER: C - Authentication logs

WHY: Authentication logs record sign-in attempts, results, identity details, and often source systems or IP addresses.

MEMORY CUE

Auth logs = sign-in evidence.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 436 | SPF

APPLIED

During day-to-day SOC operations, which email security mechanism allows a domain owner to specify which systems are authorized to send mail for the domain?

- A. SSH
- B. DHCP
- C. NTP
- D. SPF**

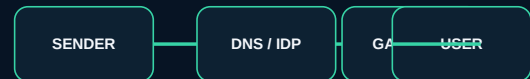
CORRECT ANSWER: D - SPF

WHY: Sender Policy Framework publishes authorized mail-sending infrastructure through DNS.

MEMORY CUE

Sender Policy Framework publishes authorized mail-sending infrastructure through DNS.

Email / Federation Trust



```

SPF=PASS  DKIM=PASS  DMARC=PASS  ALIGN=TRUE
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 437-438

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 437 | PACKET CAPTURE

APPLIED

An analyst must inspect TCP flags and application payload bytes for a suspicious connection. What evidence source is required?

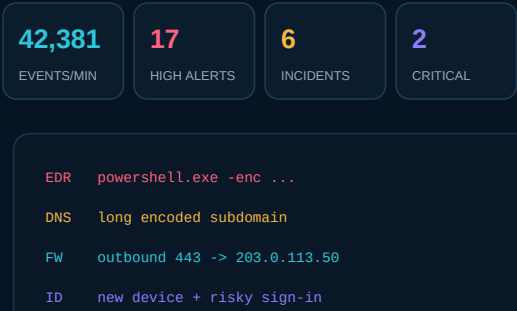
- A. Packet capture (PCAP)
- B. NetFlow only
- C. DHCP lease table
- D. Asset inventory

CORRECT ANSWER: A - Packet capture (PCAP)

WHY: PCAP preserves packet-level headers and payload data needed for detailed protocol analysis.

MEMORY CUE
PCAP = exact packets.

SOC Correlation Dashboard



Illustrative study visual - not live production telemetry

QUESTION 438 | MALWARE SANDBOX

APPLIED

In a separate enterprise scenario, an analyst wants to execute a suspicious attachment in a controlled environment and observe child processes, registry changes, and network behavior. What should be used?

- A. Production domain controller
- B. Malware sandbox
- C. Public file share
- D. Unfiltered user workstation

CORRECT ANSWER: B - Malware sandbox

WHY: A sandbox safely executes suspicious code in an isolated environment for behavioral analysis.

MEMORY CUE
Sandbox = controlled detonation and observation.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 439

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | EMAIL GATEWAY LOGS

In a separate enterprise scenario, an analyst needs to determine whether a phishing message was delivered, quarantined, or blocked and which recipients were targeted. Which telemetry is BEST?

- A. BIOS logs
- B. UPS logs
- C. Email gateway logs
- D. DHCP logs

SIMULATED EVIDENCE / ARCHITECTURE PANEL

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in

CORRECT ANSWER: C - Email gateway logs

RATIONALE

Email gateway logs record message routing, sender/recipient, reputation, authentication results, and disposition.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 440-441

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 440 | IDS

APPLIED

What technology primarily detects suspicious network activity and generates alerts without necessarily blocking the traffic?

- A. HSM
- B. NAC
- C. IPS

D. IDS

CORRECT ANSWER: D - IDS

WHY: An intrusion detection system monitors traffic and alerts on suspicious or known-bad behavior.

MEMORY CUE

IDS = detect and alert.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

EDR powershell.exe -enc ...

DNS long encoded subdomain

FW outbound 443 -> 203.0.113.50

ID new device + risky sign-in

Illustrative study visual - not live production telemetry

QUESTION 441 | NETFLOW

APPLIED

In a separate enterprise scenario, a network team wants a compact record of who communicated with whom, over which ports, and how many bytes were transferred without storing full packet payloads. What data source BEST fits?

A. NetFlow / flow records

- B. Sysmon registry events
- C. Full PCAP only
- D. BIOS audit logs

CORRECT ANSWER: A - NetFlow / flow records

WHY: Flow records summarize network conversations using metadata such as source, destination, ports, duration, and byte counts.

MEMORY CUE

Flow = conversation metadata, not full payload.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

EDR powershell.exe -enc ...

DNS long encoded subdomain

FW outbound 443 -> 203.0.113.50

ID new device + risky sign-in

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 442-443

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 442 | SYSMON

APPLIED

During day-to-day SOC operations, what Windows log source is particularly useful for recording detailed process creation when properly configured?

- A. DNS root hints
- B. Sysmon**
- C. SNMP traps
- D. DHCP only

CORRECT ANSWER: B - Sysmon

WHY: Sysmon provides detailed endpoint telemetry such as process creation, network connections, registry activity, image loading, and file events.

MEMORY CUE

Sysmon provides detailed endpoint telemetry such as process creation, network connections, registry activity, image loading, and file events.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 443 | SIEM

APPLIED

During day-to-day SOC operations, which technology aggregates security logs from multiple systems and performs correlation and alerting?

- A. RAID
- B. UPS
- C. SIEM**
- D. HSM

CORRECT ANSWER: C - SIEM

WHY: A Security Information and Event Management platform centralizes security telemetry for search, correlation, detection, investigation, and alerting.

MEMORY CUE

A Security Information and Event Management platform centralizes security telemetry for search, correlation, detection, investigation...

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 444-445

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 444 | SOAR

APPLIED

During day-to-day SOC operations, an enterprise SOC wants to automatically disable a malicious account, isolate its endpoint, and open a ticket after a confirmed alert. Which platform is MOST applicable?

- A. UPS
- B. RAID controller
- C. HSM

D. SOAR

CORRECT ANSWER: D - SOAR

WHY: Security Orchestration, Automation, and Response platforms automate repeatable incident-response workflows.

MEMORY CUE

Security Orchestration, Automation, and Response platforms automate repeatable incident-response workflows.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...
DNS  long encoded subdomain
FW   outbound 443 -> 203.0.113.50
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 445 | LESSONS LEARNED

APPLIED

In a separate enterprise scenario, after service is restored, the response team documents root cause, timeline, control failures, and improvements. Which activity is this?

A. Lessons learned / post-incident review

- B. Initial access
- C. Authentication
- D. Containment

CORRECT ANSWER: A - Lessons learned / post-incident review

WHY: Post-incident review captures lessons, identifies improvements, and updates controls and procedures.

MEMORY CUE

Afterward: learn, document, improve.

Identity / Access Flow



```
audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 446-447

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 446 | XDR

APPLIED

During day-to-day SOC operations, a multinational organization wants to combine telemetry and response capabilities across endpoints, identities, cloud workloads, and network security products. Which security technology BEST fits?

- A. NAT
- B. XDR
- C. FTP
- D. SAN

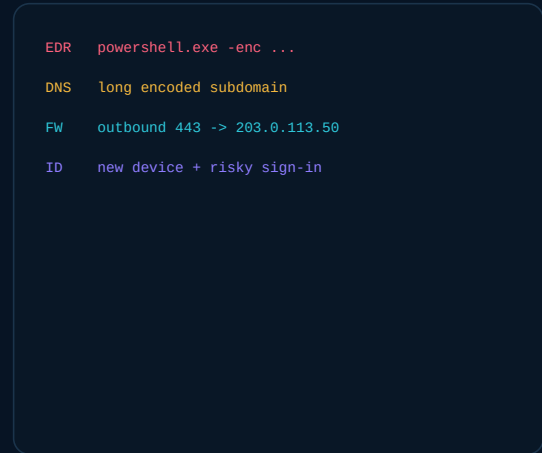
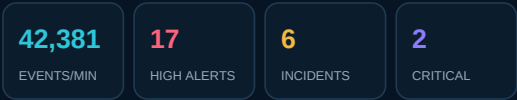
CORRECT ANSWER: B - XDR

WHY: Extended Detection and Response correlates information across multiple security domains.

MEMORY CUE

Extended Detection and Response correlates information across multiple security domains.

SOC Correlation Dashboard



Illustrative study visual - not live production telemetry

QUESTION 447 | REMEDIATION VALIDATION

APPLIED

In a separate enterprise scenario, after applying a security patch, what should the organization do to verify remediation?

- A. Assume the vulnerability is fixed
- B. Disable monitoring
- C. Rescan or validate the affected system
- D. Delete previous scan results

CORRECT ANSWER: C - Rescan or validate the affected system

WHY: Security teams should verify that remediation actually eliminated the vulnerability.

MEMORY CUE

Security teams should verify that remediation actually eliminated the vulnerability.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 448

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | INCIDENT ERADICATION

In a separate enterprise scenario, responders remove persistence mechanisms, delete malicious scheduled tasks, and patch the exploited vulnerability. Which phase is this?

- A. Recovery only
- B. Preparation
- C. Detection
- D. Eradication

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

CORRECT ANSWER: D - Eradication

RATIONALE Eradication removes the attacker, malware, persistence, and root cause from the environment.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 449-450

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 449 | PRIVILEGED ACCOUNT SEPARATION

APPLIED

During day-to-day SOC operations, an administrator uses a normal account for email and a separate privileged account for server administration. What security practice is demonstrated?

A. Privileged account separation

- B. Federation
- C. Data masking
- D. Password spraying

CORRECT ANSWER: A - Privileged account separation

WHY: Administrative credentials should not be exposed during everyday activities such as browsing or email.

MEMORY CUE

Administrative credentials should not be exposed during everyday activities such as browsing or email.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 450 | CERTIFICATE-BASED AUTHENTICATION

APPLIED

During day-to-day SOC operations, a managed laptop proves its device identity to a VPN gateway using a certificate signed by the enterprise CA. What authentication method is being used?

- A. Password spraying
- B. Certificate-based authentication**
- C. SYN cookies
- D. Data masking

CORRECT ANSWER: B - Certificate-based authentication

WHY: Certificates can serve as authentication factors when the relying system trusts the issuing CA and validates the certificate.

MEMORY CUE

Trusted device certificate can authenticate the endpoint.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 451-452

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 451 | SUSPICIOUS POWERSHELL

APPLIED

During day-to-day SOC operations, a SOC receives an alert that powershell.exe launched with an encoded command and then connected to an unfamiliar IP. What should the analyst do FIRST?

- A. Reimage the entire enterprise
- B. Delete PowerShell

C. Investigate the process and related telemetry

- D. Disable the SIEM

CORRECT ANSWER: C - Investigate the process and related telemetry

WHY: telemetry The analyst first needs to establish context and determine whether the behavior is malicious before taking disproportionate action. Useful evidence could include: - Parent process - Command line - User account - Destination IP - DNS activity -

MEMORY CUE

telemetry The analyst first needs to establish context and determine whether the behavior is malicious before taking disproportionat...

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 452 | PROXY LOGS

APPLIED

An analyst needs to determine which URLs an internal workstation requested through the organization's web gateway. What log source is MOST useful?

- A. BIOS logs
- B. UPS logs
- C. Printer logs

D. Proxy logs

CORRECT ANSWER: D - Proxy logs

WHY: Proxy logs record web requests such as destination domains, URLs, users, methods, and actions.

MEMORY CUE

Proxy logs = web browsing/request telemetry.

SOC Correlation Dashboard

42,381	17	6	2
EVENTS/MIN	HIGH ALERTS	INCIDENTS	CRITICAL

EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 453-454

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 453 | JUST-IN-TIME ACCESS

APPLIED

During day-to-day SOC operations, an administrator receives elevated privileges for 30 minutes to perform a specific task, after which the privilege is automatically removed. What model is this?

- A. Just-in-time (JIT) access
- B. Permanent standing privilege
- C. Shared administrator account
- D. Open access

CORRECT ANSWER: A - Just-in-time (JIT) access

WHY: JIT access grants privileged rights only when needed and for a limited duration.

MEMORY CUE
JIT reduces standing privilege.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 454 | OPENID CONNECT

APPLIED

During day-to-day SOC operations, a web application needs an identity layer that provides user authentication information on top of OAuth 2.0. Which protocol BEST fits?

- A. ARP
- B. OpenID Connect (OIDC)
- C. SNMPv1
- D. TFTP

CORRECT ANSWER: B - OpenID Connect (OIDC)

WHY: OIDC adds an authentication and identity layer to OAuth 2.0 using ID tokens and standardized claims.

MEMORY CUE
OIDC = authentication/identity on OAuth 2.0.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 455-456

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 455 | RANSOMWARE CONTAINMENT

APPLIED

During day-to-day SOC operations, an incident-response team confirms that a workstation is communicating with a ransomware C2 server. What is the MOST appropriate immediate containment action?

- A. Delete every corporate backup
- B. Inform the attacker
- C. Isolate the endpoint from the network
- D. Disable logging

CORRECT ANSWER: C - Isolate the endpoint from the network

WHY: Isolation limits C2 traffic, propagation, lateral movement, and additional attacker activity.

MEMORY CUE

Isolation limits C2 traffic, propagation, lateral movement, and additional attacker activity.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 456 | VULNERABILITY PRIORITIZATION

APPLIED

During day-to-day SOC operations, a vulnerability scanner reports a critical vulnerability on an internet-facing server. What should security personnel consider when prioritizing remediation? intelligence

- A. User preference only
- B. Server color and physical appearance
- C. CVSS alone and nothing else
- D. Severity, exposure, exploitability, asset importance, and threat

CORRECT ANSWER: D - Severity, exposure, exploitability, asset importance, and threat

WHY: importance, and threat intelligence Real risk depends on both vulnerability severity and organizational context.

MEMORY CUE

importance, and threat intelligence Real risk depends on both vulnerability severity and organizational context.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 457

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | DHCP LOGS

In a separate enterprise scenario, investigators have an IP address from an alert and need to determine which endpoint had that address at 10:15 AM. Which log source is MOST useful?

- A. DHCP logs
- B. Certificate transparency logs
- C. Email gateway logs
- D. WAF logs

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.

CORRECT ANSWER: A - DHCP logs

RATIONALE DHCP logs map leased IP addresses to client identifiers over time.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 458-459

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 458 | CLOUD AUDIT LOGS

APPLIED

In a separate enterprise scenario, a cloud administrator suspects that an access policy was changed through the provider control plane. Which log source should be reviewed?

A. Endpoint temperature logs

B. Cloud audit / activity logs

C. Printer logs

D. Switch CAM table only

CORRECT ANSWER: B - Cloud audit / activity logs

WHY: Cloud audit logs record administrative and API actions performed against cloud resources and control-plane services.

MEMORY CUE

Cloud audit logs = who changed cloud configuration.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 459 | FIREWALL LOGS

APPLIED

During day-to-day SOC operations, which log source would **BEST** identify outbound connections permitted or denied at the network perimeter?

A. Badge-reader logs

B. Printer logs

C. Firewall logs

D. BIOS logs

CORRECT ANSWER: C - Firewall logs

WHY: Firewall logs commonly contain source/destination IPs, ports, protocols, actions, policies, and connection information.

MEMORY CUE

Firewall logs commonly contain source/destination IPs, ports, protocols, actions, policies, and connection information.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 460-461

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 460 | SSH

APPLIED

During day-to-day SOC operations, what protocol should administrators use instead of Telnet when remotely managing a Linux server?

- A. HTTP
- B. FTP
- C. SNMPv1

D. SSH

CORRECT ANSWER: D - SSH

WHY: SSH encrypts administrative sessions, while Telnet sends information without comparable transport protection.

MEMORY CUE

SSH encrypts administrative sessions, while Telnet sends information without comparable transport protection.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 461 | SECURE BASELINE

APPLIED

In a separate enterprise scenario, an enterprise applies a standardized hardened Windows configuration to every new workstation before deployment. What operational practice is this?

- A. Secure configuration baseline
- B. Tokenization
- C. DNS poisoning
- D. Credential stuffing

CORRECT ANSWER: A - Secure configuration baseline

WHY: A secure baseline defines approved hardened settings that are consistently applied and maintained across systems.

MEMORY CUE

Baseline = standardized secure configuration.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 462-463

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 462 | SINGLE SIGN-ON

APPLIED

In a separate enterprise scenario, a user authenticates once to an enterprise identity provider and then accesses several approved applications without entering credentials again. What capability is this?

- A. Key escrow
- B. Single sign-on (SSO)
- C. NAT
- D. Password spraying

CORRECT ANSWER: B - Single sign-on (SSO)

WHY: SSO allows one authentication event to establish access to multiple integrated applications.

MEMORY CUE
SSO = authenticate once, access multiple apps.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 463 | PRIVILEGED ACCESS MANAGEMENT

APPLIED

In a separate enterprise scenario, an organization stores administrator credentials in a vault, rotates them, records privileged sessions, and requires approval for checkout. What solution category BEST fits?

- A. DLP
- B. WAF
- C. PAM
- D. NAC

CORRECT ANSWER: C - PAM

WHY: Privileged Access Management secures, governs, and monitors high-privilege accounts and credentials.

MEMORY CUE
PAM = vault + control + monitor privileged access.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 464-465

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 464 | NETWORK ACCESS CONTROL

APPLIED

A laptop fails posture checks because its endpoint protection is disabled. Which security technology can quarantine the device before full network access is granted?

A. SIEM

B. RAID

C. HSM

D. NAC

CORRECT ANSWER: D - NAC

WHY: Network Access Control evaluates devices or identities and can restrict noncompliant systems to a remediation network.

MEMORY CUE

NAC = admission control and posture enforcement.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 465 | DMARC

APPLIED

During day-to-day SOC operations, dMARC primarily builds on which two email-authentication technologies?

A. SPF and DKIM

B. DNSSEC and DHCP

C. SFTP and SNMP

D. SSH and TLS

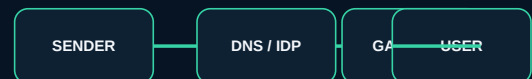
CORRECT ANSWER: A - SPF and DKIM

WHY: DMARC uses SPF/DKIM authentication and domain alignment to establish email policy. Memorize together: SPF + DKIM + DMARC

MEMORY CUE

DMARC uses SPF/DKIM authentication and domain alignment to establish email policy. Memorize together: SPF + DKIM + DMARC

Email / Federation Trust



SPF=PASS DKIM=PASS DMARC=PASS ALIGN=TRUE

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 466

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | APPLICATION ALLOWLISTING

During day-to-day SOC operations, an endpoint is configured so only software approved by the organization may execute. What control is being used?

- A. Password spraying
- B. Application allowlisting
- C. Network address translation
- D. Data masking

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

CORRECT ANSWER: B - Application allowlisting

RATIONALE Application allowlisting blocks unapproved executables by permitting only known authorized software.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 467-468

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 467 | OAUTH

APPLIED

During day-to-day SOC operations, oAuth is primarily associated with:

- A. Packet routing
- B. Disk encryption
- C. Delegated authorization
- D. Password hashing

CORRECT ANSWER: C - Delegated authorization

WHY: OAuth lets applications obtain limited access to resources without requiring users to hand over their passwords.

MEMORY CUE

OAuth lets applications obtain limited access to resources without requiring users to hand over their passwords.

Identity / Access Flow



```
audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
```

Illustrative study visual - not live production telemetry

QUESTION 468 | THREAT INTELLIGENCE

APPLIED

In a separate enterprise scenario, a SOC enriches an alert with reputation, malware-family, and observed-in-campaign information about an external IP. What capability is being used?

- A. RAID parity
- B. Load balancing
- C. Data masking
- D. Threat intelligence

CORRECT ANSWER: D - Threat intelligence

WHY: Threat intelligence supplies contextual information about adversaries, indicators, campaigns, and malicious infrastructure.

MEMORY CUE

Threat intel adds adversary context to telemetry.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 469-470

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 469 | HUNT HYPOTHESIS

APPLIED

In a separate enterprise scenario, a threat hunter starts with the statement, "If an attacker is using DNS for C2, affected hosts will show long high-entropy subdomains and unusual query volume." What is this statement?

- A. Hunt hypothesis
- B. Access-control list
- C. SLA
- D. Certificate chain

CORRECT ANSWER: A - Hunt hypothesis

WHY: A hunt hypothesis is a testable idea that guides proactive analysis of telemetry.

MEMORY CUE
Hypothesis = testable threat-hunting proposition.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 470 | RADIUS

APPLIED

During day-to-day SOC operations, a network device sends centralized authentication requests for VPN users to an AAA service commonly using UDP. What protocol is MOST likely?

- A. NFS
- B. RADIUS
- C. SMTP
- D. TACACS+

CORRECT ANSWER: B - RADIUS

WHY: RADIUS is widely used for centralized network access AAA, including VPN and wireless authentication.

MEMORY CUE
RADIUS = common network-access AAA.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 471-472

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 471 | INCIDENT IDENTIFICATION

APPLIED

An enterprise SOC correlates alerts, confirms malicious activity, and determines that an incident is actually occurring. Which response activity is being performed?

- A. Recovery
- B. Eradication

C. Detection and analysis / identification

- D. Business continuity

CORRECT ANSWER: C - Detection and analysis / identification

WHY: Identification and analysis determine whether an event is a security incident and establish scope and severity.

MEMORY CUE

Confirm and understand the incident.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 472 | EVIDENCE HASH

APPLIED

In a separate enterprise scenario, investigators calculate SHA-256 values before and after copying evidence. What are the hashes primarily used to demonstrate?

- A. Network availability
- B. Data confidentiality
- C. User authorization

D. Evidence integrity

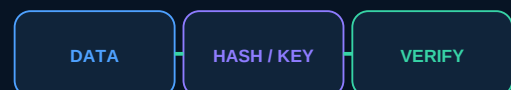
CORRECT ANSWER: D - Evidence integrity

WHY: Matching cryptographic hashes help show that evidence has not changed during handling or acquisition.

MEMORY CUE

Hash before/after to verify unchanged evidence.

Cryptography / Trust



RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 473-474

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 473 | OFFBOARDING

APPLIED

An employee leaves the organization at 5:00 PM. What identity-management action should occur promptly as part of offboarding?

A. Disable or revoke the user's access

- B. Delete all security logs
- C. Share the account with the replacement
- D. Increase the user's privileges

CORRECT ANSWER: A - Disable or revoke the user's access

WHY: Offboarding should promptly remove or disable access to prevent former personnel from using organizational resources.

MEMORY CUE

Offboarding = revoke access quickly.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

QUESTION 474 | TACACS+

APPLIED

In a separate enterprise scenario, a company wants centralized AAA for network-device administrators with separation of authentication, authorization, and accounting and TCP transport. Which protocol BEST fits?

- A. RADIUS
- B. TACACS+**
- C. DNSSEC
- D. SFTP

CORRECT ANSWER: B - TACACS+

WHY: TACACS+ is commonly used for administrative AAA on network devices and uses TCP.

MEMORY CUE

TACACS+ = network-device admin AAA.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 475

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | LEGAL HOLD

During day-to-day SOC operations, legal counsel instructs IT not to delete email or files related to pending litigation even if normal retention periods expire. What process is this?

- A. Network segmentation
- B. Data masking
- C. Legal hold
- D. Key rotation

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Forensic Evidence Workflow

COLLECT

HASH

PRESERVE

ANALYZE

REPORT

SHA256=9f2a... custodian=ML time=10:42:19Z
write_blocker=ON evidence_id=E-2026-014

CORRECT ANSWER: C - Legal hold

RATIONALE

A legal hold suspends normal deletion or destruction for information relevant to litigation or investigation.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 476-477

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 476 | WAF LOGS

APPLIED

A SOC analyst is investigating repeated SQL injection attempts against an internet-facing application. Which log source is most directly relevant?

- A. Badge logs
- B. DHCP logs
- C. UPS logs

D. WAF logs

CORRECT ANSWER: D - WAF logs

WHY: A web application firewall records and can block HTTP-layer attacks such as SQL injection and XSS.

MEMORY CUE

WAF logs = application-layer web attack telemetry.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 477 | EDR

APPLIED

During day-to-day SOC operations, what technology focuses on endpoint telemetry, behavioral detection, investigation, and response?

- A. EDR**
- B. VLAN
- C. RAID
- D. DNSSEC

CORRECT ANSWER: A - EDR

WHY: Endpoint Detection and Response provides visibility and response capabilities directly on endpoints. Examples include: - CrowdStrike Falcon - Microsoft Defender for Endpoint - SentinelOne

MEMORY CUE

Endpoint Detection and Response provides visibility and response capabilities directly on endpoints. Examples include: - CrowdStrike...

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 478-479

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 478 | FORENSIC IMAGING

APPLIED

In a separate enterprise scenario, an investigator needs a bit-for-bit copy of a suspect drive for examination while preserving the original. What should be created?

- A. Token
- B. Forensic image
- C. Data mask
- D. Incremental backup only

CORRECT ANSWER: B - Forensic image

WHY: A forensic image is a sector-level duplicate used for analysis while the original evidence is preserved.

MEMORY CUE
Analyze the forensic copy, preserve original evidence.

Forensic Evidence Workflow



SHA256=9f2a... custodian=ML time=10:42:19Z
write_blocker=ON evidence_id=E-2026-014

Illustrative study visual - not live production telemetry

QUESTION 479 | INCIDENT CONTAINMENT

APPLIED

A compromised endpoint is isolated from the network to stop lateral movement while preserving evidence. What response phase is this?

- A. Lessons learned
- B. Recovery
- C. Containment
- D. Preparation

CORRECT ANSWER: C - Containment

WHY: Containment limits spread and damage after an incident has been identified.

MEMORY CUE
Containment = stop the bleeding.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 480-481

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 480 | DKIM

APPLIED

During day-to-day SOC operations, what email-security technology provides cryptographic authentication of selected message headers and message content?

A. VLAN

B. NAT

C. ARP

D. DKIM

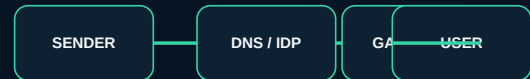
CORRECT ANSWER: D - DKIM

WHY: DomainKeys Identified Mail attaches a cryptographic signature that receiving mail systems can verify.

MEMORY CUE

DomainKeys Identified Mail attaches a cryptographic signature that receiving mail systems can verify.

Email / Federation Trust



SPF=PASS DKIM=PASS DMARC=PASS ALIGN=TRUE

Illustrative study visual - not live production telemetry

QUESTION 481 | SAML

APPLIED

During day-to-day SOC operations, which protocol is commonly used to provide web-based identity federation and enterprise SSO?

A. SAML

B. TFTP

C. ARP

D. Telnet

CORRECT ANSWER: A - SAML

WHY: Security Assertion Markup Language exchanges authentication and authorization assertions between identity and service providers.

MEMORY CUE

Security Assertion Markup Language exchanges authentication and authorization assertions between identity and service providers.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 482-483

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 482 | WEB APPLICATION FIREWALL

APPLIED

What control is specifically designed to inspect HTTP/S requests and protect web applications from attacks such as SQL injection and XSS?

- A. HSM
- B. WAF**
- C. UPS
- D. RADIUS

CORRECT ANSWER: B - WAF

WHY: A web application firewall filters application-layer web traffic and applies rules for common web attacks.

MEMORY CUE

WAF protects HTTP/S application traffic.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 483 | WIRESHARK

APPLIED

During day-to-day SOC operations, a SOC analyst needs to examine the exact packets exchanged between a compromised host and a suspected command-and-control server. Which tool is MOST appropriate?

- A. Group Policy Management
- B. Active Directory Users and Computers
- C. Wireshark**
- D. BitLocker

CORRECT ANSWER: C - Wireshark

WHY: Wireshark performs packet-level network protocol analysis.

MEMORY CUE

Wireshark performs packet-level network protocol analysis.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 484

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | PATCH WINDOW

An information-security team schedules operating-system updates for Sunday at 02:00 when business impact is lowest. What operational concept is this?

- A. Federation
- B. Key escrow
- C. RPO
- D. Maintenance / patch window

SIMULATED EVIDENCE / ARCHITECTURE PANEL

●●● Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

CORRECT ANSWER: D - Maintenance / patch window

RATIONALE A maintenance window is an approved period for changes such as patching with controlled operational impact.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 485-486

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 485 | CHAIN OF CUSTODY

APPLIED

During day-to-day SOC operations, why is maintaining chain of custody important when collecting forensic evidence?

A. It proves who handled evidence and helps demonstrate evidence integrity

B. It eliminates the need for documentation

C. It encrypts the entire network

D. It automatically proves the suspect is guilty

CORRECT ANSWER: A - It proves who handled evidence and helps demonstrate evidence integrity

WHY: demonstrate evidence integrity Chain-of-custody documentation records evidence collection, transfer, storage, examination, and handling.

MEMORY CUE

demonstrate evidence integrity Chain-of-custody documentation records evidence collection, transfer, storage, examination, and handling.

Forensic Evidence Workflow

COLLECT

HASH

PRESERVE

ANALYZE

REPORT

```
SHA256=9f2a...  custodian=ML  time=10:42:19Z
write_blocker=ON  evidence_id=E-2026-014
```

Illustrative study visual - not live production telemetry

QUESTION 486 | PASSWORDLESS AUTHENTICATION

APPLIED

During day-to-day SOC operations, an employee signs in with a FIDO2 security key using public-key cryptography and no reusable password. What authentication approach is this?

A. Password spraying

B. Passwordless authentication

C. Basic HTTP authentication

D. Shared-secret-only authentication

CORRECT ANSWER: B - Passwordless authentication

WHY: FIDO2/WebAuthn can provide phishing-resistant passwordless authentication using public-key credentials.

MEMORY CUE

Passwordless = no reusable shared password.

Identity / Access Flow

USER

AUTH

POLICY

RESOURCE

```
audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 487-488

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 487 | RECOVERY

APPLIED

In a separate enterprise scenario, after containment and eradication, which incident-response activity restores affected systems to normal business operation?

A. Reconnaissance

B. Detection

C. Recovery

D. Preparation

CORRECT ANSWER: C - Recovery

WHY: Recovery returns systems and services to normal operation and verifies that they remain secure.

MEMORY CUE

Recovery returns systems and services to normal operation and verifies that they remain secure.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 488 | RISK-BASED EXCEPTION

APPLIED

During day-to-day SOC operations, a critical server cannot be patched before quarter-end because the vendor application would fail. Management formally approves temporary network restrictions and a future patch date. What should this be documented as?

A. DNS sinkhole

B. Data classification

C. Password spray

D. Risk exception

CORRECT ANSWER: D - Risk exception

WHY: A risk exception documents temporary acceptance or alternate treatment when a required control cannot be implemented as scheduled.

MEMORY CUE

Exception = documented temporary deviation with risk treatment.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 489-490

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 489 | BEHAVIORAL BASELINE

APPLIED

During day-to-day SOC operations, a SOC analyst compares today's outbound traffic to a 30-day profile to identify systems with unusually high transfer volume. What technique is being used?

A. Behavioral baselining / anomaly detection

B. Cold-site recovery

C. Tokenization

D. Digital signing

CORRECT ANSWER: A - Behavioral baselining / anomaly detection

WHY: Baselining establishes normal behavior so meaningful deviations can be identified.

MEMORY CUE

Know normal to find abnormal.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 490 | INCIDENT PREPARATION

APPLIED

In a separate enterprise scenario, which incident-response phase includes establishing playbooks, contacts, tools, logging, and communication procedures before an incident occurs?

A. Recovery

B. Preparation

C. Eradication

D. Lessons learned only

CORRECT ANSWER: B - Preparation

WHY: Preparation builds the capabilities and procedures needed to respond effectively before incidents happen.

MEMORY CUE

Prepare before the incident.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 491-492

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 491 | CVSS

APPLIED

What scoring system is commonly used to express the technical severity characteristics of a vulnerability?

- A. SLA
- B. RPO
- C. CVSS
- D. SPF

CORRECT ANSWER: C - CVSS

WHY: The Common Vulnerability Scoring System provides standardized severity metrics for vulnerabilities.

MEMORY CUE
CVSS = vulnerability severity score.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 492 | DNS SINKHOLE

APPLIED

A security team wants known malicious domains to resolve to a controlled internal address instead of their real C2 servers. What control is this?

- A. Load balancing
- B. ARP poisoning
- C. DHCP relay
- D. DNS sinkhole

CORRECT ANSWER: D - DNS sinkhole

WHY: A DNS sinkhole redirects known-malicious domain resolution to a controlled destination to block or observe connections.

MEMORY CUE
Sinkhole malicious DNS to a safe controlled host.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
09:14:02	WS-17	resolver	aGVsbG8u...
09:14:03	WS-17	resolver	bG9uZy5x...
09:14:04	WS-17	resolver	NXDOMAIN

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 493

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | NAC

During day-to-day SOC operations, a NAC solution discovers that a connecting laptop has an outdated antivirus product. What action can NAC take?

- A. Place the system in a remediation network
- B. Remove encryption from the network
- C. Change the system's motherboard
- D. Automatically destroy the laptop

SIMULATED EVIDENCE / ARCHITECTURE PANEL

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

CORRECT ANSWER: A - Place the system in a remediation network

RATIONALE Network Access Control can quarantine noncompliant systems until security requirements are satisfied.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 494-495

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 494 | WRITE BLOCKER

APPLIED

In a separate enterprise scenario, which device or capability is used to prevent accidental modification of a storage device while forensic data is being acquired?

- A. HSM
- B. Write blocker**
- C. Load balancer
- D. NAC

CORRECT ANSWER: B - Write blocker

WHY: A write blocker permits read access while preventing writes that could alter evidence.

MEMORY CUE

Write blocker protects source evidence from modification.

Forensic Evidence Workflow

COLLECT

HASH

PRESERVE

ANALYZE

REPORT

```
SHA256=9f2a...  custodian=ML  time=10:42:19Z
write_blocker=ON  evidence_id=E-2026-014
```

Illustrative study visual - not live production telemetry

QUESTION 495 | IPS

APPLIED

Which security technology is positioned to detect malicious network traffic and actively block it inline?

- A. HSM
- B. SIEM only
- C. IPS**
- D. IDS only

CORRECT ANSWER: C - IPS

WHY: An intrusion prevention system can take inline action to block detected malicious traffic.

MEMORY CUE

IPS = detect + prevent inline.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

EDR powershell.exe -enc ...

DNS long encoded subdomain

FW outbound 443 -> 203.0.113.50

ID new device + risky sign-in

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 496-497

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 496 | DNS LOGS

APPLIED

A SOC analyst wants to identify which internal hosts resolved a newly registered malicious domain. Which telemetry should be queried first?

- A. Badge-reader logs
- B. BIOS logs
- C. RAID logs

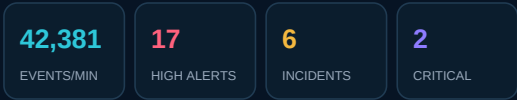
D. DNS logs

CORRECT ANSWER: D - DNS logs

WHY: DNS logs map clients to queried domain names and resolution results, making them valuable for domain-based hunting.

MEMORY CUE
DNS logs connect hosts to domain lookups.

SOC Correlation Dashboard



```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 497 | LEAST PRIVILEGE

APPLIED

During day-to-day SOC operations, which access-control concept gives a SOC analyst only the permissions required for SOC duties?

- A. Least privilege
- B. Transitive trust
- C. Open access
- D. Shared accounts

CORRECT ANSWER: A - Least privilege

WHY: Users should receive only the minimum permissions required to perform authorized responsibilities.

MEMORY CUE
Users should receive only the minimum permissions required to perform authorized responsibilities.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 498-499

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 498 | TRUE MFA

APPLIED

During day-to-day SOC operations, what authentication combination represents true multifactor authentication?

- A. Security question + password
- B. Password + hardware security key
- C. Password + PIN
- D. Fingerprint + face scan

CORRECT ANSWER: B - Password + hardware security key

WHY: Password = something you know Hardware key = something you have Two credentials from the same category do not constitute true multifactor authentication.

MEMORY CUE

Password = something you know Hardware key = something you have Two credentials from the same category do not constitute true multifactor authentication.

Identity / Access Flow



```
audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
```

Illustrative study visual - not live production telemetry

QUESTION 499 | INDICATOR OF COMPROMISE

APPLIED

In a separate enterprise scenario, a known malicious file hash and C2 domain are distributed to analysts for hunting. What are these artifacts?

- A. Service-level objectives
- B. Data owners
- C. Indicators of compromise (IOCs)
- D. Authentication factors

CORRECT ANSWER: C - Indicators of compromise (IOCs)

WHY: IOCs are observable artifacts associated with malicious activity, such as hashes, domains, IPs, or filenames.

MEMORY CUE

IOC = observable artifact linked to compromise.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 500-501

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 500 | LDAP

APPLIED

In a separate enterprise scenario, which protocol is commonly used to query and manage directory information such as users, groups, and organizational objects?

- A. IPsec
- B. TFTP
- C. NTP

D. LDAP

CORRECT ANSWER: D - LDAP

LDAP is a directory-access protocol used to query and manage directory services.

WHY:

MEMORY CUE

LDAP = directory lookup/management.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 501 | RBAC

APPLIED

During day-to-day SOC operations, what access-control model grants permissions based on a person's job function?

A. RBAC

- B. Hash-based access
- C. MAC exclusively
- D. DAC exclusively

CORRECT ANSWER: A - RBAC

Role-Based Access Control assigns permissions according to organizational roles. Example: SOC Analyst → SIEM read/search + EDR investigation

WHY:

MEMORY CUE

Role-Based Access Control assigns permissions according to organizational roles. Example: SOC Analyst → SIEM read/search + EDR inves...

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 502

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | ORDER OF VOLATILITY

In a separate enterprise scenario, during live forensics, which evidence should generally be captured before powering off a compromised workstation?

- A. Cold-site inventory
- B. Volatile memory (RAM)
- C. Archived tape backups
- D. Printed policies

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Forensic Evidence Workflow

COLLECT

HASH

PRESERVE

ANALYZE

REPORT

SHA256=9f2a... custodian=ML time=10:42:19Z
write_blocker=0N evidence_id=E-2026-014

CORRECT ANSWER: B - Volatile memory (RAM)

RATIONALE Volatile data such as RAM can be lost when power is removed and should be captured early when appropriate.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 503-504

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 503 | FALSE POSITIVE

APPLIED

During day-to-day SOC operations, a vulnerability scanner identifies a vulnerability, but manual investigation confirms the affected component is not actually installed. This is a:

- A. True negative
- B. Zero-day exploit
- C. False positive**
- D. True positive

CORRECT ANSWER: C - False positive

WHY: The security tool reported a vulnerability that does not actually exist on the system.

MEMORY CUE

The security tool reported a vulnerability that does not actually exist on the system.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 504 | INDICATOR OF ATTACK

APPLIED

During day-to-day SOC operations, a detection focuses on behavior such as credential dumping followed by remote service creation rather than a fixed file hash. What is this behavioral evidence called?

- A. Data classification
- B. Cold-site metric
- C. RPO
- D. Indicator of attack (IOA)**

CORRECT ANSWER: D - Indicator of attack (IOA)

WHY: IOAs focus on adversary behavior or intent rather than only static artifacts.

MEMORY CUE

IOA = malicious behavior pattern.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 505-506

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 505 | CLOUD AUDIT LOGS

ADVANCED

A security operations team is evaluating a capability described as follows: record administrative and API actions performed against cloud resources and control-plane services. Which operational tool, process, or control BEST fits?

A. Cloud audit / activity logs

- B. Printer logs
- C. Endpoint temperature logs
- D. Switch CAM table only

CORRECT ANSWER: A - Cloud audit / activity logs

WHY: Cloud audit logs record administrative and API actions performed against cloud resources and control-plane services.

MEMORY CUE

Cloud audit logs = who changed cloud configuration.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...
DNS  long encoded subdomain
FW   outbound 443 -> 203.0.113.50
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 506 | EMAIL GATEWAY LOGS

ADVANCED

A security operations team is evaluating a capability described as follows: record message routing, sender/recipient, reputation, authentication results, and disposition. Which operational tool, process, or control BEST fits?

- B. Email gateway logs**
- A. UPS logs
- C. DHCP logs
- D. BIOS logs

CORRECT ANSWER: B - Email gateway logs

WHY: Email gateway logs record message routing, sender/recipient, reputation, authentication results, and disposition.

MEMORY CUE

Email gateway = mail delivery and filtering evidence.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...
DNS  long encoded subdomain
FW   outbound 443 -> 203.0.113.50
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 507-508

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 507 | NAC

ADVANCED

A security operations team is evaluating a capability described as follows: network Access Control can quarantine noncompliant systems until security requirements are satisfied. Which operational tool, process, or control BEST fits?

- A. Remove encryption from the network
- B. Automatically destroy the laptop

C. Place the system in a remediation network

- D. Change the system's motherboard

CORRECT ANSWER: C - Place the system in a remediation network

WHY: Network Access Control can quarantine noncompliant systems until security requirements are satisfied.

MEMORY CUE

Network Access Control can quarantine noncompliant systems until security requirements are satisfied.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 508 | INDICATOR OF COMPROMISE

ADVANCED

A security operations team is evaluating a capability described as follows: iOCs are observable artifacts associated with malicious activity, such as hashes, domains, IPs, or filenames. Which operational tool, process, or control BEST fits?

- A. Data owners
- B. Authentication factors
- C. Service-level objectives

D. Indicators of compromise (iOCs)

CORRECT ANSWER: D - Indicators of compromise (iOCs)

WHY: iOCs are observable artifacts associated with malicious activity, such as hashes, domains, IPs, or filenames.

MEMORY CUE

iOC = observable artifact linked to compromise.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 509-510

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 509 | INCIDENT IDENTIFICATION

ADVANCED

A security operations team is evaluating a capability described as follows: identification and analysis determine whether an event is a security incident and establish scope and severity. Which operational tool, process, or control BEST fits?

A. Detection and analysis / identification

B. Recovery

C. Business continuity

D. Eradication

CORRECT ANSWER: A - Detection and analysis / identification

WHY: Identification and analysis determine whether an event is a security incident and establish scope and severity.

MEMORY CUE

Confirm and understand the incident.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 510 | SIEM

ADVANCED

A security operations team is evaluating a capability described as follows: a Security Information and Event Management platform centralizes security telemetry for search, correlation, detection, investigation, and alerting. Which operational tool, process, or control BEST fits?

A. HSM

B. SIEM

C. RAID

D. UPS

CORRECT ANSWER: B - SIEM

WHY: A Security Information and Event Management platform centralizes security telemetry for search, correlation, detection, investigation, and alerting.

MEMORY CUE

A Security Information and Event Management platform centralizes security telemetry for search, correlation, detection, investigatio...

SOC Correlation Dashboard

42,381	17	6	2
EVENTS/MIN	HIGH ALERTS	INCIDENTS	CRITICAL

EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 511

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | HUNT HYPOTHESIS

A security operations team is evaluating a capability described as follows: a a testable idea that guides proactive analysis of telemetry. Which operational tool, process, or control BEST fits?

- A. SLA
- B. Access-control list
- C. Hunt hypothesis
- D. Certificate chain

SIMULATED EVIDENCE / ARCHITECTURE PANEL

 Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

CORRECT ANSWER: C - Hunt hypothesis

RATIONALE A hunt hypothesis is a testable idea that guides proactive analysis of telemetry.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 512-513

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 512 | LEGAL HOLD

ADVANCED

A security operations team is evaluating a capability described as follows: a suspends normal deletion or destruction for information relevant to litigation or investigation. Which operational tool, process, or control BEST fits?

- A. Key rotation
- B. Data masking
- C. Network segmentation

D. Legal hold

CORRECT ANSWER: D - Legal hold

WHY: A legal hold suspends normal deletion or destruction for information relevant to litigation or investigation.

MEMORY CUE

Legal hold overrides normal deletion schedules.

Forensic Evidence Workflow

COLLECT**HASH****PRESERVE****ANALYZE****REPORT**

```
SHA256=9f2a...  custodian=ML  time=10:42:19Z
write_blocker=ON  evidence_id=E-2026-014
```

Illustrative study visual - not live production telemetry

QUESTION 513 | DNS LOGS

ADVANCED

A security operations team is evaluating a capability described as follows: map clients to queried domain names and resolution results, making them valuable for domain-based hunting. Which operational tool, process, or control BEST fits?

- A. DNS logs**
- B. BIOS logs
- C. RAID logs
- D. Badge-reader logs

CORRECT ANSWER: A - DNS logs

WHY: DNS logs map clients to queried domain names and resolution results, making them valuable for domain-based hunting.

MEMORY CUE

DNS logs connect hosts to domain lookups.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...
DNS  long encoded subdomain
FW   outbound 443 -> 203.0.113.50
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 514-515

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 514 | SPF

ADVANCED

A security operations team is evaluating a capability described as follows: sender Policy Framework publishes authorized mail-sending infrastructure through DNS. Which operational tool, process, or control BEST fits?

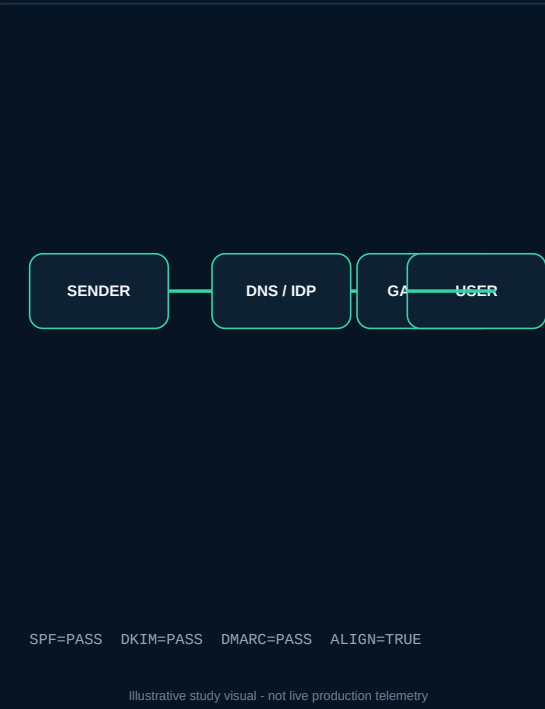
- A. DHCP
- B. SPF
- C. SSH
- D. NTP

CORRECT ANSWER: B - SPF

WHY: Sender Policy Framework publishes authorized mail-sending infrastructure through DNS.

MEMORY CUE
Sender Policy Framework publishes authorized mail-sending infrastructure through DNS.

Email / Federation Trust



QUESTION 515 | MALWARE SANDBOX

ADVANCED

A security operations team is evaluating a capability described as follows: a sandbox safely executes suspicious code in an isolated environment for behavioral analysis. Which operational tool, process, or control BEST fits?

- A. Production domain controller
- B. Unfiltered user workstation
- C. Malware sandbox
- D. Public file share

CORRECT ANSWER: C - Malware sandbox

WHY: A sandbox safely executes suspicious code in an isolated environment for behavioral analysis.

MEMORY CUE
Sandbox = controlled detonation and observation.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 516-517

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 516 | RBAC

ADVANCED

A security operations team is evaluating a capability described as follows: role-Based Access Control assigns permissions according to organizational roles. Example: SOC Analyst → SIEM read/search + EDR investigation. Which operational tool, process, or control BEST fits?

- A. Hash-based access
- B. DAC exclusively
- C. MAC exclusively

D. RBAC

CORRECT ANSWER: D - RBAC

WHY: Role-Based Access Control assigns permissions according to organizational roles. Example: SOC Analyst → SIEM read/search + EDR investigation

MEMORY CUE

Role-Based Access Control assigns permissions according to organizational roles. Example: SOC Analyst → SIEM read/search + EDR inves...

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 517 | RECOVERY

ADVANCED

A security operations team is evaluating a capability described as follows: returns systems and services to normal operation and verifies that they remain secure. Which operational tool, process, or control BEST fits?

- A. Recovery
- B. Preparation
- C. Reconnaissance
- D. Detection

CORRECT ANSWER: A - Recovery

WHY: Recovery returns systems and services to normal operation and verifies that they remain secure.

MEMORY CUE

Recovery returns systems and services to normal operation and verifies that they remain secure.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 518-519

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 518 | WEB APPLICATION FIREWALL

ADVANCED

A security operations team is evaluating a capability described as follows: a filters application-layer web traffic and applies rules for common web attacks. Which operational tool, process, or control BEST fits?

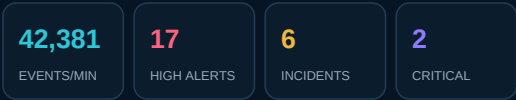
- A. HSM
- B. WAF
- C. RADIUS
- D. UPS

CORRECT ANSWER: B - WAF

WHY: A web application firewall filters application-layer web traffic and applies rules for common web attacks.

MEMORY CUE
WAF protects HTTP/S application traffic.

SOC Correlation Dashboard



```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 519 | FALSE POSITIVE

ADVANCED

A security operations team is evaluating a capability described as follows: the security tool reported a vulnerability that does not actually exist on the system. Which operational tool, process, or control BEST fits?

- A. Zero-day exploit
- B. True positive
- C. False positive
- D. True negative

CORRECT ANSWER: C - False positive

WHY: The security tool reported a vulnerability that does not actually exist on the system.

MEMORY CUE
The security tool reported a vulnerability that does not actually exist on the system.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 520

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | FIREWALL LOGS

A security operations team is evaluating a capability described as follows: commonly contain source/destination IPs, ports, protocols, actions, policies, and connection information. Which operational tool, process, or control BEST fits?

- A. Badge-reader logs
- B. BIOS logs
- C. Printer logs
- D. Firewall logs

SIMULATED EVIDENCE / ARCHITECTURE PANEL

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

EDR

powershell.exe -enc ...

DNS

long encoded subdomain

FW

outbound 443 -> 203.0.113.50

ID

new device + risky sign-in

CORRECT ANSWER: D - Firewall logs

RATIONALE Firewall logs commonly contain source/destination IPs, ports, protocols, actions, policies, and connection information.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 521-522

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 521 | XDR

ADVANCED

A security operations team is evaluating a capability described as follows: extended Detection and Response correlates information across multiple security domains. Which operational tool, process, or control BEST fits?

A. XDR

B. FTP

C. NAT

D. SAN

CORRECT ANSWER: A - XDR

WHY: Extended Detection and Response correlates information across multiple security domains.

MEMORY CUE

Extended Detection and Response correlates information across multiple security domains.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...  
DNS  long encoded subdomain  
FW   outbound 443 -> 203.0.113.50  
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 522 | IDS

ADVANCED

A security operations team is evaluating a capability described as follows: an intrusion detection system monitors traffic and alerts on suspicious or known-bad behavior. Which operational tool, process, or control BEST fits?

A. NAC

B. IDS

C. IPS

D. HSM

CORRECT ANSWER: B - IDS

WHY: An intrusion detection system monitors traffic and alerts on suspicious or known-bad behavior.

MEMORY CUE

IDS = detect and alert.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...  
DNS  long encoded subdomain  
FW   outbound 443 -> 203.0.113.50  
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 523-524

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 523 | SUSPICIOUS POWERSHELL

ADVANCED

A security operations team is evaluating a capability described as follows: telemetry The analyst first needs to establish context and determine whether the behavior is malicious before taking disproportionate action. Useful evidence could include: - Parent process - Command line - User account - Destination IP - DNS activity - EDR telemetry - Process tree - Related. Which operational tool, process, or control BEST fits?

- A. Reimage the entire enterprise
- B. Disable the SIEM

C. Investigate the process and related telemetry

- D. Delete PowerShell

CORRECT ANSWER: C - Investigate the process and related telemetry

WHY: telemetry The analyst first needs to establish context and determine whether the behavior is malicious before taking disproportionate action. Useful evidence could include: - Parent process - Command line - User account - Destination IP - DNS activity -

MEMORY CUE

telemetry The analyst first needs to establish context and determine whether the behavior is malicious before taking disproportionat...

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 524 | EDR

ADVANCED

A security operations team is evaluating a capability described as follows: endpoint Detection and Response provides visibility and response capabilities directly on endpoints. Examples include: - CrowdStrike Falcon - Microsoft Defender for Endpoint - SentinelOne. Which operational tool, process, or control BEST fits?

- A. VLAN
- B. DNSSEC
- C. RAID
- D. EDR

CORRECT ANSWER: D - EDR

WHY: Endpoint Detection and Response provides visibility and response capabilities directly on endpoints. Examples include: - CrowdStrike Falcon - Microsoft Defender for Endpoint - SentinelOne

MEMORY CUE

Endpoint Detection and Response provides visibility and response capabilities directly on endpoints. Examples include: - CrowdStrike...

SOC Correlation Dashboard

42,381	17	6	2
EVENTS/MIN	HIGH ALERTS	INCIDENTS	CRITICAL

EDR powershell.exe -enc ...

DNS long encoded subdomain

FW outbound 443 -> 203.0.113.50

ID new device + risky sign-in

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 525-526

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 525 | SSH

ADVANCED

A security operations team is evaluating a capability described as follows: encrypts administrative sessions, while Telnet sends information without comparable transport protection. Which operational tool, process, or control BEST fits?

- A. SSH
- B. HTTP
- C. SNMPv1
- D. FTP

CORRECT ANSWER: A - SSH

WHY: SSH encrypts administrative sessions, while Telnet sends information without comparable transport protection.

MEMORY CUE

SSH encrypts administrative sessions, while Telnet sends information without comparable transport protection.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 526 | PRIVILEGED ACCOUNT SEPARATION

ADVANCED

A security operations team is evaluating a capability described as follows: administrative credentials should not be exposed during everyday activities such as browsing or email. Which operational tool, process, or control BEST fits?

- A. Data masking
- B. Privileged account separation
- C. Password spraying
- D. Federation

CORRECT ANSWER: B - Privileged account separation

WHY: Administrative credentials should not be exposed during everyday activities such as browsing or email.

MEMORY CUE

Administrative credentials should not be exposed during everyday activities such as browsing or email.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 527-528

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 527 | THREAT INTELLIGENCE

ADVANCED

A security operations team is evaluating a capability described as follows: supplies contextual information about adversaries, indicators, campaigns, and malicious infrastructure. Which operational tool, process, or control BEST fits?

- A. RAID parity
- B. Data masking

C. Threat intelligence

- D. Load balancing

CORRECT ANSWER: C - Threat intelligence

WHY: Threat intelligence supplies contextual information about adversaries, indicators, campaigns, and malicious infrastructure.

MEMORY CUE

Threat intel adds adversary context to telemetry.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 528 | LEAST PRIVILEGE

ADVANCED

A security operations team is evaluating a capability described as follows: users should receive only the minimum permissions required to perform authorized responsibilities. Which operational tool, process, or control BEST fits?

- A. Shared accounts
- B. Open access
- C. Transitive trust

D. Least privilege

CORRECT ANSWER: D - Least privilege

WHY: Users should receive only the minimum permissions required to perform authorized responsibilities.

MEMORY CUE

Users should receive only the minimum permissions required to perform authorized responsibilities.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 529

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | INCIDENT ERADICATION

A security operations team is evaluating a capability described as follows: removes the attacker, malware, persistence, and root cause from the environment. Which operational tool, process, or control BEST fits?

- A. Eradication
- B. Detection
- C. Preparation
- D. Recovery only

SIMULATED EVIDENCE / ARCHITECTURE PANEL

●●● Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

CORRECT ANSWER: A - Eradication

RATIONALE Eradication removes the attacker, malware, persistence, and root cause from the environment.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 530-531

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 530 | TRUE MFA

ADVANCED

A security operations team is evaluating a capability described as follows: password = something you know Hardware key = something you have Two credentials from the same category do not constitute true multifactor authentication. Which operational tool, process, or control BEST fits?

- A. Password + PIN
- B. Password + hardware security key
- C. Fingerprint + face scan
- D. Security question + password

CORRECT ANSWER: B - Password + hardware security key

WHY: Password = something you know Hardware key = something you have Two credentials from the same category do not constitute true multifactor authentication.

MEMORY CUE

Password = something you know Hardware key = something you have Two credentials from the same category do not constitute true multifactor authentication.

Identity / Access Flow



audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

QUESTION 531 | INCIDENT CONTAINMENT

ADVANCED

A security operations team is evaluating a capability described as follows: limits spread and damage after an incident has been identified. Which operational tool, process, or control BEST fits?

- A. Preparation
- B. Lessons learned
- C. Containment
- D. Recovery

CORRECT ANSWER: C - Containment

WHY: Containment limits spread and damage after an incident has been identified.

MEMORY CUE

Containment = stop the bleeding.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 532-533

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 532 | ORDER OF VOLATILITY

ADVANCED

A security operations team is evaluating a capability described as follows: volatile data such as RAM can be lost when power is removed and should be captured early when appropriate. Which operational tool, process, or control BEST fits?

- A. Archived tape backups
- B. Cold-site inventory
- C. Printed policies

D. Volatile memory (RAM)

CORRECT ANSWER: D - Volatile memory (RAM)

WHY: Volatile data such as RAM can be lost when power is removed and should be captured early when appropriate.

MEMORY CUE

Most volatile evidence first.

Forensic Evidence Workflow

COLLECT

HASH

PRESERVE

ANALYZE

REPORT

```
SHA256=9f2a...  custodian=ML  time=10:42:19Z
write_blocker=ON  evidence_id=E-2026-014
```

Illustrative study visual - not live production telemetry

QUESTION 533 | WRITE BLOCKER

ADVANCED

A security operations team is evaluating a capability described as follows: a permits read access while preventing writes that could alter evidence. Which operational tool, process, or control BEST fits?

- A. Write blocker**
- B. Load balancer
- C. NAC
- D. HSM

CORRECT ANSWER: A - Write blocker

WHY: A write blocker permits read access while preventing writes that could alter evidence.

MEMORY CUE

Write blocker protects source evidence from modification.

Forensic Evidence Workflow

COLLECT

HASH

PRESERVE

ANALYZE

REPORT

```
SHA256=9f2a...  custodian=ML  time=10:42:19Z
write_blocker=ON  evidence_id=E-2026-014
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 534-535

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 534 | FORENSIC IMAGING

ADVANCED

A security operations team is evaluating a capability described as follows: a a sector-level duplicate used for analysis while the original evidence is preserved. Which operational tool, process, or control BEST fits?

- A. Token
- B. Forensic image**
- C. Incremental backup only
- D. Data mask

CORRECT ANSWER: B - Forensic image

WHY: A forensic image is a sector-level duplicate used for analysis while the original evidence is preserved.

MEMORY CUE

Analyze the forensic copy, preserve original evidence.

Forensic Evidence Workflow



```

SHA256=9f2a...  custodian=ML  time=10:42:19Z
write_blocker=ON  evidence_id=E-2026-014
  
```

Illustrative study visual - not live production telemetry

QUESTION 535 | SAML

ADVANCED

A security operations team is evaluating a capability described as follows: security Assertion Markup Language exchanges authentication and authorization assertions between identity and service providers. Which operational tool, process, or control BEST fits?

- A. TFTP
- B. ARP
- C. SAML**
- D. Telnet

CORRECT ANSWER: C - SAML

WHY: Security Assertion Markup Language exchanges authentication and authorization assertions between identity and service providers.

MEMORY CUE

Security Assertion Markup Language exchanges authentication and authorization assertions between identity and service providers.

Identity / Access Flow



```

audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
  
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 536-537

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 536 | DNS SINKHOLE

ADVANCED

A security operations team is evaluating a capability described as follows: a redirects known-malicious domain resolution to a controlled destination to block or observe connections. Which operational tool, process, or control BEST fits?

- A. Load balancing
- B. DHCP relay
- C. ARP poisoning

D. DNS sinkhole

CORRECT ANSWER: D - DNS sinkhole

WHY: A DNS sinkhole redirects known-malicious domain resolution to a controlled destination to block or observe connections.

MEMORY CUE
Sinkhole malicious DNS to a safe controlled host.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
09:14:02	WS-17	resolver	aGVsbG8u...
09:14:03	WS-17	resolver	bG9uZy5x...
09:14:04	WS-17	resolver	NXDOMAIN

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 537 | DKIM

ADVANCED

A security operations team is evaluating a capability described as follows: domainKeys Identified Mail attaches a cryptographic signature that receiving mail systems can verify. Which operational tool, process, or control BEST fits?

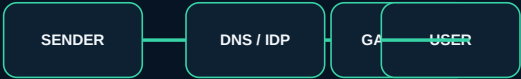
- A. DKIM
- B. NAT
- C. VLAN
- D. ARP

CORRECT ANSWER: A - DKIM

WHY: DomainKeys Identified Mail attaches a cryptographic signature that receiving mail systems can verify.

MEMORY CUE
DomainKeys Identified Mail attaches a cryptographic signature that receiving mail systems can verify.

Email / Federation Trust



SPF=PASS DKIM=PASS DMARC=PASS ALIGN=TRUE

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 538

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | DMARC

A security operations team is evaluating a capability described as follows: uses SPF/DKIM authentication and domain alignment to establish email policy. Memorize together: SPF + DKIM + this control. Which operational tool, process, or control BEST fits?

- A. DNSSEC and DHCP
- B. SPF and DKIM
- C. SSH and TLS
- D. SFTP and SNMP

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Email / Federation Trust



SPF=PASS DKIM=PASS DMARC=PASS ALIGN=TRUE

CORRECT ANSWER: B - SPF and DKIM

RATIONALE

DMARC uses SPF/DKIM authentication and domain alignment to establish email policy. Memorize together: SPF + DKIM + DMARC

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 539-540

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 539 | LESSONS LEARNED

ADVANCED

A security operations team is evaluating a capability described as follows: post-incident review captures lessons, identifies improvements, and updates controls and procedures. Which operational tool, process, or control BEST fits?

- A. Initial access
- B. Authentication

C. Lessons learned / post-incident review

- D. Containment

CORRECT ANSWER: C - Lessons learned / post-incident review

WHY: Post-incident review captures lessons, identifies improvements, and updates controls and procedures.

MEMORY CUE
Afterward: learn, document, improve.

Identity / Access Flow



```
audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l
```

Illustrative study visual - not live production telemetry

QUESTION 540 | INDICATOR OF ATTACK

ADVANCED

A security operations team is evaluating a capability described as follows: iOAs focus on adversary behavior or intent rather than only static artifacts. Which operational tool, process, or control BEST fits?

- A. Cold-site metric
- B. RPO
- C. Data classification

D. Indicator of attack (IOA)

CORRECT ANSWER: D - Indicator of attack (IOA)

WHY: IOAs focus on adversary behavior or intent rather than only static artifacts.

MEMORY CUE
IOA = malicious behavior pattern.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 541-542

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 541 | SYSMON

ADVANCED

A security operations team is evaluating a capability described as follows: provides detailed endpoint telemetry such as process creation, network connections, registry activity, image loading, and file events. Which operational tool, process, or control BEST fits?

- A. Sysmon
- B. SNMP traps
- C. DNS root hints
- D. DHCP only

CORRECT ANSWER: A - Sysmon

WHY: Sysmon provides detailed endpoint telemetry such as process creation, network connections, registry activity, image loading, and file events.

MEMORY CUE

Sysmon provides detailed endpoint telemetry such as process creation, network connections, registry activity, image loading, and file events.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 542 | CHAIN OF CUSTODY

ADVANCED

A security operations team is evaluating a capability described as follows: demonstrate evidence integrity Chain-of-custody documentation records evidence collection, transfer, storage, examination, and handling. Which operational tool, process, or control BEST fits?

- A. It eliminates the need for documentation
- B. It proves who handled evidence and helps demonstrate evidence integrity
- C. It automatically proves the suspect is guilty
- D. It encrypts the entire network

CORRECT ANSWER: B - It proves who handled evidence and helps demonstrate evidence

WHY: demonstrate evidence integrity Chain-of-custody documentation records evidence collection, transfer, storage, examination, and handling.

MEMORY CUE

demonstrate evidence integrity Chain-of-custody documentation records evidence collection, transfer, storage, examination, and handling.

Forensic Evidence Workflow

COLLECT

HASH

PRESERVE

ANALYZE

REPORT

```
SHA256=9f2a... custodian=ML time=10:42:19Z
write_blocker=ON evidence_id=E-2026-014
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 543-544

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 543 | WIRESHARK

ADVANCED

A security operations team is evaluating a capability described as follows: performs packet-level network protocol analysis. Which operational tool, process, or control BEST fits?

- A. Group Policy Management
- B. Active Directory Users and Computers
- C. Wireshark**
- D. BitLocker

CORRECT ANSWER: C - Wireshark

WHY: Wireshark performs packet-level network protocol analysis.

MEMORY CUE

Wireshark performs packet-level network protocol analysis.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...  
DNS  long encoded subdomain  
FW   outbound 443 -> 203.0.113.50  
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 544 | PROXY LOGS

ADVANCED

A security operations team is evaluating a capability described as follows: record web requests such as destination domains, URLs, users, methods, and actions. Which operational tool, process, or control BEST fits?

- A. UPS logs
- B. Printer logs
- C. BIOS logs
- D. Proxy logs**

CORRECT ANSWER: D - Proxy logs

WHY: Proxy logs record web requests such as destination domains, URLs, users, methods, and actions.

MEMORY CUE

Proxy logs = web browsing/request telemetry.

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...  
DNS  long encoded subdomain  
FW   outbound 443 -> 203.0.113.50  
ID   new device + risky sign-in
```

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 545-546

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 545 | INCIDENT PREPARATION

ADVANCED

A security operations team is evaluating a capability described as follows: builds the capabilities and procedures needed to respond effectively before incidents happen. Which operational tool, process, or control BEST fits?

- A. Preparation
- B. Recovery
- C. Lessons learned only
- D. Eradication

CORRECT ANSWER: A - Preparation

WHY: Preparation builds the capabilities and procedures needed to respond effectively before incidents happen.

MEMORY CUE
Prepare before the incident.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 546 | RANSOMWARE CONTAINMENT

ADVANCED

A security operations team is evaluating a capability described as follows: isolation limits C2 traffic, propagation, lateral movement, and additional attacker activity. Which operational tool, process, or control BEST fits?

- A. Disable logging
- B. Isolate the endpoint from the network
- C. Inform the attacker
- D. Delete every corporate backup

CORRECT ANSWER: B - Isolate the endpoint from the network

WHY: Isolation limits C2 traffic, propagation, lateral movement, and additional attacker activity.

MEMORY CUE
Isolation limits C2 traffic, propagation, lateral movement, and additional attacker activity.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 547

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | PACKET CAPTURE

A security operations team is evaluating a capability described as follows: pCAP preserves packet-level headers and payload data needed for detailed protocol analysis. Which operational tool, process, or control BEST fits?

- A. DHCP lease table
- B. Asset inventory
- C. Packet capture (PCAP)
- D. NetFlow only

SIMULATED EVIDENCE / ARCHITECTURE PANEL

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in

CORRECT ANSWER: C - Packet capture (PCAP)

RATIONALE

PCAP preserves packet-level headers and payload data needed for detailed protocol analysis.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 548-549

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 548 | NETFLOW

ADVANCED

A security operations team is evaluating a capability described as follows: flow records summarize network conversations using metadata such as source, destination, ports, duration, and byte counts. Which operational tool, process, or control BEST fits?

- A. BIOS audit logs
- B. Sysmon registry events
- C. Full PCAP only

D. NetFlow / flow records

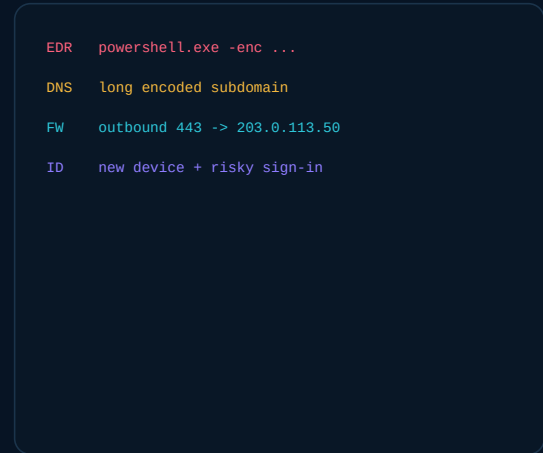
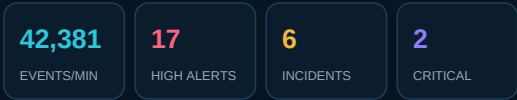
CORRECT ANSWER: D - NetFlow / flow records

WHY: Flow records summarize network conversations using metadata such as source, destination, ports, duration, and byte counts.

MEMORY CUE

Flow = conversation metadata, not full payload.

SOC Correlation Dashboard



Illustrative study visual - not live production telemetry

QUESTION 549 | VULNERABILITY PRIORITIZATION

ADVANCED

A security operations team is evaluating a capability described as follows: importance, and threat intelligence Real risk depends on both vulnerability severity and organizational context. Which operational tool, process, or control BEST fits?

A. Severity, exposure, exploitability, asset importance, and threat

- B. Server color and physical appearance
- C. CVSS alone and nothing else
- D. User preference only

CORRECT ANSWER: A - Severity, exposure, exploitability, asset importance, and threat

WHY: importance, and threat intelligence Real risk depends on both vulnerability severity and organizational context.

MEMORY CUE

importance, and threat intelligence Real risk depends on both vulnerability severity and organizational context.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 550-551

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 550 | WAF LOGS

ADVANCED

A security operations team is evaluating a capability described as follows: a web application firewall records and can block HTTP-layer attacks such as SQL injection and XSS. Which operational tool, process, or control BEST fits?

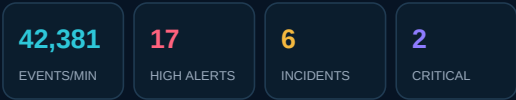
- A. UPS logs
- B. WAF logs
- C. Badge logs
- D. DHCP logs

CORRECT ANSWER: B - WAF logs

WHY: A web application firewall records and can block HTTP-layer attacks such as SQL injection and XSS.

MEMORY CUE
WAF logs = application-layer web attack telemetry.

SOC Correlation Dashboard



```
EDR powershell.exe -enc ...  
DNS long encoded subdomain  
FW outbound 443 -> 203.0.113.50  
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 551 | BEHAVIORAL BASELINE

ADVANCED

A security operations team is evaluating a capability described as follows: baselining establishes normal behavior so meaningful deviations can be identified. Which operational tool, process, or control BEST fits?

- A. Digital signing
- B. Cold-site recovery
- C. Behavioral baselining / anomaly detection
- D. Tokenization

CORRECT ANSWER: C - Behavioral baselining / anomaly detection

WHY: Baselining establishes normal behavior so meaningful deviations can be identified.

MEMORY CUE
Know normal to find abnormal.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 552-553

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 552 | EVIDENCE HASH

ADVANCED

A security operations team is evaluating a capability described as follows: matching cryptographic hashes help show that evidence has not changed during handling or acquisition. Which operational tool, process, or control BEST fits?

- A. Data confidentiality
- B. User authorization
- C. Network availability

D. Evidence integrity

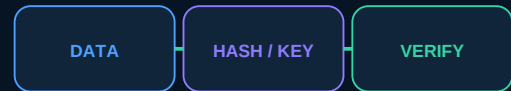
CORRECT ANSWER: D - Evidence integrity

WHY: Matching cryptographic hashes help show that evidence has not changed during handling or acquisition.

MEMORY CUE

Hash before/after to verify unchanged evidence.

Cryptography / Trust



RESULT: integrity / origin
 PRIVATE KEY: protected
 PUBLIC KEY: distributable
 SHA-256: 7c8a...

Illustrative study visual - not live production telemetry

QUESTION 553 | AUTHENTICATION LOGS

ADVANCED

A security operations team is evaluating a capability described as follows: record sign-in attempts, results, identity details, and often source systems or IP addresses. Which operational tool, process, or control BEST fits?

A. Authentication logs

- B. Printer logs
- C. File compression logs
- D. UPS logs

CORRECT ANSWER: A - Authentication logs

WHY: Authentication logs record sign-in attempts, results, identity details, and often source systems or IP addresses.

MEMORY CUE

Auth logs = sign-in evidence.

Identity / Access Flow



audit=logged
 decision=ALLOW
 factor=FIDO2
 id=marc.l

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 554-555

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 554 | SOAR

ADVANCED

A security operations team is evaluating a capability described as follows: security Orchestration, Automation, and Response platforms automate repeatable incident-response workflows. Which operational tool, process, or control BEST fits?

- A. UPS
- B. SOAR
- C. RAID controller
- D. HSM

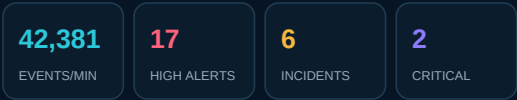
CORRECT ANSWER: B - SOAR

WHY: Security Orchestration, Automation, and Response platforms automate repeatable incident-response workflows.

MEMORY CUE

Security Orchestration, Automation, and Response platforms automate repeatable incident-response workflows.

SOC Correlation Dashboard



```
EDR powershell.exe -enc ...
DNS long encoded subdomain
FW outbound 443 -> 203.0.113.50
ID new device + risky sign-in
```

Illustrative study visual - not live production telemetry

QUESTION 555 | NETWORK ACCESS CONTROL

ADVANCED

A security operations team is evaluating a capability described as follows: evaluates devices or identities and can restrict noncompliant systems to a remediation network. Which operational tool, process, or control BEST fits?

- A. RAID
- B. SIEM
- C. NAC
- D. HSM

CORRECT ANSWER: C - NAC

WHY: Network Access Control evaluates devices or identities and can restrict noncompliant systems to a remediation network.

MEMORY CUE

NAC = admission control and posture enforcement.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 556

Immediate answers, concise rationales, and visual memory anchors.

ANALYST TASK | IPS

A security operations team is evaluating a capability described as follows: an intrusion prevention system can take inline action to block detected malicious traffic. Which operational tool, process, or control BEST fits?

- A. IDS only
- B. SIEM only
- C. HSM
- D. IPS

SIMULATED EVIDENCE / ARCHITECTURE PANEL

SOC Correlation Dashboard

42,381

EVENTS/MIN

17

HIGH ALERTS

6

INCIDENTS

2

CRITICAL

```
EDR  powershell.exe -enc ...  
DNS  long encoded subdomain  
FW   outbound 443 -> 203.0.113.50  
ID   new device + risky sign-in
```

CORRECT ANSWER: D - IPS

RATIONALE

An intrusion prevention system can take inline action to block detected malicious traffic.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 557-558

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 557 | REMEDIATION VALIDATION

ADVANCED

A security operations team is evaluating a capability described as follows: security teams should verify that remediation actually eliminated the vulnerability. Which operational tool, process, or control BEST fits?

A. Rescan or validate the affected system

B. Disable monitoring

C. Delete previous scan results

D. Assume the vulnerability is fixed

CORRECT ANSWER: A - Rescan or validate the affected system

WHY: Security teams should verify that remediation actually eliminated the vulnerability.

MEMORY CUE

Security teams should verify that remediation actually eliminated the vulnerability.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

QUESTION 558 | CVSS

ADVANCED

A security operations team is evaluating a capability described as follows: the Common Vulnerability Scoring System provides standardized severity metrics for vulnerabilities. Which operational tool, process, or control BEST fits?

A. SPF

B. CVSS

C. SLA

D. RPO

CORRECT ANSWER: B - CVSS

WHY: The Common Vulnerability Scoring System provides standardized severity metrics for vulnerabilities.

MEMORY CUE

CVSS = vulnerability severity score.

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
08:07:02	WS-22	powershell.exe	START
08:07:03	WS-22	rundll32.exe	CHILD
08:07:05	WS-22	edr-agent	ALERT

Correlate endpoint + identity + network evidence before deciding.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 559-560

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 559 | DHCP LOGS

ADVANCED

A security operations team is evaluating a capability described as follows: map leased IP addresses to client identifiers over time. Which operational tool, process, or control BEST fits?

- A. Certificate transparency logs
- B. Email gateway logs
- C. DHCP logs
- D. WAF logs

CORRECT ANSWER: C - DHCP logs

WHY: DHCP logs map leased IP addresses to client identifiers over time.

MEMORY CUE

DHCP answers: who had this IP at that time?

Simulated Security Telemetry

TIME	HOST	PROCESS	RESULT
10:21:11	10.20.5.18	203.0.113.50	ALLOW 443
10:21:12	10.20.5.18	203.0.113.50	SYN x 4,280
10:21:13	10.20.5.18	198.51.100.10	DENY 4444

Correlate endpoint + identity + network evidence before deciding.
Illustrative study visual - not live production telemetry

QUESTION 560 | OAUTH

ADVANCED

A security operations team is evaluating a capability described as follows: lets applications obtain limited access to resources without requiring users to hand over their passwords. Which operational tool, process, or control BEST fits?

- A. Password hashing
- B. Packet routing
- C. Disk encryption
- D. Delegated authorization

CORRECT ANSWER: D - Delegated authorization

WHY: OAuth lets applications obtain limited access to resources without requiring users to hand over their passwords.

MEMORY CUE

OAuth lets applications obtain limited access to resources without requiring users to hand over their passwords.

Identity / Access Flow

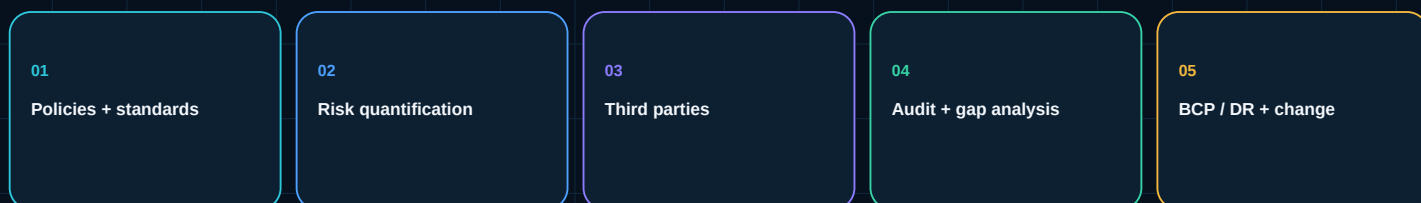


audit=logged
decision=ALLOW
factor=FIDO2
id=marc.l

Illustrative study visual - not live production telemetry

SECURITY PROGRAM MANAGEMENT & OVERSIGHT

QUESTIONS 561-700 | 140 QUESTIONS



Risk / Governance View

	Site1	Site2	Site3	Site4
Access	High	Medium	Low	Medium
AuthN	Medium	High	High	Low
IR	High	Low	Medium	Medium
Config	Medium	Medium	Low	High
Audit	High	High	Medium	Low

BY MARC LAVOIE

Security+ Master Visual Review | Questions 561-562

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 561 | POLICY

FOUNDATION

Which document provides high-level management expectations for information security?

A. Policy

- B. Routing table
- C. Packet capture
- D. Hash

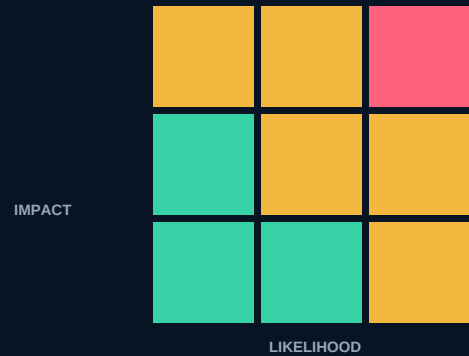
CORRECT ANSWER: A - Policy

WHY: Policies establish management's high-level requirements and organizational expectations.

MEMORY CUE

Policies establish management's high-level requirements and organizational expectations.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 562 | GUIDELINE

FOUNDATION

Which governance document provides recommended practices but generally allows flexibility rather than imposing a mandatory requirement?

- A. Procedure
- B. Guideline**
- C. Policy
- D. Standard

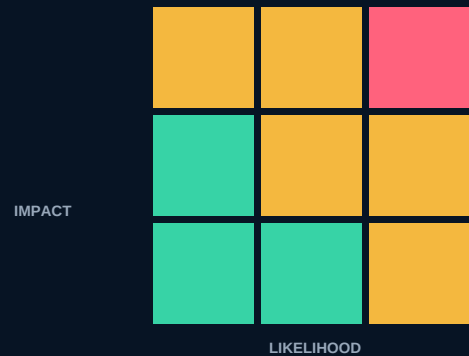
CORRECT ANSWER: B - Guideline

WHY: A guideline provides recommended approaches or best practices and is generally less mandatory than a standard.

MEMORY CUE

Guideline = recommended, not usually mandatory.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 563-564

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 563 | STANDARD

FOUNDATION

Which document normally specifies mandatory technical requirements, such as requiring AES-256 for particular data?

A. Marketing plan

B. Guideline

C. Standard

D. Incident ticket

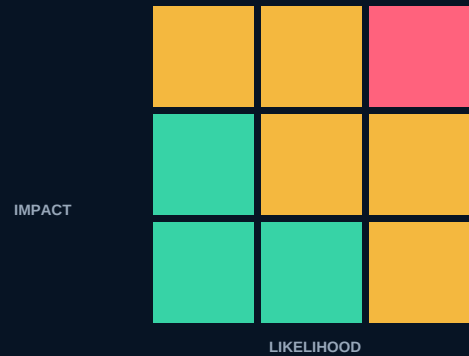
CORRECT ANSWER: C - Standard

WHY: Standards define mandatory requirements used to support organizational policies.

MEMORY CUE

Standards define mandatory requirements used to support organizational policies.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 564 | RISK APPETITE

FOUNDATION

Senior leadership states that the organization is willing to pursue aggressive cloud innovation even if it increases some operational security risk. What concept is being expressed?

A. SLE

B. Chain of custody

C. RPO

D. Risk appetite

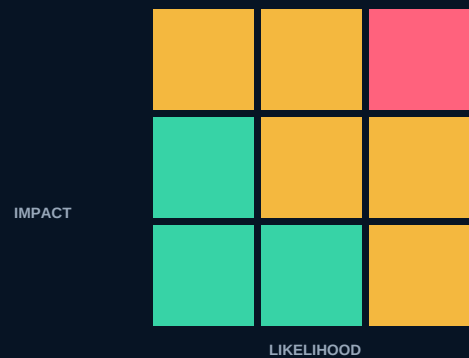
CORRECT ANSWER: D - Risk appetite

WHY: Risk appetite is the broad amount and type of risk an organization is willing to pursue or retain to achieve objectives.

MEMORY CUE

Risk appetite = broad willingness to take risk.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 565-566

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 565 | PROCEDURE

FOUNDATION

Which document usually contains detailed instructions explaining how to perform a task?

A. Procedure

- B. Risk appetite
- C. Policy
- D. Regulation

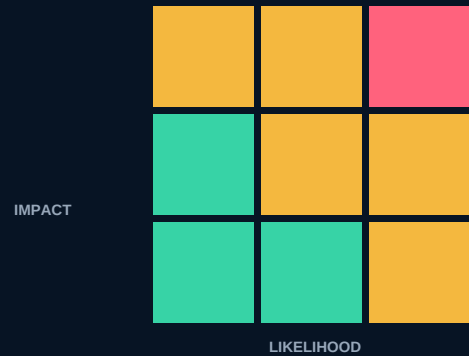
CORRECT ANSWER: A - Procedure

WHY: Procedures provide specific step-by-step instructions.

MEMORY CUE

Policy → What/why Standard → Mandatory requirement Procedure → How Guideline → Recommended practice

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 566 | EXPOSURE FACTOR

FOUNDATION

A \$400,000 asset would lose an estimated 30% of its value in a specific incident. What does the 30% represent in quantitative risk analysis?

- A. ARO
- B. Exposure factor (EF)
- C. ALE
- D. RTO

CORRECT ANSWER: B - Exposure factor (EF)

WHY: Exposure factor is the percentage of asset value expected to be lost from a single event.

MEMORY CUE

EF = percent loss from one event.

Risk / Governance View

$$\text{SLE} = \text{Asset Value} \times \text{Exposure Factor}$$

$$\text{ALE} = \text{SLE} \times \text{ARO}$$

Quantify expected loss - then compare control cost and residual risk.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 567-568

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 567 | RISK TOLERANCE

FOUNDATION

Management decides that losses of up to \$100,000 annually from a specific risk are acceptable. This describes:

- A. Non-repudiation
- B. Federation
- C. Risk tolerance**
- D. Encryption

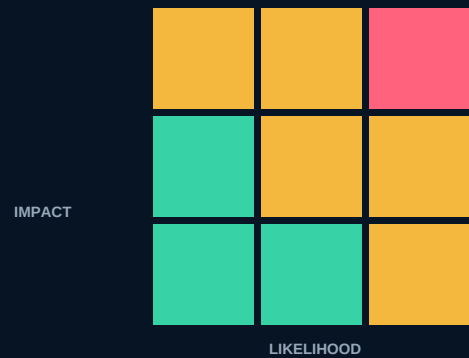
CORRECT ANSWER: C - Risk tolerance

WHY: Risk tolerance identifies the amount of risk or variation an organization is willing to accept.

MEMORY CUE

Risk tolerance identifies the amount of risk or variation an organization is willing to accept.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 568 | ANNUALIZED RATE OF OCCURRENCE

FOUNDATION

A flood affecting a particular site is estimated to occur once every five years. What is the ARO?

- A. 20
- B. 5.0
- C. 0.02
- D. 0.2**

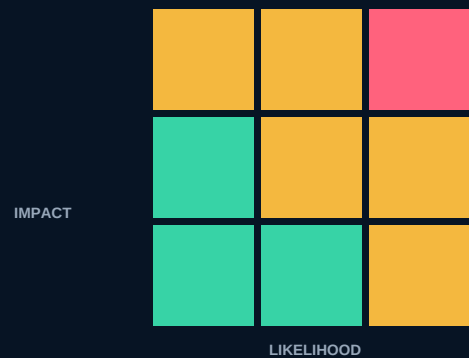
CORRECT ANSWER: D - 0.2

WHY: ARO expresses expected annual frequency; once every five years equals 1/5 or 0.2 per year.

MEMORY CUE

ARO = expected events per year.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 569-570

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 569 | RISK TRANSFER

FOUNDATION

An organization purchases cyber insurance to reduce the financial impact of ransomware. Which risk response is this?

A. Transfer

B. Avoid

C. Accept

D. Ignore

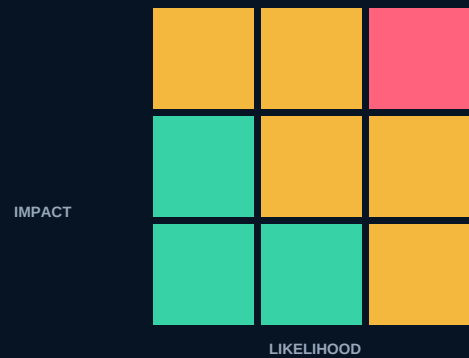
CORRECT ANSWER: A - Transfer

WHY: Cyber insurance transfers part of the financial risk to another organization.

MEMORY CUE

Cyber insurance transfers part of the financial risk to another organization.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 570 | MAXIMUM TOLERABLE DOWNTIME

FOUNDATION

Business leadership states that a manufacturing process cannot be unavailable for more than eight hours before the business impact becomes unacceptable. What metric is being described?

A. RPO

B. Maximum tolerable downtime (MTD)

C. SLE

D. ARO

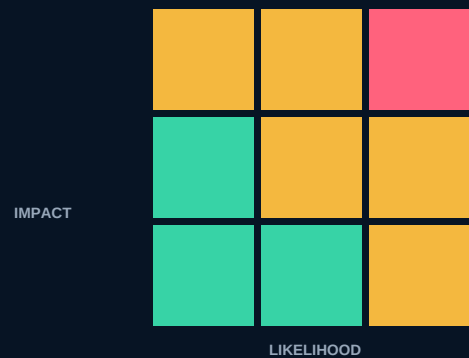
CORRECT ANSWER: B - Maximum tolerable downtime (MTD)

WHY: MTD is the longest period a process can remain unavailable before the impact becomes unacceptable.

MEMORY CUE

MTD = absolute maximum tolerable outage.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 571-572

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 571 | RISK AVOIDANCE

FOUNDATION

An organization stops offering a service because the associated security risk is considered unacceptable. Which risk response is being used?

- A. Acceptance
- B. Detection
- C. Avoidance**
- D. Transfer

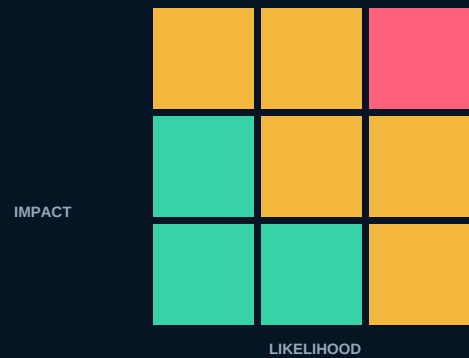
CORRECT ANSWER: C - Avoidance

WHY: Eliminating the activity producing the risk is risk avoidance.

MEMORY CUE

Eliminating the activity producing the risk is risk avoidance.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 572 | VENDOR DUE DILIGENCE

FOUNDATION

Before signing a contract with a SaaS provider that will store customer data, the company reviews the provider's security controls, audit reports, breach history, and subcontractors. What process is this?

- A. Packet capture
- B. Key escrow
- C. Password rotation
- D. Third-party due diligence**

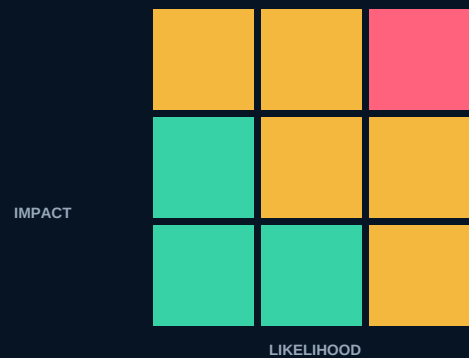
CORRECT ANSWER: D - Third-party due diligence

WHY: Third-party due diligence evaluates supplier risk before or during a business relationship.

MEMORY CUE

Assess vendor security before entrusting data/services.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 573-574

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 573 | RISK MITIGATION

FOUNDATION

An organization installs additional security controls to reduce the probability of a successful attack. This is risk:

A. Mitigation

B. Transfer

C. Avoidance

D. Acceptance

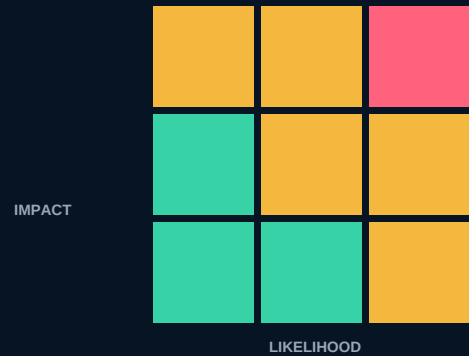
CORRECT ANSWER: A - Mitigation

WHY: Mitigation reduces the likelihood and/or impact of a risk.

MEMORY CUE

Mitigation reduces the likelihood and/or impact of a risk.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 574 | NONDISCLOSURE AGREEMENT

FOUNDATION

A contractor will receive confidential design documents and must legally agree not to disclose them. Which agreement BEST fits?

A. AUP

B. NDA

C. SLA

D. RPO

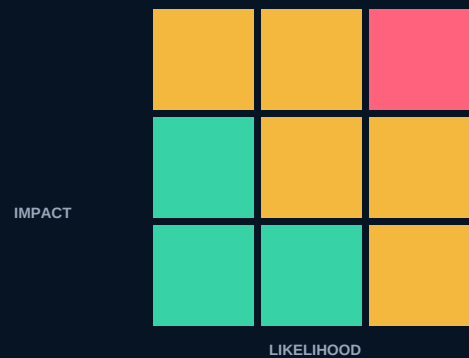
CORRECT ANSWER: B - NDA

WHY: A nondisclosure agreement establishes confidentiality obligations for sensitive information.

MEMORY CUE

NDA = confidentiality agreement.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 575-576

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 575 | RISK ACCEPTANCE

FOUNDATION

A company knowingly continues operating an old system after management formally acknowledges the remaining risk. This is risk:

A. Elimination

B. Avoidance

C. Acceptance

D. Transfer

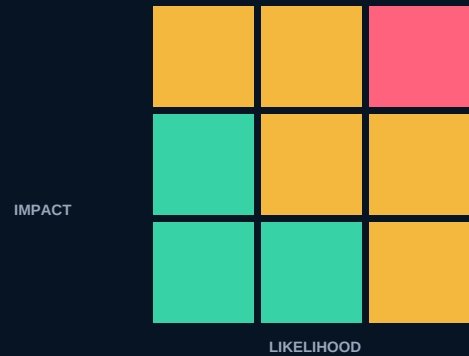
CORRECT ANSWER: C - Acceptance

WHY: Management understands the remaining risk and decides to continue operating. Memorize the four major responses: - Avoid - Mitigate - Transfer - Accept

MEMORY CUE

Management understands the remaining risk and decides to continue operating. Memorize the four major responses: - Avoid - Mitigate - ...

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 576 | ACCEPTABLE USE POLICY

FOUNDATION

Which document defines how employees are permitted to use company computers, networks, email, and internet access?

A. Chain of custody form

B. Certificate policy only

C. SLA

D. Acceptable use policy (AUP)

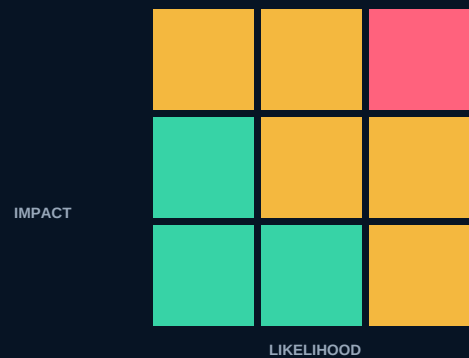
CORRECT ANSWER: D - Acceptable use policy (AUP)

WHY: An AUP defines permitted and prohibited use of organizational technology resources.

MEMORY CUE

AUP = rules for user technology use.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 577-578

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 577 | SLA

FOUNDATION

Which document commonly defines uptime, response time, and other measurable service commitments from a vendor?

A. SLA

B. MOU

C. AUP

D. NDA

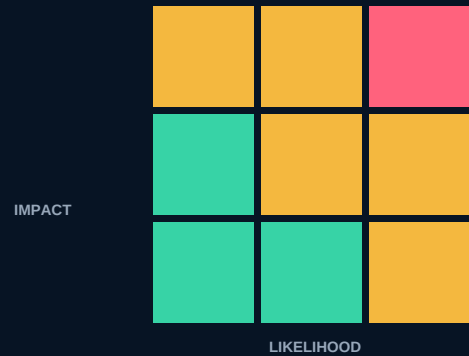
CORRECT ANSWER: A - SLA

WHY: A Service Level Agreement specifies measurable service expectations. Examples: - 99.99% availability - Response within 30 minutes - Recovery within four hours

MEMORY CUE

A Service Level Agreement specifies measurable service expectations. Examples: - 99.99% availability - Response within 30 minutes - ...

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 578 | MASTER SERVICE AGREEMENT

FOUNDATION

A company wants one overarching contract to govern common legal and commercial terms across multiple future work orders with the same supplier. Which document BEST fits?

A. RPO

B. Master service agreement (MSA)

C. AUP

D. Digital certificate

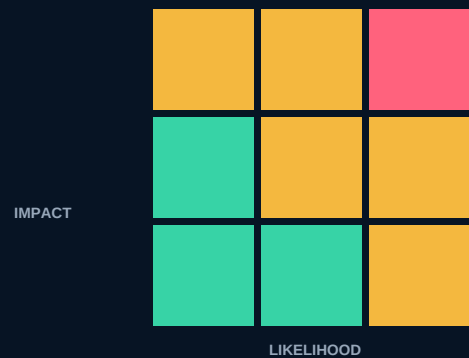
CORRECT ANSWER: B - Master service agreement (MSA)

WHY: An MSA establishes overarching terms that can apply to multiple later statements of work or engagements.

MEMORY CUE

MSA = umbrella agreement for ongoing services.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 579-580

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 579 | MOU

FOUNDATION

Two organizations want to document their intended cooperation but do not necessarily want a detailed service-level contract. Which document is MOST appropriate?

A. Certificate

B. SLA

C. MOU

D. Playbook

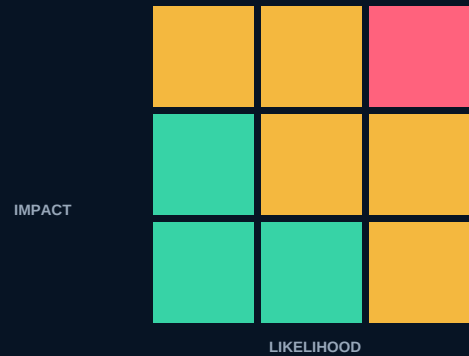
CORRECT ANSWER: C - MOU

WHY: A Memorandum of Understanding documents the intentions and responsibilities of cooperating parties.

MEMORY CUE

A Memorandum of Understanding documents the intentions and responsibilities of cooperating parties.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 580 | STATEMENT OF WORK

FOUNDATION

Which document should define the specific deliverables, scope, schedule, and responsibilities for a particular consulting project?

A. NDA

B. RPO

C. AUP

D. Statement of work (SOW)

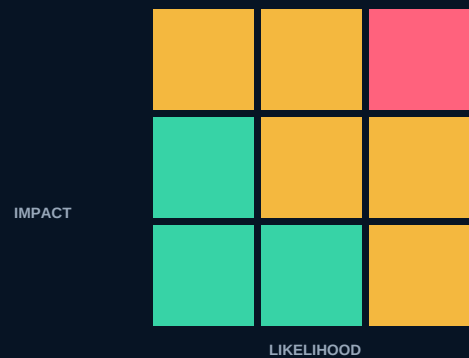
CORRECT ANSWER: D - Statement of work (SOW)

WHY: A SOW defines project-specific scope, deliverables, timelines, and responsibilities.

MEMORY CUE

SOW = what work will be delivered and how.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 581-582

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 581 | THIRD-PARTY RISK

FOUNDATION

Before granting a cloud vendor access to sensitive customer information, which activity BEST addresses third-party risk?

- A. Vendor security assessment
- B. Grant global administrator access
- C. Disable logging
- D. Eliminate contractual requirements

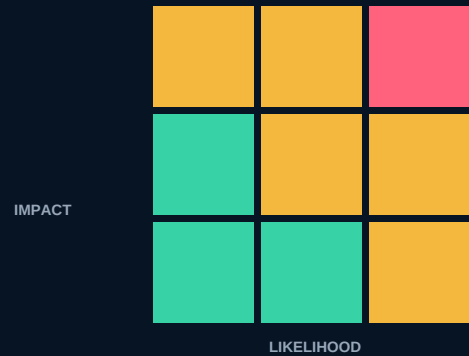
CORRECT ANSWER: A - Vendor security assessment

WHY: Organizations should evaluate vendors' security posture before sharing sensitive information or granting access.

MEMORY CUE

Organizations should evaluate vendors' security posture before sharing sensitive information or granting access.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 582 | REQUEST FOR PROPOSAL

FOUNDATION

An organization publishes requirements and asks vendors to submit competing technical and pricing solutions. What document is being issued?

- A. NDA
- B. Request for proposal (RFP)
- C. SLA only
- D. Chain-of-custody form

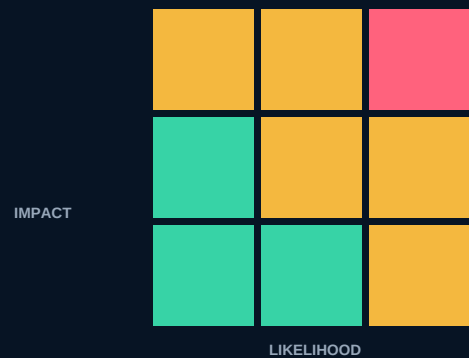
CORRECT ANSWER: B - Request for proposal (RFP)

WHY: An RFP requests proposed solutions and pricing from vendors for defined business requirements.

MEMORY CUE

RFP = invite vendors to propose a solution.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 583-584

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 583 | RECOVERY TIME OBJECTIVE

FOUNDATION

A company's business-impact analysis determines that a payment-processing system can be unavailable for no more than two hours. What does the two-hour value represent?

- A. ARO
- B. RPO
- C. RTO**
- D. SLE

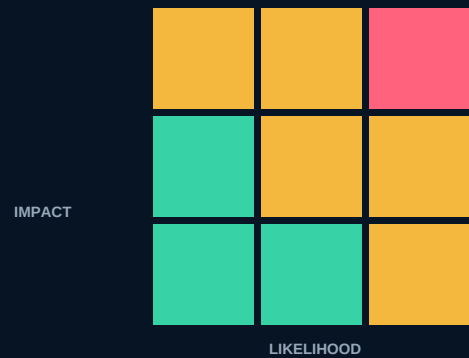
CORRECT ANSWER: C - RTO

WHY: Recovery Time Objective defines how quickly a system or service must be restored after disruption.

MEMORY CUE

Recovery Time Objective defines how quickly a system or service must be restored after disruption.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 584 | DATA OWNER

FOUNDATION

Who is generally responsible for determining the classification and access requirements for a business data set?

- A. Data custodian only
- B. Internet service provider
- C. Certificate authority
- D. Data owner**

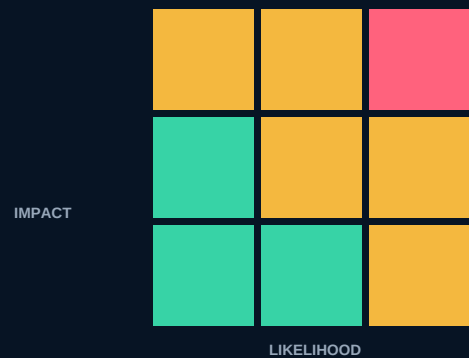
CORRECT ANSWER: D - Data owner

WHY: The data owner is accountable for business decisions such as classification, access, and acceptable handling requirements.

MEMORY CUE

Owner decides classification/access requirements.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 585-586

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 585 | RECOVERY POINT OBJECTIVE

FOUNDATION

The organization determines that no more than 15 minutes of transaction data may be lost after a failure. What does 15 minutes represent?

- A. RPO
- B. ALE
- C. RTO
- D. MTBF

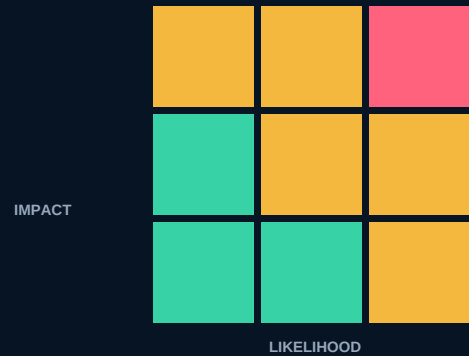
CORRECT ANSWER: A - RPO

WHY: Recovery Point Objective defines the maximum acceptable amount of data loss measured backward in time.

MEMORY CUE

RTO = How long can we be down? RPO = How much data can we lose?

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 586 | DATA CUSTODIAN

FOUNDATION

Which role typically implements storage, backup, access, and technical handling requirements defined by the data owner?

- A. External auditor
- B. Data custodian
- C. Data owner only
- D. Threat actor

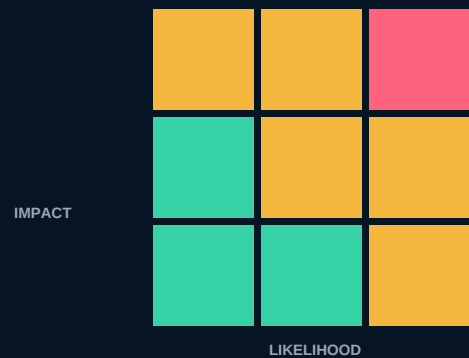
CORRECT ANSWER: B - Data custodian

WHY: A data custodian implements and operates technical controls for data according to owner and policy requirements.

MEMORY CUE

Custodian implements the owner's requirements.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 587-588

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 587 | PHISHING SIMULATION

FOUNDATION

A security team sends simulated phishing messages to employees and records who reports or interacts with them. What is the PRIMARY objective?

- A. Eliminate IAM
- B. Replace endpoint protection
- C. Measure and improve security awareness**
- D. Determine network latency

CORRECT ANSWER: C - Measure and improve security awareness

WHY: Phishing simulations help measure employee behavior and identify opportunities for additional security training.

MEMORY CUE

Phishing simulations help measure employee behavior and identify opportunities for additional security training.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

QUESTION 588 | DATA CLASSIFICATION

FOUNDATION

A company labels information Public, Internal, Confidential, and Restricted to define handling requirements. What process is this?

- A. Password spraying
- B. Load balancing
- C. Packet fragmentation
- D. Data classification**

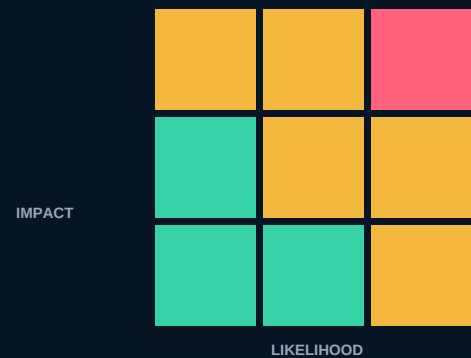
CORRECT ANSWER: D - Data classification

WHY: Data classification categorizes information according to sensitivity, value, or regulatory requirements.

MEMORY CUE

Classification drives handling controls.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 589-590

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 589 | EXTERNAL AUDIT

FOUNDATION

An independent company is hired to examine whether an organization's security controls satisfy stated requirements. This is BEST described as:

- A. External audit
- B. Vulnerability patch
- C. Administrative authentication
- D. Self-assessment

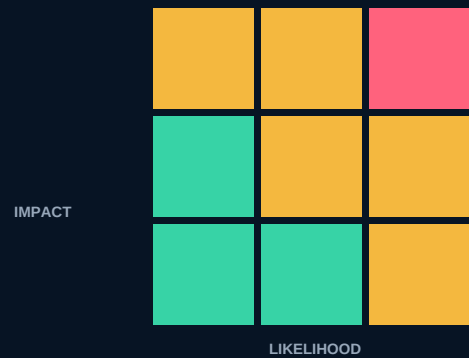
CORRECT ANSWER: A - External audit

WHY: An external audit is conducted by an independent party rather than the organization evaluating itself.

MEMORY CUE

An external audit is conducted by an independent party rather than the organization evaluating itself.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 590 | DATA RETENTION POLICY

FOUNDATION

A regulation requires transaction records to be kept for seven years and then securely disposed of. Which governance control should encode this requirement?

- A. Password policy
- B. Data retention policy
- C. Firewall ACL
- D. Routing protocol

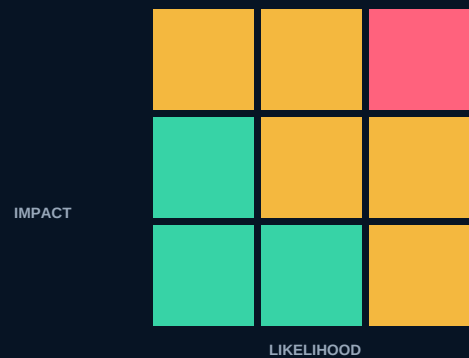
CORRECT ANSWER: B - Data retention policy

WHY: A retention policy defines how long records are kept and when they should be archived or destroyed.

MEMORY CUE

Retention = keep data for defined periods, then dispose.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 591-592

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 591 | ALE FORMULA

FOUNDATION

Which formula is used to calculate annualized loss expectancy?

A. ALE = Asset value / SLE

B. ALE = ARO + SLE

C. ALE = SLE x ARO

D. ALE = CVSS x RPO

CORRECT ANSWER: C - ALE = SLE x ARO

WHY: Annualized loss expectancy equals single loss expectancy multiplied by annualized rate of occurrence.

MEMORY CUE

ALE = SLE x ARO.

Risk / Governance View

SLE = Asset Value x Exposure Factor

ALE = SLE x ARO

Quantify expected loss - then compare control cost and residual risk.

Illustrative study visual - not live production telemetry

QUESTION 592 | REGULATORY REQUIREMENT

FOUNDATION

A healthcare organization implements controls because a law applies to the protected data it handles. What is the PRIMARY driver?

A. User preference

B. Router performance

C. Marketing guideline

D. Regulatory / legal requirement

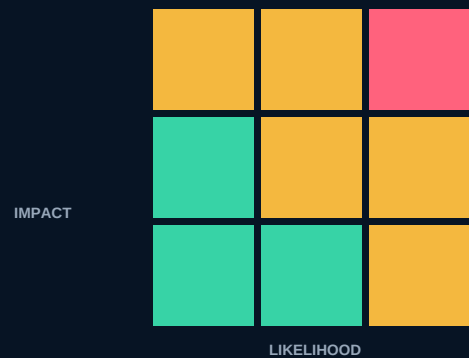
CORRECT ANSWER: D - Regulatory / legal requirement

WHY: Regulatory and legal requirements can mandate specific security, privacy, retention, or reporting obligations.

MEMORY CUE

Law/regulation can impose mandatory controls.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 593-594

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 593 | SINGLE LOSS EXPECTANCY

FOUNDATION

A server is valued at \$200,000. A successful incident is expected to cause 25% loss. What is the SLE?

A. \$50,000

B. \$100,000

C. \$25,000

D. \$200,000

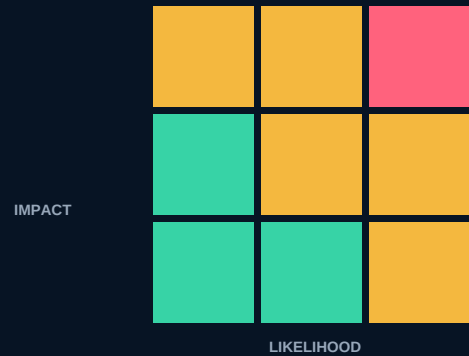
CORRECT ANSWER: A - \$50,000

WHY: $SLE = \text{Asset Value} \times \text{Exposure Factor}$, so $\$200,000 \times 0.25 = \$50,000$.

MEMORY CUE

$SLE = \text{Asset Value} \times \text{Exposure Factor}$.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 594 | GAP ANALYSIS

FOUNDATION

A security team compares current controls with a desired baseline and documents what is missing. What process is this?

A. Data masking

B. Gap analysis

C. Packet capture

D. Password spraying

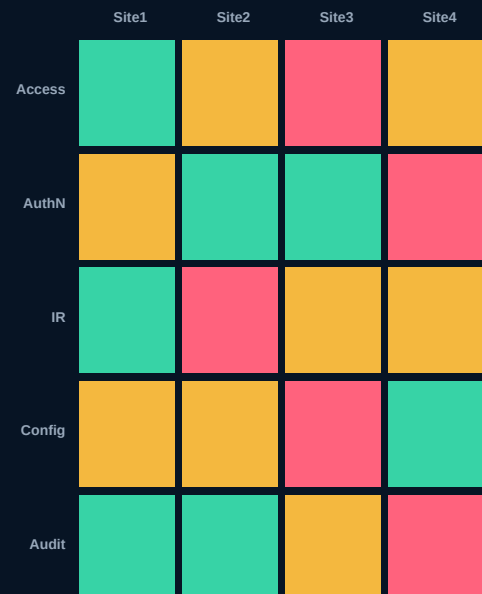
CORRECT ANSWER: B - Gap analysis

WHY: Gap analysis compares the current state to a target state to identify deficiencies and required improvements.

MEMORY CUE

Gap = current state versus desired state.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 595-596

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 595 | ANNUALIZED LOSS EXPECTANCY

FOUNDATION

If the SLE is \$50,000 and an incident is expected once every four years, what is the approximate ALE?

- A. \$200,000
- B. \$50,000
- C. \$12,500**
- D. \$5,000

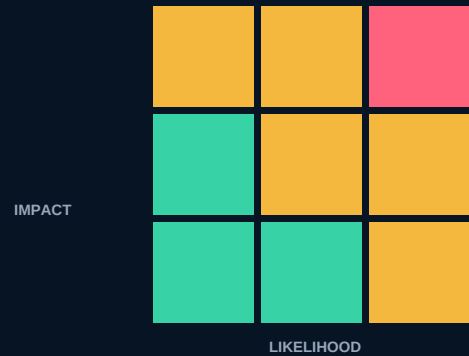
CORRECT ANSWER: C - \$12,500

WHY: Once every four years gives an ARO of 0.25, so $ALE = \$50,000 \times 0.25 = \$12,500$.

MEMORY CUE

Once every four years = ARO 0.25.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 596 | SECURITY BASELINE

FOUNDATION

Before performing a gap analysis, the team selects a defined set of expected security requirements to compare against. What is this reference point?

- A. Threat actor profile
- B. Ransom note
- C. Packet capture
- D. Security baseline**

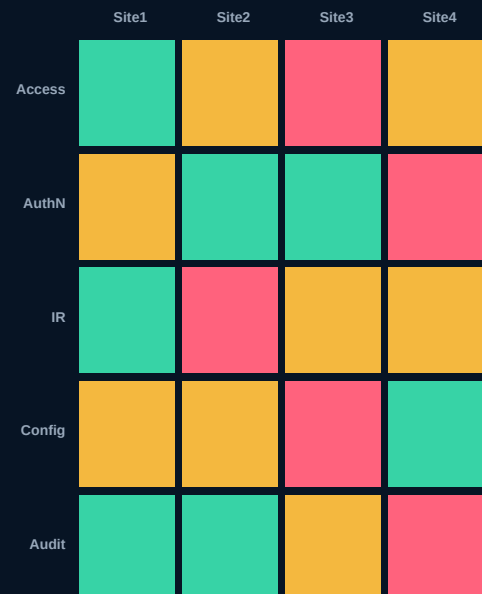
CORRECT ANSWER: D - Security baseline

WHY: A baseline establishes the expected target or minimum control state used for comparison.

MEMORY CUE

Baseline = the reference target.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 597-598

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 597 | NIST SP 800-171

FOUNDATION

A nonfederal contractor handling Controlled Unclassified Information wants a security requirements baseline specifically focused on protecting CUI. Which publication is relevant?

A. NIST SP 800-171

B. SPF

C. PCI token only

D. SAML

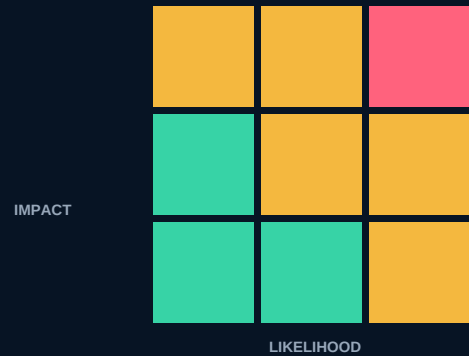
CORRECT ANSWER: A - NIST SP 800-171

WHY: NIST SP 800-171 provides requirements for protecting CUI in nonfederal systems and organizations.

MEMORY CUE

800-171 = CUI protection requirements.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 598 | ISO/IEC 27001

FOUNDATION

An organization wants an international standard for establishing and maintaining an information security management system. Which standard BEST fits?

A. CVSS

B. ISO/IEC 27001

C. SMTP

D. RADIUS

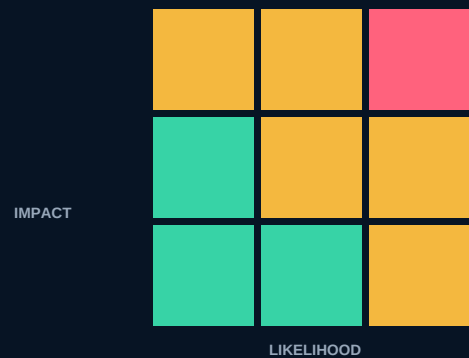
CORRECT ANSWER: B - ISO/IEC 27001

WHY: ISO/IEC 27001 specifies requirements for an information security management system (ISMS).

MEMORY CUE

27001 = ISMS standard.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 599-600

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 599 | GAP PRIORITIZATION

FOUNDATION

A gap-analysis heat map shows one location with several red control deficiencies, two yellow deficiencies, and many green areas. Where should remediation generally begin?

- A. Randomly selected controls
- B. The green controls first
- C. The highest-risk red gaps**
- D. Only the easiest low-impact item

CORRECT ANSWER: C - The highest-risk red gaps

WHY: High-risk or materially deficient gaps are generally prioritized first based on risk, impact, dependencies, and feasibility.

MEMORY CUE

Red/high-risk gaps first, then lower priorities.

Risk / Governance View

	Site1	Site2	Site3	Site4
Access	Green	Yellow	Red	Yellow
AuthN	Yellow	Green	Green	Red
IR	Green	Red	Yellow	Yellow
Config	Yellow	Yellow	Red	Green
Audit	Green	Green	Yellow	Red

Illustrative study visual - not live production telemetry

QUESTION 600 | INTERNAL AUDIT

FOUNDATION

Employees from the organization's independent internal audit function review whether security processes follow company policy. What type of audit is this?

- A. Vendor onboarding
- B. Penetration exploit
- C. External audit
- D. Internal audit**

CORRECT ANSWER: D - Internal audit

WHY: An internal audit is performed by or on behalf of the organization's internal assurance function.

MEMORY CUE

Internal audit = assurance from inside the organization.

Risk / Governance View

	Low	Medium	High
High	Yellow	Yellow	Red
Medium	Green	Yellow	Yellow
Low	Green	Green	Yellow

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 601-602

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 601 | ATTESTATION

FOUNDATION

A qualified independent party provides a formal statement about whether specified controls meet defined criteria. What is this formal assertion called?

A. Attestation

- B. Password spray
- C. Packet capture
- D. DNS sinkhole

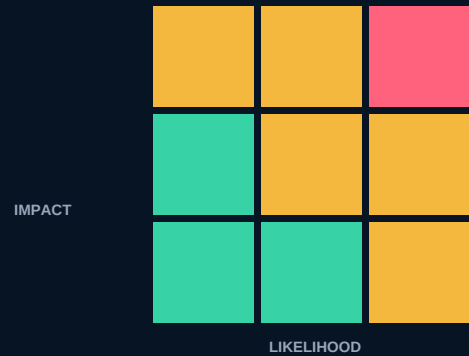
CORRECT ANSWER: A - Attestation

WHY: Attestation is a formal assertion or report regarding compliance or control conditions, often issued by an independent assessor.

MEMORY CUE

Attestation = formal assurance statement.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 602 | COMPLIANCE ASSESSMENT

FOUNDATION

A security team evaluates whether implemented controls satisfy a specific regulatory or contractual requirement set. What activity is being performed?

- A. Packet fragmentation
- B. Compliance assessment**
- C. Ransomware containment
- D. ARP inspection

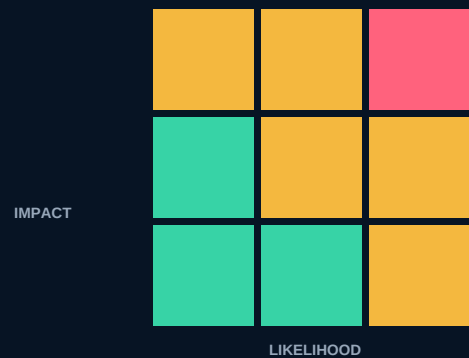
CORRECT ANSWER: B - Compliance assessment

WHY: A compliance assessment measures adherence to required standards, regulations, or contractual obligations.

MEMORY CUE

Compliance = are required obligations being met?

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 603-604

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 603 | TABLETOP EXERCISE

FOUNDATION

Leaders and technical staff walk through a hypothetical ransomware event in a meeting without actually disrupting production systems. What exercise is this?

- A. Credential stuffing
- B. Packet capture
- C. Tabletop exercise**
- D. Full interruption test

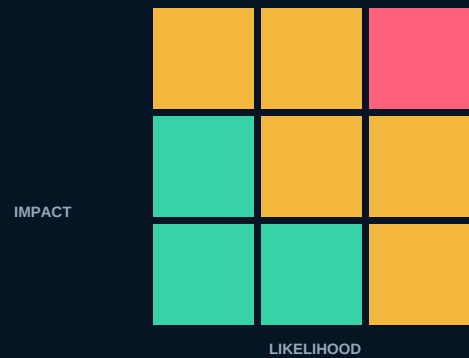
CORRECT ANSWER: C - Tabletop exercise

WHY: A tabletop exercise is a discussion-based simulation used to validate roles, decisions, communications, and procedures.

MEMORY CUE

Tabletop = discussion-based incident rehearsal.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 604 | ROLE-BASED TRAINING

FOUNDATION

Database administrators receive specialized secure-configuration training that general office users do not receive. What type of awareness approach is this?

- A. Load balancing
- B. Open access
- C. Data masking
- D. Role-based security training**

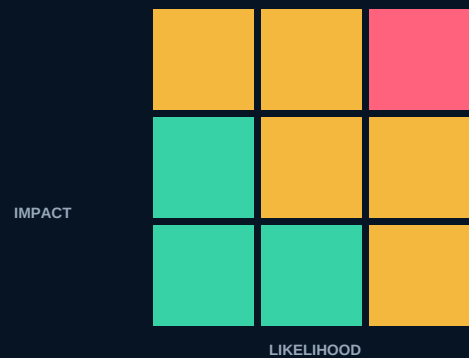
CORRECT ANSWER: D - Role-based security training

WHY: Role-based training tailors security education to responsibilities and risks associated with a specific job function.

MEMORY CUE

Training should match the user's role and risk.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 605-606

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 605 | CHANGE APPROVAL

FOUNDATION

Before a firewall policy is deployed to production, the proposed rule is reviewed for risk and approved through the change process. What control is being exercised?

A. Change approval

- B. Data remanence
- C. DNS tunneling
- D. Password spraying

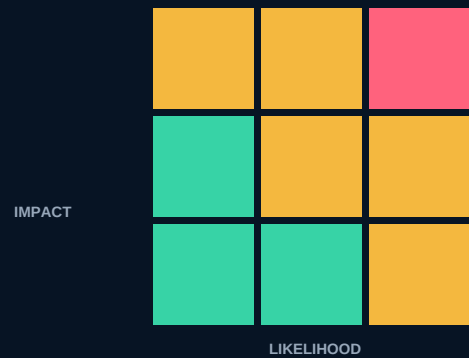
CORRECT ANSWER: A - Change approval

WHY: Formal approval helps ensure production changes are authorized, reviewed, and accountable.

MEMORY CUE

Production changes should be reviewed and authorized.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 606 | ROLLBACK PLAN

FOUNDATION

A change request includes the exact steps required to restore the previous firewall configuration if the new policy causes an outage. What is this plan called?

- A. RPO
- B. Rollback plan**
- C. NDA
- D. Data classification

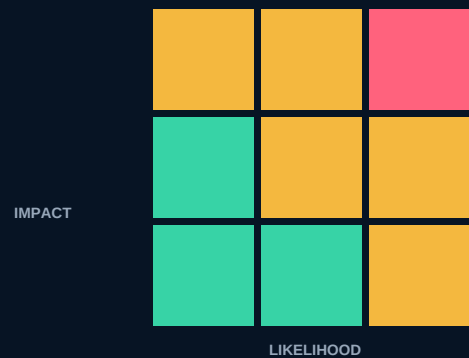
CORRECT ANSWER: B - Rollback plan

WHY: A rollback plan defines how to reverse a change and return to a known-good prior state.

MEMORY CUE

Rollback = how to undo the change safely.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 607-608

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 607 | VERSION CONTROL

FOUNDATION

Security configuration files are stored in Git so reviewers can see who changed them, compare revisions, and restore earlier versions. Which practice is this?

- A. Packet capture
- B. Data masking
- C. Version control**
- D. Cold storage only

CORRECT ANSWER: C - Version control

WHY: Version control tracks changes to files over time and supports review, accountability, and rollback.

MEMORY CUE

Version control = history + diff + rollback.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

QUESTION 608 | BUSINESS CONTINUITY

FOUNDATION

A plan describes how critical business functions will continue operating during a prolonged technology disruption. What type of plan is this?

- A. Password policy
- B. Data mask
- C. Certificate revocation list
- D. Business continuity plan (BCP)**

CORRECT ANSWER: D - Business continuity plan (BCP)

WHY: Business continuity focuses on maintaining essential business operations during disruptive events.

MEMORY CUE

BCP = keep critical business functions operating.

Risk / Governance View

IMPACT

LIKELIHOOD

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 609-610

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 609 | DISASTER RECOVERY EXERCISE

FOUNDATION

A company restores systems from backups in an alternate environment to verify that documented recovery procedures actually work. What activity is this?

A. Disaster recovery exercise / test

- B. Data classification
- C. Password spraying
- D. Whaling simulation only

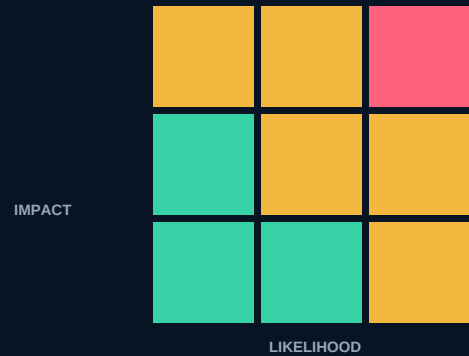
CORRECT ANSWER: A - Disaster recovery exercise / test

WHY: DR testing validates that recovery procedures, backups, infrastructure, and personnel can restore services as intended.

MEMORY CUE

Test recovery, do not assume it works.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 610 | KEY RISK INDICATOR

FOUNDATION

Management tracks the percentage of critical vulnerabilities older than 30 days to identify increasing security exposure. What type of metric is this?

- A. RPO
- B. Key risk indicator (KRI)**
- C. Digital signature
- D. Certificate chain

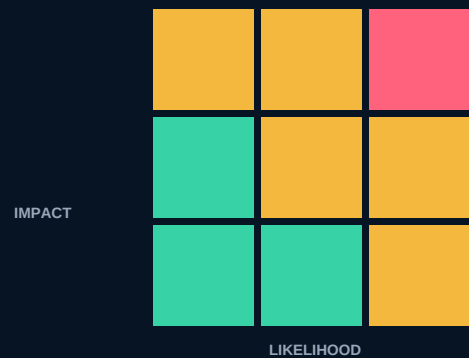
CORRECT ANSWER: B - Key risk indicator (KRI)

WHY: A KRI is a metric designed to indicate changing risk exposure or the likelihood of adverse outcomes.

MEMORY CUE

KRI = metric that signals risk trend.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 611-612

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 611 | ISO/IEC 27001

APPLIED

During a governance and risk review, a multinational organization wants an international standard for establishing and maintaining an information security management system. Which standard BEST fits?

- A. SMTP
- B. RADIUS

C. ISO/IEC 27001

D. CVSS

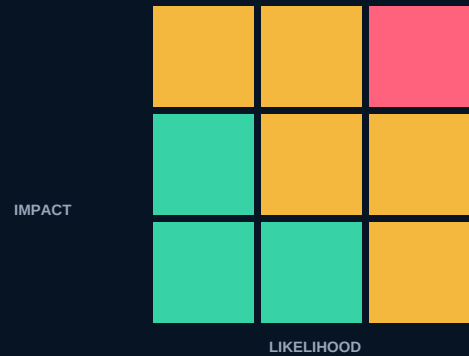
CORRECT ANSWER: C - ISO/IEC 27001

WHY: ISO/IEC 27001 specifies requirements for an information security management system (ISMS).

MEMORY CUE

27001 = ISMS standard.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 612 | VENDOR DUE DILIGENCE

APPLIED

In a separate enterprise scenario, before signing a contract with a SaaS provider that will store customer data, the company reviews the provider's security controls, audit reports, breach history, and subcontractors. What process is this?

- A. Password rotation
- B. Key escrow
- C. Packet capture

D. Third-party due diligence

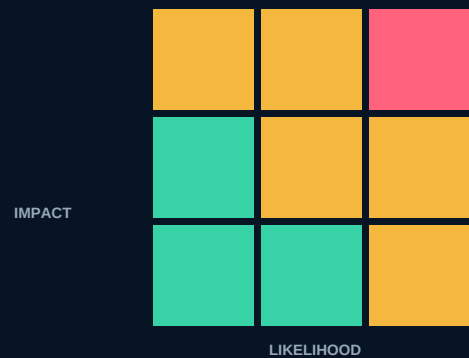
CORRECT ANSWER: D - Third-party due diligence

WHY: Third-party due diligence evaluates supplier risk before or during a business relationship.

MEMORY CUE

Assess vendor security before entrusting data/services.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 613-614

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 613 | ANNUALIZED LOSS EXPECTANCY

APPLIED

In a separate enterprise scenario, if the SLE is \$50,000 and an incident is expected once every four years, what is the approximate ALE?

A. \$12,500

B. \$5,000

C. \$200,000

D. \$50,000

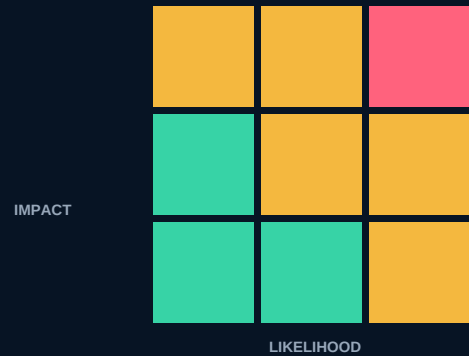
CORRECT ANSWER: A - \$12,500

WHY: Once every four years gives an ARO of 0.25, so $ALE = \$50,000 \times 0.25 = \$12,500$.

MEMORY CUE

Once every four years = ARO 0.25.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 614 | RECOVERY POINT OBJECTIVE

APPLIED

The enterprise determines that no more than 15 minutes of transaction data may be lost after a failure. What does 15 minutes represent?

A. MTBF

B. RPO

C. RTO

D. ALE

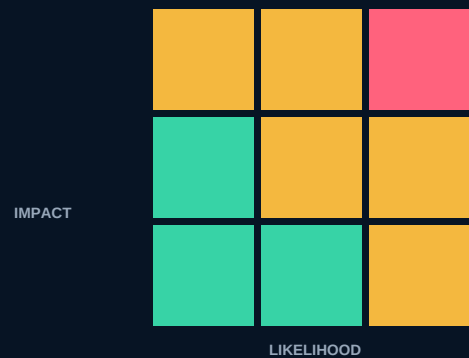
CORRECT ANSWER: B - RPO

WHY: Recovery Point Objective defines the maximum acceptable amount of data loss measured backward in time.

MEMORY CUE

RTO = How long can we be down? RPO = How much data can we lose?

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 615-616

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 615 | THIRD-PARTY RISK

APPLIED

In a separate enterprise scenario, before granting a cloud vendor access to sensitive customer information, which activity BEST addresses third-party risk?

- A. Disable logging
- B. Eliminate contractual requirements
- C. Vendor security assessment**
- D. Grant global administrator access

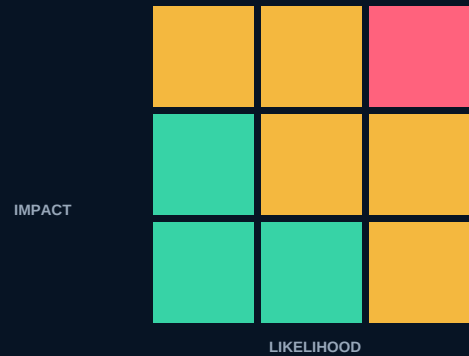
CORRECT ANSWER: C - Vendor security assessment

WHY: Organizations should evaluate vendors' security posture before sharing sensitive information or granting access.

MEMORY CUE

Organizations should evaluate vendors' security posture before sharing sensitive information or granting access.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 616 | ALE FORMULA

APPLIED

In a separate enterprise scenario, which formula is used to calculate annualized loss expectancy?

- A. $ALE = CVSS \times RPO$
- B. $ALE = \text{Asset value} / SLE$
- C. $ALE = ARO + SLE$
- D. $ALE = SLE \times ARO$**

CORRECT ANSWER: D - $ALE = SLE \times ARO$

WHY: Annualized loss expectancy equals single loss expectancy multiplied by annualized rate of occurrence.

MEMORY CUE

$ALE = SLE \times ARO$.

Risk / Governance View

$SLE = \text{Asset Value} \times \text{Exposure Factor}$

$ALE = SLE \times ARO$

Quantify expected loss - then compare control cost and residual risk.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 617-618

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 617 | ATTESTATION

APPLIED

In a separate enterprise scenario, a qualified independent party provides a formal statement about whether specified controls meet defined criteria. What is this formal assertion called?

- A. Attestation
- B. Packet capture
- C. DNS sinkhole
- D. Password spray

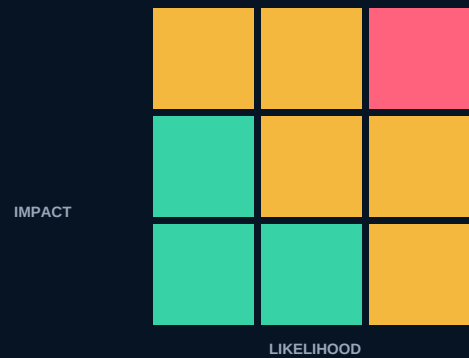
CORRECT ANSWER: A - Attestation

WHY: Attestation is a formal assertion or report regarding compliance or control conditions, often issued by an independent assessor.

MEMORY CUE

Attestation = formal assurance statement.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 618 | PHISHING SIMULATION

APPLIED

In a separate enterprise scenario, a security team sends simulated phishing messages to employees and records who reports or interacts with them. What is the PRIMARY objective?

- A. Determine network latency
- B. Measure and improve security awareness
- C. Replace endpoint protection
- D. Eliminate IAM

CORRECT ANSWER: B - Measure and improve security awareness

WHY: Phishing simulations help measure employee behavior and identify opportunities for additional security training.

MEMORY CUE

Phishing simulations help measure employee behavior and identify opportunities for additional security training.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 619-620

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 619 | REQUEST FOR PROPOSAL

APPLIED

During a governance and risk review, an organization publishes requirements and asks vendors to submit competing technical and pricing solutions. What document is being issued?

- A. NDA
- B. Chain-of-custody form
- C. Request for proposal (RFP)**
- D. SLA only

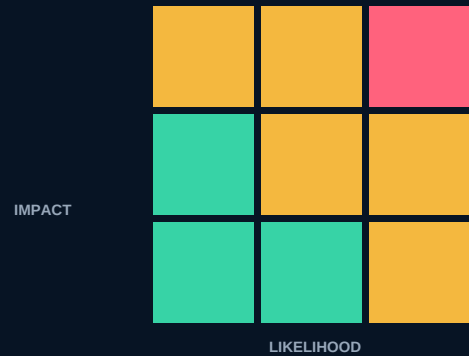
CORRECT ANSWER: C - Request for proposal (RFP)

WHY: An RFP requests proposed solutions and pricing from vendors for defined business requirements.

MEMORY CUE

RFP = invite vendors to propose a solution.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 620 | RISK MITIGATION

APPLIED

In a separate enterprise scenario, an organization installs additional security controls to reduce the probability of a successful attack. This is risk:

- A. Acceptance
- B. Transfer
- C. Avoidance
- D. Mitigation**

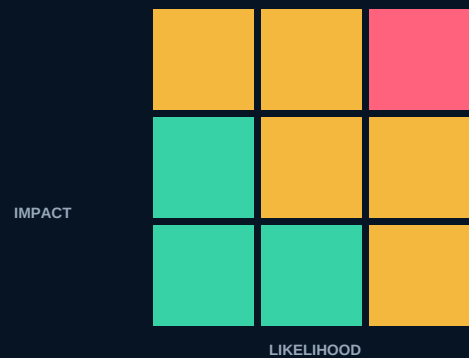
CORRECT ANSWER: D - Mitigation

WHY: Mitigation reduces the likelihood and/or impact of a risk.

MEMORY CUE

Mitigation reduces the likelihood and/or impact of a risk.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 621-623

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 621 | STANDARD

APPLIED

What document normally specifies mandatory technical requirements, such as requiring AES-256 for particular data?

- A. Standard
- B. Guideline
- C. Marketing plan
- D. Incident ticket

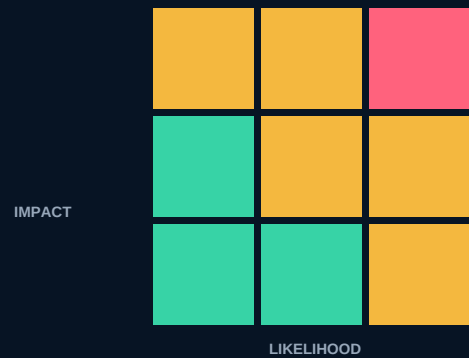
CORRECT ANSWER: A - Standard

WHY: Standards define mandatory requirements used to support organizational policies.

MEMORY CUE

Standards define mandatory requirements used to support organizational policies.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 623 | BUSINESS CONTINUITY

APPLIED

During a governance and risk review, a plan describes how critical business functions will continue operating during a prolonged technology disruption. What type of plan is this?

- A. Data mask
- B. Certificate revocation list
- C. Business continuity plan (BCP)
- D. Password policy

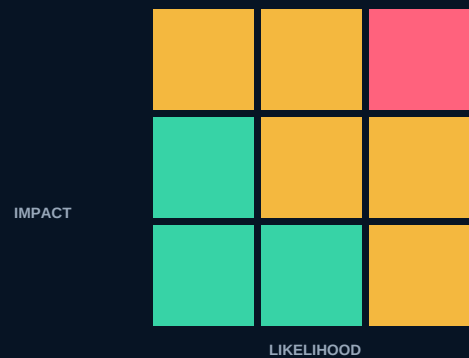
CORRECT ANSWER: C - Business continuity plan (BCP)

WHY: Business continuity focuses on maintaining essential business operations during disruptive events.

MEMORY CUE

BCP = keep critical business functions operating.

Risk / Governance View



Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 622

Immediate answers, concise rationales, and visual memory anchors.

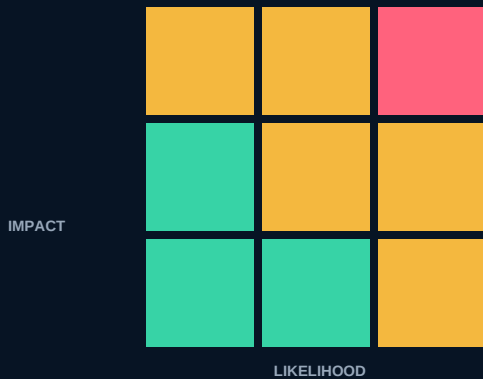
ANALYST TASK | ANNUALIZED RATE OF OCCURRENCE

During a governance and risk review, a flood affecting a particular site is estimated to occur once every five years. What is the ARO?

- A. 5.0
- B. 0.2
- C. 0.02
- D. 20

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Risk / Governance View



CORRECT ANSWER: B - 0.2

RATIONALE ARO expresses expected annual frequency; once every five years equals $1/5$ or 0.2 per year.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 624-625

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 624 | SECURITY BASELINE

APPLIED

In a separate enterprise scenario, before performing a gap analysis, the team selects a defined set of expected security requirements to compare against. What is this reference point?

- A. Packet capture
- B. Ransom note
- C. Threat actor profile

D. Security baseline

CORRECT ANSWER: D - Security baseline

WHY: A baseline establishes the expected target or minimum control state used for comparison.

MEMORY CUE

Baseline = the reference target.

● ● ● Risk / Governance View

	Site1	Site2	Site3	Site4
Access	Green	Yellow	Red	Yellow
AuthN	Yellow	Green	Green	Red
IR	Green	Red	Yellow	Yellow
Config	Yellow	Yellow	Red	Green
Audit	Green	Green	Yellow	Red

QUESTION 625 | MASTER SERVICE AGREEMENT

APPLIED

During a governance and risk review, a regional enterprise wants one overarching contract to govern common legal and commercial terms across multiple future work orders with the same supplier. What document BEST fits?

- A. Master service agreement (MSA)**
- B. Digital certificate
- C. AUP
- D. RPO

CORRECT ANSWER: A - Master service agreement (MSA)

WHY: An MSA establishes overarching terms that can apply to multiple later statements of work or engagements.

MEMORY CUE

MSA = umbrella agreement for ongoing services.

● ● ● Risk / Governance View

Security+ Master Visual Review | Questions 626-627

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 626 | RISK ACCEPTANCE

APPLIED

A regional enterprise knowingly continues operating an old system after management formally acknowledges the remaining risk. This is risk:

- B. Acceptance**

CORRECT ANSWER: B - Acceptance

WHY: Management understands the remaining risk and decides to continue operating. Memorize the four major responses: - Avoid - Mitigate - Transfer - Accept

MEMORY CUE

Management understands the remaining risk and decides to continue operating. Memorize the four major responses: - Avoid - Mitigate - ...

QUESTION 627 | DISASTER RECOVERY EXERCISE

APPLIED

In a separate enterprise scenario, a company restores systems from backups in an alternate environment to verify that documented recovery procedures actually work. What activity is this?

- A. Whaling simulation only
- B. Data classification
- C. Disaster recovery exercise / test**
- D. Password spraying

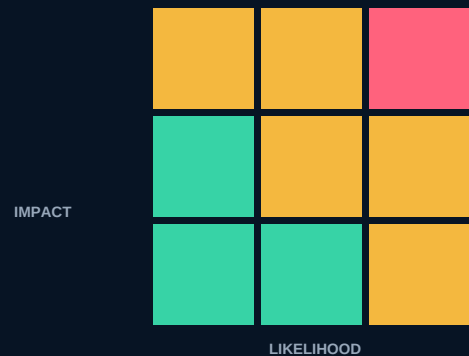
CORRECT ANSWER: C - Disaster recovery exercise / test

WHY: DR testing validates that recovery procedures, backups, infrastructure, and personnel can restore services as intended.

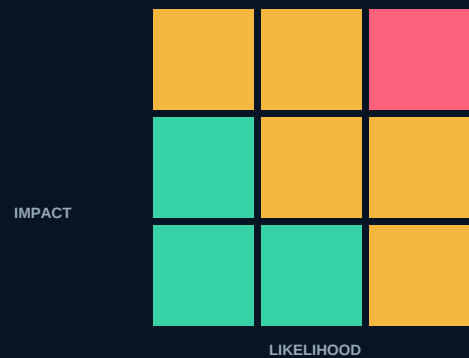
MEMORY CUE

Test recovery, do not assume it works.

 Risk / Governance View



● ● ● Risk / Governance View



Security+ Master Visual Review | Questions 628-629

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 628 | EXTERNAL AUDIT

APPLIED

In a separate enterprise scenario, an independent company is hired to examine whether an organization's security controls satisfy stated requirements. This is BEST described as:

- A. Administrative authentication
- B. Self-assessment
- C. Vulnerability patch

D. External audit

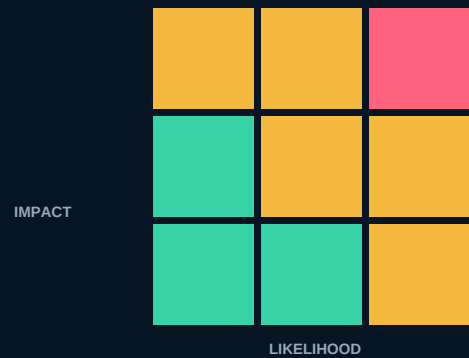
CORRECT ANSWER: D - External audit

WHY: An external audit is conducted by an independent party rather than the organization evaluating itself.

MEMORY CUE

An external audit is conducted by an independent party rather than the organization evaluating itself.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 629 | CHANGE APPROVAL

APPLIED

In a separate enterprise scenario, before a firewall policy is deployed to production, the proposed rule is reviewed for risk and approved through the change process. What control is being exercised?

- A. Change approval**
- B. Data remanence
- C. Password spraying
- D. DNS tunneling

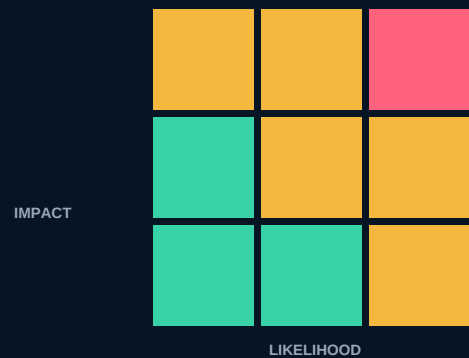
CORRECT ANSWER: A - Change approval

WHY: Formal approval helps ensure production changes are authorized, reviewed, and accountable.

MEMORY CUE

Production changes should be reviewed and authorized.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 630-631

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 630 | KEY RISK INDICATOR

APPLIED

During a governance and risk review, management tracks the percentage of critical vulnerabilities older than 30 days to identify increasing security exposure. What type of metric is this?

A. Certificate chain

B. Key risk indicator (KRI)

C. RPO

D. Digital signature

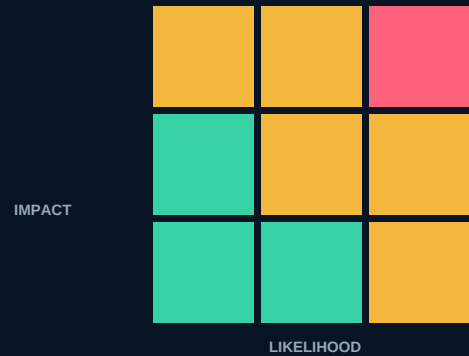
CORRECT ANSWER: B - Key risk indicator (KRI)

WHY: A KRI is a metric designed to indicate changing risk exposure or the likelihood of adverse outcomes.

MEMORY CUE

KRI = metric that signals risk trend.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 631 | DATA CLASSIFICATION

APPLIED

During a governance and risk review, a company labels information Public, Internal, Confidential, and Restricted to define handling requirements. What process is this?

A. Packet fragmentation

B. Load balancing

C. Data classification

D. Password spraying

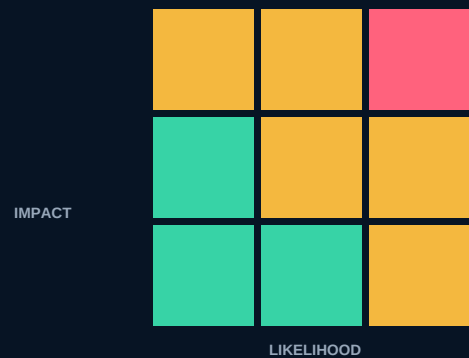
CORRECT ANSWER: C - Data classification

WHY: Data classification categorizes information according to sensitivity, value, or regulatory requirements.

MEMORY CUE

Classification drives handling controls.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 634-635

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 634 | TABLETOP EXERCISE

APPLIED

In a separate enterprise scenario, leaders and technical staff walk through a hypothetical ransomware event in a meeting without actually disrupting production systems. What exercise is this?

- A. Full interruption test
- B. Tabletop exercise**
- C. Credential stuffing
- D. Packet capture

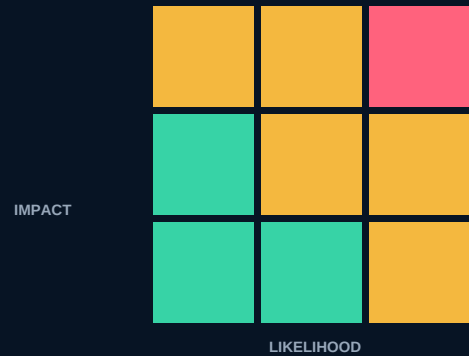
CORRECT ANSWER: B - Tabletop exercise

WHY: A tabletop exercise is a discussion-based simulation used to validate roles, decisions, communications, and procedures.

MEMORY CUE

Tabletop = discussion-based incident rehearsal.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 635 | DATA OWNER

APPLIED

During a governance and risk review, who is generally responsible for determining the classification and access requirements for a business data set?

- A. Certificate authority
- B. Data custodian only
- C. Data owner**
- D. Internet service provider

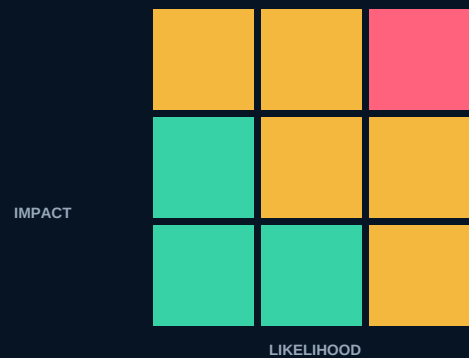
CORRECT ANSWER: C - Data owner

WHY: The data owner is accountable for business decisions such as classification, access, and acceptable handling requirements.

MEMORY CUE

Owner decides classification/access requirements.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 636-637

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 636 | RECOVERY TIME OBJECTIVE

APPLIED

In a separate enterprise scenario, a company's business-impact analysis determines that a payment-processing system can be unavailable for no more than two hours. What does the two-hour value represent?

- A. SLE
- B. ARO
- C. RPO

D. RTO

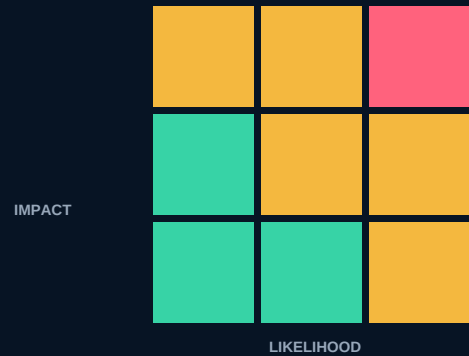
CORRECT ANSWER: D - RTO

WHY: Recovery Time Objective defines how quickly a system or service must be restored after disruption.

MEMORY CUE

Recovery Time Objective defines how quickly a system or service must be restored after disruption.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 637 | RISK TOLERANCE

APPLIED

In a separate enterprise scenario, management decides that losses of up to \$100,000 annually from a specific risk are acceptable. This describes:

- A. Risk tolerance**
- B. Encryption
- C. Federation
- D. Non-repudiation

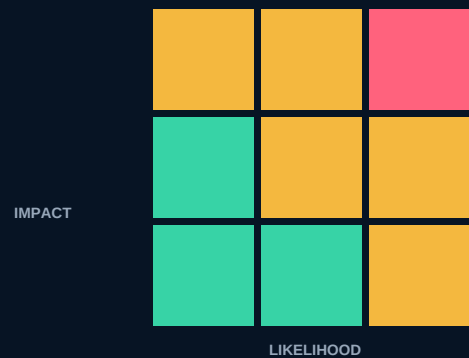
CORRECT ANSWER: A - Risk tolerance

WHY: Risk tolerance identifies the amount of risk or variation an organization is willing to accept.

MEMORY CUE

Risk tolerance identifies the amount of risk or variation an organization is willing to accept.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 638-639

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 638 | POLICY

APPLIED

In a separate enterprise scenario, which document provides high-level management expectations for information security?

- A. Routing table
- B. Policy**
- C. Hash
- D. Packet capture

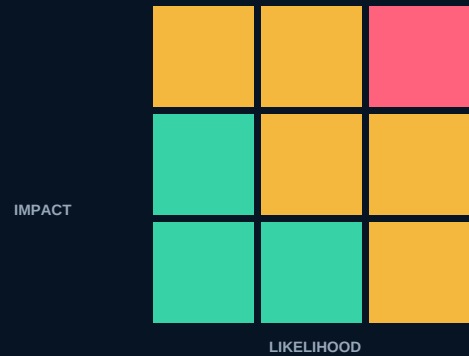
CORRECT ANSWER: B - Policy

WHY: Policies establish management's high-level requirements and organizational expectations.

MEMORY CUE

Policies establish management's high-level requirements and organizational expectations.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 639 | RISK APPETITE

APPLIED

During a governance and risk review, senior leadership states that the organization is willing to pursue aggressive cloud innovation even if it increases some operational security risk. What concept is being expressed?

- A. RPO
- B. SLE
- C. Risk appetite**
- D. Chain of custody

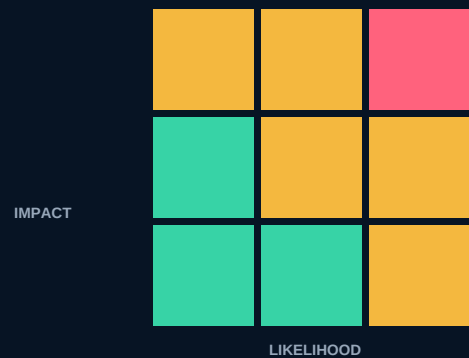
CORRECT ANSWER: C - Risk appetite

WHY: Risk appetite is the broad amount and type of risk an organization is willing to pursue or retain to achieve objectives.

MEMORY CUE

Risk appetite = broad willingness to take risk.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 640-641

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 640 | GAP PRIORITIZATION

APPLIED

In a separate enterprise scenario, a gap-analysis heat map shows one location with several red control deficiencies, two yellow deficiencies, and many green areas. Where should remediation generally begin?

- A. The green controls first
- B. Only the easiest low-impact item
- C. Randomly selected controls

D. The highest-risk red gaps

CORRECT ANSWER: D - The highest-risk red gaps

WHY: High-risk or materially deficient gaps are generally prioritized first based on risk, impact, dependencies, and feasibility.

MEMORY CUE

Red/high-risk gaps first, then lower priorities.

Risk / Governance View

	Site1	Site2	Site3	Site4
Access	Green	Yellow	Red	Yellow
AuthN	Yellow	Green	Green	Red
IR	Green	Red	Yellow	Yellow
Config	Yellow	Yellow	Red	Green
Audit	Green	Green	Yellow	Red

Illustrative study visual - not live production telemetry

QUESTION 641 | STATEMENT OF WORK

APPLIED

During a governance and risk review, which document should define the specific deliverables, scope, schedule, and responsibilities for a particular consulting project?

A. Statement of work (SOW)

- B. NDA
- C. RPO
- D. AUP

CORRECT ANSWER: A - Statement of work (SOW)

WHY: A SOW defines project-specific scope, deliverables, timelines, and responsibilities.

MEMORY CUE

SOW = what work will be delivered and how.

Risk / Governance View

	Low	Medium	High
High	Yellow	Yellow	Red
Medium	Green	Yellow	Yellow
Low	Green	Green	Yellow

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 642-643

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 642 | NIST SP 800-171

APPLIED

In a separate enterprise scenario, a nonfederal contractor handling Controlled Unclassified Information wants a security requirements baseline specifically focused on protecting CUI. Which publication is relevant?

A. SPF

B. NIST SP 800-171

C. SAML

D. PCI token only

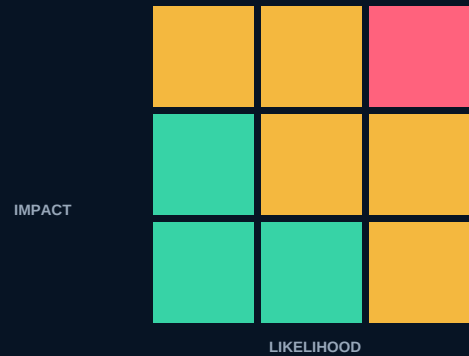
CORRECT ANSWER: B - NIST SP 800-171

WHY: NIST SP 800-171 provides requirements for protecting CUI in nonfederal systems and organizations.

MEMORY CUE

800-171 = CUI protection requirements.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 643 | DATA CUSTODIAN

APPLIED

During a governance and risk review, which role typically implements storage, backup, access, and technical handling requirements defined by the data owner?

A. Threat actor

B. Data owner only

C. Data custodian

D. External auditor

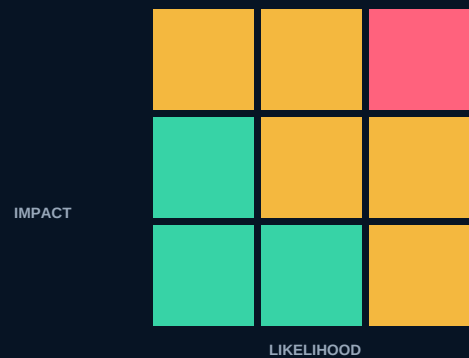
CORRECT ANSWER: C - Data custodian

WHY: A data custodian implements and operates technical controls for data according to owner and policy requirements.

MEMORY CUE

Custodian implements the owner's requirements.

Risk / Governance View



Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 644

Immediate answers, concise rationales, and visual memory anchors.

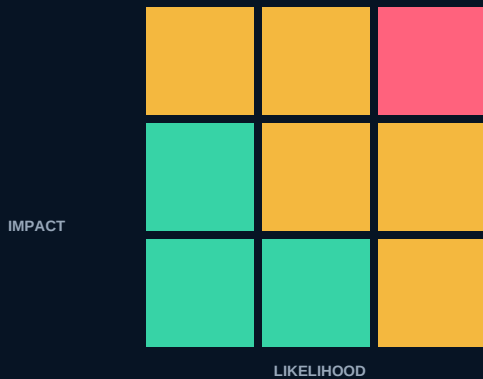
ANALYST TASK | NONDISCLOSURE AGREEMENT

During a governance and risk review, a contractor will receive confidential design documents and must legally agree not to disclose them. Which agreement BEST fits?

- A. SLA
- B. AUP
- C. RPO
- D. NDA

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Risk / Governance View



CORRECT ANSWER: D - NDA

RATIONALE

A nondisclosure agreement establishes confidentiality obligations for sensitive information.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 645-646

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 645 | ACCEPTABLE USE POLICY

APPLIED

During a governance and risk review, which document defines how employees are permitted to use company computers, networks, email, and internet access?

A. Acceptable use policy (AUP)

B. Chain of custody form

C. Certificate policy only

D. SLA

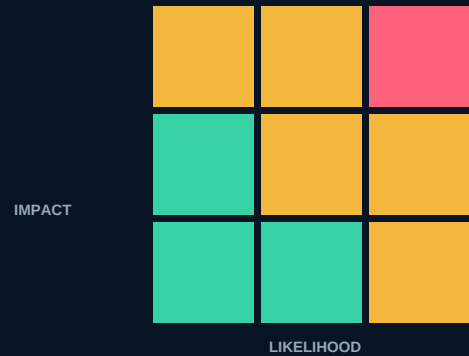
CORRECT ANSWER: A - Acceptable use policy (AUP)

WHY: An AUP defines permitted and prohibited use of organizational technology resources.

MEMORY CUE

AUP = rules for user technology use.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 646 | EXPOSURE FACTOR

APPLIED

During a governance and risk review, a \$400,000 asset would lose an estimated 30% of its value in a specific incident. What does the 30% represent in quantitative risk analysis?

A. ARO

B. Exposure factor (EF)

C. RTO

D. ALE

CORRECT ANSWER: B - Exposure factor (EF)

WHY: Exposure factor is the percentage of asset value expected to be lost from a single event.

MEMORY CUE

EF = percent loss from one event.

Risk / Governance View

$$\text{SLE} = \text{Asset Value} \times \text{Exposure Factor}$$

$$\text{ALE} = \text{SLE} \times \text{ARO}$$

Quantify expected loss - then compare control cost and residual risk.

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 647-648

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 647 | GUIDELINE

APPLIED

During a governance and risk review, which governance document provides recommended practices but generally allows flexibility rather than imposing a mandatory requirement?

- A. Policy
- B. Procedure
- C. Guideline**
- D. Standard

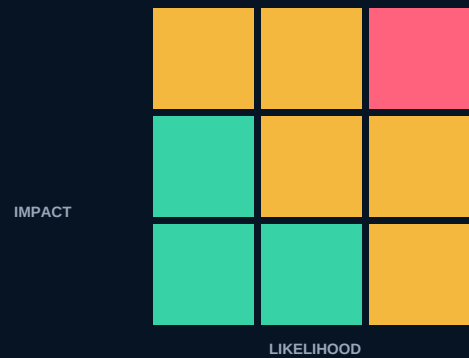
CORRECT ANSWER: C - Guideline

WHY: A guideline provides recommended approaches or best practices and is generally less mandatory than a standard.

MEMORY CUE

Guideline = recommended, not usually mandatory.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 648 | MOU

APPLIED

In a separate enterprise scenario, two organizations want to document their intended cooperation but do not necessarily want a detailed service-level contract. Which document is MOST appropriate?

- A. Playbook
- B. Certificate
- C. SLA
- D. MOU**

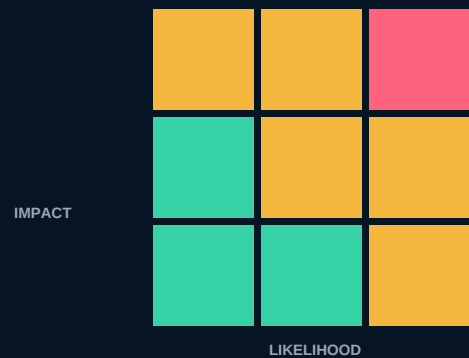
CORRECT ANSWER: D - MOU

WHY: A Memorandum of Understanding documents the intentions and responsibilities of cooperating parties.

MEMORY CUE

A Memorandum of Understanding documents the intentions and responsibilities of cooperating parties.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 649-650

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 649 | PROCEDURE

APPLIED

In a separate enterprise scenario, which document usually contains detailed instructions explaining how to perform a task?

A. Procedure

- B. Policy
- C. Risk appetite
- D. Regulation

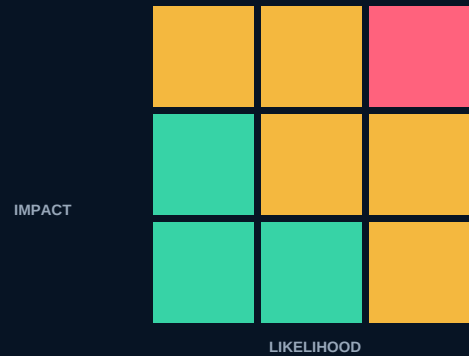
CORRECT ANSWER: A - Procedure

WHY: Procedures provide specific step-by-step instructions.

MEMORY CUE

Policy → What/why Standard → Mandatory requirement Procedure → How Guideline → Recommended practice

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 650 | COMPLIANCE ASSESSMENT

APPLIED

During a governance and risk review, a security team evaluates whether implemented controls satisfy a specific regulatory or contractual requirement set. What activity is being performed?

- A. ARP inspection
- B. Compliance assessment**
- C. Packet fragmentation
- D. Ransomware containment

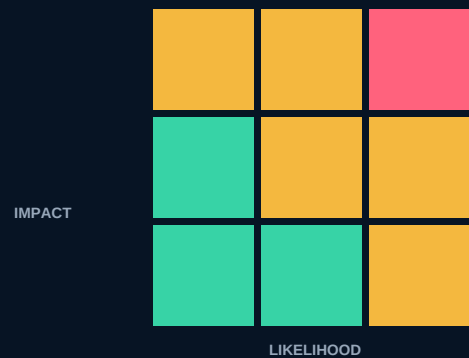
CORRECT ANSWER: B - Compliance assessment

WHY: A compliance assessment measures adherence to required standards, regulations, or contractual obligations.

MEMORY CUE

Compliance = are required obligations being met?

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 651-652

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 651 | RISK AVOIDANCE

APPLIED

A multinational organization stops offering a service because the associated security risk is considered unacceptable. Which risk response is being used?

- A. Transfer
- B. Acceptance
- C. Avoidance**
- D. Detection

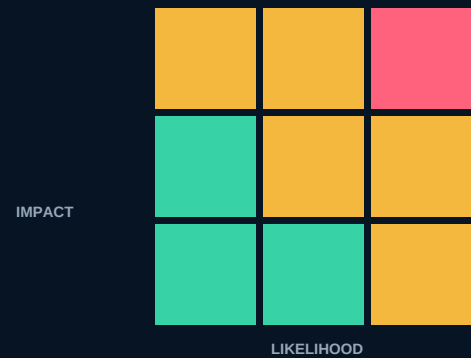
CORRECT ANSWER: C - Avoidance

WHY: Eliminating the activity producing the risk is risk avoidance.

MEMORY CUE

Eliminating the activity producing the risk is risk avoidance.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 652 | VERSION CONTROL

APPLIED

In a separate enterprise scenario, security configuration files are stored in Git so reviewers can see who changed them, compare revisions, and restore earlier versions. Which practice is this?

- A. Data masking
- B. Packet capture
- C. Cold storage only
- D. Version control**

CORRECT ANSWER: D - Version control

WHY: Version control tracks changes to files over time and supports review, accountability, and rollback.

MEMORY CUE

Version control = history + diff + rollback.

Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 653-654

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 653 | SLA

APPLIED

In a separate enterprise scenario, which document commonly defines uptime, response time, and other measurable service commitments from a vendor?

A. SLA

B. AUP

C. MOU

D. NDA

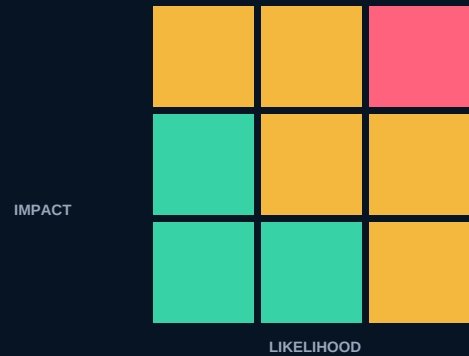
CORRECT ANSWER: A - SLA

WHY: A Service Level Agreement specifies measurable service expectations. Examples: - 99.99% availability - Response within 30 minutes - Recovery within four hours

MEMORY CUE

A Service Level Agreement specifies measurable service expectations. Examples: - 99.99% availability - Response within 30 minutes - ...

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 654 | MAXIMUM TOLERABLE DOWNTIME

APPLIED

During a governance and risk review, business leadership states that a manufacturing process cannot be unavailable for more than eight hours before the business impact becomes unacceptable. What metric is being described?

A. SLE

B. Maximum tolerable downtime (MTD)

C. ARO

D. RPO

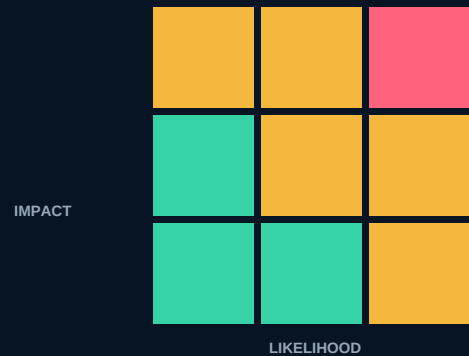
CORRECT ANSWER: B - Maximum tolerable downtime (MTD)

WHY: MTD is the longest period a process can remain unavailable before the impact becomes unacceptable.

MEMORY CUE

MTD = absolute maximum tolerable outage.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 655-656

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 655 | ROLE-BASED TRAINING

APPLIED

During a governance and risk review, database administrators receive specialized secure-configuration training that general office users do not receive. What type of awareness approach is this?

- A. Load balancing
- B. Data masking

C. Role-based security training

- D. Open access

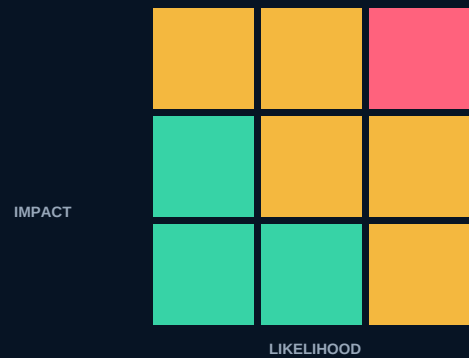
CORRECT ANSWER: C - Role-based security training

WHY: Role-based training tailors security education to responsibilities and risks associated with a specific job function.

MEMORY CUE

Training should match the user's role and risk.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 656 | DATA RETENTION POLICY

APPLIED

During a governance and risk review, a regulation requires transaction records to be kept for seven years and then securely disposed of. What governance control should encode this requirement?

- A. Routing protocol
- B. Firewall ACL
- C. Password policy

D. Data retention policy

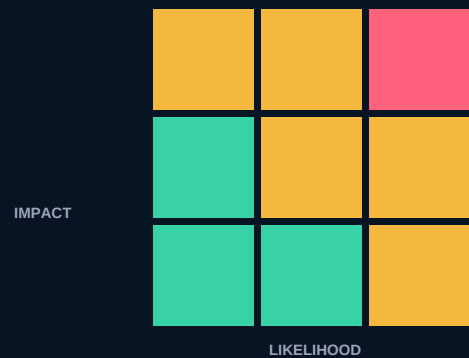
CORRECT ANSWER: D - Data retention policy

WHY: A retention policy defines how long records are kept and when they should be archived or destroyed.

MEMORY CUE

Retention = keep data for defined periods, then dispose.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 657-658

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 657 | ROLLBACK PLAN

APPLIED

During a governance and risk review, a change request includes the exact steps required to restore the previous firewall configuration if the new policy causes an outage. What is this plan called?

A. Rollback plan

B. Data classification

C. NDA

D. RPO

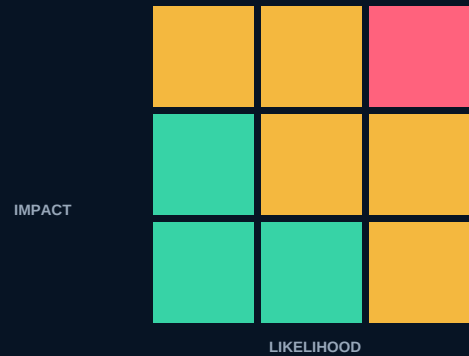
CORRECT ANSWER: A - Rollback plan

WHY: A rollback plan defines how to reverse a change and return to a known-good prior state.

MEMORY CUE

Rollback = how to undo the change safely.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 658 | INTERNAL AUDIT

APPLIED

During a governance and risk review, employees from the organization's independent internal audit function review whether security processes follow company policy. What type of audit is this?

A. Penetration exploit

B. Internal audit

C. Vendor onboarding

D. External audit

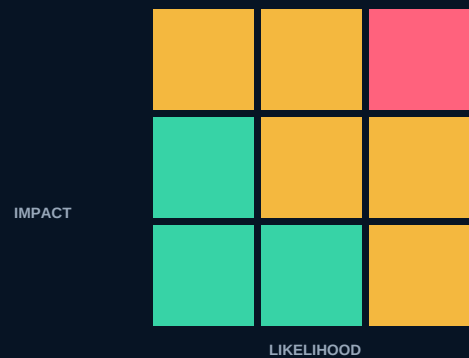
CORRECT ANSWER: B - Internal audit

WHY: An internal audit is performed by or on behalf of the organization's internal assurance function.

MEMORY CUE

Internal audit = assurance from inside the organization.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 659-660

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 659 | GAP ANALYSIS

APPLIED

During a governance and risk review, a security team compares current controls with a desired baseline and documents what is missing. What process is this?

- A. Packet capture
- B. Data masking
- C. Gap analysis**
- D. Password spraying

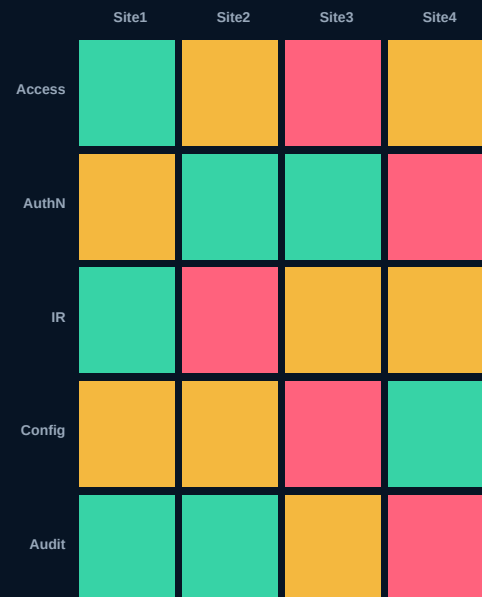
CORRECT ANSWER: C - Gap analysis

WHY: Gap analysis compares the current state to a target state to identify deficiencies and required improvements.

MEMORY CUE

Gap = current state versus desired state.

● ● ● Risk / Governance View



QUESTION 660 | SINGLE LOSS EXPECTANCY

APPLIED

A production server is valued at \$200,000. A successful incident is expected to cause 25% loss. What is the SLE?

- A. \$200,000
- B. \$100,000
- C. \$25,000
- D. \$50,000**

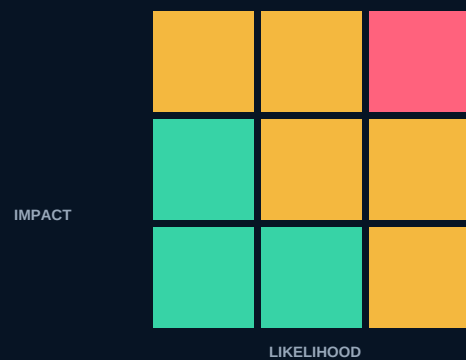
CORRECT ANSWER: D - \$50,000

WHY: $SLE = \text{Asset Value} \times \text{Exposure Factor}$, so $\$200,000 \times 0.25 = \$50,000$.

MEMORY CUE

SLE = Asset Value x Exposure Factor.

● ● ● Risk / Governance View



Security+ Master Visual Review | Questions 661-662

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 661 | STATEMENT OF WORK

ADVANCED

Management is reviewing a governance requirement described as follows: a SOW defines project-specific scope, deliverables, timelines, and responsibilities. Which governance, risk, or continuity concept BEST fits?

A. Statement of work (SOW)

B. AUP

C. RPO

D. NDA

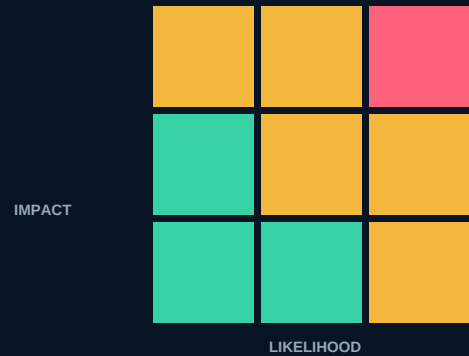
CORRECT ANSWER: A - Statement of work (SOW)

WHY: A SOW defines project-specific scope, deliverables, timelines, and responsibilities.

MEMORY CUE

SOW = what work will be delivered and how.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 662 | ACCEPTABLE USE POLICY

ADVANCED

Management is reviewing a governance requirement described as follows: an AUP defines permitted and prohibited use of organizational technology resources. Which governance, risk, or continuity concept BEST fits?

A. Chain of custody form

B. Acceptable use policy (AUP)

C. SLA

D. Certificate policy only

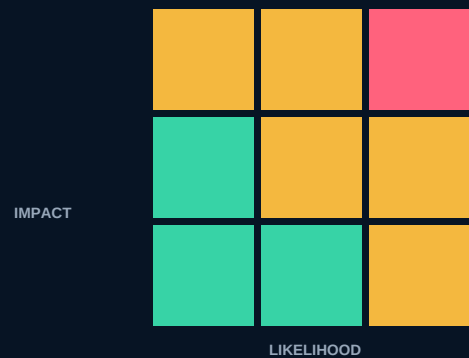
CORRECT ANSWER: B - Acceptable use policy (AUP)

WHY: An AUP defines permitted and prohibited use of organizational technology resources.

MEMORY CUE

AUP = rules for user technology use.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 663-664

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 663 | SINGLE LOSS EXPECTANCY

ADVANCED

Management is reviewing a governance requirement described as follows: $SLE = \text{Asset Value} \times \text{Exposure Factor}$, so $\$200,000 \times 0.25 = \text{this control}$. Which governance, risk, or continuity concept BEST fits?

- A. \$25,000
- B. \$200,000
- C. \$50,000**
- D. \$100,000

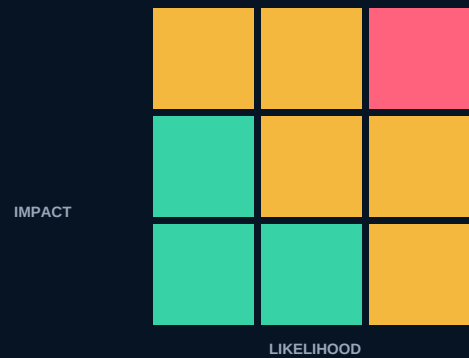
CORRECT ANSWER: C - \$50,000

WHY: $SLE = \text{Asset Value} \times \text{Exposure Factor}$, so $\$200,000 \times 0.25 = \$50,000$.

MEMORY CUE

$SLE = \text{Asset Value} \times \text{Exposure Factor}$.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 664 | SECURITY BASELINE

ADVANCED

Management is reviewing a governance requirement described as follows: a baseline establishes the expected target or minimum control state used for comparison. Which governance, risk, or continuity concept BEST fits?

- A. Ransom note
- B. Packet capture
- C. Threat actor profile
- D. Security baseline**

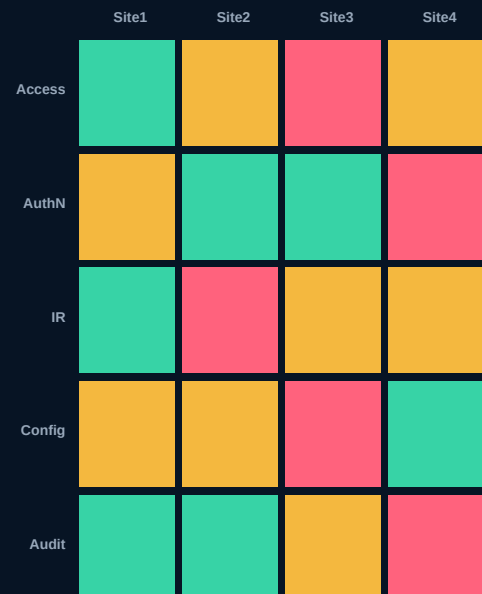
CORRECT ANSWER: D - Security baseline

WHY: A baseline establishes the expected target or minimum control state used for comparison.

MEMORY CUE

Baseline = the reference target.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 665-667

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 665 | DATA CUSTODIAN

ADVANCED

Management is reviewing a governance requirement described as follows: a implements and operates technical controls for data according to owner and policy requirements. Which governance, risk, or continuity concept BEST fits?

A. Data custodian

B. Data owner only

C. Threat actor

D. External auditor

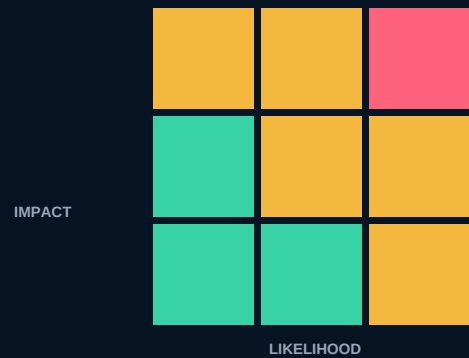
CORRECT ANSWER: A - Data custodian

WHY: A data custodian implements and operates technical controls for data according to owner and policy requirements.

MEMORY CUE

Custodian implements the owner's requirements.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 667 | SLA

ADVANCED

Management is reviewing a governance requirement described as follows: a Service Level Agreement specifies measurable service expectations. Examples: - 99.99% availability - Response within 30 minutes - Recovery within four hours. Which governance, risk, or continuity concept BEST fits?

A. AUP

B. NDA

C. SLA

D. MOU

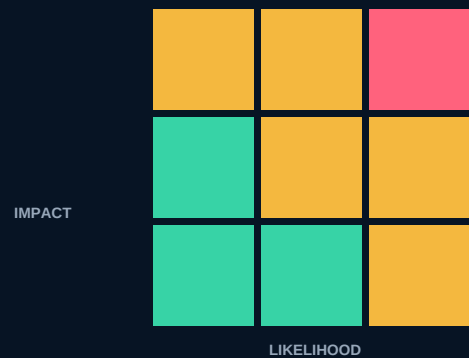
CORRECT ANSWER: C - SLA

WHY: A Service Level Agreement specifies measurable service expectations. Examples: - 99.99% availability - Response within 30 minutes - Recovery within four hours

MEMORY CUE

A Service Level Agreement specifies measurable service expectations. Examples: - 99.99% availability - Response within 30 minutes -...

Risk / Governance View



Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 666

Immediate answers, concise rationales, and visual memory anchors.

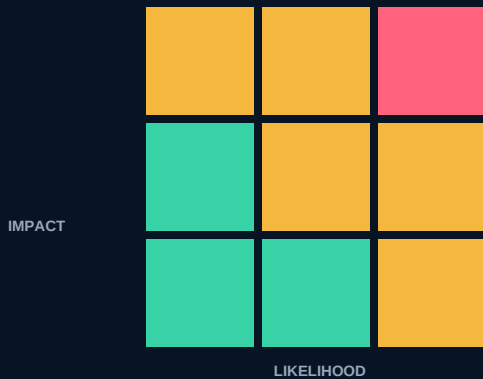
ANALYST TASK | ANNUALIZED RATE OF OCCURRENCE

Management is reviewing a governance requirement described as follows: aRO expresses expected annual frequency; once every five years equals 1/5 or per year. Which governance, risk, or continuity concept BEST fits?

- A. 20
- B. 0.2
- C. 5.0
- D. 0.02

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Risk / Governance View



CORRECT ANSWER: B - 0.2

RATIONALE ARO expresses expected annual frequency; once every five years equals 1/5 or 0.2 per year.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 668-669

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 668 | EXPOSURE FACTOR

ADVANCED

Management is reviewing a governance requirement described as follows: the percentage of asset value expected to be lost from a single event. Which governance, risk, or continuity concept BEST fits?

- A. RTO
- B. ARO
- C. ALE

D. Exposure factor (EF)

CORRECT ANSWER: D - Exposure factor (EF)

WHY: Exposure factor is the percentage of asset value expected to be lost from a single event.

MEMORY CUE

EF = percent loss from one event.

Risk / Governance View

SLE = Asset Value x Exposure Factor

ALE = SLE x ARO

Quantify expected loss - then compare control cost and residual risk.

Illustrative study visual - not live production telemetry

QUESTION 669 | STANDARD

ADVANCED

Management is reviewing a governance requirement described as follows: this controls define mandatory requirements used to support organizational policies. Which governance, risk, or continuity concept BEST fits?

- A. Standard**
- B. Guideline
- C. Incident ticket
- D. Marketing plan

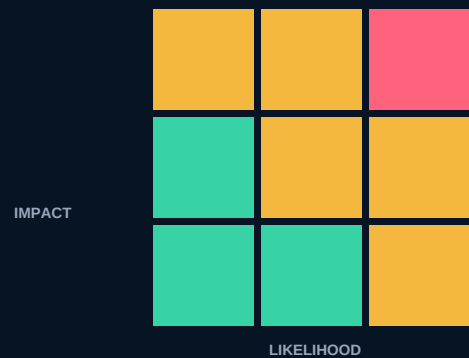
CORRECT ANSWER: A - Standard

WHY: Standards define mandatory requirements used to support organizational policies.

MEMORY CUE

Standards define mandatory requirements used to support organizational policies.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 670-671

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 670 | PROCEDURE

ADVANCED

Management is reviewing a governance requirement described as follows: this controls provide specific step-by-step instructions. Which governance, risk, or continuity concept BEST fits?

- A. Regulation
- B. Procedure**
- C. Policy
- D. Risk appetite

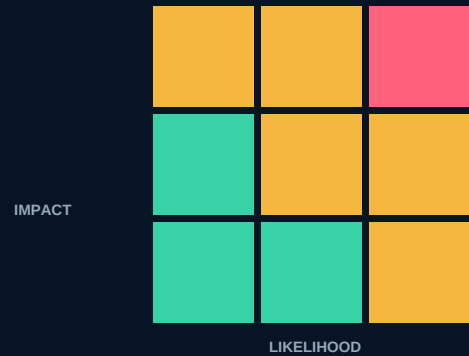
CORRECT ANSWER: B - Procedure

WHY: Procedures provide specific step-by-step instructions.

MEMORY CUE

Policy → What/why Standard → Mandatory requirement Procedure → How Guideline → Recommended practice

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 671 | RISK TOLERANCE

ADVANCED

Management is reviewing a governance requirement described as follows: identifies the amount of risk or variation an organization is willing to accept. Which governance, risk, or continuity concept BEST fits?

- A. Non-repudiation
- B. Encryption
- C. Risk tolerance**
- D. Federation

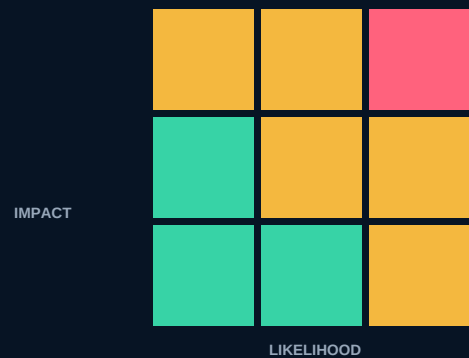
CORRECT ANSWER: C - Risk tolerance

WHY: Risk tolerance identifies the amount of risk or variation an organization is willing to accept.

MEMORY CUE

Risk tolerance identifies the amount of risk or variation an organization is willing to accept.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 672-673

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 672 | DATA RETENTION POLICY

ADVANCED

Management is reviewing a governance requirement described as follows: a retention policy defines how long records are kept and when they should be archived or destroyed. Which governance, risk, or continuity concept BEST fits?

- A. Password policy
- B. Routing protocol
- C. Firewall ACL

D. Data retention policy

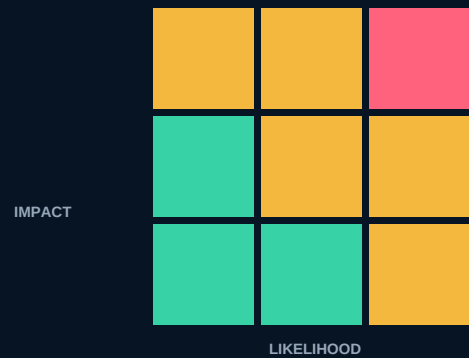
CORRECT ANSWER: D - Data retention policy

WHY: A retention policy defines how long records are kept and when they should be archived or destroyed.

MEMORY CUE

Retention = keep data for defined periods, then dispose.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 673 | VENDOR DUE DILIGENCE

ADVANCED

Management is reviewing a governance requirement described as follows: evaluates supplier risk before or during a business relationship. Which governance, risk, or continuity concept BEST fits?

- A. Third-party due diligence**
- B. Packet capture
- C. Key escrow
- D. Password rotation

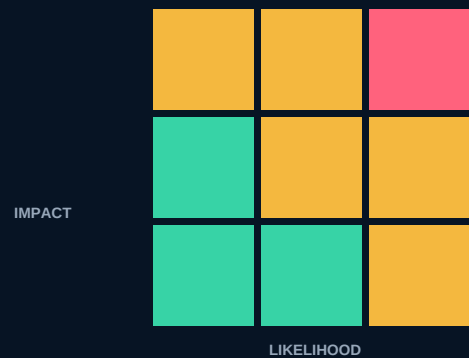
CORRECT ANSWER: A - Third-party due diligence

WHY: Third-party due diligence evaluates supplier risk before or during a business relationship.

MEMORY CUE

Assess vendor security before entrusting data/services.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 674-675

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 674 | GAP ANALYSIS

ADVANCED

Management is reviewing a governance requirement described as follows: compares the current state to a target state to identify deficiencies and required improvements. Which governance, risk, or continuity concept BEST fits?

- B. Gap analysis**

CORRECT ANSWER: B - Gap analysis

WHY: Gap analysis compares the current state to a target state to identify deficiencies and required improvements.

MEMORY CUE

Gap = current state versus desired state.

● ● ● Risk / Governance View



QUESTION 675 | REQUEST FOR PROPOSAL

ADVANCED

Management is reviewing a governance requirement described as follows: an RFP requests proposed solutions and pricing from vendors for defined business requirements. Which governance, risk, or continuity concept BEST fits?

- A. NDA
- B. SLA only
- C. Request for proposal (RFP)**
- D. Chain-of-custody form

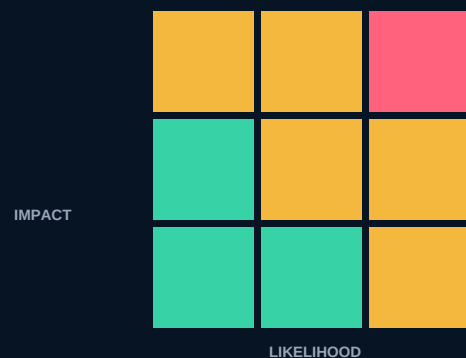
CORRECT ANSWER: C - Request for proposal (RFP)

WHY: An RFP requests proposed solutions and pricing from vendors for defined business requirements.

MEMORY CUE

RFP = invite vendors to propose a solution.

● ● ● Risk / Governance View



Security+ Master Visual Review | Questions 676-677

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 676 | RISK MITIGATION

ADVANCED

Management is reviewing a governance requirement described as follows: reduces the likelihood and/or impact of a risk. Which governance, risk, or continuity concept BEST fits?

- A. Transfer
- B. Acceptance
- C. Avoidance

D. Mitigation

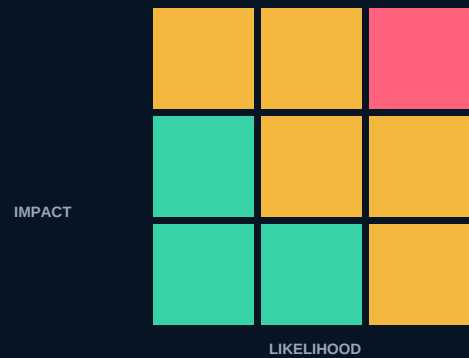
CORRECT ANSWER: D - Mitigation

WHY: Mitigation reduces the likelihood and/or impact of a risk.

MEMORY CUE

Mitigation reduces the likelihood and/or impact of a risk.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 677 | ISO/IEC 27001

ADVANCED

Management is reviewing a governance requirement described as follows: specifies requirements for an information security management system (ISMS). Which governance, risk, or continuity concept BEST fits?

- A. ISO/IEC 27001**
- B. RADIUS
- C. CVSS
- D. SMTP

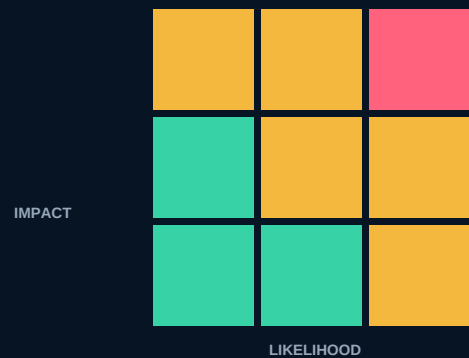
CORRECT ANSWER: A - ISO/IEC 27001

WHY: ISO/IEC 27001 specifies requirements for an information security management system (ISMS).

MEMORY CUE

27001 = ISMS standard.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 678-679

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 678 | INTERNAL AUDIT

ADVANCED

Management is reviewing a governance requirement described as follows: an performed by or on behalf of the organization's internal assurance function. Which governance, risk, or continuity concept BEST fits?

- A. Penetration exploit
- B. Internal audit**
- C. External audit
- D. Vendor onboarding

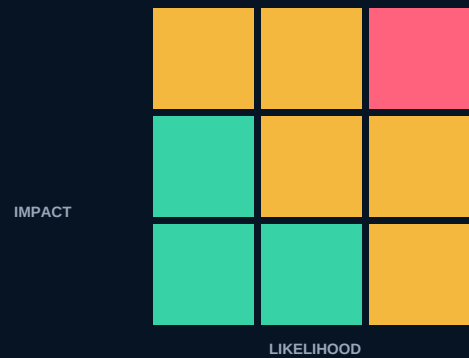
CORRECT ANSWER: B - Internal audit

WHY: An internal audit is performed by or on behalf of the organization's internal assurance function.

MEMORY CUE

Internal audit = assurance from inside the organization.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 679 | MOU

ADVANCED

Management is reviewing a governance requirement described as follows: a Memorandum of Understanding documents the intentions and responsibilities of cooperating parties. Which governance, risk, or continuity concept BEST fits?

- A. Playbook
- B. Certificate
- C. MOU**
- D. SLA

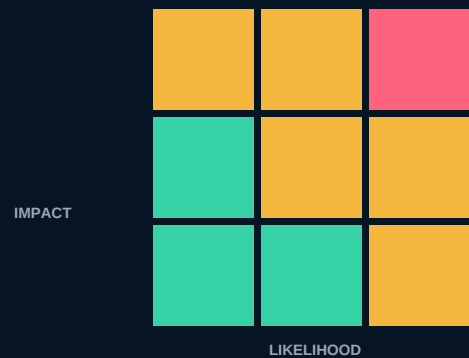
CORRECT ANSWER: C - MOU

WHY: A Memorandum of Understanding documents the intentions and responsibilities of cooperating parties.

MEMORY CUE

A Memorandum of Understanding documents the intentions and responsibilities of cooperating parties.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 680-681

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 680 | ALE FORMULA

ADVANCED

Management is reviewing a governance requirement described as follows: annualized loss expectancy equals single loss expectancy multiplied by annualized rate of occurrence. Which governance, risk, or continuity concept BEST fits?

A. ALE = Asset value / SLE

B. ALE = ARO + SLE

C. ALE = CVSS x RPO

D. ALE = SLE x ARO

CORRECT ANSWER: D - ALE = SLE x ARO

WHY: Annualized loss expectancy equals single loss expectancy multiplied by annualized rate of occurrence.

MEMORY CUE

ALE = SLE x ARO.

Risk / Governance View

SLE = Asset Value x Exposure Factor

ALE = SLE x ARO

Quantify expected loss - then compare control cost and residual risk.

Illustrative study visual - not live production telemetry

QUESTION 681 | RECOVERY POINT OBJECTIVE

ADVANCED

Management is reviewing a governance requirement described as follows: defines the maximum acceptable amount of data loss measured backward in time. Which governance, risk, or continuity concept BEST fits?

A. RPO

B. MTBF

C. RTO

D. ALE

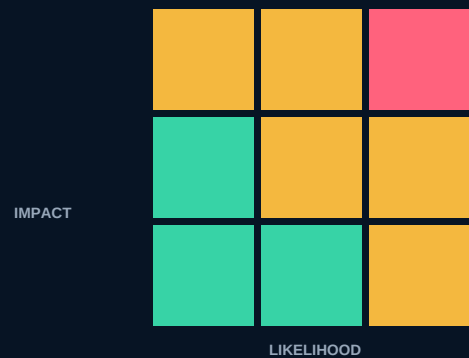
CORRECT ANSWER: A - RPO

WHY: Recovery Point Objective defines the maximum acceptable amount of data loss measured backward in time.

MEMORY CUE

RTO = How long can we be down? RPO = How much data can we lose?

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 682-683

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 682 | ANNUALIZED LOSS EXPECTANCY

ADVANCED

Management is reviewing a governance requirement described as follows: once every four years gives an ARO of 0.25, so $ALE = \$50,000 \times 0.25 =$ this control. Which governance, risk, or continuity concept BEST fits?

- A. \$200,000
- B. \$12,500**
- C. \$5,000
- D. \$50,000

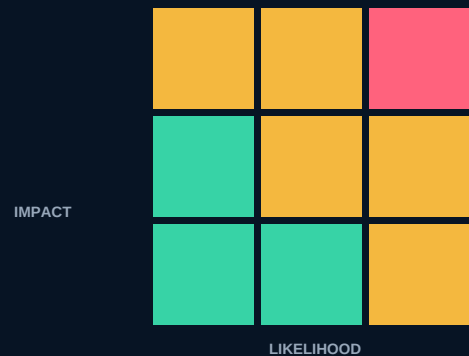
CORRECT ANSWER: B - \$12,500

WHY: Once every four years gives an ARO of 0.25, so $ALE = \$50,000 \times 0.25 = \$12,500$.

MEMORY CUE

Once every four years = ARO 0.25.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 683 | PHISHING SIMULATION

ADVANCED

Management is reviewing a governance requirement described as follows: this controls help measure employee behavior and identify opportunities for additional security training. Which governance, risk, or continuity concept BEST fits?

- A. Replace endpoint protection
- B. Eliminate IAM
- C. Measure and improve security awareness**
- D. Determine network latency

CORRECT ANSWER: C - Measure and improve security awareness

WHY: Phishing simulations help measure employee behavior and identify opportunities for additional security training.

MEMORY CUE

Phishing simulations help measure employee behavior and identify opportunities for additional security training.

Message Security Example

URGENT: Account action required

Sender: security-alert@example.invalid

Verify your account immediately.

OPEN LINK

SOC CUE: channel + urgency + identity context

Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 684-685

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 684 | EXTERNAL AUDIT

ADVANCED

Management is reviewing a governance requirement described as follows: an conducted by an independent party rather than the organization evaluating itself. Which governance, risk, or continuity concept BEST fits?

- A. Administrative authentication
- B. Self-assessment
- C. Vulnerability patch

D. External audit

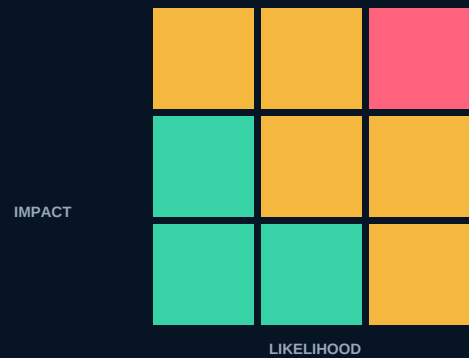
CORRECT ANSWER: D - External audit

WHY: An external audit is conducted by an independent party rather than the organization evaluating itself.

MEMORY CUE

An external audit is conducted by an independent party rather than the organization evaluating itself.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 685 | RISK ACCEPTANCE

ADVANCED

Management is reviewing a governance requirement described as follows: management understands the remaining risk and decides to continue operating. Memorize the four major responses: - Avoid - Mitigate - Transfer - Accept. Which governance, risk, or continuity concept BEST fits?

- A. Acceptance**
- B. Transfer
- C. Avoidance
- D. Elimination

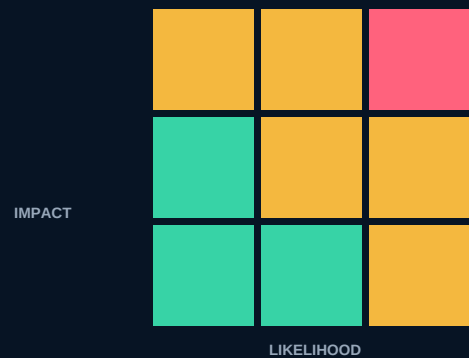
CORRECT ANSWER: A - Acceptance

WHY: Management understands the remaining risk and decides to continue operating. Memorize the four major responses: - Avoid - Mitigate - Transfer - Accept

MEMORY CUE

Management understands the remaining risk and decides to continue operating. Memorize the four major responses: - Avoid - Mitigate - ...

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 686-687

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 686 | RISK APPETITE

ADVANCED

Management is reviewing a governance requirement described as follows: the broad amount and type of risk an organization is willing to pursue or retain to achieve objectives. Which governance, risk, or continuity concept BEST fits?

- A. RPO
- B. Risk appetite**
- C. SLE
- D. Chain of custody

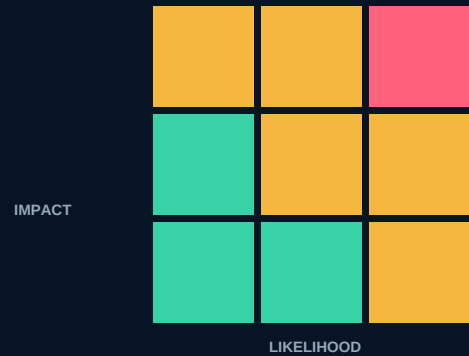
CORRECT ANSWER: B - Risk appetite

WHY: Risk appetite is the broad amount and type of risk an organization is willing to pursue or retain to achieve objectives.

MEMORY CUE

Risk appetite = broad willingness to take risk.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 687 | DATA CLASSIFICATION

ADVANCED

Management is reviewing a governance requirement described as follows: categorizes information according to sensitivity, value, or regulatory requirements. Which governance, risk, or continuity concept BEST fits?

- A. Password spraying
- B. Packet fragmentation
- C. Data classification**
- D. Load balancing

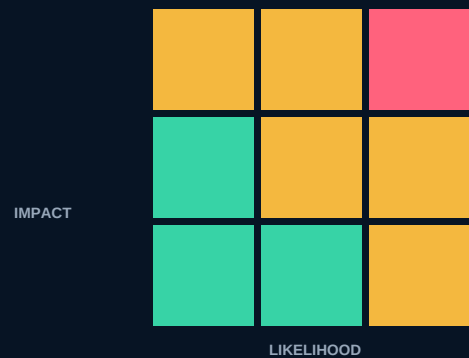
CORRECT ANSWER: C - Data classification

WHY: Data classification categorizes information according to sensitivity, value, or regulatory requirements.

MEMORY CUE

Classification drives handling controls.

Risk / Governance View



Illustrative study visual - not live production telemetry

PBQ-Style Visual Scenario | Question 688

Immediate answers, concise rationales, and visual memory anchors.

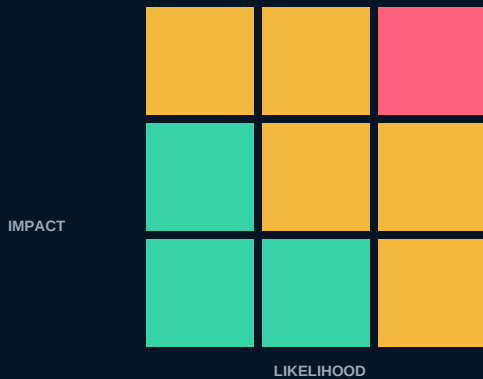
ANALYST TASK | RECOVERY TIME OBJECTIVE

Management is reviewing a governance requirement described as follows: defines how quickly a system or service must be restored after disruption. Which governance, risk, or continuity concept **BEST** fits?

- A. RPO
- B. ARO
- C. SLE
- D. RTO

SIMULATED EVIDENCE / ARCHITECTURE PANEL

● ● ● Risk / Governance View



CORRECT ANSWER: D - RTO

RATIONALE

Recovery Time Objective defines how quickly a system or service must be restored after disruption.

Treat this as a visual reasoning exercise: identify the clue, eliminate weaker options, then justify the choice.

Security+ Master Visual Review | Questions 689-690

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 689 | MAXIMUM TOLERABLE DOWNTIME

ADVANCED

Management is reviewing a governance requirement described as follows: mTD is the longest period a process can remain unavailable before the impact becomes unacceptable. Which governance, risk, or continuity concept BEST fits?

A. Maximum tolerable downtime (MTD)

B. ARO

C. RPO

D. SLE

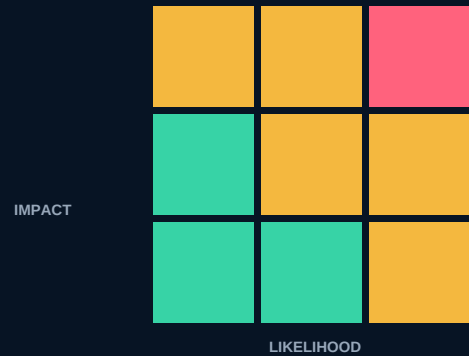
CORRECT ANSWER: A - Maximum tolerable downtime (MTD)

WHY: MTD is the longest period a process can remain unavailable before the impact becomes unacceptable.

MEMORY CUE

MTD = absolute maximum tolerable outage.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 690 | RISK TRANSFER

ADVANCED

Management is reviewing a governance requirement described as follows: cyber insurance this controls part of the financial risk to another organization. Which governance, risk, or continuity concept BEST fits?

A. Avoid

B. Transfer

C. Accept

D. Ignore

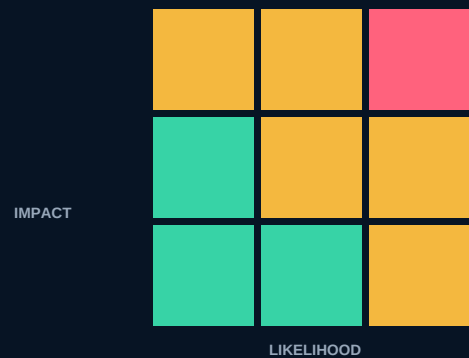
CORRECT ANSWER: B - Transfer

WHY: Cyber insurance transfers part of the financial risk to another organization.

MEMORY CUE

Cyber insurance transfers part of the financial risk to another organization.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 691-692

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 691 | POLICY

ADVANCED

Management is reviewing a governance requirement described as follows: policies establish management's high-level requirements and organizational expectations. Which governance, risk, or continuity concept BEST fits?

A. Packet capture

B. Hash

C. Policy

D. Routing table

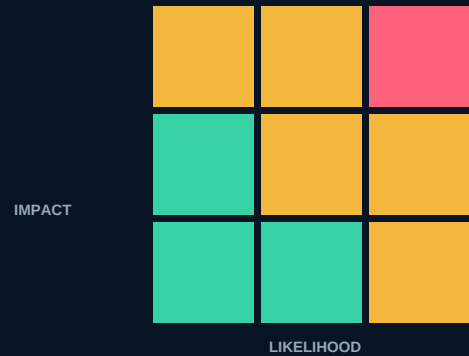
CORRECT ANSWER: C - Policy

WHY: Policies establish management's high-level requirements and organizational expectations.

MEMORY CUE

Policies establish management's high-level requirements and organizational expectations.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 692 | REGULATORY REQUIREMENT

ADVANCED

Management is reviewing a governance requirement described as follows: regulatory and legal requirements can mandate specific security, privacy, retention, or reporting obligations. Which governance, risk, or continuity concept BEST fits?

A. Marketing guideline

B. User preference

C. Router performance

D. Regulatory / legal requirement

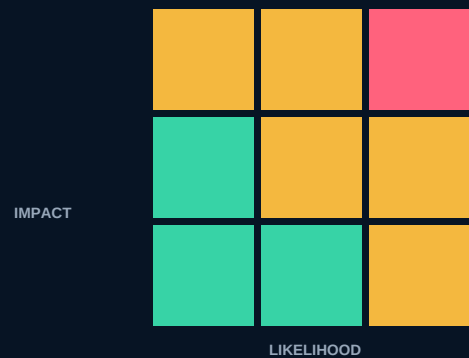
CORRECT ANSWER: D - Regulatory / legal requirement

WHY: Regulatory and legal requirements can mandate specific security, privacy, retention, or reporting obligations.

MEMORY CUE

Law/regulation can impose mandatory controls.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 695-696

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 695 | MASTER SERVICE AGREEMENT

ADVANCED

Management is reviewing a governance requirement described as follows: an MSA establishes overarching terms that can apply to multiple later statements of work or engagements. Which governance, risk, or continuity concept BEST fits?

- A. RPO
- B. Digital certificate
- C. Master service agreement (MSA)**
- D. AUP

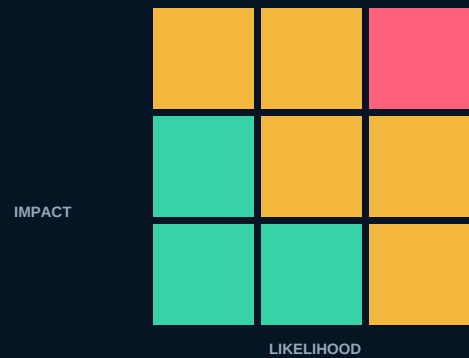
CORRECT ANSWER: C - Master service agreement (MSA)

WHY: An MSA establishes overarching terms that can apply to multiple later statements of work or engagements.

MEMORY CUE

MSA = umbrella agreement for ongoing services.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 696 | RISK AVOIDANCE

ADVANCED

Management is reviewing a governance requirement described as follows: eliminating the activity producing the risk is this control. Which governance, risk, or continuity concept BEST fits?

- A. Transfer
- B. Acceptance
- C. Detection
- D. Avoidance**

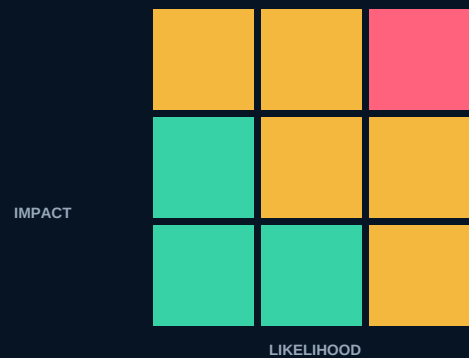
CORRECT ANSWER: D - Avoidance

WHY: Eliminating the activity producing the risk is risk avoidance.

MEMORY CUE

Eliminating the activity producing the risk is risk avoidance.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 697-698

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 697 | NIST SP 800-171

ADVANCED

Management is reviewing a governance requirement described as follows: provides requirements for protecting CUI in nonfederal systems and organizations. Which governance, risk, or continuity concept BEST fits?

A. NIST SP 800-171

B. SAML

C. SPF

D. PCI token only

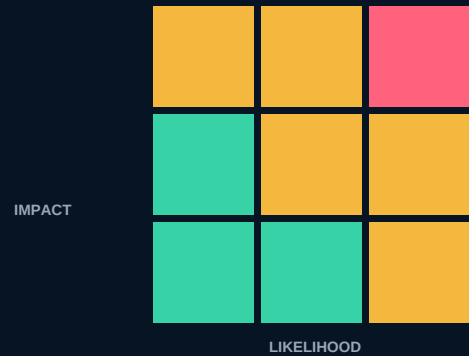
CORRECT ANSWER: A - NIST SP 800-171

WHY: NIST SP 800-171 provides requirements for protecting CUI in nonfederal systems and organizations.

MEMORY CUE

800-171 = CUI protection requirements.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 698 | THIRD-PARTY RISK

ADVANCED

Management is reviewing a governance requirement described as follows: organizations should evaluate vendors' security posture before sharing sensitive information or granting access. Which governance, risk, or continuity concept BEST fits?

A. Eliminate contractual requirements

B. Vendor security assessment

C. Grant global administrator access

D. Disable logging

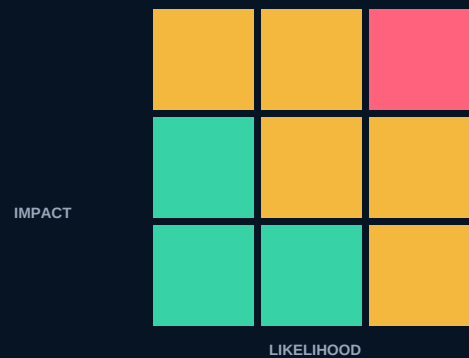
CORRECT ANSWER: B - Vendor security assessment

WHY: Organizations should evaluate vendors' security posture before sharing sensitive information or granting access.

MEMORY CUE

Organizations should evaluate vendors' security posture before sharing sensitive information or granting access.

Risk / Governance View



Illustrative study visual - not live production telemetry

Security+ Master Visual Review | Questions 699-700

Immediate answers, concise rationales, and visual memory anchors.

QUESTION 699 | GUIDELINE

ADVANCED

Management is reviewing a governance requirement described as follows: provides recommended approaches or best practices and is generally less mandatory than a standard. Which governance, risk, or continuity concept BEST fits?

- A. Standard
- B. Procedure
- C. Guideline**
- D. Policy

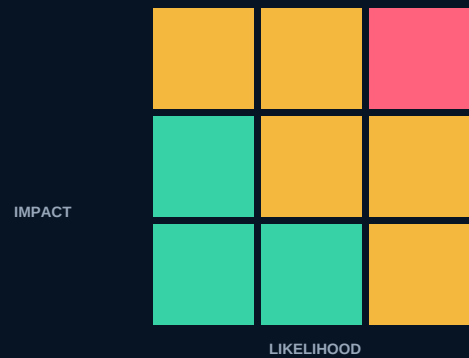
CORRECT ANSWER: C - Guideline

WHY: A guideline provides recommended approaches or best practices and is generally less mandatory than a standard.

MEMORY CUE

Guideline = recommended, not usually mandatory.

Risk / Governance View



Illustrative study visual - not live production telemetry

QUESTION 700 | NONDISCLOSURE AGREEMENT

ADVANCED

Management is reviewing a governance requirement described as follows: a establishes confidentiality obligations for sensitive information. Which governance, risk, or continuity concept BEST fits?

- A. RPO
- B. SLA
- C. AUP
- D. NDA**

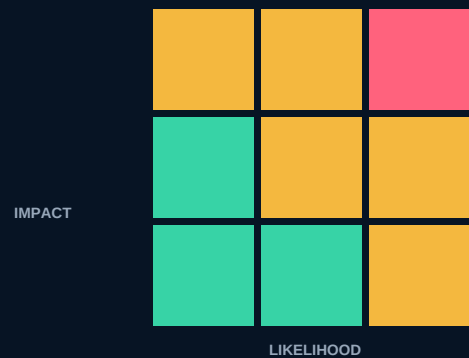
CORRECT ANSWER: D - NDA

WHY: A nondisclosure agreement establishes confidentiality obligations for sensitive information.

MEMORY CUE

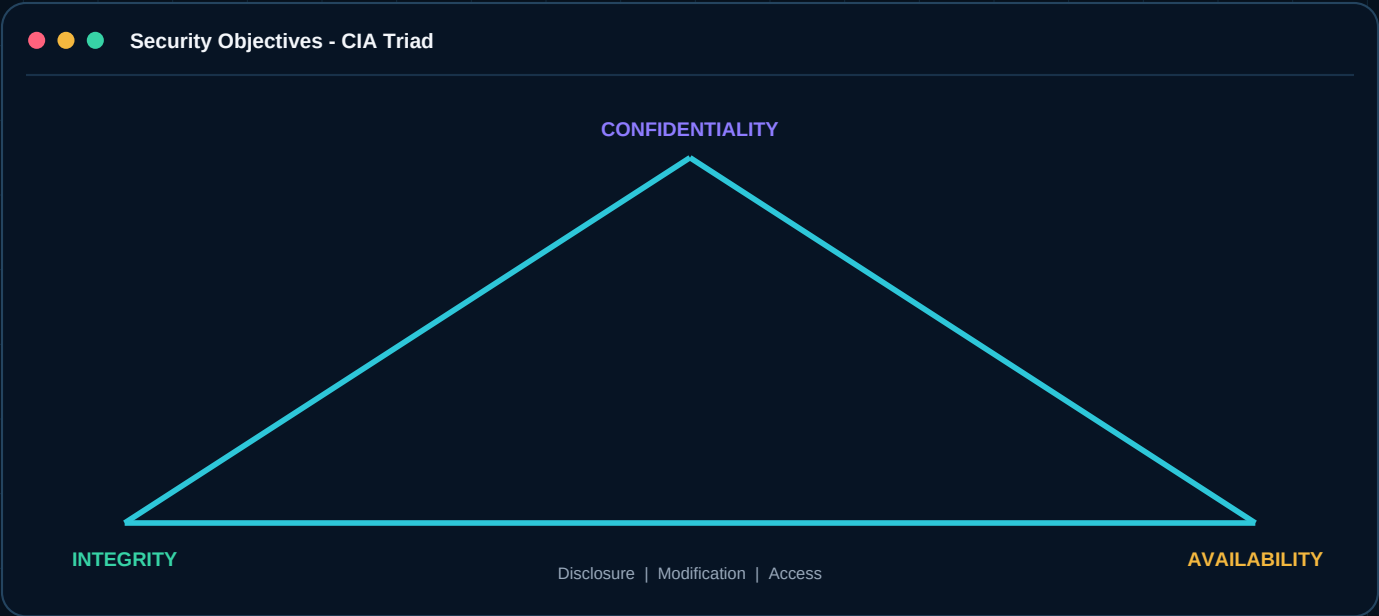
NDA = confidentiality agreement.

Risk / Governance View



Illustrative study visual - not live production telemetry

CIA + Security Control Matrix



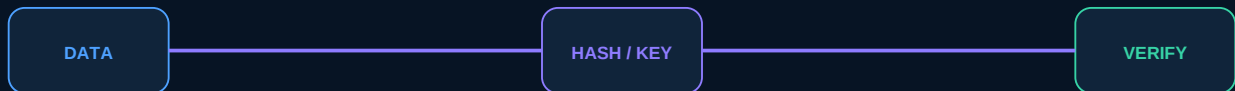
● ● ● Control Matrix

PREVENT/TECH	PREVENT/MGMT	PREVENT/OPS	PREVENT/PHYS
DETECT/TECH	DETECT/MGMT	DETECT/OPS	DETECT/PHYS
CORRECT/TECH	CORRECT/MGMT	CORRECT/OPS	CORRECT/PHYS

Control categories: technical, managerial, operational, physical. Types: preventive, deterrent, detective, corrective, compensating, directive.

Cryptography + PKI

Cryptography / Trust



RESULT: integrity / origin
PRIVATE KEY: protected
PUBLIC KEY: distributable
SHA-256: 7c8a...

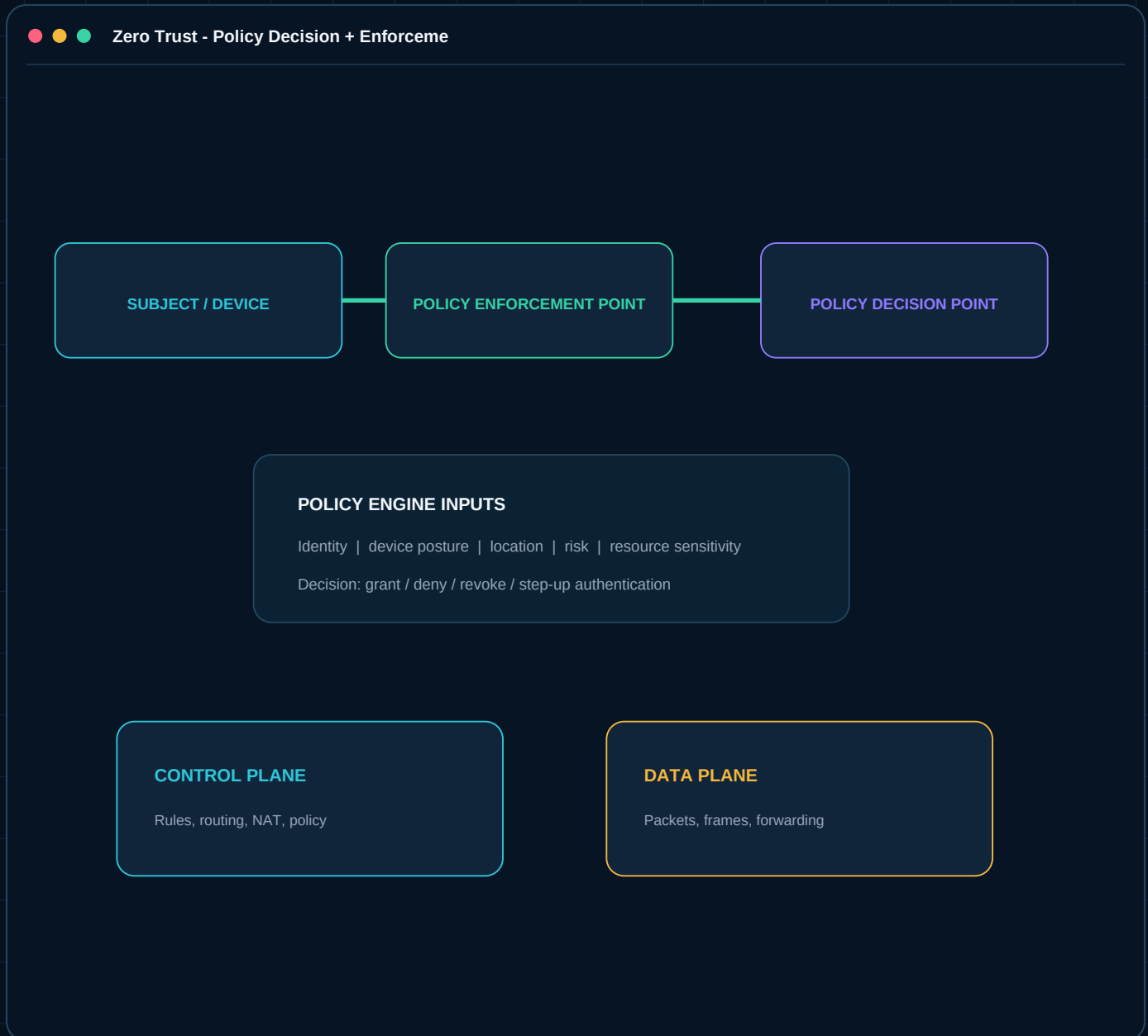
AAA + IAM

Identity / Access Flow



```
audit=logged  
decision=ALLOW  
factor=FID02  
id=marc.l
```

Zero Trust Architecture



Threat Pattern Map

CREDENTIAL

Spray • Stuffing • PtH • Kerberoast

SOCIAL

Phish • Smish • Vishing • BEC

WEB

SQLi • XSS • CSRF • Traversal

NETWORK

ARP • DNS • SYN • VLAN • DHCP

MALWARE

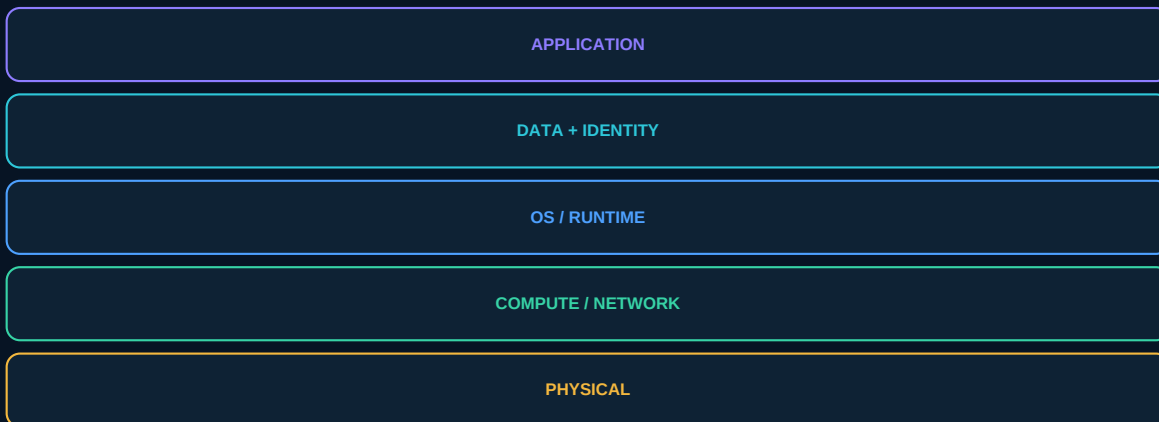
Ransomware • Worm • Trojan • Rootkit

SUPPLY

Vendor compromise • Dependency abuse

Cloud + Resilience

Architecture / Shared Responsibility



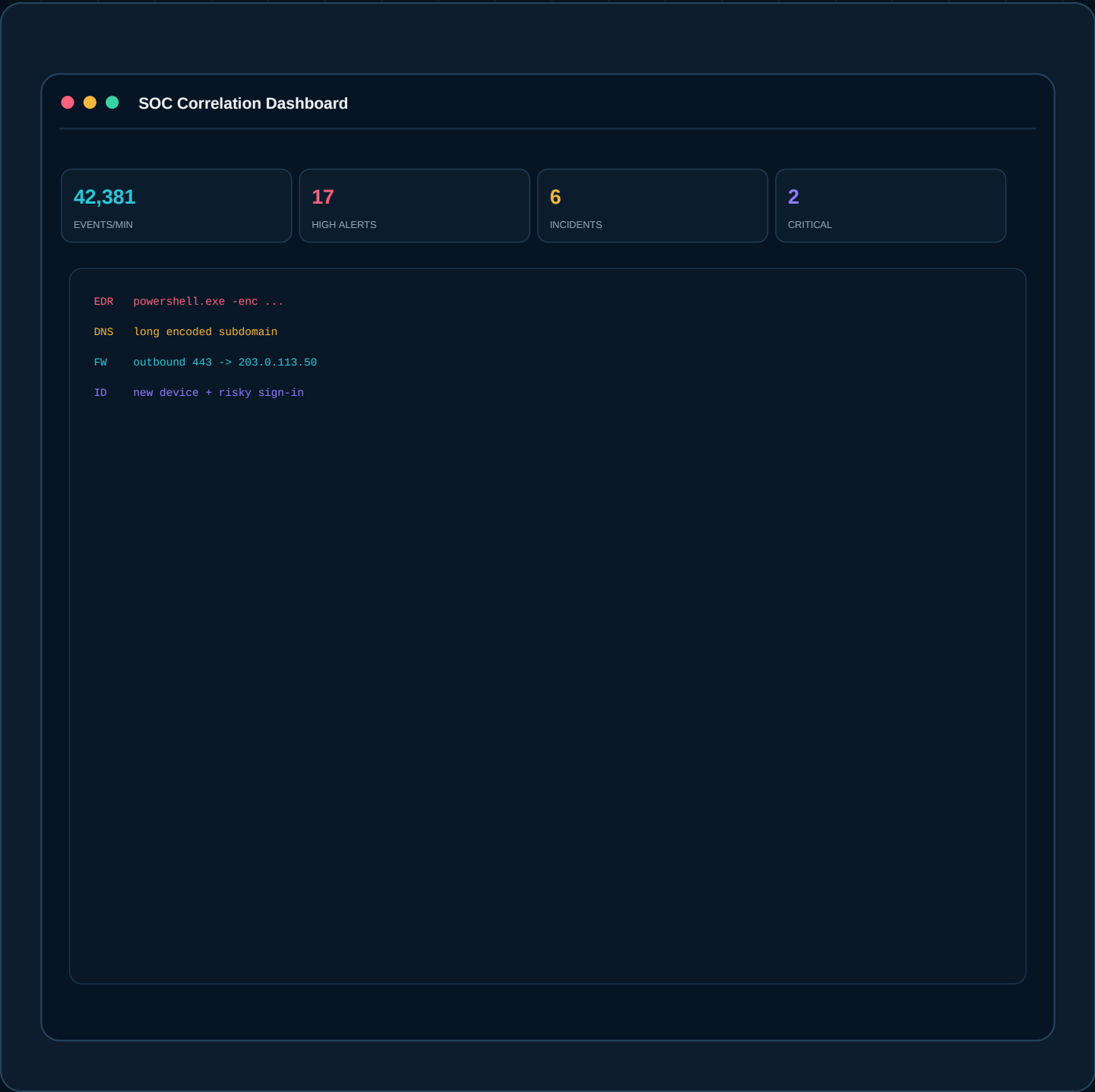
Responsibility changes by SaaS / PaaS / IaaS / on-prem model.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

SOC Telemetry Map



Incident Response + Forensics

PREPARE

IDENTIFY

CONTAIN

ERADICATE

RECOVER

LESSONS

Forensic Evidence Workflow

COLLECT

HASH

PRESERVE

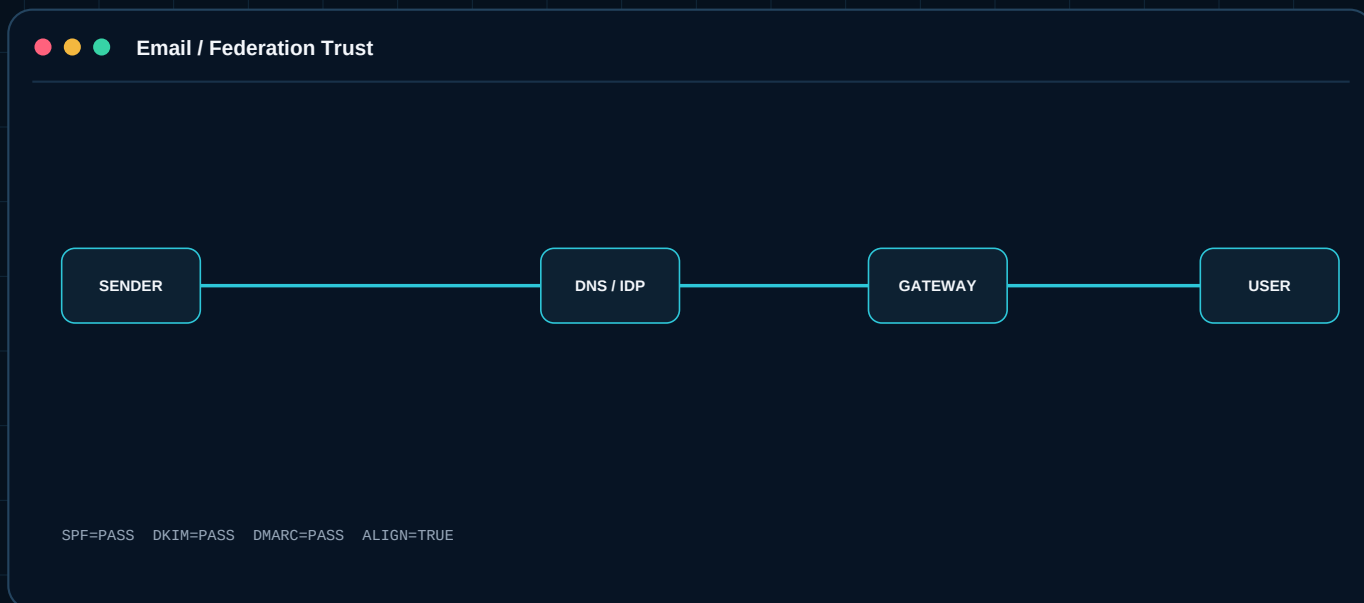
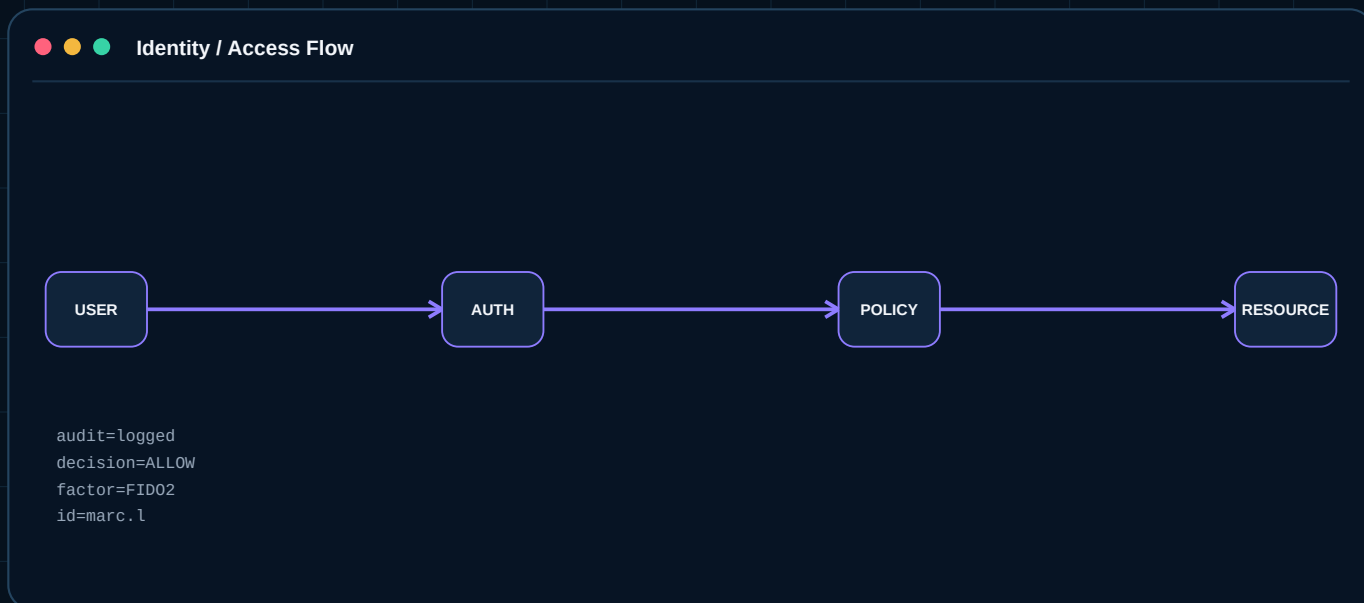
ANALYZE

REPORT

```
SHA256=9f2a...  custodian=ML  time=10:42:19Z  
write_blocker=ON  evidence_id=E-2026-014
```

Order of volatility matters. Preserve evidence integrity, document chain of custody, and validate hashes.

Identity + Email Trust



Risk + Recovery Formulas

Risk / Governance View

$$\text{SLE} = \text{Asset Value} \times \text{Exposure Factor}$$

$$\text{ALE} = \text{SLE} \times \text{ARO}$$

Quantify expected loss - then compare control cost and residual risk.

Resilience / Recovery Timeline



Backups + redundancy + tested recovery determine actual resilience.

SLE = Asset Value x Exposure Factor | ALE = SLE x ARO | RTO = downtime target | RPO = acceptable data-loss window

Gap Analysis Heatmap



CURRENT STATE -> TARGET STATE -> REMEDIATION ROADMAP

Use a baseline (for example an organizational standard or recognized framework), identify gaps, prioritize high-risk red areas, assign owners/resources, implement changes through change control, and measure progress toward the target state.

Final Exam Cram Sheet

RTO vs RPO

RTO = restore time. RPO = acceptable data-loss window.

SLE vs ALE

SLE = one event. ALE = annualized expected loss.

SPF / DKIM / DMARC

SPF authorizes senders; DKIM signs; DMARC adds alignment + policy.

SAML / OAuth / OIDC

SAML = federation assertions; OAuth = delegated authorization; OIDC adds authentication on OAuth 2.0.

SIEM / SOAR / EDR / XDR

SIEM correlates logs; SOAR automates workflows; EDR focuses endpoints; XDR correlates across domains.

Preventive / Detective / Corrective

Stop it / find it / fix or recover from it.

Hot / Warm / Cold site

Fastest / partially ready / basic facility.

Incremental / Differential

Since last backup / since last full backup.

Risk responses

Accept / Avoid / Mitigate / Transfer.

CIA

Confidentiality / Integrity / Availability.

AAA

Authentication / Authorization / Accounting.

Zero Trust

Verify explicitly, least privilege, assume breach.